



COMPUTERS, PRIVACY AND DATA PROTECTION

DATA PROTECTION AND PRIVACY

THE AGE OF
INTELLIGENT MACHINES

Edited by

Ronald Leenes, Rosamunde van Brakel,
Serge Gutwirth and Paul De Hert

VOL
10

B L O O M S B U R Y

DATA PROTECTION AND PRIVACY

The subjects of *Privacy and Data Protection* are more relevant than ever with the European General Data Protection Regulation (GDPR) becoming enforceable in May 2018. This volume brings together papers that offer conceptual analyses, highlight issues, propose solutions, and discuss practices regarding privacy and data protection. It is one of the results of the tenth annual International Conference on Computers, Privacy and Data Protection, CPDP 2017, held in Brussels in January 2017.

The book explores Directive 95/46/EU and the GDPR moving from a market framing to a 'treaty-base games frame', the GDPR requirements regarding machine learning, the need for transparency in automated decision-making systems to warrant against wrong decisions and protect privacy, the risk revolution in EU data protection law, data security challenges of Industry 4.0, (new) types of data introduced in the GDPR, privacy design implications of conversational agents, and reasonable expectations of data protection in Intelligent Orthoses.

This interdisciplinary book was written while the implications of the General Data Protection Regulation 2016/679 were beginning to become clear. It discusses open issues, and daring and prospective approaches. It will serve as an insightful resource for readers with an interest in computers, privacy and data protection.

Computers, Privacy and Data Protection

Previous volumes in this series (published by Springer)

2009

Reinventing Data Protection?

Editors: Serge Gutwirth, Yves Poullet, Paul De Hert, Cécile de Terwangne, Sjaak Nouwt

ISBN 978-1-4020-9497-2 (Print) ISBN 978-1-4020-9498-9 (Online)

2010

Data Protection in A Profiled World?

Editors: Serge Gutwirth, Yves Poullet, Paul De Hert

ISBN 978-90-481-8864-2 (Print) ISBN: 978-90-481-8865-9 (Online)

2011

Computers, Privacy and Data Protection: An Element of Choice

Editors: Serge Gutwirth, Yves Poullet, Paul De Hert, Ronald Leenes

ISBN: 978-94-007-0640-8 (Print) 978-94-007-0641-5 (Online)

2012

European Data Protection: In Good Health?

Editors: Serge Gutwirth, Ronald Leenes, Paul De Hert, Yves Poullet

ISBN: 978-94-007-2902-5 (Print) 978-94-007-2903-2 (Online)

2013

European Data Protection: Coming of Age

Editors: Serge Gutwirth, Ronald Leenes, Paul de Hert, Yves Poullet

ISBN: 978-94-007-5184-2 (Print) 978-94-007-5170-5 (Online)

2014

Reloading Data Protection

Multidisciplinary Insights and Contemporary Challenges

Editors: Serge Gutwirth, Ronald Leenes, Paul De Hert

ISBN: 978-94-007-7539-8 (Print) 978-94-007-7540-4 (Online)

2015

Reforming European Data Protection Law

Editors: Serge Gutwirth, Ronald Leenes, Paul de Hert

ISBN: 978-94-017-9384-1 (Print) 978-94-017-9385-8 (Online)

2016

Data Protection on the Move

Current Developments in ICT and Privacy/Data Protection

Editors: Serge Gutwirth, Ronald Leenes, Paul De Hert

ISBN: 978-94-017-7375-1 (Print) 978-94-017-7376-8 (Online)

2017

Data Protection and Privacy: (In)visibilities and Infrastructures

Editors: Ronald Leenes, Rosamunde van Brakel, Serge Gutwirth, Paul De Hert

ISBN: 978-3-319-56177-6 (Print) 978-3-319-50796-5 (Online)

Data Protection and Privacy

The Age of Intelligent Machines

Edited by
Ronald Leenes, Rosamunde van Brakel,
Serge Gutwirth & Paul De Hert



• H A R T •
PUBLISHING

OXFORD AND PORTLAND, OREGON

2017

Hart Publishing
An imprint of Bloomsbury Publishing Plc

Hart Publishing Ltd
Kemp House
Chawley Park
Cumnor Hill
Oxford OX2 9PH
UK

Bloomsbury Publishing Plc
50 Bedford Square
London
WC1B 3DP
UK

www.hartpub.co.uk
www.bloomsbury.com

Published in North America (US and Canada) by
Hart Publishing
c/o International Specialized Book Services
920 NE 58th Avenue, Suite 300
Portland, OR 97213-3786
USA

www.isbs.com

**HART PUBLISHING, the Hart/Stag logo, BLOOMSBURY and the
Diana logo are trademarks of Bloomsbury Publishing Plc**

First published 2017

© The editors and contributors severally 2017

The editors and contributors have asserted their right under the Copyright, Designs and Patents
Act 1988 to be identified as Authors of this work.

All rights reserved. No part of this publication may be reproduced or transmitted in any form or by any
means, electronic or mechanical, including photocopying, recording, or any information
storage or retrieval system, without prior permission in writing from the publishers.

While every care has been taken to ensure the accuracy of this work, no responsibility for loss or damage
occasioned to any person acting or refraining from action as a result of any statement
in it can be accepted by the authors, editors or publishers.

All UK Government legislation and other public sector information used in the work is Crown Copyright ©.

All House of Lords and House of Commons information used in the work is Parliamentary Copyright ©.

This information is reused under the terms of the Open Government Licence v3.0 ([http://www.
nationalarchives.gov.uk/doc/open-government-licence/version/3](http://www.nationalarchives.gov.uk/doc/open-government-licence/version/3)) except where otherwise stated.

All Eur-lex material used in the work is © European Union, <http://eur-lex.europa.eu/>, 1998–2017.

British Library Cataloguing-in-Publication Data

A catalogue record for this book is available from the British Library.

ISBN: HB: 978-1-50991-934-5
ePDF: 978-1-50991-935-2
ePub: 978-1-50991-936-9

Library of Congress Cataloguing-in-Publication Data

Names: Computers, Privacy and Data Protection (Conference) (10th : 2017 : Brussels, Belgium) |
Leenes, Ronald, editor. | van Brakel, Rosamunde, editor. | Gutwirth, Serge, editor. | Hert, Paul de, editor.

Title: Data protection and privacy : the age of intelligent machines / edited by Ronald Leenes,
Rosamunde van Brakel, Serge Gutwirth & Paul de Hert.

Description: Oxford [UK] ; Portland, Oregon : Hart Publishing, 2017. | Series: Computers, privacy
and data protection | Includes bibliographical references and index.

Identifiers: LCCN 2017045635 (print) | LCCN 2017046435 (ebook) |
ISBN 9781509919369 (Epub) | ISBN 9781509919345 (hardback : alk. paper)

Subjects: LCSH: Data protection—Law and legislation—European Union countries—Congresses. |
Privacy, Right of—European Union countries—Congresses.

Classification: LCC KJE6071.A8 (ebook) | LCC KJE6071.A8 C66 2017 (print) | DDC 342.2408/58—dc23

LC record available at <https://lcn.loc.gov/2017045635>

Typeset by Compuscript Ltd, Shannon

To find out more about our authors and books visit www.hartpublishing.co.uk. Here you will find extracts,
author information, details of forthcoming events and the option to sign up for our newsletters.

PREFACE

At the moment of writing this preface—July 2017—we are less than a year away from the GDPR becoming fully enforceable (25 May 2018). Data controllers and processors are visibly gearing up for the new data protection framework, yet significant uncertainty still exists as regards to the exact requirements (and rights) provided in the GDPR. As a result, it is no surprise that the annual Brussels based International Conference on Computers, Privacy and Data Protection which took place from 25–27 January, 2017 attracted many participants. CPDP is a non-profit platform originally founded in 2007 by research groups from the Vrije Universiteit Brussel, the Université de Namur and Tilburg University. The platform was joined in the following years by the Institut National de Recherche en Informatique et en Automatique and the Fraunhofer Institut für System und Innovationsforschung and has now grown into an interdisciplinary platform carried by 20 academic centers of excellence from the EU, the US and beyond.

This year marked the tenth anniversary of what has become (one of) the world-leading multidisciplinary meeting places for representatives of the public and private sector, academia, polity, and civil society. The conference offers the cutting edge in legal, regulatory, academic and technological development in privacy and data protection. CPDP2017 adopted “Artificial Intelligence” as its overarching theme to pave the way for a timely and thorough discussion over a broad range of ethical, legal and policy issues related to new technologies. The conference received 1024 registrations and offered participants 78 panels and, workshops and special sessions with 383 speakers from all over the world.

The conference addressed many privacy and data protection issues in its 78 panels. Far too many topics to be listed here. We refer the interested reader to the conference website www.cdpconferences.org.

We are also proud that the book volumes that are produced each year on the basis of papers solicited through a call for papers, supplemented by papers written on the basis of contributions to panels, are also very popular. CPDP papers are cited very frequently and the series has a significant readership. The previous editions of what we term the ‘CPDP series’ have been published by Springer, and we are thankful for their support over the years.

We have decided to switch publishers and this 10th volume marks the beginning of the ‘Computers, Privacy and Data Protection’ series published by Hart. To continue the CPDP-series, this first Hart volume, is entitled ‘Computers, Privacy and Data Protection, volume 10—The Age of Intelligent Machines’.

This volume brings together papers that offer conceptual analyses, highlight issues, propose solutions, and discuss practices regarding privacy and data protection.

The book explores Directive 95/46/EU and the GDPR moving from a market framing to a ‘treaty-base games frame, the GDPR requirements regarding machine learning, the need for transparency in automated decision-making systems to warrant against wrong decisions and protecting privacy, the risk-revolution in EU data protection law, data security challenges of Industry 4.0, and (new) types of data introduced in the GDPR, privacy design implications of conversational agents and reasonable expectations of data protection in Intelligent Orthoses.

The current volume can only offer a very small part of what the conference has to offer. Nevertheless, the editors feel the current volume represents a very valuable set of papers describing and discussing contemporary privacy and data protection issues.

All the chapters of this book have been peer reviewed and commented on by at least two referees with expertise and interest in the subject matters. Since their work is crucial for maintaining the scientific quality of the book we would explicitly take the opportunity to thank them for their commitment and efforts:

Meg Ambrose, Norberto Andrade, Rocco Bellanova, Colin Bennett, Bibi Van Den Berg, Michael Birnhack, Gabriela Bodea, Franziska Boehm, Jacquie Burkell, Mark Cole, Bart Custers, Lorenzo Dalla Corte, Els De Busser, Marieke de Goede, Denis Duez, Lilian Edwards, Michael Friedewald, Lothar Fritsch, Raphael Gellert, Gloria Gonzalez Fuster, Nathalie Grandjean, Dara Hallinan, Marit Hansen, Natali Helberger, Joris van Hoboken, Chris Hoofnagle, Gerrit Hornung, Kristina Irion, Irene Kamara, Els Kindt, Eleni Kosta, Daniel Le Métayer, Arno R. Lodder, Orla Lynskey, Hiroshi Miyashita, Michael Nagenborg, Bryce Newell, Ugo Pagallo, Monica Palmirani, Jo Pierson, Bart Preneel, Nadezhda Purtova, Charles Raab, Antoni Roig, Arnold Roosendaal, Ira Rubinstein, Joseph Savirimuthu, Burkhard Schafer, Bart Van der Sloot, Ivan Szekely, Linnet Taylor, Mistale Taylor, Tjerk Timan, Peggy Valcke, William Webster, Tal Zarsky.

A special word of thanks goes to the new European Data Protection Supervisor, Giovanni Buttarelli, for continuing the tradition set by his predecessor, Peter Hustinx, of closing the conference with some closing remarks. We have incorporated Mr. Butarelli’s speech as the final chapter in this volume.

*Ronald Leenes, Rosamunde van Brakel,
Serge Gutwirth & Paul De Hert*
13 July 2017

CONTENTS

<i>Preface</i>	v
<i>List of Contributors</i>	xiii

1. EU Data Protection and ‘Treaty-base Games’: When Fundamental Rights are Wearing Market-making Clothes	1
<i>Laima Jančiūtė</i>	
I. Introduction	1
A. The Case for this Study	1
B. Policy Outcomes of the Rights-based and Market-oriented Approaches	2
C. Political Pragmatism and the Early History of Fundamental Rights in the EU	4
II. Rational Choice and Historical Institutionalism	5
III. The CJEU: Filling the Gap, but Why and How Far? Tracing Strategic Interests of the Constitutional Court	8
A. The Early Challenges to the CJEU Authority	8
B. The Challenges to the CJEU Status Quo in the Post-Lisbon Era	9
C. The Member States and the CJEU’s Strategic Interests	11
D. Parameter-setting	12
IV. The Charter—A Victim of Domestic Politics?	13
A. EU Integration in the Field of Civic Interests	13
B. The Charter and the Member States’ Sovereignty Concerns	14
V. Directive 95/46/EC, GDPR, and the Market Imprint	17
A. ‘Treaty-base Games’: Explaining the Market-framing of the EU First Data Protection Instrument	17
B. The Development of the EU Data Protection Law and the Market-framing Implications	20
VI. Conclusions	25
References	26
2. The ‘Risk Revolution’ in EU Data Protection Law: We can’t Have Our Cake and Eat it, Too	33
<i>Claudia Quelle</i>	
I. Introduction	34
II. The Role of ‘Risk’ in the Risk-Based Approach	37

III.	‘Risk’ and the Legal Obligations in the GDPR.....	42
A.	The Link between ‘Theory’ and ‘Practice’	42
B.	‘Taking into Account’ the Risks.....	44
i.	Scalable Compliance Measures.....	44
ii.	Substantive Protection against Risks.....	45
iii.	The Limits to Enforcement Action against Risk-Taking.....	50
C.	The Risk-Based Approach and Legal Compliance	52
IV.	Were the Data Protection Principles and the Data Subject Rights Risk-Based to Start With?.....	53
A.	Obligations which Require a Risk-Oriented Result	54
B.	Obligations which Require a Risk-Oriented Effort.....	56
C.	Obligations which Are not Risk-Oriented.....	56
D.	The Discretion of Controllers vs the Control Rights of Data Subjects.....	58
V.	Conclusion.....	59
	References.....	60
3.	No Privacy without Transparency	63
	<i>Roger Taylor</i>	
I.	Introduction	63
II.	Describing the Harms from Loss of Privacy	64
A.	Public Perceptions of the Privacy Related Harm	65
B.	Insecure Use and Imprecise Use of Data	68
III.	How Does Data Protection Protect against Insecure and Imprecise Use of Data?.....	71
A.	The GDPR	72
B.	Transparency, Consent and Fair Processing.....	74
C.	Privacy vs Consumer Protection.....	76
IV.	Measuring the Benefits and Risks of Data-driven Automated Decision-making (Surveillance).....	77
A.	Model Surveillance System	78
B.	Estimating the Net Benefit of a Surveillance System.....	79
C.	Risks of Surveillance Systems Resulting in Net Harm	80
V.	How Might Regulators Ensure Reliable Information about the Impact of Surveillance Systems be Generated?.....	81
A.	Ownership of Data	83
VI.	Conclusion.....	84
	References.....	85
4.	Machine Learning with Personal Data	89
	<i>Dimitra Kamarinou, Christopher Millard and Jatinder Singh</i>	
I.	Introduction	89
II.	Lawfulness	93
A.	Profiling as a Type of Processing.....	93
i.	The Elements of the Profiling Process	94

B.	The Decision and its Effects.....	97
C.	Data Protection Impact Assessments (DPIA).....	99
D.	Derogations from the Rule.....	101
E.	Potential Consequences of Non-Compliance.....	102
III.	Fairness	103
IV.	Transparency	106
V.	Conclusions	110
	References.....	112
5.	Bridging Policy, Regulation and Practice? A Techno-Legal Analysis of Three Types of Data in the GDPR.....	115
	<i>Runshan Hu, Sophie Stalla-Bourdillon, Mu Yang, Valeria Schiavo and Vladimiro Sassone</i>	
I.	Introduction	115
II.	The Three Types of Data.....	119
A.	The GDPR Definitions.....	119
i.	Additional Information.....	121
ii.	Direct and Indirect Identifiers	122
iii.	Data Sanitisation Techniques	123
iv.	Contextual Controls	123
B.	Re-Identification Risks.....	124
III.	A Risk-based Analysis of the Three Types of Data	125
A.	Local, Global and Domain Linkability.....	125
B.	Anonymised Data	126
C.	Pseudonymised Data.....	126
D.	Art. 11 Data.....	128
IV.	Data Sanitisation Techniques and Contextual Controls	130
A.	Effectiveness of Data Sanitisation Techniques	130
B.	Improving Data Utility with Contextual Controls.....	134
C.	Improving Data Utility with Dynamic Sanitisation Techniques and Contextual Controls	139
V.	Conclusion.....	140
	References.....	141
6.	Are We Prepared for the 4th Industrial Revolution? Data Protection and Data Security Challenges of Industry 4.0 in the EU Context	143
	<i>Carolin Moeller</i>	
I.	Introduction	143
II.	Defining IND 4.0—The Regulatory Use and Key Features of a Sui Generis Concept	145
A.	IND 4.0 as a Regulatory Tool and as a Sui Generis Concept	145
B.	Conceptual Features of IND 4.0	147
III.	Data Protection Challenges of IND 4.0 and the EU Legal Context....	149
A.	Data Protection Challenges in regard to Customer Data in the IND 4.0 Context.....	149

B.	Data Protection Challenges in relation to Employee Data in an IND 4.0 Context.....	155
IV.	Data Security Challenges of IND 4.0 and the EU Legal Context.....	159
V.	Conclusion.....	163
	References.....	164
7.	Reasonable Expectations of Data Protection in Telerehabilitation— A Legal and Anthropological Perspective on Intelligent Orthoses	167
	<i>Martina Klausner and Sebastian Golla</i>	
I.	Introduction	167
A.	Telerehabilitation: A Challenge for Data Protection	167
B.	Research Context and Methods	168
C.	Research Focus: The Orthoses Project	169
II.	The Legal Angle: Reasonable Expectations and Privacy by Design	170
A.	Reasonable Expectations and Privacy by Design in the GDPR.....	171
B.	Gaining Legal Certainty with ‘Katz Content’	172
C.	Reasonable Expectations and the Use of Intelligent Systems in Telerehabilitation	174
III.	The Anthropological Angle: Reasonable Expectations of Minors in Brace Therapy	176
A.	Methods and Overview of Findings.....	176
B.	Analytical Framework: The Concept of ‘Territories of the Self’ (Erving Goffman)	177
C.	Discussion of Empirical Findings.....	180
i.	Attitudes Regarding Data Sharing.....	181
a)	Minimization of Data Disclosure	181
b)	Data-Sharing as Trade-Off	181
c)	Impracticity of Controlling Personal Data.....	182
d)	Data-Sharing without Concern	182
ii.	Information Preserves Concerning ‘Data Especially Worthy of Protection’	182
iii.	Attitudes and Expectations of Handling Data Concerning Health.....	184
IV.	Conclusion.....	187
	References.....	189
8.	Considering the Privacy Design Issues Arising from Conversation as Platform.....	193
	<i>Ewa Luger and Gilad Rosner</i>	
I.	Introduction	193
II.	Conversation as Platform	196
III.	The Privacy Impact of Sensed Conversation; A Focus on Child-Facing Technology	199
A.	Privacy of Child and Adult Communications.....	200
B.	Privacy of Children’s Play.....	201

C.	Inappropriate Use	201
D.	Introduction of Third Parties.....	202
IV.	The Problem of Intelligent Systems.....	202
A.	Learning, Error and the Importance of Social Context.....	204
B.	Opacity, Comprehension and Informing.....	205
C.	User Consent	207
V.	Conclusions and Recommendations.....	208
A.	Rethinking the Design of Consent Mechanism for Conversational Systems	209
B.	Create New Boundary Objects and Privacy Grammars to Support User Understanding and Trust	210
C.	Undertake Research on the Potential Increase and Normalisation of Child Surveillance	210
	References.....	211
9.	Concluding remarks at the 10th Computers, Privacy and Data Protection Conference: 27 January 2017.....	213
	<i>Giovanni Buttarelli</i>	
	<i>Index</i>	219

LIST OF CONTRIBUTORS

Sebastian J Golla

Sebastian J. Golla is a postdoctoral research assistant at Johannes Gutenberg University Mainz in the area of Public Law, Information Law, and Data Protection Law. He holds a PhD in Criminal Law from Humboldt University Berlin and studied Law at the University of Münster (Germany) and in Santiago de Chile. His research interests also include Cybercrime, Security Law, and Copyright Law.

Runshan Hu

Runshan Hu is currently pursuing a PhD degree in Computer Science at the University of Southampton. His research interests include data anonymisation, machine learning and privacy issues in decentralised data sharing systems. He received a bachelor's degree in communication engineering from the Xiamen University, Fujian, China, in 2016. Being the top student in the program, he graduated as *Distinguished Student of the year* and received the *Chinese National Scholarship* in 2016.

Laima Jančiūtė

At the time of writing and publishing of this contribution Laima was affiliated with the University of Westminster, London, as Research Fellow at the Communication and Media Research Institute where she was also finalising her doctoral research project. Her PhD thesis on the policy process of adoption of the EU General Data Protection Regulation analyses the actors and factors that shaped this major piece of legislation within theory of EU politics. Laima has a background in public administration, languages, and ICT politics. She researches data protection and privacy, policies for ICT, Internet governance, history and philosophy of technology, fundamental rights, public policy, EU governance and politics, international relations, etc. Her work is grounded in the political science perspective.

Dimitra Kamarinou

Dimitra Kamarinou is a Researcher at the Centre for Commercial Law Studies, Queen Mary University of London and a qualified Greek attorney—at—law. Prior to joining the Cloud Legal Project and the Microsoft Cloud Computing Research Centre she worked for commercial law firms, intellectual property strategy firms in London and Reading, and human rights organisations, such as The Greek Ombudsman and Amnesty International, International Secretariat,

London. Dimitra has obtained an LLM in Human Rights Law with Distinction from Birkbeck University of London, in 2010, and an LLM in Corporate and Commercial Law with Merit from Queen Mary University of London, in 2012. She has published in the fields of human rights and data protection law.

Martina Klausner

Martina Klausner is a research fellow at the Institute for European Ethnology at Humboldt-Universität zu Berlin and member of the Laboratory: Social Anthropology of Science and Technology. Her current research is focused on the social implications of the development and implementation of new technologies for motion rehabilitation. A specific interest lies on the implementation of legal standards, eg data protection regulation, in technological systems and infrastructures. Beyond the current research her work generally attends to the entanglement of urban environments, legal and political regulation and different regimes of expertise (medicine, technoscience, NGOs).

Ewa Luger

Dr Ewa Luger is a Chancellor's Fellow in the Centre for Design Informatics at the University of Edinburgh, and a consulting researcher at Microsoft Research (UK). Her research explores applied ethics within the sphere of machine intelligence. This encompasses practical considerations such as data governance, consent, privacy, transparency, and how intelligent networked systems might be made intelligible to the user, through design. Previously a Fellow at Corpus Christi College (University of Cambridge) and a postdoctoral researcher at Microsoft Research (UK), she has a background in Political Science, HCI, and digital inclusion policy in the non-profit sector.

Christopher Millard

Christopher Millard is Professor of Privacy and Information Law at the Centre for Commercial Law Studies, Queen Mary University of London and is Senior Counsel to the law firm Bristows. He has over 30 years' experience in technology law, both in academia and legal practice. He has led the QMUL Cloud Legal Project since it was established in 2009 and is QMUL principal investigator for the Microsoft Cloud Computing Research Centre. He is a Fellow and former Chairman of the Society for Computers & Law and past-Chair of the Technology Law Committee of the International Bar Association. He has published widely in the computer law field, is a founding editor of the *International Journal of Law and IT* and of *International Data Privacy Law* (both Oxford University Press), and is Editor and Co-Author of *Cloud Computing Law* (Oxford University Press, 2013).

Carolin Möller

Carolin Möller is a PhD candidate in Law at Queen Mary, University of London. Her PhD focuses on data protection and privacy implications of EU data retention and access regimes in the public security context. Her research interests include

EU justice and home affairs, data protection law, and legal considerations of new technologies.

Claudia Quelle

Claudia Quelle is a PhD researcher at the Tilburg Institute for Law, Technology and Society (TILT). Her research project concerns the risk-based approach under the General Data Protection Regulation. She started her research on this topic after writing a thesis on the data protection impact assessment for the Research Master in Law and the LLM Law and Technology at Tilburg University. She graduated *summa cum laude* and was awarded the *Hans Frankenprijs 2016*. Her first publication, 'Not just user control in the General Data Protection Regulation', won the Best Student Paper Award at the IFIP Summer School in 2016. She welcomes feedback at c.quelle@uvt.nl.

Gilad Rosner

Dr Gilad Rosner is a privacy and information policy researcher and the founder of the non-profit Internet of Things Privacy Forum. Dr Rosner is a member of the UK Cabinet Office Privacy and Consumer Advisory Group, which provides independent analysis and guidance on Government digital initiatives, and also sits on the British Computer Society Identity Assurance Working Group, focused on internet identity governance. He is a Visiting Scholar at the Information School at UC Berkeley, a Visiting Researcher at the Horizon Digital Economy Research Institute, and has consulted on trust issues for the UK government's identity assurance programme, *Verify.gov*. Dr Rosner is a policy advisor to Wisconsin State Representative Melissa Sargent, and has contributed directly to legislation on law enforcement access to location data, access to digital assets upon death, and the collection of student biometrics.

Vladimiro Sassone

Professor Vladimiro Sassone has worked at the University of Southampton since 2006, where he is the *Roke/Royal Academy of Engineering Research Chair in Cyber Security*, the *Head of the Cyber Security Group*, the *Director of the GCHQ/EP SRC Academic Centre of Excellence for Cyber Security Research (ACE-CSR)*, the *Director of the Cyber Security Academy (CSA)*, a partnership between the University, Industry and Government to advance Cyber Security through excellence in research and teaching, industrial expertise and training capacity. He collaborates with and consults for branches of Government and regulatory bodies, including the Foreign and Commonwealth Office, The Cabinet Office, GCHQ/CESG, NCA, ROCUs, Hampshire Police, FCA and Bank of England. He is the UK representative on the IFIP Technical Committee TC1, Foundations of Computer Science. Professor Sassone is the editor-in-chief of *ACM Selected Readings* and of Springer's *ARCoSS, Advanced Research in Computing and Software Science*. He is editor of *Theoretical Computer Science*, *Logical Methods in Computer Science*, *Electronic Proc. in Theoretical Computer Science* and, until recently, of *The Computer Journal*.

Valeria Schiavo

Valeria Schiavo is a fifth-year law student at LUISS Guido Carli university in Rome. Valeria has worked as a legal consultant for PricewaterhouseCoopers, in the field of international commercial law. She wrote her master dissertation in the field of EU data protection law and focused upon privacy by design measures. Valeria is also a contributor and editor of *Universitarianweb.it*, an online newspaper on law, philosophy, art and literature.

Jatinder Singh

Dr Jatinder Singh is an EPSRC Research Fellow and Senior Research Associate at the Computer Laboratory, University of Cambridge. His technical work concerns issues of security, privacy, transparency, trust and compliance in emerging technology. As part of the Microsoft Cloud Computing Research Centre, a collaboration with the Centre for Commercial Law Studies at Queen Mary University of London, he also works to explore issues where technology and law/regulation intersect. He will soon lead a team to tackle the technical management and compliance challenges of emerging technology, particularly as technology becomes increasingly automated and physical. Jat is also active in the tech-policy space, as an associate fellow for the Centre for Science and Policy, and serving on the UK Government's E-infrastructure Leadership Council.

Sophie Stalla-Bourdillon

Dr Sophie Stalla-Bourdillon is Associate Professor in Information Technology/Intellectual Property Law within Southampton Law School at the University of Southampton, specialising in Information Technology related issues. She is the Director of ILAWS, the Institute for Law and the Web and its new core iCLIC. She is a member of the Southampton Cybersecurity Centre of Excellence as well as a member of the Web Science Institute. Sophie has acted as an expert for the Organisation for the Cooperation and Security in Europe (in the field of intermediary liability) and for the Organisation for Economic Development and Cooperation (in the field of data protection, research data and anonymisation). She is part of the expert group formed by the Council of Europe on intermediary liability.

Roger Taylor

Roger Taylor is an entrepreneur, regulator and writer. He is chair of Ofqual, the qualifications regulator. He is also currently working on the use of technology and data in career decisions. He co-founded Dr Foster which pioneered the use of public data to provide independent ratings of healthcare. He has written two books: *God Bless the NHS* (Faber & Faber (2014)) and *Transparency and the Open Society* (Policy Press 2016). He founded and chairs the Open Public Services Network at the Royal Society of Arts. He is a trustee of SafeLives, the domestic abuse charity and a member of the advisory panel to Her Majesty's Inspectorate of Probation. Roger worked as a correspondent for the Financial Times in the UK and the US and, before that, as a researcher for the Consumers' Association.

Mu Yang

Dr Mu Yang is a Research Fellow at the University of Southampton, and has been working on a number of security and privacy projects supported by European Research Council, EPSRC UK and EU Horizon 2020. She has received several rewards from both academia and industry for her work in security and data privacy research, such as TrustCom best paper, The Lloyd's Science of Risk prize, and SET for BRITAIN award.

EU Data Protection and ‘Treaty-base Games’: When Fundamental Rights are Wearing Market-making Clothes

LAIMA JANČIŪTĖ

Abstract. At odds with the European rights-based approach context in which it is embedded, the EU Directive 95/46/EC (the world’s most influential privacy and data protection instrument that in 2018 will be replaced by the newly adopted GDPR) was created and has been functioning as a market-making tool. The constitutional basis for the rights-based approach to fully unfold at the EU level came along with the Lisbon Treaty. However, the governance of the rights to privacy and data protection maintains a lot of market-issue elements, and certain path dependencies emerged throughout the two decades after adoption of Directive 95/46/EC. These dynamics are determined by a complex interplay between various dimensions: the evolution of the EU politics as such (macro), the evolution of the human rights governance in the EU (meso) and the development of privacy and data protection norms and instruments namely (micro). The above represents an interesting case for analysis and will be explained with the aid of the neo-institutional theory, which allows to show how norms creation has always been intertwined with or even driven by the strategic interests of various actors. It also allows to gain insights into the constraints and possibilities determined by the market-making governance of data protection. This paper links the market-framing context of the Directive 95/46/EC to the so-called ‘treaty-base games’ known in the EU politics as one of the creative strategies in overcoming institutional constraints.

Keywords: *Data protection—Directive 95/46/EC—GDPR—fundamental rights—EU—‘treaty-base game’*

I. Introduction

A. The Case for this Study

In continental Europe, the concept of privacy as a right matured in the nineteenth century when privacy-related laws started emerging (eg in France and Germany), linking the need to protect it to the notion of personality rights and individual

autonomy, ie human dignity and honour in the broader sense, perceived as fundamental values. The creation of explicit legal protections was prompted by evolving means of communications—liberalisation and growth of the press, later photography and other technologies.¹ The Directive 95/46/EC² adopted in the EU in the 1990s has become a global standard setter in privacy protection embedding the rights-based approach. This internationally key instrument in fostering the right to privacy—the most comprehensive right, an essential enabler of many other democratic rights and institutions³—was born as a market-making tool. This study aims to research this interesting phenomenon, its determinants and implications, and what was inherited from the two decades of such state of play in the General Data Protection Regulation (GDPR)⁴—the upgrade of the Directive 95/46/EC—that needed not anymore be a market-making tool, ie to rely on a market-making legal base. It will be explored deploying political science analysis and with the aid of the neo-institutional theory. Its rational choice strand explains policy outcomes through the power contest between various actors and their strategic interests. The historical neo-institutionalist approach focuses on the temporal context in which policies emerge and the impact of earlier policy decisions on the subsequent ones. The genesis of the fundamental rights in the EU and how it has been shaped by strategic interests of various actors will be looked at to provide a contextual background. It will reveal how the governance and evolution of the rights to privacy and data protection got caught somewhere in between the extraordinary processes of the EU institutional development as a polity, underlying actor interests and the unique process of constitutionalisation of human rights in the EU. Finally, a reflection will be provided on how a certain bias to the market-making dimensions is still felt in the current promotion of privacy and data protection in the EU.

B. Policy Outcomes of the Rights-based and Market-oriented Approaches

To understand the potential tensions underlying the market-framing of a privacy protection instrument, a comparison between different privacy regulation systems

¹ D Lindsay and S Ricketson, 'Copyright, privacy and digital rights management (DRM)', in *New dimensions in privacy law: international and comparative perspectives*, ed. Andrew T. Kenyon and Megan Richardson (Cambridge: Cambridge University Press, 2010), 133–136.

² Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data, OJ L 281, 23.11.1995.

³ Louis Brandeis, 1928, cited in I Brown and CT Marsden, *Regulating code: good governance and better regulation in the information age* (Cambridge, The MIT Press, 2013c), 48; UN, The right to privacy in the digital age, Report of the Office of the United Nations High Commissioner for Human Rights, 2014, 5; UN Report of the Special Rapporteur to the Human Rights Council on the use of encryption and anonymity to exercise the rights to freedom of opinion and expression in the digital age, 2015.

⁴ Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) OJ L 119 04.05.2016.

is useful. Different choices have been made in Europe and in the USA, due to diverse historical and cultural contexts. While in the EU privacy is viewed as a fundamental right, broadly established in constitutions,⁵ in the US privacy protection is often treated as a matter of consumer rights in the context of commercial transactions, being merely one of the interests that strongly competes with others,⁶ with no explicit constitutional guarantees.⁷ The above approaches are reflected in the application of different methods to regulate privacy and data flows. In the EU privacy protection is enacted through prescriptive legal rules. In the meantime, in the USA in the private sector industry self-regulation prevails.⁸ These differences originate in two different paradigms: 'rights-based' in continental Europe and 'interest-based' in the USA, that in turn are related to two different legal traditions—civil law and common law, respectively.⁹ There are some essential implications related to these different approaches. Countries with the common law tradition lean towards lesser governmental intervention in the regulation of the economy in general. Consequently, such jurisdictions treat the disclosure and use of personal information for commercial purposes, eg direct marketing, more liberally.¹⁰ This also pertains to conceptualisation of information, including personal, as a commodity and a policy shift away from public good, societal function and value paradigm of the role of communication (when 'messages are exchanged in the process of building and sustaining community').¹¹ The shift towards this paradigm is largely embodied in the political economy of the Internet that led to monetisation of personal identity as a consequence of the wider process of commodification of information and communication.¹² In the meantime, in an attempt to secure fundamental rights of citizens, Europe tends 'to privilege privacy protection at the expense of data access to information and economic efficiency'.¹³ In Europe individual rights are closely linked to extensive social rights guaranteed through state regulatory intervention.¹⁴ Which approach is taken in designing

⁵ C Prins, 'Should ICT regulation be undertaken at an international level?', in B-J Koops et al (eds), *Starting points for ICT regulation: deconstructing prevalent policy one-liners*, (The Hague: TMC Asser, 2006), 173; LB Movius and N Krup, 'U.S. and EU Privacy Policy: Comparison of Regulatory Approaches', *International Journal of Communication* 3 (2009), 169–179.

⁶ DJ Solove and PM Schwartz, 'Reconciling Personal Information in the United States and European Union', *California Law Review* 102 (2014); UC Berkeley Public Law Research Paper No. 2271442; GWU Law School Public Law Research Paper 77 (2013), 1–5.

⁷ Movius and Krup, 'U.S. and EU Privacy Policy: Comparison of Regulatory Approaches', 174; generally, protection of privacy in the USA is linked to the Fourth Amendment of the Constitution which prohibits unlawful searches and seizures.

⁸ Prins, 'Should ICT regulation be undertaken at an international level?', 171, Movius and Krup, 'U.S. and EU Privacy Policy: Comparison of Regulatory Approaches', 169–179.

⁹ Lindsay and Ricketson, 'Copyright, privacy and digital rights management (DRM)', 136–144.

¹⁰ *ibid.*

¹¹ S Braman, *Change of state: information, policy, and power* (Cambridge, Mass.: MIT Press, 2006), 14.

¹² *ibid.* at 13–15; Vincent Mosco, *The digital sublime: myth, power, and cyberspace* (Cambridge, Mass.; London: MIT, 2005), 170.

¹³ Movius and Krup, 'U.S. and EU Privacy Policy: Comparison of Regulatory Approaches', 178.

¹⁴ F Petiteville, 'Exporting values: EU external co-operation as a soft diplomacy', in M Knodt and S Princen (eds), *Understanding the European Union's external relations*, (London; New York: Routledge, 2003), 132.

privacy protection matters, since ‘there is general agreement that a fundamental right, such as a right associated with the autonomous development of a person, will prevail over “interests”, such as interests in economic efficiency’.¹⁵ As far as self-regulatory approach is concerned, there can hardly be found any efficient initiatives.¹⁶

Although far from being flawless or uncontroversial in itself, the EU data protection regulation is rated as the most advanced privacy safeguards in the global context.¹⁷ Global dominance in this issue-area is attributed to the EU by many commentators. The EU is perceived as a creator of the global privacy rules.¹⁸ This has primarily been associated with the stipulation of the Directive 95/46/EC. But this remarkable instrument, representing prescriptive rules method, came into being wearing market-maker’s clothes that its replacement GDPR is still wearing, despite having been created in very different time in terms of the EU institutional framework. The story of why it is so, goes back to the very beginning of the EU.

C. Political Pragmatism and the Early History of Fundamental Rights in the EU

As a prelude to further discussion, it is important to point out one fact. Many accounts on the EU commence with a ‘mantra’ that it started off as a merely economic project, implicitly creating an impression that the initial absence of fundamental rights in its constitutional design is somewhat intrinsic to the very origin of the EU. It is, though, commonly omitted to be mentioned, that instead this was an outcome of intense political processes of the 1950s.¹⁹ At the time of the inception of the European Communities (hereafter EC), which also foresaw Political and Defence Communities, a rigorous human rights catalogue was being drafted. This catalogue was intended as part of the institutional design of the European Political Community, of which the establishment failed following the

¹⁵ Lindsay and Ricketson, ‘Copyright, privacy and digital rights management (DRM)’, 122–123.

¹⁶ R Gellman and P Dixon, WPF Report: many failures—a brief history of privacy self-regulation in the United States (World Privacy Forum, 2011).

¹⁷ J van Dijk, *The Network society* (London: SAGE, 3rd edition, 2012) 131, 165–166; Lillian Edwards and Gerant Howells, ‘Anonymity, consumers and the Internet: where everyone knows you’re a dog’, in C Nicoll, et al. (eds), *Digital anonymity and the Law: tensions and dimensions*, (The Hague: T.M.C. Asser Press, 2003), 233–234.

¹⁸ Brown and Marsden, ‘Regulating code: good governance and better regulation in the information age’, 54; S Princen, ‘Exporting regulatory standards: the cases of trapping and data protection’, in M Knodt and S Princen (eds), *Understanding the European Union’s external relations*, (London; New York: Routledge, 2003), 142–157; J.L. Goldsmith and T Wu, *Who controls the Internet: illusions of a borderless world* (Oxford; New York: Oxford University Press, 2006), 173–177; H Farrell, ‘Privacy in the Digital Age: States, Private Actors and Hybrid Arrangements’, in WJ Drake and EJ Wilson III (eds), *Governing global electronic networks: international perspectives on policy and power*, (Cambridge, Mass.: MIT Press, 2008c), 386–395; P De Hert and V Papakonstantinou, ‘The new General Data Protection Regulation: Still a sound system for the protection of individuals?’ *Computer Law & Security Review: The International Journal of Technology Law and Practice*, 32 (2016) 194; etc.

¹⁹ G De Búrca, ‘The evolution of EU human rights law’, in PP Craig and G De Búrca (eds), *The evolution of EU law* (Oxford; New York: Oxford University Press, 2nd edition, 2011), 465–497.

unsuccessful ratification of the European Defence Community Treaty. In light of these developments and difficulty of the underlying political processes, the idea of a comprehensive rights catalogue was subsequently abandoned while establishing the European Economic Community (thereafter EEC), in order not to hinder the process by adding an additional layer to the negotiations.²⁰ Therefore, the decades of the EEC—since 1993 rearranged into the EU—in which it functioned without full-fledged fundamental rights provisions in its primary law, were determined neither by default, nor by design, but was the result of political pragmatism. The gradual return and shaping of the human rights dimension in the EU normative domain was also related to the political and strategic interests of various actors in the EU. This is the theme of the discussion in the sections below, where the premises of the emergence of the Directive 95/46/EC under the market-making procedures and related effects are analysed. Section 2 presents the rational choice and historical institutionalism strands that form the theoretical perspective of this work. To better understand the context of the coming into existence of the EU privacy protection regime, the development of fundamental rights is explained, focusing on the role of the Court of Justice of the European Union (hereafter CJEU) in section 3, as well as of the EU Member States with regard to the Charter of Fundamental Rights of the EU (hereafter EUCFR) in section 4. Section 5 passes on to the main discussion on the interplay between the market-making and fundamental rights characteristics in the Directive 95/46/EC and the GDPR. It proposes to link the market-framing context of the Directive 95/46/EC to the so-called 'treaty-base games' known in EU politics as one of the creative strategies in overcoming institutional constraints. It then reflects on the impact that market-making logic has had on the further development of data protection in the EU. It suggests that, despite the emergence of related primary law with the Lisbon Treaty and the current prominence of this issue-area in the EU public policy-making, the ethos of the governance of privacy and data protection in the EU remains ambiguous.

II. Rational Choice and Historical Institutionalism

Privacy matters have been mostly addressed within the realms of sociology, law, or computer science, and journalism or civil-rights advocacy outside academia, while 'it is an issue of political theory, of public policy-making, of political behaviour, of public administration, of comparative politics, and of international relations' as much as it is a legal or technological one.²¹ More studies into information privacy that would be embedded in the discipline of political science are desirable.²²

²⁰ *ibid.*

²¹ CJ Bennett and CD Raab, *The governance of privacy: policy instruments in global perspective* (Cambridge, Mass.; London: MIT Press, 2006), xv–xx.

²² *ibid.*

This paper offers an account of the development of some aspects of the EU privacy and data protection regime based on considerations of new institutionalist theory. The notion of institutions in society and in political science is based on 'patterned interactions that are predictable, based upon specified relationships among the actors'.²³ New institutionalism draws attention to the role of 'informal patterns of structured interaction between groups as institutions themselves' that exist along with formal institutions.²⁴ New institutionalism investigates the impact of institutions on political decisions and policy choices. Institutions are important structural elements of a polity.²⁵ Political life is centred on institutions. They are the variables 'that matter more than anything else' in explaining political decisions in a most direct manner and 'they are also the factors that themselves require explanation'.²⁶ Since the 1990s, new institutionalism has become a mainstream approach in European studies.²⁷

In the *rational choice institutionalist* reasoning on the EU, the basic assumption is 'that actors in all relevant decision-making arenas behave strategically to reach their preferred outcome'.²⁸ Institutions can become 'autonomous political actors in their own right'²⁹ and have their own agendas.³⁰ They are driven by self-interest³¹ and compete for influence.³² Therefore, even actors formally known as 'non-political', eg civil servants or courts, do not necessarily remain 'apolitical'.³³ In asserting themselves, actors may rely on various strategies and power resources, from taking advantage of disagreement among other players, to framing issues in a certain policy realm so that it results in application of different procedures and reconfiguration of power between decision-makers, etc.³⁴ Many researchers have observed the phenomenon of 'norm entrepreneurship' actively enacted by the European Commission and the CJEU that have 'constructed a European competence in important ways, through rulings, proposals and alliances with

²³ GB Peters, *Institutional theory in political science: the new institutionalism* (London: Continuum, 3rd edition, 2012), 19.

²⁴ I Bache, Stephen George and Simon Bulmer, *Politics in the European Union* (Oxford: Oxford University Press, 3rd edition, 2011), 22.

²⁵ Peters, 'Institutional theory in political science: the new institutionalism', 185, 128–129.

²⁶ Peters, 'Institutional theory in political science: the new institutionalism', 184.

²⁷ M Aspinwall and Gerald Schneider, 'Institutional research on the European Union: mapping the field', in M Aspinwall and G Schneider (eds), *The rules of integration: institutionalist approaches to the study of Europe*, (Manchester: Manchester University Press, 2001), 6.

²⁸ *ibid.*, at 7.

²⁹ Bache, George and Bulmer, 'Politics in the European Union', 23.

³⁰ Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 4–5.

³¹ SK Schmidt, 'A constrained Commission: informal practices of agenda-setting in the Council', in M Aspinwall and G Schneider (eds), *The rules of integration: institutionalist approaches to the study of Europe*, (Manchester: Manchester University Press, 2001), 144.

³² Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 9.

³³ SS Andersen et al., 'Formal Processes: EU Institutions and Actors', in SS Andersen and KA Eliassen (eds), *Making policy in Europe*, (London: Sage, 2nd edition, 2001), 36.

³⁴ G Falkner, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Intergovernmentalism', in JJ Richardson (ed), *Constructing a Policy-Making State? Policy Dynamics in the EU*, (Oxford University Press, 2012), 292–308.

actors at various levels across the EU'.³⁵ For instance, the Commission in striving 'both to legitimise itself and to create a demand for European level public goods' that would not have been created without supranational agency, actively seeks to identify new issues, propose solutions and establish alliances.³⁶ 'The legitimacy of institutions depends ... on the capacity to engender and maintain the belief that they are the most appropriate ones for the functions entrusted to them'.³⁷ In terms of strategic interests of the CJEU, several scholars argued that its decision-making does not occur without taking 'Member States' possible reactions into account', ie can be seen as political.³⁸ Although designed as an independent institution, implementation of its judgments 'ultimately depends on the goodwill of the Member States and of their courts'.³⁹

But from the Member States perspective, an expanding supranational agency is likely to be unwelcome. When reforms are imminent, they raise actors' concerns about potential shifts in power balance.⁴⁰ A relatively minor policy change at the EU level may, however, entail a major change for specific actors, eg specific countries.⁴¹

In the *historical institutionalist* view, formation of preferences and strategic choices are conditioned by institutional context, ie by previous institutional commitments.⁴² This creates the effect of 'path dependency'—'a powerful cycle of self-reinforcing activity'.⁴³ Past decisions have an impact on interstate negotiations.⁴⁴ 'European integration is a cumulative process, where prior decisions form a basis upon which new decisions are made'.⁴⁵ Even in the liberal intergovernmentalist vision, where European integration is interpreted as rather loose, it is recognised that major decision-making in the EU does 'not take place in anarchy, but accept previous agreements (and the societal adaptation to them) as a new status quo', ie 'each bargain is recursive, influenced by past bargains and influencing future ones'.⁴⁶ Institutional structures, both formal and informal, may be challenged and may be changed when the context changes or new actors emerge.⁴⁷

³⁵ Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 4–5.

³⁶ *ibid.*

³⁷ Giandomenico Majone, 'From the Positive to the Regulatory State: Causes and Consequences of Changes in the Mode of Governance', *Journal of Public Policy* 17 (02) (1997), 161.

³⁸ Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 8.

³⁹ J Peterson and M Shackleton, 'Conclusion', in J Peterson and M Shackleton (eds), *The institutions of the European Union*, (Oxford: Oxford University Press, 3rd edition, 2012c), 386.

⁴⁰ Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 4–5.

⁴¹ PA Sabatier, 'The advocacy coalition framework: revisions and relevance for Europe', *Journal of European Public Policy*, 5(1) (1998), 121.

⁴² Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 10.

⁴³ V Lowndes and M Roberts, *Why institutions matter: the new institutionalism in political science* (Houndmills, Basingstoke: Palgrave Macmillan, 2013), 39.

⁴⁴ Aspinwall and Schneider, 'Institutional research on the European Union: mapping the field', 10.

⁴⁵ *ibid* at 12.

⁴⁶ A Moravcsik, 'Liberal intergovernmentalism and integration: A rejoinder', *Journal of Common Market Studies* 33(4) (1995), 612.

⁴⁷ C Katzenbach, 'Technologies as Institutions: rethinking the role of technology in media governance constellations', in M Puppis and N Just (eds), *Trends in Communication Policy Research: New Theories, Methods and Subjects*, (Bristol: Intellect, 2012), 124, 129.

Temporal setting and historical processes are very important dimensions in the historical institutionalist analysis.⁴⁸ The legacy of the Directive 95/46/EC and the effects of constitutionalisation of fundamental rights in the Treaty of Lisbon and the EUCFR are prime examples of the historical institutionalist perspective.

The current judiciary and regulatory activity in the EU has been commented upon as the ‘climate of data protection enforcement’.⁴⁹ It is enabled by an institutional context, which is the result of an intersection of cumulative processes of policy-making in the areas of privacy and data protection, fundamental rights and European integration. Strategic interests of a number of actors played a role along the way to both accelerate and hamper those processes as well as creatively overcome the existing constraints. This will be reflected in the analysis in the following sections.

III. The CJEU: Filling the Gap, but Why and How Far? Tracing Strategic Interests of the Constitutional Court

A. The Early Challenges to the CJEU Authority

In the absence of a supranational level human rights protection system at the outset of the EC, institutionalisation of human rights gradually emerged here through the CJEU case law from the late 1960s onwards. The beginning of this process is famously known as the ‘triptych of cases’,⁵⁰ the first of which—*Erich Stauder v City of Ulm—Sozialamt* of 1969—involved privacy issues, ie was instigated on the grounds of arguably unnecessary divulgence of personal information. However, ‘[t]he CJEU did not start as a champion of European-level human rights protection’.⁵¹ Its stance ‘that human rights were indeed, however implicitly, part of the EC legal system and that they were judicially protected within this system’,⁵² as well as that respect for fundamental rights must be guaranteed under the structural

⁴⁸ S Meunier and KR McNamara, ‘Making history: European integration and institutional change at fifty’, in S Meunier and KR McNamara (eds), *Making history: European integration and institutional change at fifty*, (Oxford; New York: Oxford University Press, 2007), 4–7.

⁴⁹ R Bond of Speechly Bircham quoted in BBC, Facebook privacy challenge attracts 25,000 users, 2014.

⁵⁰ De Búrca, ‘The evolution of EU human rights law’, 478; C-29/69 *Erich Stauder v City of Ulm—Sozialamt* [1969] ECR 419, C-11/70, *Internationale Handelsgesellschaft* [1970] ECR 1125; C-4/73 *Nold v European Commission* [1974] ECR 491.

⁵¹ B Rittberger and F Schimmelfennig, ‘The constitutionalization of the European Union: explaining the parliamentarization and institutionalization of human rights’, in *Making history: European integration and institutional change at fifty*, ed. Sophie Meunier and Kathleen R. McNamara (Oxford; New York: Oxford University Press, 2007), 223.

⁵² *ibid* at 224.

framework and the objectives of the Community, surfaced in the above-mentioned trio of rulings in the 1960s and 1970s, when the supremacy of EC law and the jurisdiction of the CJEU were disputed by some German national courts.⁵³ Later, to overcome the absence of the Community level norms, the CJEU also started referring to the European Convention of Human Rights (hereafter ECHR), to which all EC Member States were signatories, as an external source of legitimacy. Further challenges to the competence of EC law and the CJEU authority led to a number of political declarations by other supranational institutions attributing importance to the protection of fundamental rights and transferring the CJEU case law to Treaty law.⁵⁴ 'Without the rights-based challenge of the German administrative and constitutional courts, the CJEU would not have been pressed to introduce, and increasingly strengthen its commitment to, human rights review'.⁵⁵

B. The Challenges to the CJEU Status Quo in the Post-Lisbon Era

Eventually, the fundamental rights became fully constitutionalised in the Lisbon Treaty⁵⁶ and through the legally-binding force of the EUCFR,⁵⁷ providing specific legal bases for judgments in this realm. In the post-Lisbon time, challenges to the CJEU status quo as well as stimuli for activism in this issue-area continue. This is due to the domain of the European Court of Human Rights (hereafter ECtHR) case law, specialised in human rights, and the imminent EU accession to the ECHR, which will make the ECtHR an ultimate judicial authority in the EU, since the CJEU's decisions will become open to its scrutiny. The CJEU has long managed to resist such developments, but the amendments to the Lisbon Treaty made the accession mandatory.⁵⁸ In 2014, the CJEU rejected the draft accession agreement text negotiated between the European Commission and the Council of Europe as incompatible with EU law, whilst demanding also the preservation of its own exclusive powers.⁵⁹ Nevertheless, such obstruction in the process did not eliminate

⁵³ *ibid.*, at 224–225.

⁵⁴ *ibid.*, at 223–228. Eg a joint declaration by the European Parliament, the Commission and the Council of Ministers 'concerning the protection of fundamental rights', published in 1977; in 1978—'Declaration on Democracy' by the European Council; later—references to the human rights in the Single European Act in 1986, etc. (*ibid.*). Further, the Maastricht Treaty of 1992 gave more formal recognition to human rights which was consolidated in subsequent Amsterdam and Nice Treaties (De Búrca, 'The evolution of EU human rights law', 479–480).

⁵⁵ Rittberger and Schimmelfennig, 'The constitutionalization of the European Union: explaining the parliamentarization and institutionalization of human rights', 228.

⁵⁶ Signed in 2007, came into force in 2009.

⁵⁷ Discussed in the following section.

⁵⁸ S Douglas-Scott, 'The Court of Justice of the European Union and the European Court of Human Rights after Lisbon', in SA de Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon*, (Oxford: Hart, 2013), 153–179; I Cameron, 'Competing rights?' in SA de Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon*, (Oxford: Hart, 2013), 181–206.

⁵⁹ Opinion 2/13 EU:C:2014:2475.

the aim of accession, debated for several decades⁶⁰ and enshrined in the provisions of the Lisbon Treaty, from the EU political agenda,⁶¹ nor did it remove the related political pressure. In the meantime, the ECtHR gained a reputation of innovative and strong jurisprudence with regard to privacy protection.⁶² The current engagement with the rights to privacy and data protection by the CJEU that particularly came to the fore with the still much debated landmark rulings of April and May 2014, invalidating the Data Retention Directive⁶³ and in favour of the right to de-listing from search engines' results,⁶⁴ respectively, can be linked to this context. It poses a need for the CJEU to build a strong profile in the field of fundamental rights.

At the moment the CJEU is undergoing a quite substantial political transformation, because it is in the process of asserting itself as a fundamental rights court. It feels pressure coming from the competition with the ECtHR, operating on the same continent, which works brilliantly in this respect. The CJEU is extremely worried about this competition. In order to show the world that they are capable of acting as a fundamental rights court, which is an important factor, because it is an important dimension to show that the EU is a bit more understandable to its citizens and a bit more friendly, it has chosen, among other subjects, data protection. And that has to do with the two rulings which were quite staggering. The two decisions, with similar undertones, on the same topic, so close to each other, were not accidental.⁶⁵

While the relationship between the two Courts can be deemed a friendly one, the CJEU refers to the ECtHR case law more frequently.⁶⁶ It is determined by the diverse history of the two institutions, as well as sources and scope of competence they have built upon that resulted in ECtHR's much vaster case law in the field of human rights. Despite the cooperative rather than confrontational co-existence of the two human rights protection systems in Europe, for the above-explained

⁶⁰ For the history of the accession agenda from 1979 onwards see, for instance, Vaughne Miller, EU Accession to the European Convention on Human Rights, SN/IA/5914 House of Commons, 2011, 3. But the political competition between the two Courts reaches much further backwards: already in the 1950s there were serious discussions around whether the ECHR or other source should underpin the EC human rights regime, and 'who should be the final arbiter' in case of controversies (De Búrca, 'The evolution of EU human rights law', 469). The possibility of the Community accession to the ECHR was raised already then (ibid, 468–469).

⁶¹ AFCO, Accession to the European Convention on Human Rights (ECHR): stocktaking after the ECJ's opinion and way forward, hearing, 20 April 2016.

⁶² L Costa and Y Poullet, 'Privacy and the regulation of 2012', *Computer Law and Security Review: The International Journal of Technology and Practice* 28(3) (2012): 255.

⁶³ Joined Cases C-293/12 and C-594/12 *Digital Rights Ireland and Seitlinger and Others*, invalidating Directive 2006/24/EC.

⁶⁴ Case C-131/12 *Google Spain SL and Google Inc. v Agencia Española de Protección de Datos (AEPD) and Mario Costeja González*, enacted principles of the right to erasure (of personal information).

⁶⁵ Interview with a Permanent Representation official, January 2015, Brussels. At another research meeting with EU official in February 2016 the tendency of data protection cases being dealt with under the auspices of the CJEU Grand Chamber in the recent years was noted as a remarkable development.

⁶⁶ Douglas-Scott, 'The Court of Justice of the European Union and the European Court of Human Rights after Lisbon', 157–160.

reasons, the CJEU has a strategic need to actively exercise the enactment of the EUCFR. Its fundamental rights actorness has already started gaining momentum, as shown by the references to the CJEU judgment in the recent ECtHR rulings.⁶⁷

C. The Member States and the CJEU's Strategic Interests

Apart from afore-discussed factors, there are other pressures related to the strategic interests of the Court. The CJEU now features as a powerful supranational level actor in EU politics. Most notably, this is linked to its ability to have developed the doctrine of the supremacy of EU law over national law. The difficulty for governments, despite an existing formal mechanism allowing to do so, to overturn its judgments in practice, prompt some commentators to attribute 'dictatorial power' to this institution.⁶⁸ However, while this institution is known to have brought the European integration much further than it was originally envisaged and it has demonstrated the institutional and political capacity to rule against Member States interests, it still remains sensitive to national interests in a broader sense. The national interest of Member States differs and CJEU judgments tend to affect them differently. A number of Member States deem having a strong EU legal system with a strong role for the CJEU in it as beneficial. The Court is unlikely to make decisions that would fundamentally compromise national systems and could make these allied governments cease favouring its strong powers.⁶⁹ This probably can explain the CJEU's decisions of 2013⁷⁰ and 2015⁷¹ in favour of the use of biometrics in the national ID documents—a very intrusive privacy undermining state surveillance measure—that are somewhat incongruent with its latest data protection wave, its own earlier case law, and tangibly depart from the ECtHR stance taken in these matters.⁷² These cases were brought against the German and Dutch governments which are known as supportive of strong CJEU's authority.⁷³ Moreover, disapproving of the use of biometrics would also have implications for other EU countries which have introduced them in the ID documents.

⁶⁷ References made to the Joined Cases C-293/12 and C-594/12 *Digital Rights Ireland and Seitlinger and Others*, invalidating Directive 2006/24/EC, in the ECtHR's *Roman Zakharov v. Russia and Szabo and Vissy v. Hungary* of 2015.

⁶⁸ Falkner, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Inter-governmentalism', 298.

⁶⁹ KJ Alter, 'Who Are the 'Masters of the Treaty'? European Governments and the European Court of Justice', *International Organization*, 52(1) (1998): 121–147.

⁷⁰ Case C-291/12 *Michael Schwarz v Stadt Bochum* [2013].

⁷¹ Joined Cases C-446/12 to C-449/12 *Willems v Burgemeester van Nuth* [2015].

⁷² T Wisman, 'Willems: Giving Member States the Prints and Data Protection the Finger', *European Data Protection Law Review*, 1(3) (2015): 245–248; CJEU, Press Release No 135/13, Judgment in Case C-291/12 *Michael Schwarz v Stadt Bochum*, Luxembourg, 17 October 2013.

⁷³ Alter, 'Who Are the 'Masters of the Treaty'? European Governments and the European Court of Justice', 137.

D. Parameter-setting

It is important to understand this actor's motivations as the CJEU's judgments go far beyond the interpretation of the law in single cases, and have a tangible potential to alter the existing policy regimes in the EU and influence policy processes.⁷⁴ The CJEU, therefore, has been one of the key elements in the EU institutional framework. Its decisions create 'a rule-based context for policy making ... set the parameters for future initiatives and shape actor expectations'.⁷⁵ This is known as judicial policy-making.⁷⁶ The CJEU case law also forms a layer of the EUCFR, discussed in the next section.

The CJEU case law is part of the EU privacy and data protection *acquis* and has the effects of the above-mentioned parameter-setting. References to this case law are made in explaining the reasoning behind some aspects of the GDPR draft proposal text.⁷⁷ Further, in the process various actors referred to the CJEU case law in their effort to make the case in advocating for or against certain provisions in the GDPR.⁷⁸ Most remarkably, some of the Court's landmark rulings issued in 2014⁷⁹ and 2015⁸⁰ have been heavy-weighted contributions to the earlier mentioned⁸¹ climate of data protection enforcement in the EU with important effects on the course of the data protection reform.⁸²

The construction and protection of its authority by the CJEU, especially the supremacy discourse, as well as strategic behaviour that can be inferred in at least

⁷⁴ Falkner, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Inter-governmentalism'; Laurie Buonanno and Neill Nugent, *Policies and policy processes of the European Union* (Basingstoke: Palgrave Macmillan, 2013), 57–59.

⁷⁵ B Bjurulf and O Elgström, 'Negotiating transparency: the role of institutions' in O Elgström and C Jönsson (eds), *European Union negotiations: processes, networks and institutions*, (New York; London: Routledge, 2005), 53.

⁷⁶ Falkner, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Inter-governmentalism'; Majone, 'From the Positive to the Regulatory State: Causes and Consequences of Changes in the Mode of Governance'.

⁷⁷ European Commission, Proposal for a Regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation), 25.01.2012, COM(2012) 11 final.

⁷⁸ Eg, see Commission references to C-70/10 *Scarlett Extended SA v Société belge des auteurs, compositeurs et éditeurs SCRL (SABAM)* [2011] I-11959 made in Incoming Presidency Note, 17072/14, 2014, 7, fn 3, regarding IP addresses and broad interpretation of personal data definition; references made by the Belgian Commission for the Protection of Privacy to C-101/01 *Lindqvist* [2003] I-12971 regarding social media exemption/inclusion in the Opinion No. 10/2014, etc.

⁷⁹ above fn 63 and fn 64.

⁸⁰ Case C-362/14, *Maximilian Schrems v Data Protection Commissioner* of 06 October 2015, invalidating the Safe Harbour agreement.

⁸¹ See this paper at fn 49.

⁸² The spring 2014 rulings (above, fn 63 and 64) consistently emerged as important mobilising factors in changing the attitudes of the delegations in the Council (interviews with a number of EU officials conducted in 2015). The *Google Spain* ruling (above, fn 64) is also directly related to the provisions on the right to be forgotten in the GDPR in that the policy stance behind those provisions was enhanced with this ruling. The *Schrems* judgment (above, fn 80) had implications for provisions on the international data transfers and adequacy decisions in Chapter V GDPR.

some of its rulings, as discussed in this section, reflect rationalist lines of the neo-institutional theory. The tangible parameter-setting effects of the CJEU's judgments and its contribution to the development of the fundamental rights in the EU embed considerations of the historical institutionalist branch of this theory.

IV. The Charter—A Victim of Domestic Politics?

A. EU Integration in the Field of Civic Interests

Apart from the CJEU input covered in the previous section, the EU became more steadily and systematically engaged with human rights since around the 1990s.⁸³ There are various contextual aspects to that. As discussed above, there was a need for more sources of legitimacy for its own institutions, such as the CJEU.⁸⁴ Besides, major political, economic and societal changes in the 1980s and 1990s led to an incremental consideration of non-economic interests in general in the EU policies. Such civic interests as environmental protection and consumer protection acquired a Treaty base in the Single European Act and the Maastricht Treaty, respectively. The amendments to the Treaty of Amsterdam also put an emphasis on requirements in the field of health, safety, environmental and consumer protection to be enacted in single market regulation. This tendency was driven by concerns raised by waves of Euroscepticism, but also by changing actor landscape altered by the enlargements that increased the number of NGOs and governments advocating for promotion of civic interests. Moreover, with time and gained experience public policy was progressing towards more balanced rules.⁸⁵ From yet another perspective, the pillar system introduced by the Maastricht Treaty and repealed by the Lisbon Treaty was something rather artificial and hardly sustainable for long, as intensifying integration generates various overspills between different policy realms:

[T]he area of policy and legislation known as JHA can appropriately be regarded as the obverse side of the coin which is the European Union's well-established internal market. The pressing need for the European Union's governments to work ever more closely together to protect physical security and civil liberties derives precisely from the ceaseless deepening of the Union's internal market. ... The aspiration of some to regard the 'JHA pillar' as institutionally isolated forever from the Union's central achievement until now, the single internal market, can be seen today as a highly implausible one.⁸⁶

⁸³ Andersen et al., 'Formal Processes: EU Institutions and Actors', 3.

⁸⁴ European Parliament, *The Charter of Fundamental Rights*, 2016.

⁸⁵ AR Young and HS Wallace, *Regulatory politics in the enlarging European Union: weighing civic and producer interests* (Manchester: Manchester University Press, 2000).

⁸⁶ B Donnelly, 'Justice and home affairs in the Lisbon Treaty: a constitutionalising clarification?' *Eipascopia* 1 (2008): 22.

Therefore, such single market features as free movement made clarification and codification of citizen rights at the EU level inevitable. Although some views link the stipulation of the EUCFR to the then imminent enlargements and accession of many Eastern and Central European countries, which were viewed as potentially less developed democracies due to their totalitarian past. Certain prejudices with regard to these countries, it is thought, led to the stipulation of the EUCFR as a form of political conditionality in order to obtain the commitment to fundamental rights protection from the new Member States.⁸⁷

In any case, the EUCFR was drafted as a modernised and vaster as well as technology-savvy rights catalogue, which the bespoke article on the protection of personal data⁸⁸ and the updated wording in Article 7 enshrining the right to privacy⁸⁹ are signs of. However, fundamental rights had to wait till the coming into force of the Lisbon Treaty in 2009 to reach their full-powered constitutionalisation and to gain legal Treaty bases for their protection, after the drawback during the stipulation of the Treaty of Nice and the failure of the Constitutional Treaty altogether in 2005, which was the second attempt to fully legally activate the EU rights catalogue. This had to do with domestic politics and their projection onto the processes of EU integration in the field of civic rights, as will now be discussed in more detail.

B. The Charter and the Member States' Sovereignty Concerns

To maintain their territorial political authority, the national political elites tend to favour vertical integration. Horizontal integration and the potential 'emergence of a transnational civic identity' is undesired by those elites, as it would enhance the legitimacy of the supranational sphere, and would undermine their domestic influence as a consequence.⁹⁰ The EUCFR, establishing supranational rights dimensions, entailed a substantial base for building such transnational European identity and values. This sort of progression was acceptable for most EU governments, but the views of some governments differed. Especially, the UK was dissenting to it.

The UK is an EU Member State with a particular track record. While having been offered a membership since the conception of the EC in the 1950s, the

⁸⁷ B Puchalska, 'The Charter of Fundamental Rights of the European Union: Central European Opt-Outs and the Politics of Power', *Europe-Asia Studies* 66(3) (2014): 488–506.

⁸⁸ Article 8 of the EUCFR; the on-going debates about the relationship between the right to protection of personal data and the right to privacy are not touched upon in this paper since it does not have an impact on the perspective addressed in this study. In any case, academic views are very divergent regarding separatedness of the two rights (eg see O Lynskey, 'Deconstructing data protection: the 'Added-value' of a right to data protection in the EU legal order', *International and Comparative Law Quarterly* 63(3) (2014): 569–597; R Gellert and S Gutwirth, 'The legal construction of privacy and data protection', *Computer Law & Security Review: The International Journal of Technology Law and Practice* 29(5) (2013): 522–530; G González Fuster, *The Emergence of Personal Data Protection as a Fundamental Right of the EU* (Springer Cham Heidelberg: New York Dordrecht London, 2014), etc.).

⁸⁹ In this article of the EUCFR the word 'correspondence' featuring in the Article 8 of the ECHR on the protection of private life is replaced with the term 'communication'.

⁹⁰ DN Chryssochoou, *Theorizing European integration*, London (Routledge, 2nd edition, 2009), 81.

country joined the Treaties only in 1973. However, since its accession, it has gained a reputation of 'a spoiler and scavenger', and a 'hesitant' Member State,⁹¹ as it has opposed most of the policy initiatives and obtained a series of exemptions from various EU instruments and agreements. Both the Directive 95/46/EC⁹² and the newly adopted GDPR were perceived as unwelcome by the UK,⁹³ amongst others, due to sovereignty concerns or giving up national powers to Brussels. Demonisation of European integration, escalated by the competition between British conservative political forces in recent years,⁹⁴ finally culminated in the referendum-based decision to split from the EU—the so-called Brexit—in June 2016.

In the late 1990s, when the EUCFR was due to be adopted, most EU governments wanted it to be given a Treaty status in the Nice Treaty. The UK led a coalition of a few opposing governments to prevent such a development. As consequently the Charter was merely 'solemnly proclaimed' by the EU governing institutions in 2000, its legal status was rather uncertain and, accordingly, the impact weaker for almost a decade. With the coming into force of the Lisbon Treaty in 2009, the Charter acquired a legally-binding status, but again failed to be incorporated into the EU Treaties and became an annex to them due to concerns of some countries that the Charter might open up an avenue to weaken the national governments' position with regard to their citizens through its potential interpretations by the CJEU. The UK felt particularly uneasy with this catalogue inferring a threat of spillover of some continental economic and social rights through the Charter, as well as was wary of more prescriptively enshrined rights as compared to common law principles. The UK, along with the Czech Republic and Poland, insisted on a guarantee that citizens in their states would not gain new rights through the Charter. Such a guarantee was granted in Protocol 30 of the Lisbon Treaty.⁹⁵

However, UK isolationist politics are not limited to the EU only. Soon after the drafting of the EU Lisbon Treaty, the UK Conservatives, at odds with the history, became uncomfortable with commitments to another international rights catalogue—the ECHR.⁹⁶ The proposals as radical as withdrawal from the above

⁹¹ PG Taylor, *International organization in the age of globalization* (London: Continuum, 2003), 99–134.

⁹² Bennett and Raab, 'The governance of privacy: policy instruments in global perspective', 93–94, 96.

⁹³ P Oltermann, Britain accused of trying to impede EU data protection law, *The Guardian*, 27 September 2013.

⁹⁴ R Winnett and R Mason, David Cameron to take on the 'Ukip fruitcakes' with EU referendum, *The Telegraph*, 1 May 2013; Alex Hunt, UKIP: The story of the UK Independence Party's rise, *The BBC*, 21 November 2014.

⁹⁵ Buonanno and Nugent, 'Policies and policy processes of the European Union', 246–250.

⁹⁶ Winston Churchill, the Second World War time British Prime Minister, is viewed as one of the main initiators and visionaries of this Convention as well as of the related institutions—the Council of Europe and the ECtHR (see European Commission, no date, Winston Churchill: calling for a United States of Europe), 'to hold states to account by a higher judicial authority upholding a European-wide set of values' (see Francesca Klug, Human rights: Cameron's message to Europe, *The Guardian*, 25 January 2012). The drafting of the Convention 'was heavily influenced by British lawyers' (see Jean-Claude Mignon, European court of human rights is not perfect, but it's still precious, *The Guardian*, 19 April 2012). Churchill was envisaging that building of a 'United States of Europe' would help 'to eliminate the European ills of nationalism' (see above, this footnote, European Commission), that led to two very atrocious wars in the 20th century.

Convention and replacement of its national transposition by a new national law have been propagated by the conservative forces since around 2010.⁹⁷ These proposals became part of the Tories' manifesto in the 2015 election.⁹⁸ Such discourses were particularly reinforced when, inter alia, a ruling of the ECtHR enacting this convention caused difficulties for the British government to deport from the country a Jordanian cleric allegedly linked to the terrorism. The Court ruled against deportation on the grounds of protection of the right to a fair trial based on the real risk that evidence obtained by torture would be used.⁹⁹

Puchalska suggests that the Czech and Polish opt-outs from the Charter also have to be interpreted as a power-game and 'political point-scoring at home and in Europe', since the issue claims articulated behind these oppositions could hardly be justified. These claims referred to threats to sovereign decision-making in the realm of family law in Poland and probability of property restitution demands by Germans expelled from these countries after World War II in both cases. Moreover, the opt-out agendas were not mandated by a due democratic process in either Member States. The acceptance of the UK, the Czech Republic and Poland's opt-outs undermined the overall symbolic value of the EUCFR, she argues.¹⁰⁰

Apart from the three stand-alone opt-outs, general national sovereignty concerns are also locked in the provisions of the EUCFR, such as Article 51(1) limiting application of the document in the Member States only to the implementation of the EU law. Even more so, Article 6(1) of the Treaty on European Union ensures that '[t]he provisions of the Charter shall not extend in any way the competences of the Union as defined in the Treaties'. The EUCFR, therefore, has provided for overarching protection of fundamental rights in implementing the EU law, but not in the areas regulated only by national law, ie it did not cover all actual allegations of fundamental rights infringements in the EU.¹⁰¹ Thus, this qualified EU human rights regime resulted as less robust as compared with that contemplated in the 1950s, which foresaw 'that monitoring and responding to human rights abuses by or within Member States would be a core task of the European Community, while the current constitutional framework resists and seeks to limit any role for the EU in monitoring human rights within the Member States'.¹⁰² In particular, the internal projection of this regime is less ambitious than the promotion of human rights in the EU external policies.¹⁰³ A persisting anxiety among at least some Member States is that infusing the EU with deeper

⁹⁷ UK Parliament, European Convention on Human Rights (Withdrawal) Bill 2010–12, 2010; above 96, Klug; above, 96, Mignon.

⁹⁸ N Watt and O Bowcott, Tories plan to withdraw UK from European convention on human rights, *The Guardian*, 3 October 2014.

⁹⁹ *Othman (Abu Qatada) v. The United Kingdom*—8139/09 [2012] ECHR 56.

¹⁰⁰ Puchalska, 'The Charter of Fundamental Rights of the European Union: Central European Opt-Outs and the Politics of Power', 504.

¹⁰¹ See, for instance, European Parliament, Petition 1079/2011 by Aris Christidis (Greek and German), on alleged infringement of civil and human rights by the German judicial authorities, 2016; see also Wisman, 'Willems: Giving Member States the Prints and Data Protection the Finger'.

¹⁰² De Búrca, 'The evolution of EU human rights law', 495–496.

¹⁰³ *ibid.*, 495–497.

commitments to human rights might generate unforeseen extension in the scope of its competence'.¹⁰⁴

This section explained the factors not specifically related to the issue-area of privacy and data protection in the EU, such as overall sovereignty concerns of the Member States, that nevertheless affected enactment of these rights alongside other fundamental rights since the 1990s. If the EUCFR had been included in the Treaty of Nice stipulated just a few years after the coming into effect of the Directive 95/46/EC, this law would have had a very different 'life'. The theme of this section—the way the emergence of the Charter was shaped by tensions related to the EU integration and the Member States' responses to it in preserving their spheres of competence—points to the rational choice institutionalism dimension. The historical institutionalism is present in the effects of the uneasy process of the addition of a human rights catalogue to the EU primary law for the protection of fundamental rights. The next section will reflect on what dynamics have been created by injecting privacy and data protection into the EU regulation and implementing it through a market-making mechanism, the reasons for such happening, and the implications.

V. Directive 95/46/EC, GDPR, and the Market Imprint

A. 'Treaty-base Games': Explaining the Market-framing of the EU First Data Protection Instrument

Historically, the national Data Protection Authorities (DPAs) are thought to have played a key role in the instalment of the Directive 95/46/EC, ie a harmonising data protection instrument, in the EU *acquis*. The DPAs 'were among the first independent regulatory agencies in Europe'¹⁰⁵ following the passage of comprehensive national privacy laws in a number of European countries in the 1970s and 1980s, including some of the EU founding Members, such as France, Germany, and Luxembourg. Supranational level action was prompted when the DPAs, in light of potential venue-shopping for data processing operations, used their powers to prevent data exchanges with the EC countries, eg Belgium and Italy, where privacy laws were absent at the end of the 1980s.¹⁰⁶ Apart from interference with the accomplishment of the single market, the situation was also affecting the plans to launch the Schengen System, leading the previously reluctant Commission to undertake the drafting of the EC-wide law—Directive 95/46/EC—to create a

¹⁰⁴ SA de Vries, U Bernitz and S Weatherill, 'Introduction', in SA de Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon*, (Oxford: Hart, 2013), 4.

¹⁰⁵ AL Newman, 'Protecting privacy in Europe: administrative feedbacks and regional politics', in S Meunier and KR McNamara (eds), *Making history: European integration and institutional change at fifty*, (Oxford; New York: Oxford University Press, 2007), 130, 132.

¹⁰⁶ *ibid* at 130–133.

level playing field across all Member States. Despite industry's efforts to stop it, the European level privacy protection regime was adopted, requiring the presence of data protection rules and independent DPAs in all EU Member States, and expanding the regulatory powers of these agencies. Moreover, at the supranational level, the role of national DPAs was institutionalised and cooperation consolidated by a provision establishing the Article 29 Working Party composed of national regulators. Since its first meeting in 1997, it has been actively involved in the process of development and enforcement of the rules as well as in the evaluation of the adequacy of privacy regimes in foreign countries.¹⁰⁷

The previous sections briefly covered the history of fundamental rights in the EU to explain the absence of related primary law at the time of the emergence of the first supranational privacy protection legislation. In the absence of the legal base conferring on the EU competence to legislate in the sphere of human rights, the Directive 95/46/EC was stipulated on the basis of Article 100a of the EC Treaty (now Article 114 of the Treaty on the Functioning of the EU (hereafter TFEU)) enabling the EU to adopt measures related to the functioning of the internal market. Modern privacy and data protection laws are commonly associated with certain economic objectives, such as raising consumer confidence in e-commerce and not hampering international personal data flows related to exchange of goods and services.¹⁰⁸

However, from the macro-level EU politics perspective, rather than a genuine market-making exercise, particularly, looking at the fact that the main legal base was changed in the GDPR,¹⁰⁹ adoption of the Directive 95/46/EC under internal market procedures could be seen as part of the broader phenomenon of 'treaty-base games'. This term refers to the presence of a certain political agenda behind the choice of a given legal base, ie an Article in the EU Treaties, in order to overcome formal constraints or opposition.¹¹⁰ There is a wide variety of policy processes in the EU, each of which is subject to a diverse decision-making procedure. The intergovernmental and supranational competence vary across different policy areas.¹¹¹ A Treaty base determines the procedure and the constellation of power among the actors.¹¹² For example, there was a conflict between the Council of Ministers and the European Parliament (EP) in 2012 when the change of the Treaty base by the former resulted in reduction of the EP legislating powers in that dossier during the redrafting of the Schengen package. The legal base was changed by the Council from Article 77 of the TFEU, encompassing an ordinary legislative

¹⁰⁷ *ibid* at 123–138.

¹⁰⁸ Brown and Marsden, 'Regulating code: good governance and better regulation in the information age', 50–51.

¹⁰⁹ It is now Article 16 of the Treaty on the Functioning of the European Union (TFEU)—the new legal basis for the adoption of data protection rules introduced by the Lisbon Treaty.

¹¹⁰ M Rhodes, 'A regulatory conundrum: industrial relations and the social dimension', in S Leibfried and P Pierson (eds), *European social policy: between fragmentation and integration*, (Washington, D.C.: Brookings Institution, 1995c), 78–122.

¹¹¹ Buonanno and Nugent, 'Policies and policy processes of the European Union', 77–86.

¹¹² E Versluis, M van Keulen and P Stephenson, *Analyzing the European Union policy process* (Basingstoke: Palgrave Macmillan, 2011), 13.

procedure and the co-legislator's capacity for the EP, to Article 70. Under this Article, the EP became an observer and the Member States had more decision-making freedom.¹¹³ In a similar fashion, (at times rather odd and fuzzy) issue linkages to the internal market or competition policy, where the supranational institutions have long been delegated more competence, are known to have been made strategically sometimes. Framing an issue as one policy area instead of another allows application of a certain Treaty legal base.¹¹⁴ The switch from law enforcement to internal market procedures was made while stipulating the Data Retention Directive to overcome the lack of unanimity in the Council required under the former at the time. Resorting to an internal market legal base made it possible for the UK—the main proponent of that legislation—to rely on qualified majority voting to get this measure passed in the Council.¹¹⁵ Even in such domain as defence policy with the most limited EU level mandate some supranational initiatives were enacted through market-framing them.¹¹⁶

The realm of Justice and Home Affairs (JHA), with which privacy and data protection, as fundamental rights, sit more naturally along with other civil liberties, as also follows from the current governance of these rights at the EU and national level,¹¹⁷ had been gradually transitioning from the third to the first pillar until the full 'communitarisation'¹¹⁸ of JHA with the Lisbon Treaty.¹¹⁹ Until then, the 'treaty-base game' strategy (ie the deliberate choice of a 'convenient' legal base) to enable application of the Community method to JHA issue-areas where it was not yet formally foreseen was quite usual.¹²⁰ The content of the Directive 95/46/EC clearly transcended the boundaries of the first pillar.¹²¹ The move of data protection from the Commission Directorate-General responsible for the internal market to the Directorate-General dealing with justice affairs

¹¹³ ALDE, Schengen: Council declares war on the European Parliament, 7 June 2012.

¹¹⁴ Falkner, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Intergovernmentalism', 300–301.

¹¹⁵ C Jones and B Hayes, The EU Data Retention Directive: a case study in the legitimacy and effectiveness of EU counter-terrorism policy (Statewatch, 2013); Taylor, M., Privacy and Data Protection in the European Parliament: An Interview with Sophie in 't Veld, *Utrecht Journal of International and European Law*, Vol. 31(80), 2015, pp. 141–142.

¹¹⁶ U Mörtz, 'Framing an American threat: the European Commission and the technology gap', in M Knodt and S Princen (eds), *Understanding the European Union's external relations*, (London, New York: Routledge, 2003), 75–91; Defence policies pre-Lisbon fell under the so-called second pillar.

¹¹⁷ In most Member States they are within the competence of the Ministries of Justice. At the EU level the responsible institutional branches are the Directorate-General Justice and Consumers of the European Commission, Committee on Civil Liberties, Justice and Home Affairs in the European Parliament, and the Justice and Home Affairs configuration of the Council of Ministers.

¹¹⁸ This refers to the 'Community' method by means of which most EU decisions are taken. It is characterised by the use of the ordinary legislative procedure when the Council and the EP act as co-legislators. It also assigns an exclusive agenda-setting role for the European Commission and significant powers for the CJEU. It involves the use of qualified majority voting in the Council.

¹¹⁹ Donnelly, 'Justice and home affairs in the Lisbon Treaty: a constitutionalising clarification?', 22.

¹²⁰ Falkner, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Intergovernmentalism', 300–301.

¹²¹ S Simitis, 'From the market to the polis: The EU Directive on the protection of personal data', *Iowa Law Review* 80(3) (1995): 445–469.

in 2005¹²² also indicates that the remit of the internal market was not entirely a 'natural habitat' for the enactment of the rights to privacy and data protection. Hence, the use of the Article 100a as the legal base in Directive 95/46/EC can be seen as a straightforward way for the Commission to take action at the time of drafting of this document prior to the availability of specific fundamental rights competences.

As the above analysis demonstrates, the Directive 95/46/EC was not a unique case in EU politics when market-framing of issues of seemingly different nature occurred based on strategic motivations. The discussed 'treaty-base games', which encompass the strategic use of a certain legal base in increasing one's relative power as well as the role that the DPAs' interests played in the coming into being of the EU level data protection instrument relate to notions of rational choice institutionalism. The impact of the very emergence of a regional data protection instrument on related EU and international law links to the historical institutionalist perspective. This perspective is also relevant to the way in which the given political and institutional setting at the time of drafting of the Directive, eg the absence of the primary law on fundamental rights in the EU, determined its market-framing, and how this impacted upon the later privacy and personal data protection policy outcomes, some of which are examined below.

B. The Development of the EU Data Protection Law and the Market-framing Implications

Have policy-making dynamics in the 1990s and the market-framing of Directive 95/46/EC born any problematic outcomes? The normative views regarding compatibility of fundamental rights and market-making dimensions, with the latter aiming at free cross-border flow of personal data, differ. While these two dimensions may be deemed mutually reinforcing in that harmonisation and consistency is complementary to the effective enforcement of fundamental rights in the EU,¹²³ on the one hand, converging the two perspectives in one law can be seen as a controversial design in terms of the actual interests protected under such policy instrument, on the other hand.¹²⁴ The alignment of privacy protection with the free flow of data appears ambiguous¹²⁵ and is hardly entirely non-antithetical.¹²⁶

The Directive 95/46/EC along with subsequent sector specific laws have offered an 'internationally unprecedented level of privacy protection'.¹²⁷ It has been an

¹²² Statewatch, EU policy 'putsch': Data protection handed to the DG for 'law, order and security', 6 July 2005.

¹²³ P Hustinx, EU Data Protection Law: The Review of Directive 95/46/EC and the Proposed General Data Protection Regulation, 2014, 45.

¹²⁴ van Dijk, 'The Network society', 165.

¹²⁵ Simitis, 'From the market to the polis: The EU Directive on the protection of personal data', 446.

¹²⁶ J McNamee, Free flow of data—what is it?, 2016; G González Fuster and A Scherrer, Big Data and smart devices and their impact on privacy, Study, 2015.

¹²⁷ Newman, 'Protecting privacy in Europe: administrative feedbacks and regional politics', 123.

important factor, that a comprehensive data protection regime in Europe was constructed 'prior to the information technology revolution of the late 1990s', making consumer information within Europe 'much less readily available' when compared to the USA.¹²⁸ Importantly, the Directive became a standard-setter not only internationally, as mentioned in the Introduction, but has also played a standard-setting role internally, during the recent EU data protection reform. The level of protection enshrined in this law was consistently referred to as a red line that should not be trespassed (ie lowered) in the policy debates that surrounded the GDPR.¹²⁹ There are, however, various implications of the substantive impact of this instrument's framing within market-making competence.

Primarily, such situation meant that protection under such legislation could be afforded only if linkages could be found to the enactment of the single market. While the CJEU seemed to have relied on a rather broad interpretation of the scope of the Directive, or at least in certain cases,¹³⁰ and '[v]ery few activities truly escape the scope of application of EU economic law',¹³¹ it nevertheless can be said that the potential of the Directive could not fully unfold due to its legal base. Lynskey found that the aims of the EU data protection policy were uncertain and that the Directive suffers from an 'identity crisis'. The relationship between the dual objectives is at least peculiar, and this law was on the verge of being invalid due to the lack of the legal basis for fundamental rights pre-Lisbon. A much less bold stance in drawing upon fundamental rights dimension in the Directive in the CJEU case law could also be noticed. This tangibly changed with the coming into force of the Lisbon Treaty.¹³²

Perplexities also arose when the Commission stipulated the US-EU Passenger Name Record (hereafter PNR) agreement of 2004 on the same legal base pertaining to internal market measures as in the Directive 95/46/EC. The agreement also in part relied on the Directive itself, ie its provisions on transfers to third countries and adequacy decisions. In 2006, this agreement was annulled by the CJEU on the grounds that, despite personal data in question having originated in the commercial context, their further use for public security and law enforcement was outside the scope of the Directive as well as Community competence. In ruling so, the CJEU made no assessment of whether the agreement was breaching air passenger rights, as requested by the EP.¹³³ This indicates how the EU privacy protection

¹²⁸ *ibid* at 124.

¹²⁹ eg see European Commission, Remarks by Commissioner Jourová after the launch of the Data protection regulation trilogue, 24 June 2015.

¹³⁰ H Hijmans and A Scirocco, 'Shortcomings in EU data protection in the third and the second pillars. Can the Lisbon treaty be expected to help?', *Common Market Law Review*, 46(5) (2009): 1502–1503.

¹³¹ S Weatherill, 'From economic rights to fundamental rights', in SA de Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon*, (Oxford: Hart, 2013), 14.

¹³² O Lynskey, 'From market-making tool to fundamental right: the role of the Court of Justice in data protection's identity crisis', in S Gutwirth et al. (eds), *European Data Protection: Coming of Age*, (Hedeborg: Springer, 2013), 59–84.

¹³³ European Commission, Press release No 46/06, 30 May 2006.

regime, for long mainly centred around the Directive 95/46/EC, left grey areas in dealing with realities related to the overlap between economic and law enforcement activities in the era of ‘a growing reliance by Governments on the private sector to conduct and facilitate digital surveillance’.¹³⁴ The Court’s reasoning in this PNR case, which was built on the ‘technicalities’ of the EU law system, can also be interpreted as a way to escape taking a stance with regards to harms to privacy that would have been more politically charged and far-reaching, while at the same time invalidating the agreement.

The EU data protection regime was profoundly affected by the former pillar division structure of the EU, which was abolished by the Lisbon Treaty. Data protection within each pillar was structured around separate sets of instruments. The former pillar division produced uncertainties as to which instruments applied to specific instances in the processing of data.¹³⁵

The EU data protection system, hence, has been evolving as fragmented and underdeveloped in the areas other than market regulation.¹³⁶ As a result, this fragmentation is also reflected in the Article 29 Working Party mandate’s circumscription to internal market issues. Additional supervisory groups had to be established for other areas.¹³⁷ Currently, however, there are various policy initiatives under-way to mitigate these differences,¹³⁸ in addition to the recently adopted Directive 2016/680 replacing the Council Framework Decision 2008/977/JHA that will regulate processing of personal data for law enforcement purposes.¹³⁹

Further, market-based reasoning had some impact on the timing of the EU data protection reform. The review of Directive 95/46/EC and the drafting of its replacement, the GDPR, has often been referred to as long overdue.¹⁴⁰ For instance, according to the EP rapporteur for the GDPR Jan Philipp Albrecht, this reform

¹³⁴ above n 3 UN 2014 at 14.

¹³⁵ FRA, *Data Protection in the European Union: the role of National Data Protection Authorities. Strengthening the fundamental rights architecture in the EU II*, 2010, 14.

¹³⁶ *ibid* at 7; Hijmans and Scirocco, ‘Shortcomings in EU data protection in the third and the second pillars. Can the Lisbon treaty be expected to help?’.

¹³⁷ AL Newman, ‘Watching the watchers: transgovernmental implementation of data privacy policy in Europe’, *Journal of Comparative Policy Analysis: Research and Practice* 13(2) (2011): 184–185.

¹³⁸ De Hert and Papakonstantinou, ‘The new General Data Protection Regulation: Still a sound system for the protection of individuals?’, 180. These initiatives include Proposal for a Regulation on the European Union Agency for Criminal Justice Cooperation (Eurojust), COM(2013)/0535, Proposal for a Regulation on the European Union Agency for Law Enforcement Cooperation and Training (Europol) and repealing Decisions 2009/371/JHA and 2005/681/JHA, COM(2013) 173 and Proposal for a Regulation on the establishment of the European Public Prosecutor’s Office, COM(2013) 534.

¹³⁹ Directive (EU) 2016/680 of 27 April 2016 of the European Parliament and of the Council on the protection of natural persons with regard to the processing of personal data by competent authorities for the purposes of the prevention, investigation, detection or prosecution of criminal offences or the execution of criminal penalties, and on the free movement of such data, and repealing Council Framework Decision 2008/977/JHA, OJ L 119 04.05.2016.

¹⁴⁰ BEUC, *EU data protection law gets much needed update*, 2015.

was ten years late already at its starting point given 'the realities out there'.¹⁴¹ Despite that the Commission's own reports of 2003 and 2007 on the implementation of Directive 95/46/EC stated a number of issues, including tangible divergences and deficiencies of its enactment between Member States, for long it preferred to apply corrective measures rather than amending the Directive, based on the premise that the identified shortcomings were not posing 'a real problem for the *internal market*' (emphasis added).¹⁴²

The drafting of the GDPR that took place in a very different institutional setting as compared to the stipulation of the Directive 95/46/EC, encompassed also a historical development:

The data protection reform package is the first legislation proposed since the entry into force of the Charter of Fundamental Rights of the European Union in 2009 that explicitly aims at comprehensively guaranteeing a fundamental right, namely the fundamental right to data protection.¹⁴³

Notwithstanding the above, market-making connotations still surround this new instrument and with this privacy and data protection conceptualisation in the EU, despite not being necessary anymore from the institutional point of view. While the 'free flow of personal data' element in the title of the Directive 95/46/EC was not present in the original proposal and emerged only during the process of its drafting as a consequence of industry lobbying,¹⁴⁴ the GDPR, even though being a core part of the first legislation enacting an EU fundamental right, inherited this element.¹⁴⁵ It is interesting to note that, although having been steered under the auspices of this body's segment responsible for justice and fundamental rights, the heading of the Commission's statement celebrating the finalisation of the data protection reform rejoices it as a boost for the Digital Single Market,¹⁴⁶ rather than a boost for fundamental rights. In the Commission's document on its work programme for 2016, data protection reform (at odds with its legal base) is clearly classed as relating to the Digital Single Market, instead of the area of justice and fundamental rights.¹⁴⁷ The EP, which positions itself as a fundamental rights

¹⁴¹ CPDP, EU data protection reform: Have we found the right balance between fundamental rights and economic interests? Youtube, 2015.

¹⁴² Hustinx, 'EU Data Protection Law: The Review of Directive 95/46/EC and the Proposed General Data Protection Regulation', 24–25.

¹⁴³ FRA, Annual report 2012—Fundamental rights: challenges and achievements in 2012, 2013, 104.

¹⁴⁴ CJ Bennett and CD Raab, 'The adequacy of privacy: the European Union Data Protection Directive and the North American response', *The Information Society* 13(3) (1997): 248.

¹⁴⁵ The reference to the free flow of data is made even in the very Article 16 TFEU, on which the GDPR is based.

¹⁴⁶ Commission (EU), Agreement on Commission's EU data protection reform will boost Digital Single Market, 15 December 2015.

¹⁴⁷ Commission (EU), Letter of intent with regard to the preparation of the Commission Work Programme 2016, 9 September 2015.

actor,¹⁴⁸ and has indeed been advancing important initiatives in this regard,¹⁴⁹ also accepts that the GDPR is a key enabler of the Digital Single Market.¹⁵⁰ The formulation of the EU Fundamental Rights Agency's comments on the 2012 data protection reform proposals seem to interpret the fundamental rights objectives in the GDPR as somewhat secondary: '[t]he key objective of the draft Regulation is to strengthen the internal market while ensuring effective protection of the fundamental rights of individuals, in particular their right to data protection'.¹⁵¹ 'One of the key objectives of the data protection reform is to "increase the effectiveness of the fundamental right to data protection"'.¹⁵²

At the operational level, the attachment of the data protection reform to the goals related to the Digital Single Market posed a political deadline,¹⁵³ which contributed to the speedier completion of this reform. Especially, this put pressure on the negotiators in the trilogue phase that turned out to be a prompt and effective one, if compared to the protracted earlier stages of the process. More broadly thinking, the choice to politically market the reform as an important element in achieving key economic goals can also be seen as strategic in the light of frequent accusations of overregulation directed at the EU¹⁵⁴ and in light of economic recession. However, it remains uncertain which dimension might be instrumental to which one and various questions can be asked. It needs to be better understood why a more genuine emphasis on post-industrial values, such as fundamental rights, does not seem to suffice for the EU to advocate its policies in this challenging time for the credibility of its institutions. Privacy and data protection have been strongly articulated in the EU in the recent years. '[E]ven without the GDPR, this time data protection is really in the mainstream of public policy'.¹⁵⁵ But although the EU has been ambitious in this realm, rather than 'addressing the principles or values of privacy and data protection as such' the GDPR seems to be focused on 'the adaptation of legislative arrangements to the new circumstances'.¹⁵⁶ For the time being, implementation of these rights, that for long has been mainly embedded in the market-making component, has not fully 'flipped' to draw on purely fundamental rights perceptions.

¹⁴⁸ eg, see European Parliament, The situation of fundamental rights in the European Union in 2015, 14 June 2016.

¹⁴⁹ eg, European Parliament, Draft Report on fundamental rights implications of big data: privacy, data protection, non-discrimination, security and law-enforcement (2016/2225(INI)), LIBE, 19 October 2016; European Parliament, MEPs call for EU democracy, rule of law and fundamental rights watchdog, Press release. 25 October 2016.

¹⁵⁰ eg, see European Parliament, Q&A: new EU rules on data protection put the citizen back in the driving seat/ What does the 'data protection package' consist of? 1 June 2016.

¹⁵¹ FRA, Opinion of the European Union Agency for Fundamental Rights on the proposed data protection reform package, FRA Opinion—2/2012, 7.

¹⁵² *ibid.*, at 12–13.

¹⁵³ eg, see European Council, 24/25 October 2013 Conclusions, EUCO 169/13, 3–4; European Council, European Council meeting (25 and 26 June 2015)—Conclusions, EUCO 22/15, 7.

¹⁵⁴ BBC, EU should 'interfere' less—Commission boss Juncker, 19 April 2016.

¹⁵⁵ G Buttarelli, The General Data Protection Regulation: Making the world a better place? Keynote speech at 'EU Data Protection 2015 Regulation Meets Innovation' event, 2015, 3.

¹⁵⁶ H Hijmans, *The European Union as a constitutional guardian of internet privacy and data protection*, PhD thesis (University of Amsterdam, 2016), 502.

VI. Conclusions

The Directive 95/46/EC came into being at the point in time when supranational institutions had limited competences and formal powers in the sphere of non-economic matters, such as fundamental rights, while at the same time being increasingly bound by the pressures to engage with civic interests for a wide range of reasons. As this paper aimed to explain, the curious case of a classic fundamental right enacted through means of a market-making measure in a jurisdiction traditionally embedded in the rights-based paradigm that the Directive 95/46/EC embodied, was not determined by a so-perceived predominantly economic origin of the EU *per se* and alleged related biases. Rather, it was an outcome of much broader macro-level political processes unrelated to fundamental rights that nevertheless translated into specific factors that had been shaping the governance of privacy in the EU for several decades and that are still influencing it. The absence of the fundamental rights primary law at the time of stipulation of the Directive was a matter of political and historical circumstances. These circumstances could have potentially developed differently, in which case the first EU data protection instrument would not have been conceptualised in market-making reasoning.

A political science lens and rational choice and historical institutionalism considerations have been proposed as tools to interpret the 'twists and turns' of the path that brought the patterns of enforcement of the rights to privacy and data protection the way it has been unfolding. Drawing on these theoretical strands, the notions of strategic actor interests and the effects of historical policy choices on subsequent policy outcomes helped to recount some of the important constraints and drivers with which privacy and personal data protection in the EU has been evolving. Pragmatic political choices of the 1950s left the EU without a formally constitutionalised human rights regime for several decades. As it was discussed, the framing of the Directive 95/46/EC in market-making logic, as a minimum, resulted in a fluctuated undefined boundary between the economic and the rights dimensions in it. It made reliance on the latter dimension rather fragile in enacting the right to privacy in the EU before it could be supported by primary law, ie the legally-binding EUCFR and provisions in the Lisbon Treaty. However, the legacy of linkages of the governance of privacy and data protection to other, economic policy goals that, it could be argued, the Directive 95/46/EC simply could not escape, as this study tried to demonstrate, is not gone despite all the important institutional changes that enabled the building of the upgrade of this law—the GDPR—on fundamental rights promoting primary law clauses. Whether the linkages to the economic benefits are justified and still needed can be debated. But at the very least, it can be said that the conceptualisation of the governance of the rights to privacy and data protection in the EU is still in flux and still catching up with significant achievements in the macro-level EU institutional design.

References

- AFCO, 'Accession to the European Convention on Human Rights (ECHR): stocktaking after the ECJ's opinion and way forward' (2016) <<http://www.europarl.europa.eu/committees/en/afco/events-hearings.html?id=20160420CHE00201>> accessed 20 December 2016.
- ALDE, 'Schengen: Council declares war on the European Parliament' (2012) <<http://www.alde.eu/nc/key-priorities/civil-liberties/single-news/article/schengen-council-declares-war-on-the-european-parliament-39119/>> accessed 30 September 2016.
- Alter, KJ, 'Who Are the "Masters of the Treaty?": European Governments and the European Court of Justice' (1998) 52(1) *International Organization* 121–147.
- Andersen, SS, Kjell, AE and Nick, S, 'Formal Processes: EU Institutions and Actors' in SS Andersen and AE Kjell (eds), *Making policy in Europe*, 2nd edn (London, Sage, 2001) 20–43.
- Aspinwall, M and Schneider, G, 'Institutional research on the European Union: mapping the field' in G Schneider and M Aspinwall (eds), *The rules of integration: institutionalist approaches to the study of Europe* (Manchester, Manchester University Press, 2001) 1–18.
- Bache, I, George, S and Bulmer, S, *Politics in the European Union*, 3rd edn (Oxford, Oxford University Press, 2011).
- BBC, 'Facebook privacy challenge attracts 25,000 users' (2014) <<http://www.bbc.co.uk/news/technology-28677667>> accessed 1 June 2015.
- , 'EU should "interfere" less—Commission boss Juncker' (2016) <<http://www.bbc.com/news/world-europe-36087022>> accessed 10 September 2016.
- Bennett, CJ and Raab, CD, 'The adequacy of privacy: the European Union Data Protection Directive and the North American response' (1997) 13(3) *The Information Society* 245–264.
- , *The governance of privacy: policy instruments in global perspective* (Cambridge, Mass., London, MIT Press, 2006).
- BEUC, 'EU data protection law gets much needed update' (2015) <<http://www.beuc.eu/publications/eu-data-protection-law-gets-much-needed-update/html>> accessed 10 October 2016.
- Bjurulf, B and Elgström, O, 'Negotiating transparency: the role of institutions' in O Elgström and C Jönsson (eds), *European Union negotiations: processes, networks and institutions* (New York, London, Routledge, 2005) 45–62.
- Braman, S, *Change of state: information, policy, and power* (Cambridge, Mass., MIT Press, 2006).
- Brown, I, and Marsden, CT, *Regulating code: good governance and better regulation in the information age* (Cambridge, Mass., The MIT Press, 2013c).
- Buonanno, L, and Nugent, N, *Policies and policy processes of the European Union* (Basingstoke, Palgrave Macmillan, 2013).
- Buttarelli, G, 'The General Data Protection Regulation: Making the world a better place? Keynote speech at "EU Data Protection 2015 Regulation Meets Innovation" event' (San Francisco, 8 December 2015) <https://secure.edps.europa.eu/EDPSWEB/webdav/site/mySite/shared/Documents/EDPS/Publications/Speeches/2015/15-12-08_Truste_speech_EN.pdf> accessed 5 October 2016.
- Cameron, I, 'Competing rights?' in SA De Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon* (Oxford: Hart, 2013) 181–206.

- Chryssochoou, DN, *Theorizing European integration*, 2nd edn (London, Routledge, 2009).
- CJEU, 'Press Release No 135/13, Judgment in Case C-291/12 Michael Schwarz v Stadt Bochum' (2013) <<http://curia.europa.eu/jcms/upload/docs/application/pdf/2013-10/cp130135en.pdf>> accessed 10 June 2015.
- Costa, L, and Pouillet, Y, 'Privacy and the regulation of 2012' (2012) 28(3) *Computer Law and Security Review: The International Journal of Technology and Practice* 254–262.
- CPDP, 'EU data protection reform: Have we found the right balance between fundamental rights and economic interests?' (2015) <<https://www.youtube.com/watch?v=wPHsz9Y6SZM>> accessed 4 April 2016.
- De Búrca, G, 'The evolution of EU human rights law' in PP Craig and G De Búrca (eds), *The evolution of EU law*, 2nd edn (Oxford, New York, Oxford University Press, 2011) 465–497.
- De Hert, P, and Papakonstantinou, V, 'The new General Data Protection Regulation: Still a sound system for the protection of individuals?' (2016) 32(2) *Computer Law & Security Review: The International Journal of Technology Law and Practice* 179–194.
- De Vries, SA, Bernitz, U and Weatherill, S, 'Introduction?' in SA de Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon* (Oxford, Hart, 2013) 1–7.
- Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data, *Official Journal L* 281, 23/11/1995 P. 0031–0050.
- Donnelly, B, 'Justice and home affairs in the Lisbon Treaty: a constitutionalising clarification?' (2008) 1 *Eipiascope* <http://aei.pitt.edu/11043/1/20080509184107_SCOPE2008-1-4_BrendanDonnelly.pdf> accessed 22 March 2016.
- Douglas-Scott, S, 'The Court of Justice of the European Union and the European Court of Human Rights after Lisbon' in SA de Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon* (Oxford, Hart, 2013) 153–179.
- Edwards, L and Howells, G, 'Anonymity, consumers and the Internet: where everyone knows you're a dog' in C. Nicoll, et al. (eds), *Digital anonymity and the Law: tensions and dimensions*, (The Hague, T.M.C. Asser Press, 2003) 207–248.
- European Commission, 'Winston Churchill: calling for a United States of Europe' (no date) <https://europa.eu/european-union/sites/europaeu/files/docs/body/winston_churchill_en.pdf> accessed 11 April 2016.
- , 'Press release No 46/06' (2006) <http://europa.eu/rapid/press-release_CJE-06-46_en.htm> accessed 5 July 2016.
- , Proposal for a Regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation), 25.01.2012, COM(2012) 11 final.
- , 'Remarks by Commissioner Jourová after the launch of the Data protection regulation trilogy' (2015) <http://europa.eu/rapid/press-release_STATEMENT-15-5257_en.htm> accessed 26 June 2015.
- , 'Letter of intent with regard to the preparation of the Commission Work Programme 2016' (2015) <<http://data.consilium.europa.eu/doc/document/ST-11693-2015-INIT/en/pdf>> accessed 2 February 2016.
- , 'Agreement on Commission's EU data protection reform will boost Digital Single Market' (2015) <http://europa.eu/rapid/press-release_IP-15-6321_en.htm> accessed 17 December 2015.

- European Council, '24/25 October 2013 Conclusions, EUCO 169/13' (2013) <https://www.consilium.europa.eu/uedocs/cms_data/docs/pressdata/en/ec/139197.pdf> accessed 12 December 2016.
- , 'European Council meeting (25 and 26 June 2015)—Conclusions, EUCO 22/15' (2015) <<http://www.consilium.europa.eu/en/press/press-releases/2015/06/26-euco-conclusions/>> accessed 12 December 2016.
- European Parliament, 'Q&A: new EU rules on data protection put the citizen back in the driving seat/ What does the 'data protection package' consist of?' (2016) <<http://www.europarl.europa.eu/news/en/news-room/20160413BKG22980/qa-new-eu-rules-on-data-protection-put-the-citizen-back-in-the-driving-seat>> accessed 22 June 2016.
- , 'The situation of fundamental rights in the European Union in 2015' (2016) <<http://www.europarl.europa.eu/committees/en/libe/events-hearings.html?id=20160616CHE00191>> accessed 22 June 2016.
- , 'Petition 1079/2011 by Aris Christidis (Greek and German), on alleged infringement of civil and human rights by the German judicial authorities' (2016) <<http://www.europarl.europa.eu/sides/getDoc.do?type=COMPARL&reference=PE-567.846&format=PDF&language=EN&secondRef=02>> accessed 30 September 2016.
- , 'Draft Report on fundamental rights implications of big data: privacy, data protection, non-discrimination, security and law-enforcement (2016/2225(INI))', (LIBE, 2016) <[http://www.europarl.europa.eu/oeil/popups/ficheprocedure.do?reference=2016/2225\(INI\)&l=en](http://www.europarl.europa.eu/oeil/popups/ficheprocedure.do?reference=2016/2225(INI)&l=en)> accessed 01 December 2016.
- , 'MEPs call for EU democracy, rule of law and fundamental rights watchdog, Press release' (2016) <<http://www.europarl.europa.eu/news/en/news-room/20161020IPR47863/meps-call-for-eu-democracy-rule-of-law-and-fundamental-rights-watchdog>> accessed 1 December 2016.
- , 'The Charter of Fundamental Rights' (2016) <http://www.europarl.europa.eu/atyourservice/en/displayFtu.html?ftuId=FTU_1.1.6.html> accessed 20 December 2016.
- Falkner, G, 'Promoting Policy Dynamism: The Pathways Interlinking Neo-functionalism and Intergovernmentalism' in JJ Richardson (ed), *Constructing a Policy-Making State? Policy Dynamics in the EU* (Oxford University Press, 2012) 292–308
- Farrell, H, 'Privacy in the Digital Age: States, Private Actors and Hybrid Arrangements' in WJ Drake and EJ Wilson III (eds), *Governing global electronic networks: international perspectives on policy and power* (Cambridge, Mass., MIT Press, 2008c) 386–395.
- FRA, 'Data Protection in the European Union: the role of National Data Protection Authorities. Strengthening the fundamental rights architecture in the EU II' (2010) <http://fra.europa.eu/sites/default/files/fra_uploads/815-Data-protection_en.pdf> accessed 9 April 2016.
- , 'Opinion of the European Union Agency for Fundamental Rights on the proposed data protection reform package, FRA Opinion—2/2012' (2012) <<http://fra.europa.eu/sites/default/files/fra-opinion-data-protection-oct-2012.pdf>> accessed 5 November 2015.
- , 'Annual report 2012—Fundamental rights: challenges and achievements in 2012' (2013) <http://fra.europa.eu/sites/default/files/annual-report-2012-chapter-3_en.pdf> accessed 7 April 2016.
- Gellert, R and Gutwirth, S, 'The legal construction of privacy and data protection' (2013) 29(5) *Computer Law & Security Review: The International Journal of Technology Law and Practice* 522–530.

- Gellman, R and Dixon, P, 'WPF Report: many failures—a brief history of privacy self-regulation in the United States' (2011) <<https://www.worldprivacyforum.org/2011/10/report-many-failures-a-brief-history-of-privacy-self-regulation/>> accessed 10 September 2016.
- Goldsmith, JL, and Wu, T., *Who controls the Internet: illusions of a borderless world* (Oxford, New York, Oxford University Press, 2006).
- González Fuster, G, *The Emergence of Personal Data Protection as a Fundamental Right of the EU* (New York, Dordrecht, London, Springer Cham Heidelberg, 2014).
- González Fuster, G and Scherrer, A, 'Big Data and smart devices and their impact on privacy, Study' (2015) <[http://www.europarl.europa.eu/RegData/etudes/STUD/2015/536455/IPOL_STU\(2015\)536455_EN.pdf](http://www.europarl.europa.eu/RegData/etudes/STUD/2015/536455/IPOL_STU(2015)536455_EN.pdf)> accessed 03 April 2016.
- Hijmans, H, *The European Union as a constitutional guardian of internet privacy and data protection*, PhD thesis (University of Amsterdam, 2016).
- Hijmans, H and Scirocco, A, 'Shortcomings in EU data protection in the third and the second pillars. Can the Lisbon treaty be expected to help?' (2009) 46(5) *Common Market Law Review* 1502–1503.
- Hunt, A, 'UKIP: The story of the UK Independence Party's rise' (21 November 2014) <<http://www.bbc.com/news/uk-politics-21614073>> accessed 5 February 2016.
- Hustinx, P, 'EU Data Protection Law: The Review of Directive 95/46/EC and the Proposed General Data Protection Regulation' (2014) <https://secure.edps.europa.eu/EDPSWEB/webdav/site/mySite/shared/Documents/EDPS/Publications/Speeches/2014/14-09-15_Article_EUI_EN.pdf> accessed 15 June 2016.
- Jones, C and Hayes, B, 'The EU Data Retention Directive: a case study in the legitimacy and effectiveness of EU counter-terrorism policy' (Statewatch, 2013) <<http://www.statewatch.org/news/2013/dec/secile-data-retention-directive-in-europe-a-case-study.pdf>> accessed 10 December 2016.
- Katzenbach, C, 'Technologies as Institutions: rethinking the role of technology in media governance constellations' in M Puppis and N Just (eds), *Trends in Communication Policy Research: New Theories, Methods and Subjects* (Bristol, Intellect, 2012) 117–137.
- Klug, F, 'Human rights: Cameron's message to Europe' *The Guardian* (25 January 2012) <<http://www.theguardian.com/commentisfree/2012/jan/25/human-rights-cameron-europe#>> accessed 11 April 2016.
- Lindsay, D and Ricketson, S, 'Copyright, privacy and digital rights management (DRM)' in AT Kenyon and M Richardson (eds), *New dimensions in privacy law: international and comparative perspectives* (Cambridge, Cambridge University Press, 2010) 121–153.
- Lowndes, V and Roberts, M, *Why institutions matter: the new institutionalism in political science* (Houndmills, Basingstoke, Palgrave Macmillan, 2013).
- Lynskey, O, 'From market-making tool to fundamental right: the role of the Court of Justice in data protection's identity crisis' in S Gutwirth et al (eds) *European Data Protection: Coming of Age* (London, Springer, 2013) 59–84.
- , 'Deconstructing data protection: the "Added-value" of a right to data protection in the EU legal order' (2014) 63(3) *International and Comparative Law Quarterly* 569–597.
- Majone, G, 'From the Positive to the Regulatory State: Causes and Consequences of Changes in the Mode of Governance' (1997) 17(2) *Journal of Public Policy* 139–167.
- McNamee, J, 'Free flow of data—what is it?' (2016) <<https://edri.org/free-flow-of-data/>> accessed 02 December 2016.

- Meunier, S and McNamara, KR, 'Making history: European integration and institutional change at fifty' in S Meunier and KR McNamara (eds), *Making history: European integration and institutional change at fifty* (Oxford, New York, Oxford University Press, 2007) 1–20.
- Mignon, J, 'European court of human rights is not perfect, but it's still precious' *The Guardian* (19 April 2012) <<http://www.theguardian.com/law/2012/apr/19/european-court-of-human-rights-human-rights>> accessed 11 April 2016.
- Miller, V, 'EU Accession to the European Convention on Human Rights' SN/IA/5914 House of Commons (2011) <<http://researchbriefings.files.parliament.uk/documents/SN05914/SN05914.pdf>> accessed 20 December 2016.
- Moravcsik, A, 'Liberal intergovernmentalism and integration: A rejoinder' (1995) 33(4) *Journal Of Common Market Studies* 611–628.
- Mörth, U, 'Framing an American threat: the European Commission and the technology gap' in M Knodt and S Princen (eds), *Understanding the European Union's external relations* (London, New York, Routledge, 2003) 75–91.
- Mosco, V, *The digital sublime: myth, power, and cyberspace* (Cambridge, Mass., London, MIT, 2005).
- Movius, LB and Krup, N, 'U.S. and EU Privacy Policy: Comparison of Regulatory Approaches' (2009) 3 *International Journal of Communication* 169–187.
- Newman, AL, 'Protecting privacy in Europe: administrative feedbacks and regional politics,' in S Meunier and KR McNamara (eds), *Making history: European integration and institutional change at fifty* (Oxford, New York, Oxford University Press, 2007) 123–138.
- , 'Watching the watchers: transgovernmental implementation of data privacy policy in Europe' (2011) 13(3) *Journal of Comparative Policy Analysis: Research and Practice* 181–194.
- Oltermann, P, 'Britain accused of trying to impede EU data protection law' *The Guardian* (27 September 2013) <<https://www.theguardian.com/technology/2013/sep/27/britain-eu-data-protection-law>> accessed 10 April 2016.
- Peterson, J and Shackleton M, 'Conclusion' in J Peterson and M Shackleton (eds), *The institutions of the European Union*, 3rd edn (Oxford, Oxford University Press, 2012c) 382–402.
- Petiteville, F, 'Exporting values: EU external co-operation as a soft diplomacy' in M Knodt and S Princen (eds), *Understanding the European Union's external relations* (London, New York, Routledge, 2003) 127–141.
- Princen, S, 'Exporting regulatory standards: the cases of trapping and data protection.' in M Knodt and S Princen (eds), *Understanding the European Union's external relations* (London, New York, Routledge, 2003) 142–157.
- Prins, C, 'Should ICT regulation be undertaken at an international level?' in B Koops et al. (eds), *Starting points for ICT regulation: deconstructing prevalent policy one-liners* (The Hague, TMC Asser, 2006) 151–201.
- Puchalska, B, 'The Charter of Fundamental Rights of the European Union: Central European Opt-Outs and the Politics of Power' (2014) 66(3) *Europe-Asia Studies* 488–506.
- Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) *OJ L 119 04.05.2016*.
- Rhodes, M, 'A regulatory conundrum: industrial relations and the social dimension.' in S Leibfried and P Pierson (eds), *European social policy: between fragmentation and integration* (Washington, D.C., Brookings Institution, 1995c) 78–122.

- Rittberger, Berthold, and Frank Schimmelfennig. 'The constitutionalization of the European Union: explaining the parliamentarization and institutionalization of human rights' in S Meunier and KR McNamara (eds), *Making history: European integration and institutional change at fifty* (Oxford, New York, Oxford University Press, 2007) 213–229.
- Schmidt, SK, 'A constrained Commission: informal practices of agenda-setting in the Council' in G Schneider and M Aspinwall (eds), *The rules of integration: institutionalist approaches to the study of Europe* (Manchester, Manchester University Press, 2001) 125–146.
- Simitis, S, 'From the market to the polis: The EU Directive on the protection of personal data.' (1995) 80(3) *Iowa Law Review* 445–469.
- Solove, DJ and Schwartz, PM, 'Reconciling Personal Information in the United States and European Union' (2014) 102 *California Law Review*; UC Berkeley Public Law Research Paper No. 2271442; GWU Law School Public Law Research Paper 77 (2013) <<http://ssrn.com/abstract=2271442>> accessed 14 December 2013.
- Statewatch, 'EU policy 'putsch': Data protection handed to the DG for 'law, order and security' (2005) <<http://www.statewatch.org/news/2005/jul/06eu-data-prot.htm>> accessed 20 June 2015.
- Taylor, M, 'Privacy and Data Protection in the European Parliament: An Interview with Sophie in 't Veld' (2015) 31(80) *Utrecht Journal of International and European Law* 141–144.
- UK Parliament, 'European Convention on Human Rights (Withdrawal) Bill 2010-12' (2010) <<http://services.parliament.uk/bills/2010-12/europeanconventiononhumanrightswithdrawal.html>> accessed 10 April 2016.
- UN, 'The right to privacy in the digital age, Report of the Office of the United Nations High Commissioner for Human Rights' (2014) <http://www.ohchr.org/EN/HRBodies/HRC/RegularSessions/Session27/Documents/A.HRC.27.37_en.pdf> accessed 10 August 2015.
- UN, 'Report of the Special Rapporteur to the Human Rights Council on the use of encryption and anonymity to exercise the rights to freedom of opinion and expression in the digital age' (2015) <<http://daccess-dds-ny.un.org/doc/UNDOC/GEN/G15/095/85/PDF/G1509585.pdf?OpenElement>> accessed 10 August 2015
- Van Dijk, J, *The Network society*, 3rd edn (London, Sage, 2012).
- Watt, N and Bowcott, O, 'Tories plan to withdraw UK from European convention on human rights' *The Guardian* (3 October 2014) <<http://www.theguardian.com/politics/2014/oct/03/tories-plan-uk-withdrawal-european-convention-on-human-rights>> accessed 11 April 2016.
- Weatherill, S, 'From economic rights to fundamental rights.' in SA De Vries, U Bernitz and S Weatherill (eds), *The protection of fundamental rights in the EU after Lisbon* (Oxford: Hart, 2013) 11–36.
- Winnett, R and Mason, R, 'David Cameron to take on the 'Ukip fruitcakes' with EU referendum' *The Telegraph* (1 May 2013) <<http://www.telegraph.co.uk/news/worldnews/europe/eu/10032073/David-Cameron-to-take-on-the-Ukip-fruitcakes-with-EU-referendum.html>> accessed 10 April 2016.
- Wisman, T, 'Willems: Giving Member States the Prints and Data Protection the Finger' (2015) 1(3) *European Data Protection Law Review* 245–248.
- Young, AR and Wallace, HS, *Regulatory politics in the enlarging European Union: weighing civic and producer interests* (Manchester, Manchester University Press, 2000).

2

The ‘Risk Revolution’ in EU Data Protection Law: We can’t Have Our Cake and Eat it, Too

CLAUDIA QUELLE

Abstract. The risk-based approach has been introduced to the GDPR to make the rules and principles of data protection law ‘work better’. Since controllers are formally responsible and accountable for the way in which they implement the GDPR, the notion of risk is used to enable them to determine the technical and organisational measures which they should take. This chapter will argue, however, that it is impossible to require controllers to calibrate compliance measures in terms of risk, whilst maintaining that this does not affect the legal obligations to which they are subject. We cannot have our cake and eat it, too. Section II first defines the risk-based approach and distinguishes it from a harm-based approach, as well as from risk regulation, risk-based regulation and risk management. The risk-based approach introduces the notion of risk as a mandatory reference point for the calibration of legal requirements by controllers. Section III explicates the relationship between ‘risk’ and the obligations of controllers, as addressed, in particular, by articles 24 (responsibility), 25(1) (data protection by design) and 35 (data protection impact assessment). It argues that controllers have to take into account the risks when they take measures to implement the GDPR. In combination with the data protection impact assessment, this development can buttress a substantive turn in data protection law. The other side of the coin is, however, that controllers are entrusted with the responsibility not only to improve upon the data protection obligations specified by the legislature, but also to second-guess their use in the case at hand. Section IV argues that none of the obligations of the controller were fully risk-based to start with. In fact, the risk-based approach is in direct conflict with the non-scalability of the provisions in Chapter III (rights of the data subject).

Keywords: *The risk-based approach—the data protection impact assessment—meta-regulation—accountability—controller responsibility—scalability*

I. Introduction

The Article 29 Data Protection Working Party (the WP29) has been a proponent of the adoption of an accountability- and risk-based approach throughout the reform of the Data Protection Directive.¹ It has, however, neglected to explicate in a consistent manner how ‘risk’ relates to the obligations in data protection law. The WP29 has consistently maintained that the legal obligations are not affected by the shift of responsibility towards controllers. In an attempt to dissuade concerns about the role of controllers under the upcoming General Data Protection Regulation (the GDPR),² it issued the ‘Statement on the role of a risk-based approach in data protection legal frameworks’. The main purpose of this statement is to ‘set the record straight’, as, according to the WP29, ‘the risk-based approach is increasingly and wrongly presented as an alternative to well-established data protection rights and principles, rather than as a scalable and proportionate approach to compliance’.³ This ties in to their earlier opinion on the principle of accountability, which portrays accountability not as a replacement of prescriptive rules, but rather as a way to make ‘the substantive principles of data protection ... work better’.⁴ In the words of CIPL, ‘[t]he risk-based approach is not meant to replace or negate existing privacy regulation and data protection principles’, but rather to ‘bridge the gap between high-level privacy principles on the one hand, and compliance on the ground on the other’.⁵ The risk-based approach to accountability, according to CIPL, affects the ‘controls, compliance steps and verifications’ which should be taken, but at the same time, ‘[t]his does not absolve the organisation from the overall obligation to comply with the GDPR’.⁶

¹ Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data [1995] OJ L 281/31 (Data Protection Directive. See especially: Article 29 Data Protection Working Party and Working Party on Police and Justice, ‘The Future of Privacy. Joint Contribution to the Consultation of the European Commission on the legal framework for the fundamental right to protection of personal data’ WP 168 (2009), 20; Article 29 Data Protection Working Party, ‘Opinion 3/2010 on the principle of accountability’ WP 173 (2010), 13; Article 29 Data Protection Working Party, ‘Statement of the Working Party on current discussions regarding the data protection reform package’ (2013), 2–3; Article 29 Data Protection Working Party, ‘Statement on the role of a risk-based approach in data protection legal frameworks’ WP 2018 (2014).

² Regulation (EU) 2016/679 of the European Parliament and of the Council of 17 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) [2016] OJ L 119/2 (GDPR).

³ WP29, ‘Statement on the role of a risk-based approach’, 2.

⁴ WP29, ‘Opinion 3/2010 on the principle of accountability’, 5.

⁵ Centre for Information Policy Leadership, ‘A Risk-based Approach to Privacy: Improving Effectiveness in Practice’ 19 June 2014, www.informationpolicycentre.com/privacy-risk-management.html, 1, 4.

⁶ Centre for Information Policy Leadership, ‘Risk, High Risk, Risk Assessments and Data Protection Impact Assessments under the GDPR’ 21 December 2016, www.informationpolicycentre.com/eu-gdpr-implementation.html, 20.

DIGITALEUROPE had previously proposed an approach under which controllers would have extensive discretion to develop the procedures and rules necessary to prevent any privacy harms from arising (see section II).⁷ The WP29 was therefore right to clarify that the risk-based approach should not give controllers free reign. Yet, the WP29 cannot maintain that the data protection principles in the GDPR should be applied in the same manner and have the same outcome, 'whatever the processing and the risks for the data subjects'.⁸ It is time to set the record straight again. How exactly does the risk-based approach relate to compliance with the obligations in the GDPR?

This chapter will argue that, while the risk-based approach does not replace and do away with the data protection obligations, it does supplement and alter them. In other words, it does affect what the obligations of controllers require in the case at hand. Section II distinguishes the risk-based approach from a number of similar regulatory approaches, to which it has been related in existing literature and policy documents. Section III discusses the risk-based approach as it is present in the GDPR, focussing in particular on articles 24 (responsibility of the controller), 25(1) (data protection by design) and 35 (the data protection impact assessment). This section draws from the text of the GDPR to elucidate the role of 'risk', arguing that it calibrates compliance in two ways: by scaling the measures that controllers have to take, and by asking that the compliance measures actually address risks to the rights and freedoms of individuals. The risk-based approach thereby tones down legal requirements when they are not in proportion to the risks posed by the processing, but also brings in further protection of the rights and freedoms of individuals. So how can the WP29 maintain that the legal obligations are not affected? Section IV discusses the most plausible defence of the WP29: that data protection law was scalable to begin with. A number of provisions in the GDPR could be reconciled with the risk-based approach for this very reason, although it cannot be denied that the risk-based approach supplements and alters them. Other provisions, particularly those regarding the control rights of data subjects, explicitly reject the discretion allocated to controllers under the risk-based approach.

Although the risk-based approach has been on the agenda of researchers and policy-makers for years, there is as of yet no clear, concise, and consistent overview of its meaning under the GDPR. The relationship between the risk-based approach and compliance has not been addressed properly before. This chapter provides an in-depth legal and regulatory analysis of this new feature of the data protection landscape. The legal analysis explicates the role of 'risk', which we will be faced with from 25 May 2018 onwards, when the GDPR will become fully enforceable. It gives rise to a crucial question, which data protection regulators

⁷ DIGITALEUROPE, 'DIGITALEUROPE comments on the risk-based approach' 28 August 2013, http://teknologiateollisuus.fi/sites/default/files/file_attachments/elinkeinopolitiikka_digitalisaatio_tietosuojadigitaleurope_risk_based_approach.pdf.

⁸ WP29, 'Statement on the role of a risk-based approach', 3.

and courts would do well to address: should the risk-based approach affect the technical and organisational measures taken by controllers to make possible the exercise of data subject's control rights, or is this domain off-limits? A regulatory analysis clarifies what the risk-based approach, and in particular the data protection impact assessment (DPIA), could add, from a regulatory perspective, to data protection law. This analysis elucidates the link between the DPIA and compliance, shedding light on the strengths and weaknesses of the meta-regulatory shift towards accountability under the GDPR.

The risk-based approach under the GDPR is closely connected to the recent emphasis on the accountability of the controller. In 2010, the WP29 published an opinion on accountability so as to move data protection 'from "theory to practice"'.⁹ A few months later, the Commission recommended a number of accountability obligations, such as (what was then known as) privacy by design, the privacy impact assessment, and the requirement to appoint a data protection officer.¹⁰ The GDPR includes the principle of accountability in article 5: controllers shall be responsible for, and able to demonstrate compliance with, the principles relating to the processing of personal data. The GDPR also introduces article 24; now named 'responsibility of the controller', the Parliament proposed that the heading of this article refers to accountability as well.¹¹ With reference to article 24, the WP29 sees the risk-based approach as a 'core element of the principle of accountability'.¹² More precisely, the risk-based approach can be seen as a particular take on accountability, which uses the notion of risk to enable controllers to determine how to implement abstract legal requirements in practice by helping them 'determine the general types of measures to apply'.¹³ This is part of the 'revolution ... away from paper-based, bureaucratic requirements and towards compliance in practice',¹⁴ which allocates greater responsibility towards controllers for data protection on the ground.

In the following, the notion of risk is treated as pertaining to 'a potential negative impact'¹⁵ on 'the rights and freedoms of natural persons'.¹⁶ It has to be clarified at the outset that this does not refer only to the rights of the data subject contained in

⁹ WP29, 'Opinion 3/2010 on the principle of accountability', 3.

¹⁰ Commission (EC), 'A comprehensive approach on personal data protection in the European Union' COM(2010) 609 final, s 2.2.4.

¹¹ Committee on Civil Liberties, Justice and Home Affairs, 'Report on the proposal for a regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data' A7-0402/2013.

¹² WP29, 'Statement on the role of a risk-based approach', 2.

¹³ WP29, 'Opinion 3/2010 on the principle of accountability', 13.

¹⁴ C. Kuner, 'The European Commission's Proposed Data Protection Regulation: A Copernican Revolution in European Data Protection Law' (2012) *Bloomberg BNA Privacy & Security Law Report* 1, 1.

¹⁵ WP29, 'Statement on the role of a risk-based approach', 3. But see: Article 29 Data Protection Working Party, 'Guidelines on Data Protection Impact Assessment (DPIA) and determining whether processing is "likely to result in a high risk" for the purposes of Regulation 2016/679' WP 248 (2017), 15.

¹⁶ GDPR, arts 24–25 and recitals 74–75.

Chapter III (access, rectification, erasure, etc.). Recital 75 makes specific reference to the interest of data subjects to exercise control over their data, as well as to discrimination, identity theft or fraud, financial loss, damage to the reputation, loss of confidentiality of personal data protected by professional secrecy, the unauthorised reversal of pseudonymisation, and any other significant economic or social disadvantage. The WP29 has clarified that 'the scope of "the rights and freedoms" of data subjects primarily concerns the right to privacy but may also involve other fundamental rights such as freedom of speech, freedom of thought, freedom of movement, prohibition of discrimination, right to liberty, conscience and religion'.¹⁷ Indeed, the GDPR seeks to offer a balanced form of protection of all fundamental rights that are at stake in the context of the processing of personal data.¹⁸

II. The Role of 'Risk' in the Risk-Based Approach

The risk-based approach is best regarded as a means to bring compliance 'from theory to practice'. This section will define the role of risk under the risk-based approach and distinguish it from other uses of this notion. While there is a rough consensus on the general meaning of the risk-based approach, it is conflated with a number of other uses of 'risk'. The risk-based approach should, in particular, be carefully distinguished from risk regulation, risk-based regulation, and risk analysis or risk management. The risk-based approach under the GDPR should also be distinguished from the more outcome-oriented, harm-based approaches that have been advocated in the past, most notably by DIGITALEUROPE and the RAND Corporation.

The risk-based approach is what Lynskey describes as an attempt 'to incorporate an unprecedented emphasis on risk, as a factor which triggers or tempers the application of data protection regulation'.¹⁹ In the words of Macenaite, under the GDPR, 'risk has become ... a key indicator in deciding whether additional legal and procedural safeguards are required in a particular context in order to shield data subjects from potential negative impacts stemming from specific data processing activities'.²⁰ The idea is, more specifically, 'to combine the use of risk management tools with a calibration of the controllers' obligations according to the level of risk at stake'.²¹ As mentioned above, the risk-based approach uses the notion of risk

¹⁷ WP29, 'Statement on the role of a risk-based approach', 3; WP29, 'Guidelines on Data Protection Impact Assessment', 15.

¹⁸ GDPR, recital 4.

¹⁹ O Lynskey, *The Foundations of EU Data Protection Law* (Oxford, Oxford University Press, 2015) 81.

²⁰ M Macenaite, 'The "Riskification" of European Data Protection law through a two-fold shift' *The European Journal of Risk Regulation* (forthcoming), 2.

²¹ R Gellert, 'Data protection: a risk regulation? Between the risk management of everything and the precautionary alternative' (2015) 5(1) *International Data Privacy Law* 3, 13.

to enable controllers to calibrate their legal obligations. CIPL introduced the verb 'to calibrate' in this context.²² A relevant definition of 'to calibrate' is 'to determine the correct range for (an artillery gun, mortar, etc.) by observing where the fired projectile hits'.²³ Controllers are to gauge the risks posed by their processing operation to the rights and freedoms of individuals, and use this to determine 'the correct range' of their legal obligations, so as to ensure that they hit the mark on the ground. In short, under the risk-based approach, 'risk' functions as a reference point for the calibration of legal requirements by controllers.

This is different from the function of 'risk' under risk regulation, as this notion is then used to determine whether a particular activity should be subject to government regulation, legal or otherwise, to start with. Hood, Rothstein and Baldwin define risk regulation as 'governmental interference with market or social processes to control potential adverse consequences'.²⁴ Governmental interference thus qualifies as 'risk regulation' if the *aim* of the regulatory intervention is to control some kind of risk. Confusion can arise because risk regulation is often accompanied by the triangle of risk assessment, risk management and risk communication. Existing risk regulation instruments in the EU, for example, often require regulatory intervention to be based on scientific risk assessments as well as on regulatory impact assessments.²⁵ To make matters more confusing, this type of regulation has also been called *risk-based* regulation.²⁶

Gellert has portrayed data protection law as risk regulation, i.e. regulation meant to address the risks posed by the introduction of ICTs into society.²⁷ The GDPR can be understood as such because it seeks to prevent a set of unwanted events or outcomes: it seeks to protect, through rules which apply *ex ante*, the rights and freedoms of individuals, and in particular their right to the protection of personal data.²⁸ Data protection law has long subjected a number of specific types of data processing scenarios to (more stringent) regulation, arguably because of their riskiness. For example, the processing of special categories of data is subject to a more stringent regime because of the possibility of discriminatory effects,²⁹ while the processing of data outside of an (automated) filing system falls outside the scope of the GDPR, for it is less easily accessible to others and therefore

²² Centre for Information Policy Leadership, 'A Risk-based Approach to Privacy: Improving Effectiveness in Practice', 1, 4; Centre for Information Policy Leadership, 'The Role of Risk Management in Data Protection' 23 November 2014, 1.

²³ <http://www.dictionary.com/browse/calibrator>

²⁴ C Hood, H Rothstein and R Baldwin, *The Government of Risk: Understanding Risk Regulation Regimes* (Oxford, Oxford University Press 2001), 3. cf Gellert, 'Data protection: a risk regulation?', 6.

²⁵ Macenaite, 'The "Riskification" of European Data Protection law through a two-fold shift', 5–6.

²⁶ J Black, 'The Emergence of Risk-Based Regulation and the New Public Risk Management in the United Kingdom' (2005) 3 *Public Law* 510, 514.

²⁷ Gellert, 'Data protection: a risk regulation?', 3.

²⁸ GDPR, art 1(2).

²⁹ See, eg: GDPR, art 9; WP29, 'Statement on the role of a risk-based approach', 2; Lynskey, *The Foundations of EU Data Protection Law*, 82.

less susceptible to confidentiality issues and misuse.³⁰ Thus, in the words of Irion and Luchetta, data protection law borrows from risk-based regulation.³¹ The risk-based *approach* refers, however, to a more specific feature of the GDPR, concerning the way in which controllers should implement data protection law to achieve its aims.

In another sense of the word, 'risk-based regulation' or 'a risk-based approach to regulation' concerns the way in which so-called regulatory agencies prioritise action. Under such an approach, the government agencies tasked with oversight and enforcement score the risks posed by firms so as to target enforcement action on those areas which are most problematic.³² This helps them to focus on the bigger picture, i.e. to 'assess the risks of the firm on a dynamic, ongoing, and future basis rather than seek[ing] to capture the state of the firm at the particular point in time when the inspection or supervision visit occurs'.³³ In the words of Lynskey, '[t]his move towards a more risk-based approach' allows regulatory resources to be used 'in a more efficient and targeted way'.³⁴ The risk-based enforcement style is recommended by the WP29, which asks supervisory authorities to '[target] compliance action and enforcement activity on areas of greatest risk'.³⁵ Data protection officers are also explicitly instructed to 'have due regard to the risk associated with the processing operations' in the performance of their tasks, which enables them, for example, to provide internal training activities where this is most useful.³⁶ The difference with the true risk-based approach of the GDPR, is that risk-based regulation typically refers to a strategy employed by the *government agencies* tasked with supervision and enforcement.³⁷ There might be confusion about this point because, under a decentred understanding of regulation,³⁸ it is possible to conflate controllers with various governmental risk regulators.³⁹ This will be further discussed below.

At first sight, the risk-based approach is simply a deregulatory take on risk-based regulation by government agencies. I have previously argued that the DPIA

³⁰ GDPR, art 2(1) and recital 15.

³¹ K Irion and G Luchetta, 'Online Personal Data Processing and EU Data Protection Reform: Report of the CEPS Digital Forum' (Centre for European Policy Studies Brussels 2013), 23.

³² R Baldwin, M Cave and M Lodge, *Understanding Regulation: Theory, Strategy, and Practice* (Oxford, Oxford University Press, 2012), 281–283.

³³ J Black and R Baldwin, 'Really Responsive Risk-Based Regulation' (2010) 32(2) *Law & Policy* 181, 188.

³⁴ Lynskey, *The Foundations of EU Data Protection Law*, 84.

³⁵ WP29, 'Statement on the role of a risk-based approach', 4.

³⁶ GDPR, art 39(2); Article 29 Data Protection Working Party, 'Guidelines on Data Protection Officers ('DPOs') WP 242 rev.01 (2017), 18.

³⁷ See, eg: BM Hutter, 'The Attractions of Risk-based Regulation: accounting for the emergence of risk ideas in regulation' (2005) ESRC Centre for Analysis of Risk and Regulation Discussion Paper no 33, 4–6, <https://www.lse.ac.uk/accounting/CARR/pdf/DPOs/Disspaper33.pdf>. But see Gellert, 'Data protection: a risk regulation?', 13.

³⁸ See generally: J Black, 'Decentering Regulation: Understanding the Role of Regulation and Self-Regulation in a 'Post-Regulatory' World' (2001) 54(1) *Current Legal Problems* 103.

³⁹ Compare: Hood, Rothstein and Baldwin, *The Government of Risk: Understanding Risk Regulation Regimes*, 10 (risk regulation regimes can be conceived of at different levels).

and the prior consultation of articles 35 and 36 permit supervisory authorities to enforce the law in a risk-based manner, while ‘outsourcing’ the laborious task of risk assessment to the controller.⁴⁰ The ‘indiscriminate general notification obligations’ in the Data Protection Directive were replaced by ‘procedures and mechanisms which focus instead on those types of processing operations which are likely to result in a high risk to the rights and freedoms of natural persons’.⁴¹ The idea appears to be that, rather than sifting through endless notifications, supervisory authorities can sit back and wait until controllers start a prior consultation—as is mandatory for processing operations which the DPIA reveals to be too risky—on their own accord.⁴² The DPIA and the prior consultation are thus supposedly mechanisms which enable supervisory authorities to enforce the law in a risk-based manner. In this vein, Gonçalves rightly criticises the risk-based approach as ‘the key enforcement method (...) leaving data protection issues mainly to data controllers to decide’.⁴³ I would like to add to her analysis that the notion of risk is not only used ‘as a criterion for some control or supervision to operate’,⁴⁴ but also as a reference point with which controllers should calibrate the legal requirements which they have to implement—and it is this latter role of ‘risk’ which I am interested in.

The risk-based approach has a complicated relationship with risk analysis and risk management on the side of the controller. In ‘We Have Always Managed Risks in Data Protection Law’, Gellert sketches an ideal type, in the non-normative, Weberian sense, of the risk-based approach. Under this ideal type, the data protection principles are replaced with ‘risk analysis tools’, which enable controllers ‘to determine what the most appropriate safeguards are for each processing operation’ and ‘to manage the risk, that is, to take a decision whether or not to undertake the processing at stake’.⁴⁵ Gellert appears to imply that data protection law can be collapsed into risk management on the ground. He has argued that the structure of data protection law bears resemblance to risk regulation and risk management frameworks. Indeed, like risk regulators, controllers have to set their own norms or standards, gather relevant information, and change their behaviour accordingly.⁴⁶ This is part of the numerous balancing acts which data protection law requires controllers to make,⁴⁷ and will be further discussed in section IV.

⁴⁰ C Quelle, ‘The data protection impact assessment: what can it contribute to data protection?’ (LLM thesis, Tilburg University 2015) <http://arno.uvt.nl/show.cgi?fid=139503>, 112, 127.

⁴¹ GDPR, recital 89.

⁴² GDPR, art 36; recitals 89–90 and 94.

⁴³ ME Gonçalves, ‘The EU data protection reform and the challenges of big data: remaining uncertainties and ways forward’ (2017) 26(2) *Information & Communications Technology Law* 90, 114.

⁴⁴ Gonçalves, ‘The EU data protection reform and the challenges of big data: remaining uncertainties and ways forward’, 101.

⁴⁵ R Gellert, ‘We Have Always Managed Risks in Data Protection Law: Understanding the Similarities and Differences Between the Rights-Based and the Risk-Based Approaches to Data Protection’ (2016) 4 *European Data Protection Law Review* 482, 490 and 482.

⁴⁶ Compare: Gellert, ‘Data protection: a risk regulation?’, 6–7.

⁴⁷ Compare: Gellert, ‘We Have Always Managed Risks in Data Protection Law’, 9.

It could even be said that, by requiring them to engage in risk management, the risk-based approach turns controllers into risk regulators which should adopt the method of risk-based regulation. But this is not the full story. The risk-based approach does not replace the principles and rules of data protection. Instead, it requires controllers to calibrate what it means, according to the law, to protect the rights and freedoms of individuals. In other words, the risk-based approach, as we know it, does not *reduce* data protection law to risk analysis. Instead, it uses the notion of 'risk' to regulate how controllers implement the law in practice.

Finally, we should distinguish the risk-based approach from a harm-based approach, under which it is up to controllers to decide how to prevent harm. DIGITALEUROPE and the RAND Corporation have both advocated in favour of a harm-based approach. DIGITALEUROPE, a large lobby group for the digital industry, has suggested that controllers should be accountable for materialised harm, but that any rules which specify how to prevent harms from arising are disproportionately burdensome. It is in favour of an 'outcome-based organisational accountability obligation' which grants controllers full discretion over the means which are chosen to manage risk. This proposal rests on the assumption that industry is best placed, at least epistemically, to determine *how* to assess and address the relevant risks.⁴⁸ The RAND Corporation proposed a more sophisticated, and less deregulatory, take on the harm-based approach. It envisions the Fair Information Principles as ways to meet a set of Outcomes, namely individual choice, the free use of data, and enforcement. Data protection law contains these Principles, but there should be no *generally binding* obligations, at the EU level, on how to meet them; data protection practices should be assessed on the basis of their compliance with the Principles, rather than on the basis of a 'process orientated review'.⁴⁹ Both proposals seek to get rid of generally applicable, mandatory processes such as the DPIA.

The risk-based approach is similar to harm-based approaches in that it shifts attention to the possible outcomes of data processing operations. As a specific approach to accountability, it 'puts emphasis on certain outcomes to be achieved in terms of good data protection governance'.⁵⁰ The difference is that the risk-based approach, as adopted in the GDPR, also regulates how controllers should prevent harm, whereby the harms we are concerned with are interferences with the rights and freedoms of individuals. The DPIA is an important part of the risk-based approach, as it helps controllers to implement the GDPR in such a way that the rights and freedoms of individuals are respected. A harm-based approach is instead about abolishing such 'design' or 'output' obligations altogether,

⁴⁸ DIGITALEUROPE, 'DIGITALEUROPE comments on the risk-based approach', 3–4.

⁴⁹ N Robinson, H Graux, M Botterman and L Valeri, 'Review of the European Data Protection Directive' (The RAND Corporation technical report series 2009) www.rand.org/content/dam/rand/pubs/technical_reports/2009/RAND_TR710.pdf, 48–49, 51.

⁵⁰ WP29, 'Opinion 3/2010 on the principle of accountability', 17.

in favour of a more ex post, outcome-oriented review.⁵¹ If such an approach had been adopted, data protection law would have been reduced as much as possible to discretionary risk analysis and risk management practices on the side of the controller.

The risk-based approach should thus be distinguished from a number of other ways in which ‘risk’ or ‘harm’ plays a role, or could play a role, in data protection law. The main point of confusion is the connection between the notion of risk and the legal requirements in the GDPR. The risk-based approach is not an internal choice in favour of risk-based compliance practices, nor does it require controllers to manage risks *instead of* ‘ticking the boxes’ of purpose limitation, data minimisation, transparency and consent. It forms a legal requirement for controllers to calibrate their legal obligations in terms of risk. The following section elucidates the link between ‘risk’ and the legal obligations in the GDPR.

III. ‘Risk’ and the Legal Obligations in the GDPR

The relationship between the risk-based approach and adherence to the legal requirements of data protection is addressed in particular by articles 24, 25(1) and 35 of the GDPR. These provisions determine how controllers should give hands and feet to data protection law in practice.

A. The Link between ‘Theory’ and ‘Practice’

Articles 24 and 25(1) of the GDPR form the core of the risk-based approach. In short, they regulate what controllers must do when they take measures to meet the requirements of the GDPR. They are meta-obligations in the sense that they regulate how controllers should interpret and apply other requirements in the GDPR. Article 24 concerns the responsibility of controllers, whereas article 25(1) focuses on the types of measures which the controller could take.

Article 24(1): ‘Taking into account the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller shall implement appropriate technical and organisational measures to ensure and to be able to demonstrate that processing is performed in accordance with this Regulation’.

Article 25(1): ‘Taking into account the state of the art, the cost of implementation and the nature, scope, context and purposes of processing as well as the risks of varying likelihood and severity for rights and freedoms of natural persons posed by the processing, the controller shall, both at the time of the determination of the means for processing

⁵¹ See generally on design, output and outcome obligations: Baldwin, Cave and Lodge, *Understanding Regulation: Theory, Strategy, and Practice*, 297–298.

and at the time of the processing itself, implement appropriate technical and organisational measures, such as pseudonymisation, which are designed to implement data-protection principles, such as data minimisation, in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects'.

Both articles 24 and 25(1) specify that the controller has to implement technical and organisational measures to ensure that the processing of personal data meets the legal requirements. This is hardly novel.⁵² It is more relevant that these provisions also regulate the way in which controllers should take measures to implement the law. As noted by Macenaite, they require 'all the measures necessary to comply' to be scaled 'according to the risks posed by the relevant processing operations'.⁵³ If there was any doubt, recital 74 clarifies that it is in relation to the 'appropriate and effective measures' that the risks to the rights and freedoms of natural persons should be taken into account. In short, articles 24 and 25(1) require controllers to take into account the risks to the rights and freedoms of individuals when they make the jump 'from theory to practice'.

Both provisions also refer to the nature, scope, context and purposes of the processing and the likelihood and severity of the risk. Keeping in mind that these are parameters and factors with which to gauge the risk,⁵⁴ the two articles can be read as specifying that the compliance measures taken by the controller should take into account the risks posed by the processing operation. The notion of 'risk' is thus the main reference point for the interpretation and implementation of the GDPR.

The state of the art and the cost of implementation are also relevant considerations. They are included in article 25(1). Since article 24 and article 25(1) both cover any technical and organisational compliance measure, their scope is the same, meaning that these two additional factors always apply next to the factor of 'risk'. As a result, the risk-based approach does not require the controller to take measures when this would be impossible or disproportionately burdensome. It is, for example, not required that the controller achieves the highest possible level of security,⁵⁵ or that processing operations which carry any risk whatsoever are foregone. Nor would the controller, under a risk-based approach, need to take all imaginable measures to address the possibility that biases in algorithmic systems will have discriminatory effects. This might be for the best, as a stricter approach would, in the words of Barocas and Selbst, 'counsel against using data mining altogether'.⁵⁶ The GDPR does not, however, address how the three factors

⁵² It has even been said that article 24 'does not add very much to existing obligations', see eg: D Butin, M Chicote and D Le Métayer, 'Strong Accountability: Beyond Vague Promises' in S Gutwirth, R Leenes and P De Hert (eds), *Reloading Data Protection* (Dordrecht, Springer, 2014) 354–355.

⁵³ Macenaite, 'The "Riskification" of European Data Protection law through a two-fold shift', 19–20.

⁵⁴ GDPR, recitals 75 and 76.

⁵⁵ See also: GDPR, art 32(1).

⁵⁶ S Barocas and A Selbst, 'Big Data's Disparate Impact' (2016) 104 *California Law Review* 671, 729–730.

should be weighed, granting controllers a considerable amount of discretion in this regard. The factor of cost and the discretion of the controller both raise questions with respect to the ways in which the fundamental rights of individuals can be limited.⁵⁷

B. ‘Taking into Account’ the Risks

What does it mean for the compliance measures to *take into account* the risks to the rights and freedoms of individuals? The following sub-sections argue that this phrase sees to both the extensiveness of the measures which should be taken to ensure compliance and the outcomes which should be reached through these measures.

i. Scalable Compliance Measures

The risk-based approach entails that ‘where a company ... is responsible for riskier data processing operations (data protection), they are required to be more diligent in the steps they take to comply’,⁵⁸ and vice versa. The GDPR is scalable both with respect to its accountability obligations and with respect to other compliance measures.

A number of accountability obligations explicitly only apply to risky or high-risk processing. This includes the requirement to appoint a representative in the EU, to notify supervisory authorities and data subjects of a data breach, to maintain records, to conduct a DPIA and to consult the supervisory authority (the prior consultation).⁵⁹ It follows from the risk-based approach that the higher the risk, the more elaborate the DPIA should be, and the more extensive controllers should document the various steps which they take. If the risk is lower, less extensive measures are required. The scalability of these provisions was discussed at the start of the shift to an accountability-based framework. To ensure that accountability is not unnecessarily burdensome for controllers, the WP29 clarified from the start that the accountability obligations should be scalable; they should be determined by ‘the facts and circumstances of each particular case’. More specifically, the measures to be implemented should be adaptable to ‘the risk of the processing and the types of data processed’.⁶⁰ The EDPS, in favour of mandatory data protection officers and DPIAs, proposed that these accountability obligations

⁵⁷ See, eg: Charter of Fundamental Rights of the European Union [2000] OJ C-354/3, art 52(1); Case C-131/12 *Google Spain* [2014] ECR-I 000, ECLI:EU:C:2014:317, paras 81 and 97.

⁵⁸ European Data Protection Supervisor, ‘Opinion 8/2016 on Coherent Enforcement of Fundamental Rights in the Age of Big Data’ (2016), 7.

⁵⁹ GDPR, arts 27(2)(a), 33(1), 34(1), 35(1) and 36(1).

⁶⁰ WP29, ‘Opinion 3/2010 on the principle of accountability’, 13.

should only apply if 'certain threshold conditions' are met.⁶¹ The Commission formulated this threshold with reference to the level of risk, noting that data protection officers and impact assessments are appropriate only for firms which are involved in 'risky processing'.⁶²

The risk-based approach is not limited, however, to these accountability obligations. It applies to any technical or organisational measure that is taken to ensure that the processing is performed in accordance with the GDPR. As recently pointed out by the Advocate-General in *Rīgas satiksme*, why even require controllers to carry out a full compliance check, involving several balancing acts, if the processing can readily be understood to be permissible?⁶³ In the words of CIPL, 'processing operations which raise lower risks to the fundamental rights and freedoms of individuals may generally result in fewer compliance obligations, whilst 'high risk' processing operations will raise additional compliance obligations'.⁶⁴ It will not be necessary for controllers involved in low-risk processing operations to put in much effort to meet the desired result. Thus, the risk-based approach also means that controllers in charge of 'daily, harmless data processing'⁶⁵ need not put in as much effort to determine whether they are processing special categories of data, to which stricter rules apply. Nor are they required to do as much to provide the needed information in an intelligible form. And, by way of a third example, they may not have to put in place a system to facilitate the exercise of the data subject's right of access. The relationship between the risk-based approach and the control rights of data subjects is further examined in section IV.

ii. Substantive Protection against Risks

The notion of risk not only influences whether extensive compliance measures are necessary; the requirement to take compliance measures which 'take into account' the risks, also gives substance and direction to the steps which must be taken to comply. Controllers should make an effort to implement the GDPR in such a way that they actually offer sufficient protection of the rights and freedoms of

⁶¹ European Data Protection Supervisor, 'Opinion of the European Data Protection Supervisor on the Communication from the Commission to the European Parliament, the Council, the Economic and Social Committee and the Committee of the Regions—"A comprehensive approach on personal data protection in the European Union"' (2011), 22.

⁶² Commission (EC), 'Proposal for a Regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)' COM (2012) 11 final, 6–7.

⁶³ Case C-13/06, *Rīgas satiksme* [2017] ECLI:EU:C:2017:43, Opinion of AG Bobek, para 92. See also: EML Moerel en JEJ Prins, 'Privacy voor de homo digitalis' (2016) 146(1) *Handelingen Nederlandse Juristen-Vereniging*.

⁶⁴ Centre for Information Policy Leadership, 'Risk, High Risk, Risk Assessments and Data Protection Impact Assessments under the GDPR', 3.

⁶⁵ Commission (EC), 'Impact Assessment Accompanying the GDPR' SEC (2012) 72, final, Annex 4, s 1.1.

individuals. This interpretation is supported by article 35. The DPIA directs attention towards issues such as ‘the effects of certain automated decisions’ and the vulnerability of data subjects to discrimination.⁶⁶ The following argues that the DPIA is not exactly a process for building and demonstrating compliance;⁶⁷ it is a process for building *compliance 2.0*: a form of compliance which also respects the rights and freedoms of individuals. In the words of the WP29, ‘as the DPIA is updated throughout the lifecycle project, it will ensure that data protection and privacy are considered’.⁶⁸

The DPIA opens up space to consider sensitive data protection issues because of its focus on the impact on the rights and freedoms of individuals and on the proportionality of this impact in relation to the purposes pursued by the controller. Article 35 requires controllers to assess the impact of the envisaged processing operations on the protection of personal data if the type of processing is likely to result in a high risk to the rights and freedoms of natural persons. More specifically, it requires controllers to assess the proportionality of their processing operations as well as the risks posed by them, so as to identify sufficient measures to address the risks to the rights and freedoms of individuals. Following article 35(7)(b), the controllers of high-risk processing operations have to assess ‘the necessity and proportionality of the processing operations in relation to the purposes’. This refers, firstly, to the data minimization principle, according to which the processing of personal data must be ‘adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed’.⁶⁹ Secondly, article 36(7)(b) also explicitly refers to proportionality; presumably, the question here is whether the processing, necessary for the specified purpose or a compatible purpose, would be excessive in relation to the impact on the rights and freedoms of individuals (proportionality *strictu sensu*).⁷⁰ This question can be answered using the knowledge gathered through the second assessment that is to take place, in accordance with article 35(7)(c): ‘an assessment of the risks to the rights and freedoms of data subjects’.⁷¹ Controllers need to specify and assess the risks depending on the particularities and specificities of each data processing case.⁷² Finally, the controller has to devise ways to address the risks to the rights and freedoms of data subjects/individuals. This includes safeguards, security measures and mechanisms to ensure the protection of personal data.⁷³

⁶⁶ WP29, ‘Guidelines on Data Protection Impact Assessment’, 12.

⁶⁷ Compare: WP29, ‘Guidelines on Data Protection Impact Assessment’, 4.

⁶⁸ WP29, ‘Guidelines on Data Protection Impact Assessment’, 13.

⁶⁹ GDPR, art 5(1)(c).

⁷⁰ Commissie voor de Bescherming van de Persoonlijke Levenssfeer, ‘Ontwerp van aanbeveling uit eigen beweging met betrekking tot de gegevensbeschermingseffectbeoordeling en voorafgaande raadpleging voorgelegd voor publieke bevraging’ CO-AR-2016-004, 7. See generally: LA Bygrave, *Data Privacy Law: An International Perspective* (Oxford, Oxford University Press, 2014) 147–150.

⁷¹ GDPR, art 35(7)(c).

⁷² GDPR, recital 76.

⁷³ GDPR, art 35(7)(d).

The DPIA enables controllers to design technical and organizational measures that are suitable to protect the rights and freedoms of individuals. It also asks controllers to check whether their processing operation would not unduly jeopardise the rights and freedoms of individuals, even if the identified risk mitigation measures are taken. In the words of CIPL, '[o]rganisations will have to make a reasoned and evidenced decision whether to proceed with processing in light of any residual risks, taking into account "proportionality" vis-à-vis purposes, interests and/or benefits'.⁷⁴ This contributes to a rights-friendly implementation of the GDPR. In the past, the European Court of Human Rights has turned to the proceduralisation of human rights in response to the risk-right encounter.⁷⁵ However, perhaps counter-intuitively, the risk-based approach and the DPIA may well carry a substantive turn in data protection law. The focus on the protection of the rights and freedoms of individuals forms a departure from the traditional focus on data quality and procedural legitimacy.

Traditionally, the principles of data protection carry little substance. From the perspective of Irion and Luchetta, 'data protection regulation is often implicit when it should be direct'.⁷⁶ In the words of Bygrave, very few data protection instruments 'expressly operate with a criterion of social justification', resorting instead to procedural norms.⁷⁷ This can be illustrated through Burkert's distinction between the material and the procedural component of data protection law. The material component of the GDPR relates to the quality of 'electronic information-handling'. The principles guard against over-collection, the use of inaccurate data, and problems with the integrity of the data, but they are not typically understood as addressing 'the material *normative* issue of what is acceptable to be processed for which purpose'.⁷⁸ Rather than imposing strict substantive limitations, data protection law traditionally relies on a number of procedures to legitimise processing operations. The GDPR still refers to a number of *ex ante* procedures, such as the inform-and-consent procedure, which can legitimize otherwise illegal processing operations, and the legislative process, which can result in an obligation to process personal data. The GDPR also creates *ex post* oversight procedures, such as the control rights of data subjects to access, rectify and erase their data. Unfortunately, the emphasis on procedures to legitimize the processing of personal data has proven to be disappointing when it comes to preventing controversial types of collection and use. Few data subjects have exercised their

⁷⁴ Centre for Information Policy Leadership, 'Risk, High Risk, Risk Assessments and Data Protection Impact Assessments under the GDPR', 10.

⁷⁵ N van Dijk, R Gellert and K Rommetveit, 'A risk to a right? Beyond data protection risk assessments' *Computer Law & Security Review* 32(2) (2015) 286, 294, 299.

⁷⁶ Irion and Luchetta, 'Online Personal Data Processing and EU Data Protection Reform: Report of the CEPS Digital Forum', 50.

⁷⁷ LA Bygrave, *Data Protection Law: Approaching Its Rationale, Logic and Limits*, Information Law Series 10 (The Hague, Kluwer Law International, 2002) 62–63.

⁷⁸ H Burkert, 'Data-protection legislation and the modernization of public administration' (1996) 62 *International Review of Administrative Sciences* 557, 559.

ability to consent and their rights of access, rectification and erasure to secure a high level of protection. Koops worries that all those procedures in data protection law do not succeed in tackling the harms which we want to address.⁷⁹ The WP29 similarly emphasised during the reform that '[c]ompliance should never be a box-ticking exercise, but should really be about ensuring that personal data is sufficiently protected'.⁸⁰ This move against formalism is based on the idea that data protection law should protect data subjects against something or some things, and that neither the traditional material requirements, nor the procedural safeguards, get us there.

A number of data protection principles could accommodate concerns about the proportionality *strictu sensu* of potential interferences with the rights and freedoms of individuals. The risk-based approach and the DPIA play an important role by creating a context within which the policy goals of data protection law can be formulated with greater clarity. The DPIA, in particular, could help to absorb the shock of a substantive turn of the GDPR, should it indeed take place. To elucidate how the data protection principles and the focus on risks to the rights and freedoms relate to each other, it is helpful to consider a controversial example: that of the personalisation of news feeds. News personalisation can impact the privacy of the individual, as well as his or her right to receive information.⁸¹ It is, nonetheless, quite readily permitted, particularly if explicit consent has been obtained.⁸² It could be argued that news personalisation is not a legitimate purpose or that the fairness principle of Article 5(1)(a) requires controllers to keep the impact of their processing operations on the rights and freedoms of individuals to an acceptable level.⁸³ Particularly the principle of fairness could, in theory, encompass such an interpretation. According to Bygrave, fairness implies that the processing should not intrude unreasonably upon the data subject's privacy, or interfere unreasonably with their autonomy and integrity, thus requiring balance and proportionality.⁸⁴ Nonetheless, as with any norm that is formulated in broad, general terms (also known as a 'principle'), the problem from the perspective of effectiveness is that controllers can easily misunderstand or contest the meaning that is ascribed to them by the supervisory authority. Indeed, 'debates can always be had about

⁷⁹ Bert-Jaap Koops, 'The trouble with European data protection law' *International Data Privacy Law* 4(4) (2014) 250, 255.

⁸⁰ WP29, 'Statement of the Working Party on current discussions regarding the data protection reform package', 2.

⁸¹ See generally: S Eskens, 'Challenged by News Personalization: Five Perspectives on the Right to Receive Information' (Draft 6 June 2017, on file).

⁸² GDPR, art 22(2)(c).

⁸³ See on the legitimacy of a purpose: Article 29 Data Protection Working Party, 'Opinion 03/2012 on purpose limitation' (2013) WP 203, 19–20.

⁸⁴ Bygrave, *Data Protection Law*, 58.

their interpretation'.⁸⁵ If a supervisory authority suddenly decided to tackle news personalisation through the principle of fairness, this is likely to come as a shock to controllers. Needless to say, they will not have been able to establish compliance. Legal uncertainty also renders enforcement action against big data companies less effective, as they are likely to start costly and lengthy court proceedings before changing their conduct. Black notes that '[g]eneral rules are vulnerable to challenges as to their interpretation and application. Amoral calculators are likely to contest the agency's interpretation of the rule and assessment of compliance'.⁸⁶ Indeed, under a pessimistic view, the use of so-called 'principles-based regulation' allows controllers 'to do what they want without fear of breaching strict rules'.⁸⁷ One way to clarify the meaning of principles is for supervisory authorities to engage in 'regulatory conversations' to foster 'shared sensibilities' on the meaning of the principles.⁸⁸ The term 'conversation' is a bit of a misnomer because it also includes one-sided statements, such as guidance documents. Supervisory authorities can, for example, issue guidance documents on the requirements in the GDPR.⁸⁹ They could specify what the fairness principle entails, explaining whether or in what way it affects the permissibility of news personalisation.

The DPIA fosters another *track of conversation*, not about specific provisions of the GDPR, but about the risks which controllers are permitted to take. As argued by Binns, DPIA's 'can add an additional layer that brings responsibility for considering and deliberating on risky and complex data protection issues'.⁹⁰ The DPIA thus attempts to avoid legal battles about the meaning of the data protection principles. It does so by steering controllers to adopt proper risk management practices through a separate track of conversation. This supplements, rather than replaces, the data protection principles. From the perspective of Irion and Luchetta, the focus on risks to the rights and freedoms of individuals should make it less acceptable for controllers 'to invoke flexibility [of the data protection principles] against the spirit of the regulation'.⁹¹ Vice versa, the risk-based approach should render it

⁸⁵ J Black, 'Forms and paradoxes of principles-based regulation' (2008) 3(4) *Capital Markets Law Journal* 425, 453.

⁸⁶ J Black, 'Managing Discretion' (2001) ARLC Conference Papers www.lse.ac.uk/collections/law/staff%20publications%20full%20text/black/alrc%20managing%20discretion.pdf, 24.

⁸⁷ Baldwin, Cave and Lodge, *Understanding Regulation: Theory, Strategy, and Practice*, 303.

⁸⁸ J Black, 'The Rise, Fall and Fate of Principles Based Regulation' (2010) LSE Law, Society and Economy Working Papers 17/2010, https://papers.ssrn.com/sol3/papers.cfm?abstract_id=1712862, 5–6, 8; J Braithwaite, 'Rules and Principles: A Theory of Legal Certainty' (2002) 27 *Australian Journal of Legal Philosophy* 47, 71.

⁸⁹ GDPR, art 58(3)(b).

⁹⁰ R Binns, 'Data protection impact assessments: a meta-regulatory approach' (2017) 7(1) *International Data Privacy Law* 22, 35.

⁹¹ Irion and Luchetta, 'Online Personal Data Processing and EU Data Protection Reform: Report of the CEPS Digital Forum', 50.

more acceptable when the data protection principles are stretched so as to protect against risks to the rights and freedoms of individuals.

iii. The Limits to Enforcement Action against Risk-Taking

To properly understand the role of the separate *track of conversation* that is opened up by the DPIA, it is important to acknowledge that there are limited options with respect to sanctioning. To be able to issue fines, supervisory authorities will have to point to an infringement of one of the rules or principles of the GDPR. A related issue is that, for the risk-based approach to lead to substantive protection, supervisory authorities are required to play an active role, requiring a substantial commitment in terms of resources. Setting aside this practical hurdle, let's turn to the question of whether the risk-based approach really requires controllers to offer substantive protection.

A first complication is that there is no clear duty for the controller to actually take mitigating measures. Article 35(7)(d) does not contain a verb to indicate what the controller must do with respect to 'the measures envisaged to address the risks'.⁹² Must it devise them, or also implement them? Most of the measures suggested in ICO's PIA Code of Practice would be required under the data protection principles. This is the case with respect to the decision to anonymise the data when possible, to set up access request systems and policies, to make the data subjects aware of the collection, and to put in place data processing agreements.⁹³ But, as discussed above, measures in relation to news personalisation are not clearly required by the GDPR. Arguably, however, if such a measure was identified to address a risk to a right during the DPIA, and the DPIA report is approved, it should also be implemented. It is a key part of the accountability system that 'it should be punishable if a data controller does not honour the representations made in binding internal policies'.⁹⁴ The controller has the responsibility to monitor implementation of the measures which were identified during an approved DPIA.⁹⁵ Thus, article 25 contains the duty to review, where necessary, whether the DPIA is complied with.⁹⁶ Recital 95 even speaks of 'obligations deriving from the carrying out of data protection impact assessments'. It is not clear, however, under

⁹² These two complications are both directly addressed in: Council of Europe Consultative Committee of the Convention for the Protection of Individuals With Regard to Automatic Processing of Personal Data, 'Guidelines on the protection of individuals with regard to the processing of personal data in a world of Big Data' T-PD (2017) 01, ss 2.4 and 2.5.

⁹³ Information Commissioner's Office, 'Conducting Privacy Impact Assessments Code of Practice' (2014) 28.

⁹⁴ WP29, 'Opinion 3/2010 on the principle of accountability', 17.

⁹⁵ D Kloza, N van Dijk, R Gellert, I Böröcz, A Tanas, E Mantovani and P Quinn, 'Data protection impact assessments in the European Union: complementing the new legal framework towards a more robust protection of individuals' (2017) d.pia.lab Policy Brief No. 1/2017, http://virthost.vub.ac.be/LSTS/dpialab/images/dpialabcontent/dpialab_pb2017-1_final.pdf, 2.

⁹⁶ GDPR, art 33(11).

what circumstances a DPIA leads to binding obligations with respect to the measures which were identified.

A second complication is the lack of a clear duty to take *good* measures. Can controllers get away with a symbolic effort or a box-checking exercise? What if the decision-makers within the organization have approved a DPIA report which does not sufficiently address the relevant risks? This question is particularly difficult to answer if the processing should be considered to be compliant, as it follows a reasonable and foreseeable interpretation of the rules and principles, yet still poses high risks to the rights and freedoms of individuals. During the prior consultation of article 36, supervisory authorities can ban or limit processing operations which are deemed to pose high risks to the rights and freedoms of individuals. But here is the bottleneck: the text of the GDPR is quite ambiguous as to whether this is permitted if there is no infringement of the GDPR. The competent supervisory authority can make use of its powers if it 'is of the opinion that the intended processing referred to in paragraph 1 would infringe this Regulation, in particular where the controller has insufficiently identified or mitigated the risk'.⁹⁷ The WP29 perpetuates the ambiguity, stating that supervisory authorities should carry out 'enforcement procedures in case of non-compliance of controllers, which may imply challenging risk analysis, impact assessments as well as any other measures carried out by data controllers'.⁹⁸ But what if there is 'a mismatch between the rules and the risks'?⁹⁹ What if the controller cannot readily be regarded as non-compliant, despite the risks posed by the processing operation? The mismatch can arise because there is no explicit, self-standing obligation to protect individuals against risks to their rights and freedoms.¹⁰⁰ Indeed, the obligation under articles 24 and 25(1) does not appear to contain a general duty to mitigate risks; the duty is only to take risks into account when implementing other provisions of the GDPR.¹⁰¹ By appealing to 'the spirit' of the GDPR (the protection of rights and freedoms of individuals in the context of the processing of personal data), the risk-based approach attempts to side-step the legal norms.

In sum, the DPIA plays an important role under the risk-based approach, as it regulates how controllers think about, and handle, risks to the rights and freedoms of individuals. It makes an important contribution to data protection law by steering controllers to go beyond data quality and inform-and-consent. At the end of the day, however, it does lack the teeth needed to convince contrarious controllers. If we want to add substantive protection to data protection law, the 'amoral calculator' will have to be sanctioned with reference to the principles of data protection,

⁹⁷ GDPR, arts 36(2) and 58(2)(f).

⁹⁸ WP29, 'Statement on the role of a risk-based approach', 4.

⁹⁹ Black, 'The Rise, Fall and Fate of Principles Based Regulation', 23.

¹⁰⁰ Quelle, 'The data protection impact assessment: what can it contribute to data protection?', s 2.5.2.2.

¹⁰¹ Against: Commissie voor de Bescherming van de Persoonlijke Levenssfeer, 'Ontwerp van aanbeveling uit eigen beweging met betrekking tot de gegevensbeschermingseffectbeoordeling en voorafgaande raadpleging voorgelegd voor publieke bevraging', 13.

since there is no explicit, self-standing obligation to actually take good (enough) measures to address the risks. The DPIA presents us with a dilemma faced by meta-regulation for corporate social responsibility in general. By regulating how controllers manage the risks posed by their processing operation, the GDPR regulates also the 'grey areas', with respect to which there is no democratic consensus on how to act.¹⁰² There are, however, problems related to the legal accountability for issues which fall under the responsibility of corporations. Parker phrases the problem succinctly by asking: 'how is it possible for the *law* to make companies accountable for going *beyond the law*'?¹⁰³ Indeed, 'the substantive goals at which internal processes are aimed must be adequately specified and enforced external to the company'.¹⁰⁴ At the moment, EU data protection law suffers from a lack of clarity regarding its overarching policy goals. What the risk-based approach can do, is render a substantive interpretation of its core principles more predictable, as a concern for risks to the rights and freedoms of individuals becomes part of data protection policy and practice through regulatory conversations.

C. The Risk-Based Approach and Legal Compliance

It follows from the previous sub-sections that the risk-based approach affects what is considered to be compliant, and therefore also affects what the law requires in a particular case. CIPL and the Article 29 Working Party were too quick to dismiss the effect of the risk-based approach on the obligations of the GDPR. As noted by Gellert, there is no real difference between the calibration of implementation measures, and the calibration of the controller's obligations.¹⁰⁵

The controller's obligations are affected in two ways: in light of the measures that should be taken and in light of the outcome that should be reached. Firstly, the risk-based approach affects the extensiveness of the measures that are to be taken to ensure compliance. If a controller need not do as much to ensure that a data subject's personal data can be deleted on request, or that the data minimization principle is respected, then surely these rights and principles are also affected. We cannot regulate the way in which the requirements of data protection are to be applied (the *how*: more or less measures), as well as maintain that the requirements have an independent meaning, which should be complied with regardless of whether the implementation measures were deemed sufficient.

¹⁰² Quelle, 'The data protection impact assessment: what can it contribute to data protection?', 114; C Parker, *The Open Corporation: Effective Self-regulation and democracy* (New York, Cambridge University Press, 2002) 245. See also Binns, 'Data protection impact assessments: a meta-regulatory approach'.

¹⁰³ C Parker, 'Meta-regulation—legal accountability for corporate social responsibility' in D McBarnet, A Voiculescu and T Campbell (eds), *The New Corporate Accountability: Corporate Social Responsibility and the Law* (Cambridge, Cambridge University Press, 2007) 207, 237.

¹⁰⁴ Parker, 'Meta-regulation—legal accountability for corporate social responsibility', 231.

¹⁰⁵ Gellert, 'Data protection: a risk regulation?', 16.

The second way in which the risk-based approach affects the obligations of controllers, is by asking them to make sure that their compliance measures protect against potential interferences with the rights and freedoms of individuals (the outcome: fundamental rights protection). Following articles 24 and 25(1) and recital 74, the measures taken to implement the GDPR have to take into account the risk to the rights and freedoms of natural persons. This arguably means that they should provide adequate protection of these fundamental rights. The DPIA supports this interpretation, as it requires controllers of high-risk processing operations to assess the proportionality of the processing and the risks to the rights and freedoms of individuals, as well as to identify measures to address the risks. However, as noted above, the GDPR does not contain a hard, independent obligation to actually protect the rights and freedoms of individuals. It should be understood as an interpretative tool and a channel for regulatory conversation with which to give extra hands and feet to the data protection principles. Nonetheless, if a controller is steered to ensure that its profiling activities do not unduly hamper the right to receive information, then this surely supplements the principles in the GDPR.

Both aspects of the risk-based approach are a true novelty of the GDPR. Controllers have always had to implement the law, but under the Data Protection Directive, they were not required to assess whether the legal requirements are sufficient to achieve protection or, to the contrary, whether they are disproportionately burdensome. The risk-based approach requires controllers to calibrate, and even to second-guess, the rules put in place by the legislature. It accords to them a responsibility that they did not formally possess before: the responsibility to ensure that data protection law sufficiently protects the rights and freedoms of individuals without imposing disproportionate burdens or limitations. If the risk-based approach existed prior to the adoption of the GDPR, it was directed at Member States rather than at controllers. With the exception of the data security obligation, the Data Protection Directive referred to 'risk' as a relevant consideration when allocating space for Member States to create exceptions to the law.¹⁰⁶ Under the GDPR, 'risk' is instead about the controller's calibration of data protection law.

IV. Were the Data Protection Principles and the Data Subject Rights Risk-Based to Start With?

The risk-based approach has far-reaching consequences with respect to the authority of the legal requirements. It is no surprise that there have been several attempts to protect the core principles of data protection law from 'riskification'.

¹⁰⁶ Data Protection Directive, arts 13(2) and 18(2); Macenaite, 'The "Riskification" of European Data Protection law through a two-fold shift', 17–18.

The statement of the WP29 indicates that only the ‘accountability obligations’ (such as the impact assessment, documentation, and data protection by design) and any other ‘compliance mechanisms’ can be more or less extensive ‘depending on the risk posed by the processing in question’.¹⁰⁷ According to Gonçalves, the WP29 means to say that the risk-based approach can only supplement the law by requiring additional measures; it cannot ‘evade strict compliance in some situations’.¹⁰⁸ Gellert, in a similar manner, reads the WP29’s statement as entailing that ‘the core principles of data protection are still rights-based’, i.e. not to be calibrated in terms of risk. However, this type of reasoning does not take into account the role of risk as the link between ‘theory’ and ‘practice’. If the risk-based approach indeed requires the calibration of compliance measures, as argued in section III, it affects what the core principles of data protection require.

Another tack is to maintain that the core principles of data protection were risk-based to start with. It is only in this sense that the WP29 can hold that ‘a data controller whose processing is relatively low risk may not have to do as much to comply with its legal obligations as a data controller whose processing is high-risk’.¹⁰⁹ The WP29 argues with respect to principles such as ‘legitimacy, data minimization, purpose limitation, transparency, data integrity and data accuracy’, that ‘due regard to the nature and scope of such processing have always been an integral part of the application of those principles, so that they are inherently scalable’.¹¹⁰ It is, therefore, highly relevant that, as pointed out by Gellert, the data protection principles require controllers to make a number of balancing acts and that this renders them scalable in a manner similar to the risk-based approach.¹¹¹

To assess whether the provisions in the GDPR were already risk-based, it is helpful to distinguish between two types of obligations: those that require a risk-oriented result and those that require a risk-oriented effort. Some obligations in the GDPR are formulated as what is known in contract law as *obligations de résultat*, specifying an outcome that the controller is obligated to attain no matter the circumstances. Other provisions impose an obligation to make reasonable efforts (an *obligation de moyens*).¹¹² Both types of obligation can be risk-oriented, either in the result that is required or the effort that the controller should put in.

A. Obligations which Require a Risk-Oriented Result

A number of provisions in the GDPR are scalable in terms of result. That is to say, they are more or less prohibitive, depending on the foreseeable results of the

¹⁰⁷ WP29, ‘Statement on the role of a risk-based approach’, 2, 3.

¹⁰⁸ Gonçalves, ‘The EU data protection reform and the challenges of big data: remaining uncertainties and ways forward’, 101.

¹⁰⁹ WP29, ‘Statement on the role of a risk-based approach’, 2.

¹¹⁰ WP29, ‘Statement on the role of a risk-based approach’, 3.

¹¹¹ Gellert, ‘We Have Always Managed Risks in Data Protection Law’.

¹¹² B Van Alsenoy, ‘Liability under EU Data Protection Law: From Directive 95/46 to the General Data Protection Regulation’ (2016) 7 *JIPITEC* 271, 273.

processing operation. It has already been noted in section III that the principle of fairness can be interpreted as seeing to the potential impact on the rights and freedoms of data subjects. The principles of lawfulness and of purpose limitation are also, in part, oriented towards the risks posed by the processing. As a result of these principles, the processing of personal data is more or less readily permitted, depending on the impact on the data subjects.

The principle of data minimization entails that the processing of personal data should be limited to what is necessary for the purposes for which the data was collected.¹¹³ Following the principle of purpose limitation, further processing is permitted if the new purpose is not incompatible with the old purpose.¹¹⁴ The GDPR provides a number of factors, including 'the consequences of the intended further processing for data subjects' and 'the existence of appropriate safeguards'.¹¹⁵ More specifically, according to the WP29, 'the more negative or uncertain the impact of further processing might be, the more unlikely it is to be considered as compatible use'.¹¹⁶ The principle is thus more or less stringent, depending on the consequences which may arise if the processing takes place. Other factors include the context of collection and the nature of the personal data—factors which are also relevant under the risk-based approach.¹¹⁷

A similar situation arises with respect to the principle of lawfulness. The processing of personal data is only lawful if the controller can rely on one of the grounds of article 6. Under article 6(1)(f), the controller is permitted to process personal data on the basis of its legitimate interest, or that of a third party, unless this interest is 'overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data'.¹¹⁸ This test takes into account, according to the WP29, 'the various ways in which an individual may be affected—positively or negatively—by the processing of his or her personal data'. It is thereby important 'to focus on prevention and ensuring that data processing activities may only be carried out, provided they carry no risk or a very low risk of undue negative impact on the data subjects' interests or fundamental rights and freedoms'.¹¹⁹ Again, the WP29 looks at the impact of the processing, and in particular whether the consequences are likely and whether they are unduly negative, considering the safeguards taken to address the risks.

It follows both from the risk-based approach and from the principles discussed above that the processing of personal data should be less readily permitted if the risk is relatively high, and vice versa. Indeed, as discussed in section III, the risk-based approach can be seen as an important supplement to these principles of data protection by emphasizing the importance of risk mitigation. The scalability

¹¹³ GDPR, art 5(1)(c).

¹¹⁴ GDPR, art 5(1)(b).

¹¹⁵ GDPR, art 6(4)(d) and recital 50.

¹¹⁶ WP29, 'Opinion 03/2012 on purpose limitation', 25–26.

¹¹⁷ GDPR, art 6(4)(d) and recital 50.

¹¹⁸ GDPR, art 6(1)(f).

¹¹⁹ Article 29 Data Protection Working Party, 'Opinion 06/2014 on the Notion of Legitimate Interests of the Data Controller under Article 7 of Directive 96/46/EC' WP 217 (2014), 37.

of these data protection principles does not mean, however, that the risk-based approach has no effect on the legal obligations of the controller. There are discrepancies between the tests carried out under articles 5(1)(b) and 6(1)(f) and the one carried out under the risk-based approach. For example, the Court of Justice of the European Union (CJEU) has ruled that the balancing test of article 6(f) should look specifically to the rights arising from Articles 7 and 8 of the Charter.¹²⁰ Under the risk-based approach, on the other hand, potential interferences with other rights should also factor in. Moreover, the risk-based approach renders these principles scalable both in terms of result and in terms of effort. As discussed in section III, it permits controllers to take fewer measures with respect to processing operations that can reasonably be estimated to be of low-risk, even though they may turn out to have harmful consequences. The risk-based approach therefore affects even those obligations that were already risk-oriented in terms of result.

B. Obligations which Require a Risk-Oriented Effort

Other provisions in the GDPR permit controllers to take fewer measures when the risk is low, and require more measures when the risk is high. This is explicitly the case with respect to the principle of integrity and confidentiality. Article 5(1)(f) requires controllers to ensure that the data is ‘processed in a manner that ensures appropriate security of the personal data ... using appropriate technical and organisational measures’. Article 32 specifies that measures are appropriate when they ensure a level of security appropriate to the risk. Since a complete removal of the risk is not possible,¹²¹ article 32 settles for measures that are reasonable in view of the risks posed to the rights and freedoms of natural persons, as well as the state of the art and the cost of implementation. The factors are the same as under the risk-based approach. Nonetheless, the risk-based approach does affect the legal obligation of the controller, as it also introduces a concern for the rights and freedoms of individuals. The data protection impact assessment should affect the types of security measures adopted by controllers, as they are required to ensure that these measures are suitable to protect not only security, but also the higher values embodied in the fundamental rights of individuals.

C. Obligations which Are not Risk-Oriented

There is an inevitable clash between the risk-based approach and obligations which are not risk-oriented in either result or effort. This arises, in particular, with respect to the provisions of Chapter III, containing the control rights of data subjects.

¹²⁰ Cases C-468/10 and C-469/10, *ASNEF and FECEMD* [2011] ECR I-00000, EU:C:2011:777, para 40.

¹²¹ See also: GDPR, acts 33 and 34.

The risk-based approach is most clearly at odds with data subject rights that impose an *obligation de résultat*. The right of access, for example, is absolute; the controller must give a data subject access to her data if she puts in a request to this end. This means that controllers will have to take all the measures necessary to be able to respect this right when it is exercised. To be able to give a data subject the required insight into the processing, controllers will have to maintain documentation regarding the purposes for which data is processed, the recipients of the data, the logic and the effects of any automated decision-making which is used, as well as all the other information that data subjects have a right to receive. Thus, the WP29 will have to make a clear decision as to whether rights 'should be respected regardless of the level of the risks', or whether it is permissible, for example, to do less by way of documentation, even though 'documentation is an indispensable internal tool (...) for the exercise of rights by data subjects'.¹²² If a less extensive records management and access request system is put in place by controllers of relatively harmless operations, they simply may not be able to provide data subjects with the information to which they are entitled under article 15.

Other data subject rights contain exceptions that change their nature to an *obligation de moyens*. This category includes the duty to provide information to the data subject even though the data has not been obtained from her directly (no disproportionate effort required) and the duty of a controller to inform other controllers when the data subject invokes her right to erasure (taking into account the available technology and the cost of implementation).¹²³ It might be assumed that these exceptions render the provisions compatible with the risk-based approach. They do not, however, make reference to the same factors as articles 24 and 25(1). Under the risk-based approach, the likelihood and severity of risks are to be assessed in light of the nature, context, purpose and scope of the processing, and to be considered in relation to the cost of any measures taken and the state of the art. Article 14(5)(b) refers to the disproportionality of providing information to the data subject, but specifies a number of situations in which this would be the case, leaving much less room for a balancing act on the side of the controller than under a pure risk-based approach. Article 17(2) refers to the cost and the state of the art, but not to the risks posed by the processing, meaning that controllers can avoid taking costly measures even though the risk posed to the data subject is high. The exceptions which found their way into Chapter III therefore do not resolve the tension between the risk-based approach and the obligations of controllers with respect to the rights of data subjects. The risk-based approach would give rise to further limitations of the rights of data subjects than Chapter III provides for.

¹²² WP29, 'Statement on the role of a risk-based approach', 2–3.

¹²³ GDPR, arts 14(5) and 17(2).

D. The Discretion of Controllers vs the Control Rights of Data Subjects

The risk-based approach significantly alters the provisions discussed above. Articles 24 and 25(1) do not simply codify or explicate a pre-existing feature of data protection law. Controllers are endowed with and encumbered by the responsibility to calibrate the legal requirements in the GDPR. Many of the requirements in the GDPR lend themselves to risk-based calibration and could even be enhanced in this manner. The principles of fairness, the principle of purpose limitation and the legitimate interest-test are particularly suitable to be reformulated in light of the risks posed to the rights and freedoms of individuals. On the other hand, however, the risk-based approach affords controllers a discretion that they would otherwise not formally enjoy. They are only required to take compliance measures to the extent that it would be appropriate for them to do so, given the risks posed to the rights and freedoms of individuals, the cost of the measure, and the state of the art. In the absence of further guidance, controllers enjoy a considerable discretion with regard to the appropriate balance between these factors.

The provisions in Chapter III are explicitly at odds with the discretionary power of the controller under the risk-based approach. If the risk-based approach would apply in full, it would permit controllers to limit both *obligations de résultat* and the *obligations de moyens* on the grounds that their implementation is not technically feasible or is not worth the cost in light of the low level of risk to the rights and freedoms of individuals. This would limit the rights of data subjects in contradiction to article 23. Any limitation of the provisions of Chapter III in Union or Member State law has to meet a number of conditions reminiscent of Article 52(1) of the Charter.¹²⁴ Article 23 requires any such limitation to be prescribed by law and to make reference, inter alia, to the purpose of the processing, the categories of personal data, the scope of the restrictions, the safeguards against abuse or unlawful access or transfer, the risks to the rights and freedoms of data subjects, and the right of data subjects to be informed about the restriction. This is at odds with the open reference to ‘risk’ in articles 24 and 25(1) of Chapter IV, which grants controllers a relatively large margin of discretion to decide on the scope of the restriction and on the safeguards that have to be taken.

The clash between the risk-based approach and the control rights of data subjects is not easily resolved. Given the right regulatory environment, the risk-based approach could lead to more substantive protection, indicating that it may not be desirable to get rid of the risk-based approach altogether. The risk-based approach is also a means to ensure that the obligations in the GDPR are not disproportionately burdensome. It requires controllers to temper the widely applicable data protection regime so as to make it less demanding with regard to innocent processing

¹²⁴ Compare: Convention for the Protection of Individuals with regard to Automatic Processing of Personal Data [1981], art 9.

operations. This is one way to meet the requirement of EU law that legal obligations are necessary and proportionate to achieve their aim.¹²⁵ Also the control rights of data subjects are subject to this requirement. In *Google Spain*, the CJEU created the duty for search engines to 'adopt the measures necessary to withdraw personal data' whenever a data subject rightly exercises her right to be delisted. It is, however, only because the search engine's activities were 'liable to significantly affect the fundamental rights to privacy and to the protection of personal data' and 'in light of the potential seriousness of that interference' that this duty is justified.¹²⁶ On the other hand, however, the 'riskification' of Chapter III could greatly lessen the power of data subjects in the data protection arena. In short, a controller could refuse to give a data subject access to her data on the basis that the effort would not be worth the result. It is therefore tempting to agree with the WP29 that the rights of data subjects 'should be respected regardless of the level of the risks which the [data subjects] incur through the data processing involved'.¹²⁷ During the reform, the WP29 had already expressed concern over other exceptions that grant controllers a large amount of discretion with respect to the control rights of data subjects.¹²⁸ It may be necessary to restrict the scope of application of the risk-based approach, and make do with the specific exceptions present in Chapter III.

V. Conclusion

Data protection regulators are trying to have their cake and eat it, too. They want controllers to implement data protection law in an improved form, without, however, undermining the status of the legal requirements drafted by the legislature. This chapter has argued that the risk-based approach undeniably affects the rules and principles of data protection. The risk-based approach requires controllers to adjust their legal obligations in light of the risk posed by their processing operation to the rights and freedoms of individuals, the cost of implementation, and the state of the art. Controllers are entrusted with the responsibility to ensure that the GDPR results in an appropriate level of protection of the rights and freedoms of individuals without being disproportionately burdensome. They will have to tone down or enhance data protection law, depending on the processing operation at hand. Since this affects what it takes to be compliant, it, in effect, changes the obligations of controllers. The WP29 appears to argue that the data protection

¹²⁵ Treaty on European Union, art 5(4).

¹²⁶ *Google Spain*, paras 80–81.

¹²⁷ WP29, 'Statement on the role of a risk-based approach', 2; WP29, 'Statement of the Working Party on current discussions regarding the data protection reform package', 3.

¹²⁸ Article 29 Data Protection Working Party, 'Appendix Core topics in view of the trilogue—Annex to the Letters from the Art. 29 Wp to Lv Ambassador Ilze Juhansone, Mep Jan Philip Albrecht, and Commissioner Věra Jourová in view of the trilogue' (2015), 11.

principles were risk-based to start with. A number of provisions are somewhat risk-oriented in terms of result or in terms of effort. None of them, however, grant the controllers the same discretion as does the risk-based approach. This discretion is particularly difficult to reconcile with respect to the control rights of data subjects.

References

- Van Alsenoy, B, 'Liability under EU Data Protection Law: From Directive 95/46 to the General Data Protection Regulation' (2016) 7 *JIPITEC* 271.
- Article 29 Data Protection Working Party and Working Party on Police and Justice, 'The Future of Privacy. Joint Contribution to the Consultation of the European Commission on the legal framework for the fundamental right to protection of personal data' WP 168 (2009).
- , 'Opinion 3/2010 on the principle of accountability' WP 173 (2010).
- , 'Opinion 03/2012 on purpose limitation' WP 203 (2013).
- , 'Statement of the Working Party on current discussions regarding the data protection reform package' (2013).
- , 'Opinion 06/2014 on the Notion of Legitimate Interests of the Data Controller under Article 7 of Directive 96/46/EC' WP 217 (2014).
- , 'Statement on the role of a risk-based approach in data protection legal frameworks' WP 2018 (2014).
- 'Appendix Core topics in view of the trilogue—Annex to the Letters from the Art. 29 Wp to Lv Ambassador Ilze Juhanšone, Mep Jan Philip Albrecht, and Commissioner Věra Jourová in view of the trilogue' (2015).
- , 'Guidelines on Data Protection Officers ('DPOs') WP 242 rev.01 (2017).
- Baldwin, R, Cave, M and Lodge, M, *Understanding Regulation: Theory, Strategy, and Practice* (Oxford, Oxford University Press, 2012).
- Barocas, S, and Selbst, A, 'Big Data's Disparate Impact' (2016) 104 *California Law Review* 671.
- Binns, R, 'Data protection impact assessments: a meta-regulatory approach' (2017) 7(1) *International Data Privacy Law* 22.
- Black J and Baldwin R, 'Really Responsive Risk-Based Regulation' (2010) 32(2) *Law & Policy* 181.
- Black, J, 'Decentring Regulation: Understanding the Role of Regulation and Self-Regulation in a 'Post-Regulatory' World' (2001) 54(1) *Current Legal Problems* 103.
- , 'Managing Discretion' (2001) ARLC Conference Papers www.lse.ac.uk/collections/law/staff%20publications%20full%20text/black/alrc%20managing%20discretion.pdf.
- , 'The Emergence of Risk-Based Regulation and the New Public Risk Management in the United Kingdom' (2005) 3 *Public Law* 510.
- , 'Forms and paradoxes of principles-based regulation' (2008) 3(4) *Capital Markets Law Journal* 425.
- , 'The Rise, Fall and Fate of Principles Based Regulation' (2010) LSE Law, Society and Economy Working Papers 17/2010, https://papers.ssrn.com/sol3/papers.cfm?abstract_id=1712862.

- Braithwaite, J, 'Rules and Principles: A Theory of Legal Certainty' (2002) 27 *Australian Journal of Legal Philosophy* 47.
- Burkert, H, Data-protection legislation and the modernization of public administration' (1996) 62 *International Review of Administrative Sciences* 557.
- Butin, D, Chicote, M, and Le Métayer, D, 'Strong Accountability: Beyond Vague Promises' in S Gutwirth, R Leenes and P De Hert (eds), *Reloading Data Protection* (Dordrecht, Springer, 2014).
- Bygrave, LA, *Data Protection Law: Approaching Its Rationale, Logic and Limits*, Information Law Series 10 (The Hague, Kluwer Law International, 2002).
- , *Data Privacy Law: An International Perspective* (Oxford, Oxford University Press, 2014).
- Cases C-468/10 and C-469/10, *ASNEF and FECMD* [2011] ECR I-00000, EU:C:2011:777.
- Case C-131/12 *Google Spain* [2014] ECR-I 000, ECLI:EU:C:2014:317.
- Case C-13/06, *Rīgas satiksme* [2017] ECLI:EU:C:2017:43, Opinion of AG Bobek.
- Centre for Information Policy Leadership, 'A Risk-based Approach to Privacy: Improving Effectiveness in Practice' 19 June 2014, www.informationpolicycentre.com/privacy-risk-management.html.
- , 'The Role of Risk Management in Data Protection' 23 November 2014.
- , 'Risk, High Risk, Risk Assessments and Data Protection Impact Assessments under the GDPR' 21 December 2016, www.informationpolicycentre.com/eu-gdpr-implementation.html.
- Commissie voor de Bescherming van de Persoonlijke Levenssfeer, 'Ontwerp van aanbeveling uit eigen beweging met betrekking tot de gegevensbeschermingseffectbeoordeling en voorafgaande raadpleging voorgelegd voor publieke bevraging' CO-AR-2016-004.
- Commission (EC), 'A comprehensive approach on personal data protection in the European Union' COM(2010) 609 final.
- , 'Impact Assessment Accompanying the GDPR' SEC (2012) 72, final.
- , 'Proposal for a Regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)' COM (2012) 11 final.
- Committee on Civil Liberties, Justice and Home Affairs, 'Report on the proposal for a regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data' A7-0402/2013..
- Council of Europe Consultative Committee of the Convention for the Protection of Individuals With Regard to Automatic Processing of Personal Data, 'Guidelines on the protection of individuals with regard to the processing of personal data in a world of Big Data' T-PD (2017) 01.
- DIGITALEUROPE, 'DIGITALEUROPE comments on the risk-based approach' 28 August 2013, http://teknologiateollisuus.fi/sites/default/files/file_attachments/elinkeinopolitiikka_digitalisaatio_tietosuoja_digitaleurope_risk_based_approach.pdf.
- van Dijk, N, Gellert, R, and Rommetveit, K, 'A risk to a right? Beyond data protection risk assessments' 2015) 32(2) *Computer Law & Security Review* (286).
- Eskens, S, 'Challenged by News Personalization: Five Perspectives on the Right to Receive Information' (Draft 6 June 2017, on file).
- European Data Protection Supervisor, 'Opinion of the European Data Protection Supervisor on the Communication from the Commission to the European Parliament, the

- Council, the Economic and Social Committee and the Committee of the Regions—“A comprehensive approach on personal data protection in the European Union” (2011).
- , ‘Opinion 8/2016 on Coherent Enforcement of Fundamental Rights in the Age of Big Data’ (2016).
- Gellert, R, ‘Data protection: a risk regulation? Between the risk management of everything and the precautionary alternative’ (2015) 5(1) *International Data Privacy Law* 3.
- , ‘We Have Always Managed Risks in Data Protection Law: Understanding the Similarities and Differences Between the Rights-Based and the Risk-Based Approaches to Data Protection’ (2016) 4 *European Data Protection Law Review* 482.
- Gonçalves, ME, ‘The EU data protection reform and the challenges of big data: remaining uncertainties and ways forward’ (2017) 26(2) *Information & Communications Technology Law* 90.
- Hood, C, Rothstein H, and Baldwin, R, *The Government of Risk: Understanding Risk Regulation Regimes* (Oxford, Oxford University Press 2001).
- Hutter, BM, ‘The Attractions of Risk-based Regulation: accounting for the emergence of risk ideas in regulation’ (2005) ESRC Centre for Analysis of Risk and Regulation Discussion Paper no 33, <https://www.lse.ac.uk/accounting/CARR/pdf/DPs/Disspaper33.pdf>.
- Information Commissioner’s Office, ‘Conducting Privacy Impact Assessments Code of Practice’ (2014).
- Irion, K and Luchetta, G, ‘Online Personal Data Processing and EU Data Protection Reform: Report of the CEPS Digital Forum’ (Centre for European Policy Studies Brussels 2013).
- Kloza, D, van Dijk, N, Gellert, R, Böröcz, I, Tanas, A, Mantovani, E, and Quinn, P, ‘Data protection impact assessments in the European Union: complementing the new legal framework towards a more robust protection of individuals’ (2017) d.pia.lab Policy Brief No. 1/2017, http://virthost.vub.ac.be/LSTS/dpiablab/images/dpiablabcontent/dpiablab_pb2017-1_final.pdf.
- Koops, Bert-Jaap, ‘The trouble with European data protection law’ (2014) 4(4) *International Data Privacy Law* 250.
- Kuner, C, ‘The European Commission’s Proposed Data Protection Regulation: A Copernican Revolution in European Data Protection Law’ (2012) *Bloomberg BNA Privacy & Security Law Report* 1.
- Lynskey, O, *The Foundations of EU Data Protection Law* (Oxford, Oxford University Press, 2015).
- Macenaite, M, ‘The “Riskification” of European Data Protection law through a two-fold shift’ *The European Journal of Risk Regulation* (forthcoming).
- Moerel, EML, en Prins, JEJ, ‘Privacy voor de homo digitalis’ (2016) 146(1) *Handelingen Nederlandse Juristen-Vereniging*. English version: *Privacy for the Homo digitalis: Proposal for a new regulatory framework for data protection in the light of big data and the internet of things*, available here: https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2784123.
- Parker, C, *The Open Corporation: Effective Self-regulation and democracy* (New York, Cambridge University Press, 2002).
- , ‘Meta-regulation—legal accountability for corporate social responsibility’ in D McBarnet, A Voiculescu and T Campbell (eds), *The New Corporate Accountability: Corporate Social Responsibility and the Law* (Cambridge, Cambridge University Press, 2007).
- Quelle, C, ‘The data protection impact assessment: what can it contribute to data protection?’ (LLM thesis, Tilburg University 2015) <http://arno.uvt.nl/show.cgi?fid=139503>.
- Robinson, N, Graux, H, Botterman, M, and Valeri, L, ‘Review of the European Data Protection Directive’ (The RAND Corporation technical report series 2009) www.rand.org/content/dam/rand/pubs/technical_reports/2009/RAND_TR710.pdf, 48–49.

No Privacy without Transparency

ROGER TAYLOR

Abstract. Transparency requirements need to be strengthened if they are to address potential harm from automated decision-making—dangers that the public have identified as a concern in surveys about privacy protection. Specifically, where the logic of a decision algorithm cannot be easily disclosed, rights to information are insufficient to support informed consent. This is true of the expanded rights to information under the GDPR as well as other data protection regimes. These expanded rights may assist in understanding the legality of data processing, but fall short of enabling an assessment of the wisdom of making such processing legal. This paper describes a model of the net benefit or harm of automated decision-making systems and uses this to outline the information that would be required to inform consent or to enable regulatory oversight. It considers the obstacles to providing this, some of which arise as a consequence of privacy protection itself.

I. Introduction

This paper makes three propositions. First, that a significant proportion of harm from data processing from which the public wishes to be protected arises not from unauthorised or insecure use of data but from poor implementation of data processing for authorised and desired purposes. This is explored in the second section of the paper. The second proposition is that data protection regulation offers insufficient protection from these harms. This is explored in the third section of the paper. The third proposition is that the information necessary to assess whether automated processing is beneficial or harmful requires information not about the purpose or the methodology but about the outcomes of such processing and, in particular, false positive and false negative rates. This is explored in the fourth section of the paper using a model of automated decision-making. The concluding remarks consider what would be necessary for it to be possible to provide this information to enable an accurate assessment of the benefit or harm of automated decision-making.

II. Describing the Harms from Loss of Privacy

Ideas of privacy and the harms associated with a loss of privacy have changed over time and in response to technological developments. In antiquity, private matters were those areas of life over which the public and the state had limited or no legitimate remit. Aristotle's distinction between the household and the state is often cited as an early formulation of this view.¹ A more developed idea in the same vein is John Stuart Mill's view that there are areas of life where the intrusion of law or public censure can only reduce human happiness—areas where the individual's autonomy and individuality should not just be recognised but encouraged.² It remains an important idea today and has been used in court to limit government interference in matters of family planning and sexual relations.³

The idea that privacy was about control over information developed in response to new technology. In 1890, Brandeis and Warren's proposals for a right to privacy⁴ under US law was prompted by fears of: 'the too enterprising press, the photographer, or the possessor of any other modern device for recording or reproducing scenes or sounds' which had, they said, created circumstances in which 'gossip is no longer the resource of the idle and of the vicious, but has become a trade'. Brandeis and Warren sought a legal basis for protection against the sharing of information that falls short of being slanderous but where the subject has a right to protection from 'the effect of the publication upon his estimate of himself and upon his own feeling'.

Seventy years later, William Prosser reviewed the legal use of privacy⁵ and found that press intrusion remained a central concern for the US courts. He also identified another issue. Alongside protection from intrusion, embarrassment, or being placed in a false light, he found that the courts had recognised the right to be protected against the 'appropriation of someone's name or likeness'.

Prosser's examples of this include the use of someone's pictures in an advertisement without permission or adopting a name in order to fraudulently pose as someone's relative. Identity theft was a rare event in his day but with the rise of digital technology, it has become a constant and daily concern for anyone engaged in online activity.

Lack of privacy has been linked to a variety of problems throughout history. However, these problems have little else that connects them. The danger of the state legislating about my sex life, the danger of press intrusion and the danger of my credit card details being stolen online have little in common apart from the link

¹ Aristotle *Politics*.

² John Stuart Mill, *On Liberty* (1869).

³ e.g. *Griswold v. Connecticut* (1965) 381 U.S. 479 on contraception or *Roe v. Wade* (1973) 410 U.S. 113 on abortion both reference privacy.

⁴ Samuel D. Warren and Louis D. Brandeis, 'The Right to Privacy' (1890) *Harvard Law Review*, Vol. 4, No. 5, pp. 193–220.

⁵ W Prosser, 'Privacy' (1960) *California Law Review* 48: 383–423.

to privacy. For that reason, the mechanism used to protect against these harms—constitutional limitations on the legislature, press regulation, data protection laws—have nothing in common apart from their connection to the idea of privacy.

The rise of digital technology and artificial intelligence is creating a new set of potential harms that can arise from the misuse of personal information. The fact that these concerns are discussed under the heading of ‘privacy’ does not imply that the remedy will have anything in common with the mechanisms we have used to protect against previous dangers.

Facebook stated in evidence to the FTC in 2010 ‘Given the vast differences between Justice Brandeis’s conception of privacy and the way the concept applies to users on the social web, privacy cannot be viewed in one static way across every interaction that a user might have. Instead, an effective framework for privacy on the social web must focus on users’ expectations, which depends on the nature and context of the relationships that users have with the companies and other services with which they interact’.⁶

A. Public Perceptions of the Privacy Related Harm

Public views of the dangers of sharing information with online services have been extensively researched in the US, Europe and elsewhere. In testimony to a congressional inquiry,⁷ Professor Alan Westin summarises the US polling evidence as follows: ‘we have concern about privacy, but also a desire to enjoy the benefits of a consumer society, and the question is, how do Americans divide in those balances between those two values?’

Polling in the UK has yielded similar conclusions—that people are concerned about sharing data and the risks to data security; that they want risks minimised but recognise they are a necessary evil; and that the justification for taking these risks is the degree of personal benefit that results.⁸

The benefits the public wish to see are not just personal. Many are both public as well as personal, for example better public services or crime prevention; and some primarily public, such as research.⁹ But personal benefit was what people were most interested in. For example, one survey found ‘more tailored services’

⁶ Facebook, ‘Response to the Federal Trade Commission preliminary FTC staff report ‘protecting consumer privacy in an era of rapid change: a proposed framework for Businesses and Policymakers’ (2011) available at: https://www.ftc.gov/sites/default/files/documents/public_comments/preliminary-ftc-staff-report-protecting-consumer-privacy-era-rapid-change-proposed-framework/00413-58069.pdf [Accessed 2 Feb. 2017].

⁷ US Congress Subcommittee on Commerce, Trade and Consumer Protection of the Committee on Energy and Commerce, ‘Opinion Surveys: What consumers have to say about information privacy’ (2001).

⁸ ScienceWise, ‘Big Data Public views on the collection, sharing and use of personal data by government and companies’ (2014).

⁹ Wellcome Trust, ‘Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data’ (2013).

was the most popular justification for data sharing with 'public benefit' coming second with half as many responses.¹⁰

The specific benefits identified in public opinion surveys include better and/or cheaper services and products (both from government and companies),¹¹ more tailored/personalised services and communications,¹² preventing crime and exposing dishonesty¹³ and transactional convenience.¹⁴ The dangers are loss of control over data leading to either privacy invasion (people knowing things you would wish them not to) or economic harms through identity theft, fraud or other misuse of data;¹⁵ nuisance marketing and poorly targeted advertising;¹⁶ and discrimination whether by government or commercial organisations such as insurers.¹⁷ Worries about these dangers were exacerbated by a sense that data controllers were not to be trusted or were not being open about how data was being used.¹⁸

This balancing of the benefits against the risks is often described in terms of a rational 'trade-off' that the public are willing to make.¹⁹ However, many surveys and commentators have pointed out that public attitudes often appear to reflect irrational and contradictory viewpoints rather than a rational trade-off between competing priorities.

The 'privacy paradox'²⁰ refers to the fact that people in surveys express strong levels of concern about lack of control over their private data while at the same time showing a strong appetite for products such as social media or store cards that depend, in most cases quite transparently, on the individuals sharing personal data.

Evidence of contradictory opinions can also be found within the survey data.

A UK survey found that receiving more personalised services and recommendations was the most common reason for favouring company use of personal data

¹⁰ Deloitte, 'Data Nation 2012: our lives in data' (2012) available at: <https://www2.deloitte.com/content/dam/Deloitte/uk/Documents/deloitte-analytics/data-nation-2012-our-lives-in-data.pdf>.

¹¹ Lee Rainie and M Duggan, 'Privacy and Information Sharing' (2015) Pew Research Center. Available at: <http://www.pewinternet.org/2016/01/14/2016/Privacy-and-Information-Sharing/>; Deloitte 2012,

¹² Wellcome Trust 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data'; Deloitte 2012 (n 11), Lee Rainie (n 12).

¹³ Wellcome Trust; 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data'; Deloitte 'Data Nation 2012: our lives in data'; Daniel Cameron, Sarah Pope and Michael Clemence 'Dialogue on Data' (2014) Ipsos MORI Social Research Institute.

¹⁴ Wellcome Trust; 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data'; Rainie, 'Privacy and Information Sharing'.

¹⁵ Wellcome Trust; 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data'; Deloitte, 'Data Nation 2012: our lives in data'; Rainie, 'Privacy and Information Sharing'.

¹⁶ Wellcome Trust; 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data'; Rainie, 'Privacy and Information Sharing'.

¹⁷ Wellcome Trust; 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data'; Rainie, 'Privacy and Information Sharing'.

¹⁸ Deloitte, 'Data Nation 2012: our lives in data'; Rainie, 'Privacy and Information Sharing'.

¹⁹ Data & Marketing Association, 'Data privacy: What the consumer really thinks' (2015).

²⁰ Susan Barnes, 'A privacy paradox: Social networking in the United States' (2006) *First Monday*, 11(9).

even though people were more than twice as likely to be dissatisfied as satisfied with the way that companies used browsing data to personalise communications.²¹

Another found that 41% of people agreed that: 'Organisations I interact with clearly explain why they collect and share data about me'. But, in the same survey, most people said that they would prefer not to share data because they 'don't know what happens with it'. The authors described these findings as a 'clear contradiction'.²² The same survey found that loss or theft of data was the number one concern and yet the institutions the public most trusted to hold data (government and public services) had the worst record for data breaches.

The contradiction is especially stark in research by the Annenberg School of Communications,²³ which found that 55% of US citizens disagreed (38% of them strongly) that 'It's okay if a store where I shop uses information it has about me to create a picture of me that improves the services they provide for me'. But when asked if they would take discounts in exchange for allowing their supermarket to collect information about their grocery purchases, 43% said yes. This included many people who had disagreed with the first statement.

These apparent contradictions may reflect, as some have suggested, a lack of understanding. Surveys of the US public find low levels of appreciation of how privacy policies work²⁴ and, in particular, the way in which companies share anonymised data to generate user profiles which predict behaviours or characteristics.²⁵

An alternative explanation, supported by the Annenberg research, is that consumers are resigned to the current way in which data sharing works but believe they are being offered a poor deal. They are theoretically happy to engage in data sharing and recognise it can be of benefit. But rather than engaging in a rational weighing of risks and benefits, they are frustrated by the fact that they have insufficient information to make an informed judgement. They suspect they are being offered a bad bargain—that there is a better deal that could be achieved but which no-one is putting on the table. Surveys consistently find high levels of distrust: public suspicion that their data is being used in ways that are not disclosed; awareness that this may affect them adversely; and a sense that they do not have sufficient control over what goes on.²⁶

To an individual faced by a system which they believe is unfairly rigged against them, but where they believe there is probably still a net benefit in participating,

²¹ Deloitte, 'Data Nation 2012: our lives in data';

²² Deloitte, 'Data nation 2014: Putting customers first' (2014) available at: <https://www2.deloitte.com/content/dam/Deloitte/uk/Documents/deloitte-analytics/deloitte-uk-data-nation-2014.pdf>.

²³ Joseph Turow, Michael Hennessy and Nora A. Draper, 'The Tradeoff Fallacy: How Marketers are Misrepresenting American Consumers and Opening Them Up to Exploitation' University of Pennsylvania (2015).

²⁴ Pew Research Center, 'What Internet Users Know About Technology and the Web' (2014).

²⁵ J Thuro, 'The Tradeoff Fallacy: How Marketers are Misrepresenting American Consumers and Opening Them Up to Exploitation'.

²⁶ Commission (EC), 'Special Eurobarometer 359: Attitudes on Data Protection and Electronic Identity in the European Union' (2011); Mary Madden and Lee Rainie, 'Americans' Attitudes About Privacy, Security and Surveillance' (2015) Pew Research Center.

the rational response is to insist that the terms of trade are unreasonable, but to take part none-the-less. This is the behaviour we observe.

Such behaviour is not paradoxical or contradictory. It is rational and consistent with a world in which promises not to share personal data still leave room for companies to trade detailed anonymised records which are then used to infer with varying degrees of accuracy highly personal things, such as whether or not someone is pregnant.²⁷ The observed behaviour is rational and consistent with a situation in which the public are being offered a data 'trade-off', but are denied the means to assess whether or not it is beneficial.²⁸ As one research participant said about sharing data with companies: 'none of them have ever told me how I benefit'.²⁹

B. Insecure Use and Imprecise Use of Data

There are two elements of the way the discourse is framed in surveys and policy discussion which can exacerbate this sense of powerlessness. First, there is the role of informed consent and the reliance on a mechanism in which individuals exercise personal control over how their data is used. This approach is of limited value if the individual is faced with a set of data-sharing options all of which are sub-optimal.

Second, there is the focus on legal control over the purpose or uses to which personal data is applied. Such control can be ineffective if the problem is not the purpose to which the data is being put but the manner in which it is used for that purpose. To explore this possibility, we can define two quite distinct problems that users can encounter with the use of their personal data—the first we call insecure use, the second imprecise use.

1. Insecure use of data. This causes harms through unauthorised or illegal use whether that be through loss or theft of data or use by data controllers outside of areas for which they have legal authority. Harms here would include identity theft and fraud or sharing with third parties without permission and could result in financial loss, nuisance marketing or discrimination.
2. Imprecise use of data. This is use of data within legally authorised purposes, but in a manner that none-the-less harms the data subject through the poor quality of the application e.g. personalisation algorithms that produce advertising of no interest to the data subject; medical algorithms that have a

²⁷ Charles Duhigg, 'How companies learn your secrets' *New York Times* (Feb 16 2012) <http://www.nytimes.com/2012/02/19/magazine/shopping-habits.html>.

²⁸ Dara Hallinan and Michael Friedewald, 'Public Perception of the Data Environment and Information Transactions: A Selected-Survey Analysis of the European Public's Views on the Data Environment and Data Transactions' (2012) *Communications & Strategies*, No. 88, 4th Quarter 2012, pp. 61–78.

²⁹ Jamie Bartlett, *The Data Dialogue* (Demos 2012).

high error rate in diagnosis; financial algorithms that make inaccurate risk assessments; or security algorithms that have low precision in identifying threats. These problems can also result in financial loss, nuisance marketing or discrimination.

There are examples in the public opinion surveys of harms that are as likely to arise from imprecise use of data for a desired purpose as from unauthorised use of data. For example, ‘more tailored and personalised services or recommendations’ is cited in one survey as one of the primary benefits from sharing data,³⁰ while in another ‘nuisance marketing’ and the inappropriate ‘targeting’ of individuals by companies was seen as principle risk.³¹ While nuisance marketing may be manageable to some degree through limiting the purposes for which data is used, nuisance marketing may equally arise as the result of imprecise targeting of communication and advertising to people who are actively seeking such targeting as a benefit. If my only remedy is to define ever more precisely the information I wish to receive, I may still fail and find I am pestered because I do not control the way in which such options are framed. Even if I succeed in adequately defining the content, frequency and style of communications I wish to receive, it will be a pyrrhic victory since I will have had to perform exactly the work that the personalisation algorithm claimed to be able to do for me—which was the original reason for agreeing to share data. What I require is a reliable way to assess the precision of the algorithm before consenting.

A similar tension can be found in other areas. The use of personal data to identify fraud, to unearth dishonesty and to stop people cheating has received support in surveys while at the same time, people expressed concern that use of data might lead to ‘discrimination’.³² This does not just refer to discrimination against protected characteristics, but refers to any unfair difference in treatment such as rejection of credit or insurance, rejection of benefits claims, or differential pricing. The issue at stake here is not whether in principle it is a good idea to use data for these purposes. It is a question of whether data used in this way is done well or poorly. When using data profiling to determine whether to accept or reject insurance risks or benefits claims, the difference between discrimination and unearthing dishonesty is not a difference in purpose, approach or generic consequence. The difference is the precision of the risk estimates and propensity scores generated by the algorithms.

The potential harm from insecure use features prominently in consumer surveys. Harm from imprecise use of data is less often identified as a specific category of risk. However, this may reflect the structure of the survey questions which typically present loss or theft of data as a separate category, rather than a clear public view about the relative risks presented by these two issues.

³⁰ Deloitte, ‘Data Nation 2012: our lives in data’.

³¹ Wellcome Trust, ‘Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data’.

³² Wellcome Trust, ‘Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data’.

There is substantial evidence of the potential harm that can arise from data-driven systems which are designed to do something the public regard as beneficial, but do so with insufficient precision. Health applications have, in particular, been subjected to a degree of scrutiny and found wanting. Applications that aim to treat psychological illnesses were highly variable in their effectiveness and were, in some cases, based on weak scientific evidence with the risk that they might be doing ‘more harm than good’.³³ Three out of four apps designed to diagnose melanoma were found to wrongly categorise 30% of melanomas or more as ‘unconcerning’.³⁴ Diagnosis and triage apps have been found to perform poorly in general.³⁵ Wearable technology to support weight loss has been found to diminish the impact of weight loss programmes.³⁶

Data-driven applications designed to provide information may also be doing their customers a disservice. If I use an online media platform that promises to make me better informed, I risk, instead, being provided with a stream of information that leaves me less well informed³⁷ but more emotionally secure in the correctness of my own beliefs.³⁸ The harm here does not relate to unauthorised use of data. I want my personal data to be used to identify relevant information. However, the execution may fall short of what I hoped for in ways that are harmful and which I have no way of discerning.

There is, additionally, evidence of websites using personal information to engage in price discrimination against customers. This can be regarded as a form of lack of precision, since the customer is sharing data online in the hope of accessing keener pricing but is instead subjected to an algorithm which identifies them as an appropriate target for higher prices. Although evidence of this is not widespread, it does occur and there is potential for it to increase.³⁹

In summary, there is substantial evidence that a significant risk of sharing data with automated decision-making systems is lack of precision. It is not possible to estimate whether the risks associated with imprecise use are greater or less than the risks associated with insecure use. However, the relative risk of imprecision increases to the extent that personal data is used more widely to drive automated decisions by intelligent machines. And while it is true that with further data

³³ S Leigh, S Flatt, ‘App-based psychological interventions: friend or foe?’ (2015) *Evidence-Based Mental Health* 18:97–99.

³⁴ JA Wolf, JF Moreau et al. ‘Diagnostic Inaccuracy of Smartphone Applications for Melanoma Detection’ (2013) *JAMA Dermatol.* 149(4):422–426. doi:10.1001/jamadermatol.2013.2382.

³⁵ Hannah L Semigran, Jeffrey A Linder, Courtney Gidengil and Ateev Mehrotra, ‘Evaluation of symptom checkers for self diagnosis and triage: audit study’ (2015) *BMJ* 351:h34800.

³⁶ JM Jakicic JM, KK Davis et al ‘Effect of Wearable Technology Combined With a Lifestyle Intervention on Long-term Weight Loss The IDEA Randomized Clinical Trial’, (2016) *JAMA* (11): 1161–1171. doi:10.1001/jama.2016.12858.

³⁷ David Lazer, ‘The rise of the social algorithm’ (2015) *Science* Vol. 348, Issue 6239, pp. 1090–1091 DOI: 10.1126/science.aab1422.

³⁸ Eli Pariser, *The Filter Bubble: What the Internet Is Hiding From You* (Viking 2012).

³⁹ The White House (Executive Office of the President of the United States), *Big data and differential pricing* (2015).

gathering and testing we would expect the precision of data-driven algorithms to increase, it is also true that there are strong incentives within markets and society that will encourage increasingly imprecise and harmful algorithms. Transparency is important because such algorithms can operate harmfully across populations without the harm being evident. These issues, explored in detail in section 4 below, make it plausible that in the long run, we might expect the dangers of ‘rogue algorithms’ behaving in legal ways that result in widespread, unintended harm to be as great a threat as insecure processing of data.

III. How Does Data Protection Protect against Insecure and Imprecise Use of Data?

The need to control how data is used has been central to data protection from the start. The US HEW Fair Information Practices⁴⁰ established the principle that data subjects should know what data was collected and how it was used; they should be able to correct data; and they should be assured that it would not be used for any other purpose without consent. The OECD⁴¹ built on this, emphasising that data collection and processing must be limited and lawful; that data processing should for a specific limited purpose; that data subjects are entitled to know what data is collected, how it is used and to review and correct information; and that data should not be used for any other purpose except by consent or legal authority. These same principles inform EU data protection regulations including the GDPR under which data processing is illegal unless it falls under one of the specified categories of use; that it should be proportional to such use; that data subjects have rights to be informed, to correct data and, where appropriate, limit use through withholding of consent.⁴²

This framework was developed prior to the widespread use of automated decision-making systems and is designed to ensure secure use of data, as defined above. It is not designed to protect against the imprecise use of data in automated decision-making.

Where the logic of any such decision system is static and sufficiently simple to be disclosed and understood, a description of the use of the data might be sufficient to enable data subjects, citizens and regulators to assess the likely precision

⁴⁰ Department of Health, Education and Welfare (US), *Report of the Secretary's Advisory Committee on Automated Personal Data Systems, Records, Computer, and the Rights of Citizens* (1973).

⁴¹ OECD *Recommendation of the council concerning guidelines governing the protection of privacy and transborder flows of personal data* (1980).

⁴² REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC [2016] OJ L 119/12 (GDPR).

of the approach and any risks that might result. This may be helpful in informing consent decisions or political opinions. However, with more sophisticated decision algorithms this is not possible.

A. The GDPR

New rights and protections afforded by the GDPR do not remedy this deficit. The regulations are designed to protect the Fundamental Rights and Freedoms defined in the EU charter. The rights specifically referenced (in recital 4) include

'In particular the respect for private and family life, home and communications, the protection of personal data, freedom of thought, conscience and religion, freedom of expression and information, freedom to conduct a business, the right to an effective remedy and to a fair trial, and cultural, religious and linguistic diversity.'

The two fundamental rights most frequently referenced in GDPR are Article 8 rights to data protection (e.g. recitals 39, 65, 71) and Article 25 rights to non-discrimination (e.g. recital 71). Processing that does not have legal authority and processing with legal authority that results in discrimination against protected characteristics are clearly identified as breaching the regulations.

Some of the language used suggests there may be broader protections against the adverse consequences of data processing. In particular, recitals 75 and 85 provide a list of risks including the following:

where the processing may give rise to discrimination, identity theft or fraud, financial loss, damage to the reputation, loss of confidentiality of personal data protected by professional secrecy, unauthorised reversal of pseudonymisation, or any other significant economic or social disadvantage;

The reference to data processing that gives rise to 'any other significant economic or social disadvantage' might suggest an intention to provide wide scope for protection against legal processing that performs poorly with negative results for the data subject. This is listed as an additional issue over and above discrimination or unauthorised use.

Recital 71 may also appear to address the question of precision in algorithmic decision-making:

In order to ensure fair and transparent processing in respect of the data subject, taking into account the specific circumstances and context in which the personal data are processed, the controller should use appropriate mathematical or statistical procedures for the profiling, implement technical and organisational measures appropriate to ensure, in particular, that factors which result in inaccuracies in personal data are corrected and the risk of errors is minimised ...

However, it is far from clear that imprecise propensity scores could be regarded as 'inaccuracies' in personal data any more than a record of a diagnosis given by

a doctor would be regarded as incorrect personal data on the grounds that the doctor had a poor record of accurate diagnosis. The reference to ‘risk of errors’ would seem to apply to this same sense of ‘inaccuracies’ in data. An organisation that was assiduous in ensuring the correct recording of the output of a relatively imprecise algorithm would appear to be justified in claiming it was minimising the risk of error under this definition. Any such claim would fall short of what the public would expect ‘minimising the risk of error’ to mean.

The supposed new right to an ‘explanation’ with regard to automated decision-making (Art. 13-15 and 22) does not resolve the problem. It is true that data subjects must be informed of any ‘consequences’ of data processing. However close analysis⁴³ finds that this requirement does not go further than the requirements of some existing data protection regimes and implies nothing more than a generic explanation of processing: for example, that the consequence of a credit check is that you may or may not get a loan. It does not protect against the risk that such an algorithm is imprecise with the result that it produces credit scores that unfairly penalise data subjects.

The right not to be subjected to automated decision-making (Art. 22) is also of no help if I want to benefit from automated decision-making but only to do so secure in the knowledge that the algorithms used are sufficiently precise and not harmful.

Finally, there are some welcome clarifications to your rights of data access (Art.15). But, as described in more detail in section 3 below, data about yourself can rarely, if ever, provide a basis for querying the precision and accuracy of a complex decision-making algorithm since such an assessment requires knowledge of how the algorithm operates at a population level, not at an individual level.

The lack of clear steps to address imprecision means that the GDPR falls short of the ambition of recital 4 that ‘The processing of personal data should be designed to serve mankind’. It leaves ample room for poor quality processing that complies with the law and yet results in nuisance marketing, poor medical advice, undeserved credit ratings, rejected insurance applications or information flows that distort perceptions and mislead.

In passing, it is worth noting that the illegality of discrimination against protected characteristics but the lack of protection against the broader impact of imprecise algorithms has the potential to produce peculiar results. For example, if an algorithm designed to identify low priced insurance systematically performed

⁴³ Sandra Wachter, Brent Mittelstadt and Luciano Floridi, ‘Why a Right to Explanation of Automated Decision-Making Does Not Exist in the General Data Protection Regulation’ (2016). *International Data Privacy Law*, Forthcoming. Available at SSRN: <https://ssrn.com/abstract=2903469>; Against: Dimitra Kamarinou, Christopher Millard and Jatinder Singh, *Machine Learning with Personal Data*, this volume.

worse for people of a particular ethnicity it might be in breach of the regulations. However, if it performed poorly for all customers it would not. If a travel recommendation service produced targeted communications that are deemed an invasive nuisance for women but did not do this for men, it might be in breach. But if men and women were equally annoyed by its communications it would likely not be.

B. Transparency, Consent and Fair Processing

Transparency and informed consent are central features of data protection regimes around the world, providing the basis for fair processing of data in the absence of any more specific legal permission.⁴⁴ Discussions of the value of consent often assume that it allows a user to assess the risks and benefits of a particular agreement to share data. In the words of the Canadian regulator: 'being informed about and understanding an organization's policies and practices allow individuals to provide meaningful consent. Individuals should be able to understand the risks and benefits of sharing their personal information with the organization and be in a position to freely decide whether to do so'.⁴⁵

The gap between this intent and the reality has been widely noted. Criticism of consent has 'reached a crescendo on both sides of the Atlantic' and 'perhaps more surprisingly the critique of notice and consent has more recently been echoed by regulators, industry and privacy advocates'.⁴⁶

Much of the attention has focussed on the complexity of the information users are expected to understand; the imbalance in power between organisations seeking consent and individuals; the broad nature of the consents sought and the non-obvious nature of what these consents might enable.⁴⁷ It has also been observed that the reliance on privacy notices as a form of consumer protection risks giving false assurance and undermining effective consumer protection.⁴⁸ These problems are further exacerbated by the increasing number of objects that automatically and continuously collect data making the point at which consent should be sought less clear.⁴⁹

⁴⁴ Eg US Privacy Act, 1974; EU Data Protection Directive art 7; GDPR art 6; Asia Pacific Economic Cooperation Privacy Framework.

⁴⁵ https://www.priv.gc.ca/en/privacy-topics/collecting-personal-information/consent/gl_oc_201405/.

⁴⁶ Fred H Cate, 'Big data consent and the future of data protection' in Cassidy R. Sugimoto, Hamid R. Ekbia, Michael Mattioli (eds), *Big Data Is Not a Monolith* (MIT press 2016).

⁴⁷ *Ibid.*

⁴⁸ Omri Ben-Shahar and Carl Schneider, *More Than You Wanted to Know: The Failure of Mandated Disclosure* (Princeton University Press 2014).

⁴⁹ S Dritsas et al. 'Protecting privacy and anonymity in pervasive computing: trends and perspectives' (2006) *Telematics and Informatics* 23 196–210; E Luger and T Rodden, 'Terms of Agreement:

This has prompted calls to rely less on consent in which the individual is expected to assess the acceptability of the risk/benefit trade off, and to instead put more weight on regulation and accountability regimes in which service providers take on the responsibility for ensuring such trade-offs fall within parameters set by law and regulation.⁵⁰

The GDPR has responded to that need by placing greater emphasis on the duties of the data controller to demonstrate compliance and giving greater powers on regulators to intervene. The requirement to keep audit trails of data processing could, perhaps, provide a mechanism whereby regulators could examine the question of the precision of algorithmic decision-making. However, in the broader context of the regulations, the purpose of such powers would seem to be to ensure that data is processed securely and is done so in a way that does not infringe fundamental rights. It falls short of securing rights to information about the precision of decision-making algorithms.

To illustrate the regulatory gap this creates, we can compare the use of consent for medical intervention with the use of consent under data protection regulations. With the former, there is typically an explicit requirement that the patient be informed not only about the nature of the procedure and the rationale but also about the risks that it presents. This does not refer simply to the risks of the procedure going wrong or the doctor doing something that the patient had not wanted. It refers also to the risks that arise if the procedure goes entirely as intended.

It is also of note that in the literature on medical ethics, there is strong recognition that consent and oversight are not alternatives but complementary activities. There is a clear understanding that consent only operates effectively within a context of trust established by effective regulation of those same risks that patients are expected to accept as part of informed consent. Consent to treatment is to a large degree based on trust in the individuals, professions and institutions of medicine.⁵¹ In this context, trust has been defined as ‘a willing dependency on another’s actions’ which ‘is limited to the area of need and is subject to overt and covert testing. The outcome of trust is an evaluation of the congruence between the expectations of the trusted person and actions.’⁵²

The accountability mechanisms of medical regulation by professions and governments, along with a medical culture that recognises the importance

Rethinking Consent for Pervasive Computing’ (2013) *Interacting with Computers*, 25(3); Richard Gomer, MC Schraefel and Enrico Gerding, ‘Consenting Agents: Semi-Autonomous Interactions for Ubiquitous Consent’ (2014) *UbiComp* <http://dx.doi.org/10.1145/2638728.2641682>.

⁵⁰ Cate (n 47).

⁵¹ Kennet Calman, ‘Communication of risk: choice, consent, and trust’ (2002) *The Lancet*, Volume 360, Issue 9327, 166–168.

⁵² JE Hupcey, J Penrod, JM Morse and C Mitcham, ‘An exploration and advancement of the concept of trust’ (2001) *Journal of Advanced Nursing*, 36: 282–293. doi:10.1046/j.1365-2648.2001.01970.x.

of scientific inquiry, ethics and care, provide the ‘overt and covert testing’ that support the development of trust. An analogous accountability regime in privacy regulation would aim to make consent a meaningful assessment of the congruence between our expectations of what users of personal data are doing and what is in fact occurring. Data protection regulation will not be able to achieve this if it does not address risks of imprecise use of data—risks that the public regard as significant issues for data protection.

C. Privacy vs Consumer Protection

One possible explanation for the focus on use based consent, rather than risk based consent, in data protection regulations would be a view that risks of unauthorised use are matters relevant to privacy and risks relating to authorised use should be viewed as consumer protection issues. In this view, privacy regulation should concern itself primarily with preventing information being used illegally, beyond consent or without due care to security. The question of whether use of personal data within legal consented services is beneficial or harmful is matter for consumer protection organisations.

This same view might take comfort from the view that market competition might be expected to drive imprecise decision systems out of the market in favour of more precise mechanisms. We will outline in the next section why market forces are likely in many cases to favour less precision rather than more.

The arguments against separating consumer protection issues from data protection issues are practical. First, there is the consideration that this distinction does not map well to the way in which the public think about the risks of data use as described in Section 1 above.

Second, the practical mechanisms to address imprecision are the same as those used to address insecure use of data. Consent and transparency around use of data are unlikely to cease being important parts of any regulatory regime. In that context, separating the risks of imprecise use from insecure use is confusing and cumbersome.

Thirdly, the regulatory mechanism to ensure transparency about the precision of decision-making systems will need to address questions of ownership and control of the underlying data sets on which those systems operate. The skills and expertise to police the various ways in which automated decision-making can harm individuals do not divide neatly into those relevant to ‘consumer’ issues as opposed to those relevant to a more restricted definition of ‘privacy’ issues.

It is true that consumer protection research mechanisms can be of value. This includes conducting research among the users of an application or putting an application through a range of scenarios. This last approach was used by the EU

to investigate whether Google was distorting search results in favour of its own shopping service.⁵³

However, these approaches have limitations when applied to sophisticated AI driven surveillance systems which continuously generate information about the quality and nature of their decisions. While it is technically possible to gather information about the quality of these systems without access to the data on which they run, this approach has the disadvantage of being economically inefficient and inherently less reliable.

It therefore makes sense to explore how privacy regulation can address the question of risks and benefits as a totality considering both risks to security and risks of imprecision within the same framework of regulations. The next section sets out in more detail the challenges this creates.

IV. Measuring the Benefits and Risks of Data-driven Automated Decision-making (Surveillance)

A simplified model of a dynamic surveillance system—an automated intelligent data-driven decision-making system—is used to present a view of how information about the risks and benefits of such systems can be generate from user data and to highlight how individual and corporate rights over information interact with the potential to generate this information.

Automated decision systems can operate according to fixed algorithms, but much of the power of digital technology comes from the ability of surveillance systems to operate dynamically, continually improving and optimising their algorithms. Surveillance capitalism—the ability to collect data about customers, segment audiences, predict behaviour and tailor products or offers to different segments—has become a primary driver of value creation in industries such as retailing, finance and the media.⁵⁴ Governments use similar techniques of digital surveillance for policing and national security and there are ambitions to greatly expand the use of digital surveillance techniques to improve public services such as health and education. This model can be applied equally to search engines such as Google, advertising driven media such as Facebook, and web services such as Amazon or Spotify as it can to potential future applications of data-driven decision-making such as AI-driven diagnostics or HR systems.

⁵³ European Commission press release *Antitrust: Commission fines Google €2.42 billion for abusing dominance as search engine by giving illegal advantage to own comparison shopping service* 27 June 2017.

⁵⁴ Shoshana Zuboff, 'Big other: surveillance capitalism and the prospects of an information civilization', (2015) *Journal of Information Technology* Vol 30, 75–89.

A. Model Surveillance System

We characterise digital surveillance systems with a five step model as follows.⁵⁵

Step 1: Define A surveillance system must first define a propensity of interest (i.e. tendency to purchase a particular product, respond to a drug, or commit a crime) and find an association with attributes (data) known about the target population. Examples include estimates of the likelihood of involvement in criminal activity based on communications metadata; estimates of the likelihood of buying a product based on browsing history; or estimates of the likelihood of responding to medication based on blood pressure readings and family history. The associations are normally based on historic data or research studies, but can be based on any a priori beliefs.

Step 2: Identify A surveillances system must be able to collect and process attribute data across a population and categorise individuals according to propensities, typically defining a series of segments by clustering on the basis of similar attributes and propensities. Examples might include ‘terrorist threat’, ‘white van man’ or ‘hypertensive’.

Step 3: Intervene The surveillance organisation must then have the ability to systematically intervene across a population according to the segment an individual is in: wire-tapping some and not others; advertising to some and not others; recommending medical treatments to one group and not to the other.

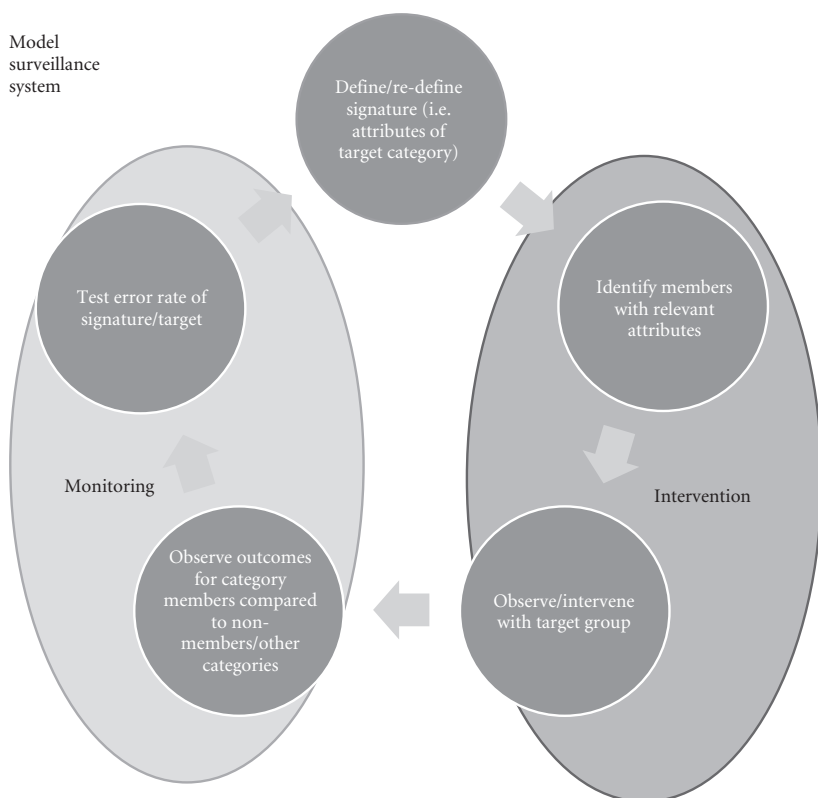
Many non-digital surveillance systems stop at this point and operate using static segments and static rules defining the interventions for each. There are two further steps that characterise dynamic surveillance system which data-driven digital systems are particularly well suited to. The two steps are:

Step 4: Observe outcomes Surveillance systems can collect information about the outcomes across the surveilled population. The outcome should relate to the propensity of interest—e.g. was the individual identified as a threat prosecuted for criminal activity; did the individual identified as a prospect buy the product; did the patient given a diagnosis respond positively to treatment. Ideally outcomes are collected equally for the whole population regardless of the intervention but this is often not possible. For example, ideally, the system will monitor the future blood pressure and stroke rate among treated and untreated people whether defined as hypertensive or not; it will measure the purchasing behaviour of those to whom a promotional message was sent and those to whom it was not.

Step 5: Test error rate Outcome data can then be used to test the sensitivity and specificity of categories/segments by identifying how well propensity estimates forecast real behaviour and looking for attributes that correlate with unexpected behaviour. If a cost is assigned to inaccurate intervention (where the outcome is

⁵⁵ This model is based on a model presented in Roger Taylor and Tim Kelsey *Transparency and the Open Society* (Policy Press, 2016).

not as predicted or accuracy is no higher than random) and a benefit to accurate intervention, a net benefit of the surveillance can be calculated.



B. Estimating the Net Benefit of a Surveillance System

To estimate the net benefit of a surveillance system we need to know how often it incorrectly estimates a propensity and intervenes in a way that is non-beneficial or harmful or fails to intervene when it would be beneficial. We need to know both its false positive rate and its false negative rate along with the costs associated with each type of error.

Such estimates do not exist in the public domain for most surveillance systems, but healthcare is one area where they do exist. The results show that information about the purpose of surveillance does not provide reliable information about the benefit of such a system. Breast screening programmes have been assumed to be beneficial based on estimates from past studies. Meta-analysis of the outcomes from breast screening suggest that it may be causing more harm than good

because the likelihood that it will recommend unnecessary tests is more costly to people than the likelihood it will detect cancer earlier than would have occurred without screening.⁵⁶ A description of the purposes of breast screening or the way the data was used could never reveal this.

Information about false positives and negatives is equally useful in assessing the value of a surveillance system that makes recommendations regarding news, diet, investment, or exercise regimes. Before consenting to an application that segments the population on the basis of their exercise regime and heart rate to make exercise recommendations, I would be wise to ask the extent to which people who follow its advice see improved heart health as opposed to suffering heart attacks as compared to those who do not.

C. Risks of Surveillance Systems Resulting in Net Harm

There are reasons to believe that, even with the best intentions, surveillance systems have the potential for significant harm. The example of breast cancer screening shows how even in a relatively transparent and closely regulated area of activity, it is possible that surveillance systems intended to protect people may be harmful. Judging whether the harm that results from false negatives and false positives outweighs the benefit of correct categorisation is not something that can be done reliably from cursory examination. It relies on repeated interrogation of the impact across populations.

There is an additional problem in market driven situations. Market competition may incentivise algorithms that make users happy but this can be wholly consistent with harming the individuals concerned. Algorithms will typically be optimised against a measure that is at best a proxy for the benefit that the data subject wishes to receive. For example, an application making recommendations about my exercise regime based on information about my heart rate and my exercise may be optimised to produce the greatest improvement in heart health or it may be optimised to produce the highest resubscription rate by users. It might be assumed that if users like it, it is doing them good. However, it is equally possible that users are delighted by recommendations that are damaging to their health.

In a similar way, concerns about filter bubbles can be characterised as a mismatch between a customer desire to be kept informed and the aim of the algorithm to keep the customer happy as measured by their tendency to click on links. The latter may mean hiding information from them that displeases them.

Finally, even if an algorithm is calibrated against exactly the outcome that the data subject is interested in, the optimal level of false positives and false negatives for the operator of a surveillance system is likely to differ from the socially optimal level that the data subject would choose. Take for example, a commercial

⁵⁶ PC Gotzsche and K Jorgensen, 'Screening for breast cancer with mammography', *Cochrane Database of Systematic Reviews* 2013, No 6. Art No: CD001877. DOI: 10.1002/14651858.CD001877.

surveillance system designed to help people identify the most suitable product at the lowest price. The data subject's interests are met by doing just that. The interests of the operator of the system would be met by identifying the combination of product and price that yields the optimum combination of customer loyalty and profit margin. The risks of misaligned incentives become troubling when applied to the promotion of potentially addictive products such as gambling, loans or alcohol.

As a result, it is unlikely that the GDPR will achieve its ambition of ensuring that: 'The processing of personal data should be designed to serve mankind.' Indeed, given the likely spread of AI decision-making systems to a wide range of mechanisms from self-driving cars and medical diagnostics to share trading and employment decisions, there is a risk that without stronger transparency the processing of personal data will be a significant cause of harm to mankind.

V. How Might Regulators Ensure Reliable Information about the Impact of Surveillance Systems be Generated?

We can identify three steps that could help in enabling accurate assessment of the risks and benefits of data-driven surveillance systems. First, establishing independent rights to access data for audit and assurance will be of great value. This step has been recommended by a number of commentators including, for example, Wachter⁵⁷ who suggests that regulations should '*allow for examination of automated decision-making systems, including the rationale and circumstances of specific decisions, by a trusted third party. ... The powers of Supervisory Authorities could be expanded in this regard.*'

This might allow for a meaningful explanation of the consequences of data processing from an unconflicted source. It is unclear the extent to which the authors are recommending third parties be allowed access to raw data, but the implication is that they would have such access since it is proposed as a mechanism to allow scrutiny without compromising commercial confidentiality.

This approach is of value because the data held within a surveillance system provides a unique insight into how the system is operating which it would not be possible to replicate through external testing of a system. Requirements placed on organisations to produce analyses of impact according to fixed regulatory formulae run the risk of prompting gaming more than transparency.

However, the success of this approach would depend on the level of data access and the analytical competence of the third party. There is a risk that if this right

⁵⁷ Wachter, 'Why a Right to Explanation of Automated Decision-Making Does Not Exist in the General Data Protection Regulation'.

is assigned only to regulatory bodies, the scale of the task could prove intractable. An alternative approach would be to establish rights of access to data for scientific and public interest purposes. The specific consideration given to these issues in Art. 21 GDPR helps in this regard.

Second, there may also be value in distinguishing between the different ways in which data is used in surveillance when giving consent to data collection. Using the model described above we can draw a distinction between the way data is used in steps 2 and 3—where the output is a categorisation of individuals to determine interventions; and steps 4 and 5—where the output is a measure of the accuracy of the surveillance system. We can label the first part ‘intervention’ and the second, ‘monitoring’.

When I consent to the use of data within a surveillance system, I consent on the same terms to both uses. However, I have quite different interests in the way that my data is used for these purposes in at least two regards:

1. **Third party access** Allowing third party access to data for the purposes of intervention carries significant risks. Allowing it for monitoring can protect me since the more people who review data-driven algorithmic decision-making systems, the greater the likelihood that unintended harm from surveillance is brought to light. Furthermore, since monitoring can be conducted with access to identifiers, third party access for this purpose poses a lower security risk than access for intervention.
2. **Breadth of data collected and data linking** When data is used for intervention, risks are reduced if I can limit the data used to the minimum necessary. When data is used for monitoring, I benefit from the widest possible set of data being used since this increases the possibility of associations being found that are operating in entirely unexpected ways.

To illustrate this, imagine again an app that draws data about exercise and heart rate to provide recommendations about health. Imagine that part of the system is designed to target recommendations for vitamin supplements on the basis of heart rate and exercise to those who respond positively to such recommendations. Such an application might identify and target a particular pattern of exercise and heart rate which, unbeknownst to the application, is a proxy for people who smoke. In this way, the application might prove highly effective at promoting a harmful course of action, given evidence of adverse effects of some supplements on smokers⁵⁸ and evidence that smokers who take vitamin supplements believe it has a protective effect against continued smoking.⁵⁹ However, if the application had no access to data about smoking, it would be impossible for anyone to know.

⁵⁸ D Albanes, O P Heinonen et al. ‘Alpha-Tocopherol and beta-carotene supplements and lung cancer incidence in the alpha-tocopherol, beta-carotene cancer prevention study: effects of base-line characteristics and study compliance’ (1996) *J Natl Cancer Inst.* 88(21):1560–70.

⁵⁹ Wen-Bin Chiou, Chin-Sheng Wan, Wen-Hsiung Wu & King-Teh Lee, ‘A randomized experiment to examine unintended consequences of dietary supplement use among daily smokers: taking supplements reduces self-regulation of smoking’ (2011) *Addiction* 106(12), pp.2221–2228.

To protect my privacy, I have an interest in keeping to a minimum the data used by a surveillance system to categorise me and intervene. However, to understand the net benefit of subjecting myself to this system, my interests are best served by allowing the widest possible set of data to be used.

These two issues are inter-dependent. My interests in allowing broader data sets for usage in monitoring is dependent on the issue of third party access. The potential to generate greater insight into surveillance systems is of limited or no value if it is monopolised by the operator of the surveillance system.

A. Ownership of Data

The third way in which regulation might address the potential harm from data-driven algorithms is by addressing rights of ownership in databases. Such a review is timely since technological developments are changing the accepted view about the natural ownership of data, namely that I own the product of my labour.

Historically, much of our understanding of product quality, economic gain and social impact comes from survey data collected by specific organisations for an agreed research purpose. The collection of data is often costly and the labour conducted primarily by people employed for that purpose. As a result, it seems natural to regard the product of this work as belonging to the person who commissioned and paid for the survey.

The collection of transactional data from surveillance systems is very different in two regards. First is the degree to which information collected from us is used as part of a representative sample or is a unique record in a data set from an entire population. When I answer a telephone poll, I understand that my answers may be no different to another's and it is used to represent a wider group of people. When genetic information or my personal browsing history is collected, the information is likely unique to me. This matters not just because it makes it potentially re-identifiable but also because in some fundamental way, it belongs to me. It is my product, not yours.⁶⁰

A second change that has come about is the way that information is gathered through digital technology. Google own the understanding of how we use search terms to find relevant information because they created the search engine and they analysed the data. But, as some commentators have pointed out, there is an argument that the data on which that knowledge is based was created by all of us collectively since we are the people who typed in all the search terms.⁶¹

There is a shift from a presumption that data belongs to the data collector to an acknowledgement that data about me belongs to me and data about a population

⁶⁰ RA Spinellow, 'Property rights in genetic information' (2004) *Ethics Inf Technol.* 6(1):29–42.

⁶¹ F Pasquale, *The Black Box Society: The Secret Algorithms that Control Money and Information*, (Harvard University Press, 2015).

may belong in important regards to all of us collectively. The first of these is relatively easy to recognise in legal and ethical codes. The second more problematic, not least as it can conflict with the first.

The ethical considerations regarding whether or not individuals should consent—or even have the right to consent—to the use of their data for monitoring are not the same as the considerations regarding control of data for intervention. Withholding consent for use of my data for intervention has, in the main, implications for no-one but me and is quite reasonably my decision alone. In contrast, withholding consent from the use of data for monitoring always has implications for others as it reduces both the reliability with which a surveillance system can operate and, more importantly, reduces the reliability with which its net benefit can be assessed. In other words, it increases the likelihood of harm to others.

This is an issue that has been confronted in medicine where an important distinction is drawn between research—the discovery of new knowledge—and audit, assuring the quality of a medical service. Research must always be based on explicit consent. Consent can be assumed for audit of services by those providing the service, and treatment made conditional on this consent. Guidance from the General Medical Council states: ‘If it is not possible to provide safe care without disclosing information for audit, you should explain this to the patient and the options open to them.’⁶²

Given the power of surveillance systems such as Google, Amazon and Facebook—and the likely power in the future of similar systems in finance, health-care and employment—the need to understand the net-benefit of such systems is pressing. To be credible any such assessment should involve independent scrutiny. Given the complexity of the problem, a single regulatory view of the problem is likely to be sub-optimal.

VI. Conclusion

All these considerations point to the need to introduce a far greater degree of transparency into the way that data sets about populations are used to drive decision-making about individuals; the benefits of reducing monopoly control over the data sets that underpin these services and enforcing a plurality of access to underlying data; and the need to consider the extent to which certain data assets have characteristics akin to strategic public assets such as rail networks or power systems.

This does not imply that they should not be privately owned. But it does imply that rights or private ownership should be limited both at an institutional and an

⁶² General Medical Council *Confidentiality guidance: Disclosing information with consent*

individual level to ensure that collectively and individually we are able to understand the risks and benefits incurred by sharing our information.

This can be addressed by, for example, rights of scientific access to data sets for specific purposes; or rights of community access to data sets for assurance regarding the impact of algorithmic decision making. Perhaps in time, it may be appropriate to start to insist upon rights of common carriage over data assets for service providers. It would be possible to split organisations into those that control population-wide data assets and those that provide services based on data in the same way that control of rail and telephone networks has been separated from provision of certain services. In addition to enabling greater transparency about the impact of algorithms, this approach would have the additional benefit of reducing opportunities for rent-seeking from control of data assets.

If the use of personal data stores becomes widespread, it could lead to a similar outcome. However, we should expect data controllers to employ strategies to limit this possibility. Regulatory action may help to counter those strategies.

There is much to work out in how such ideas could be translated into practice. However, the starting point is an acknowledgement of the fact that our current approach to privacy protection needs significant adaptation in the face of specific harms posed by intelligent machines.

References

- Albanes, O P Heinonen et al. 'Alpha-Tocopherol and beta-carotene supplements and lung cancer incidence in the alpha-tocopherol, beta-carotene cancer prevention study: effects of base-line characteristics and study compliance' (1996) *J Natl Cancer Inst.* 88(21):1560–70.
- Aristotle *Politics*.
- Susan Barnes, 'A privacy paradox: Social networking in the United States' (2006) *First Monday*, 11(9).
- Jamie Bartlett, *The Data Dialogue* (Demos 2012).
- Omri Ben-Shahar and Carl Schneider, *More Than You Wanted to Know: The Failure of Mandated Disclosure* (Princeton University Press 2014).
- Kennet Calman, 'Communication of risk: choice, consent, and trust' (2002) *The Lancet*, Volume 360, Issue 9327, 166—168.
- Daniel Cameron, Sarah Pope and Michael Clemence 'Dialogue on Data' (2014) Ipsos MORI Social Research Institute.
- Fred H Cate, 'Big data consent and the future of data protection' in Cassidy R. Sugimoto, Hamid R. Ekbia, Michael Mattioli (eds), *Big Data Is Not a Monolith* (MIT press 2016).
- Wen-Bin Chiou, Chin-Sheng Wan, Wen-Hsiung Wu & King-Teh Lee, 'A randomized experiment to examine unintended consequences of dietary supplement use among daily smokers: taking supplements reduces self-regulation of smoking' (2011) *Addiction* 106(12), pp.2221–2228.

- Commission (EC), 'Special Eurobarometer 359: Attitudes on Data Protection and Electronic Identity in the European Union' (2011); Commission (EC) press release Antitrust: Commission fines Google €2.42 billion for abusing dominance as search engine by giving illegal advantage to own comparison shopping service 27 June 2017.
- Data & Marketing Association, 'Data privacy: What the consumer really thinks' (2015).
- Deloitte, 'Data Nation 2012: our lives in data' (2012) available at: <https://www2.deloitte.com/content/dam/Deloitte/uk/Documents/deloitte-analytics/data-nation-2012-our-lives-in-data.pdf>.
- 'Data nation 2014: Putting customers first' (2014) available at: <https://www2.deloitte.com/content/dam/Deloitte/uk/Documents/deloitte-analytics/deloitte-uk-data-nation-2014.pdf>.
- Department of Health, Education and Welfare (US), Report of the Secretary's Advisory Committee on Automated Personal Data Systems, Records, Computer, and the Rights of Citizens (1973).
- S Dritsas et al. 'Protecting privacy and anonymity in pervasive computing: trends and perspectives' (2006) *Telematics and Informatics* 23 196–210;
- Charles Duhigg, 'How companies learn your secrets' *New York Times* (Feb 16 2012) <http://www.nytimes.com/2012/02/19/magazine/shopping-habits.html>.
- Facebook, 'Response to the Federal Trade Commission preliminary FTC staff report 'protecting consumer privacy in an era of rapid change: a proposed framework for Businesses and Policymakers' (2011) available at: https://www.ftc.gov/sites/default/files/documents/public_comments/preliminary-ftc-staff-report-protecting-consumer-privacy-era-rapid-change-proposed-framework/00413-58069.pdf [Accessed 2 Feb. 2017].
- Richard Gomer, M C Schraefel and Enrico Gerding, 'Consenting Agents: Semi-Autonomous Interactions for Ubiquitous Consent' (2014) *UbiComp* <http://dx.doi.org/10.1145/2638728.2641682>.
- P.C. Gotzsche and K. Jorgensen, 'Screening for breast cancer with mammography', *Cochrane Database of Systematic Reviews* 2013, No 6. Art No: CD001877. DOI: 10.1002/14651858.CD001877.
- Dara Hallinan and Michael Friedewald, 'Public Perception of the Data Environment and Information Transactions: A Selected-Survey Analysis of the European Public's Views on the Data Environment and Data Transactions' (2012) *Communications & Strategies*, No. 88, 4th Quarter 2012, pp. 61–78.
- JE Hupcey, J Penrod, JM Morse and C Mitcham, 'An exploration and advancement of the concept of trust' (2001) *Journal of Advanced Nursing*, 36: 282–293. doi:10.1046/j.1365-2648.2001.01970.x.
- JM Jakicic JM, KK Davis et al 'Effect of Wearable Technology Combined With a Lifestyle Intervention on Long-term Weight Loss The IDEA Randomized Clinical Trial', (2016). *JAMA* (11):1161–1171. doi:10.1001/jama.2016.12858.
- Dimitra Kamarinou, Christopher Millard and Jatinder Singh, Machine Learning with Personal Data, in: Ronald Leenes, Rosamunde Van Brakel, Serge Gutwirth, Paul De Hert (eds), *Computers, Privacy and Data Protection 10: the Age of Intelligent Machines* (Oxford, Hart, 2017).
- David Lazer, 'The rise of the social algorithm' (2015) *Science* Vol. 348, Issue 6239, pp. 1090–1091 DOI: 10.1126/science.aab1422.
- S Leigh, S Flatt, 'App-based psychological interventions: friend or foe?' (2015) *Evidence-Based Mental Health* 18:97–99.

- E Luger and T Rodden, 'Terms of Agreement: Rethinking Consent for Pervasive Computing' (2013) *Interacting with Computers*, 25(3).
- Mary Madden and Lee Rainie, 'Americans' Attitudes About Privacy, Security and Surveillance' (2015) Pew Research Center.
- John Stuart Mill *On Liberty* (1869).
- OECD Recommendation of the council concerning guidelines governing the protection of privacy and transborder flows of personal data (1980).
- Eli Pariser, *The Filter Bubble: What the Internet Is Hiding From You* (Viking 2012).
- Frank Pasquale, *The Black Box Society: The Secret Algorithms that Control Money and Information*, (Harvard University Press, 2015).
- Pew Research Center, 'What Internet Users Know About Technology and the Web' (2014).
- W. Prosser, 'Privacy' (1960) *California Law Review* 48: 383–423.
- REGULATION (EU) 2016/679 OF THE EUROPEAN PARLIAMENT AND OF THE COUNCIL of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC [2016] OL J 119/12L (General Data Protection Regulation).
- Lee Rainie and M Duggan, 'Privacy and Information Sharing' (2015) Pew Research Center. Available at: <http://www.pewinternet.org/2016/01/14/2016/Privacy-and-Information-Sharing/>.
- Hannah L Semigran, Jeffrey A Linder, Courtney Gidengil and Ateev Mehrotra, 'Evaluation of symptom checkers for self diagnosis and triage: audit study' (2015) *BMJ* 351:h34800.
- Samuel D. Warren and Louis D. Brandeis, 'The Right to Privacy' (1890) *Harvard Law Review*, Vol. 4, No. 5, pp. 193–220.
- ScienceWise, 'Big Data Public views on the collection, sharing and use of personal data by government and companies' (2014).
- RA Spinellow, 'Property rights in genetic information' (2004) *Ethics Inf Technol.* 6(1):29–42.
- Roger Taylor and Tim Kelsey, *Transparency and the Open Society* (Policy Press 2016).
- Joseph Turow, Michael Hennessy and Nora A. Draper, 'The Tradeoff Fallacy: How Marketers are Misrepresenting American Consumers and Opening Them Up to Exploitation' University of Pennsylvania (2015).
- US Congress Subcommittee on Commerce, Trade and Consumer Protection of the Committee on Energy and Commerce, 'Opinion Surveys: What consumers have to say about information privacy' (2001).
- Sandra Wachter, Brent Mittelstadt and Luciano Floridi, 'Why a Right to Explanation of Automated Decision-Making Does Not Exist in the General Data Protection Regulation' (2016). *International Data Privacy Law*, Forthcoming. Available at SSRN: <https://ssrn.com/abstract=2903469>.
- Wellcome Trust, 'Summary Report of Qualitative Research into Public Attitudes to Personal Data and Linking Personal Data' (2013).
- The White House (Executive Office of the President of the United States), *Big data and differential pricing* (2015).
- JA Wolf, JF Moreau et al. 'Diagnostic Inaccuracy of Smartphone Applications for Melanoma Detection' (2013) *JAMA Dermatol.* 149(4):422–426. doi:10.1001/jamadermatol.2013.2382.
- Shoshana Zuboff, 'Big other: surveillance capitalism and the prospects of an information civilization', (2015) *Journal of Information Technology* Vol 30, 75–89.

4

Machine Learning with Personal Data[†]

DIMITRA KAMARINOU*, CHRISTOPHER MILLARD**
AND JATINDER SINGH***

Abstract. This chapter provides an analysis of the impact of using machine learning to conduct profiling of individuals in the context of the recently adopted EU General Data Protection Regulation.

The purpose of this chapter is to explore the application of relevant data protection rights and obligations to machine learning, including implications for the development and deployment of machine learning systems and the ways in which personal data are collected and used. In particular, we consider what compliance with the first data protection principle of lawful, fair, and transparent processing means in the context of using machine learning for profiling purposes. We ask whether automated processing utilising machine learning, including for profiling purposes, might in fact offer benefits and not merely present challenges in relation to fair and lawful processing.

Keywords: Machine learning—personal data—lawfulness—fairness—transparency

I. Introduction

The quest for intelligent machines emerged as a research field soon after World War II.¹ By 1950, Alan Turing had proposed what became known as the ‘Turing

[†] This paper has been produced by members of the Microsoft Cloud Computing Research Centre, a collaboration between the Cloud Legal Project, Centre for Commercial Law Studies, Queen Mary University of London and the Computer Laboratory, University of Cambridge. The authors are grateful to members of the MCCRC team for helpful comments and to Microsoft for the generous financial support that has made this project possible. Responsibility for views expressed, however, remains with the authors.

* Researcher, Cloud Legal Project, Centre for Commercial Law Studies, Queen Mary University of London.

** Professor of Privacy and Information Law, Centre for Commercial Law Studies, Queen Mary University of London.

*** Senior Research Associate, Computer Laboratory, University of Cambridge.

¹ John McCarthy, ‘What is Artificial Intelligence’ (2007) Stanford University <http://www-formal.stanford.edu/jmc/whatisai/node1.html> accessed 12 June 2016.

Test' whereby a machine would be deemed to exhibit intelligence if it could engage in a text conversation that fooled a human into thinking the machine was also a human.² John McCarthy coined the term 'artificial intelligence' in 1955 and later defined it as

'the science and engineering of making intelligent machines, especially intelligent computer programs.'³

In other words, 'artificial intelligence (AI) is usually defined as the science of making computers do things that require intelligence when done by humans'.⁴

Research in machine learning, as a sub-set of artificial intelligence (AI), has been very important in the evolution of AI, as machine learning programs 'automatically improve with experience'⁵ and have 'the ability to learn without being explicitly programmed'.⁶

The widespread, and low cost, availability of cloud computing, which enables much faster, cheaper, and more scalable processing of very large amounts of data, means that machine learning can now take advantage of vast sets of data and the effectively unlimited resources of the cloud. Major cloud computing players like Amazon,⁷ IBM,⁸ Google,⁹ and Microsoft¹⁰ now provide cloud-supported machine learning services and tools, with a significant focus on predictive analytics. Moreover, cloud computing has allowed researchers and businesses to collaborate in machine learning processes as well as to enlist the help of thousands of other people in labelling (describing the characteristics of) data in an effort to facilitate (certain types of) learning.¹¹ Meanwhile, Amazon Mechanical Turk provides a very large-scale, cloud-based, crowdsourced market for what Amazon's Jeff Bezos has called 'artificial artificial intelligence' in which human 'Workers' (aka 'Turkers') bid to undertake 'Human Intelligence Tasks' to feed into learning processes.¹²

Practical applications of machine learning include image and speech recognition, natural language processing (NLP) that can be used in translation or in

² Alan Turing, 'Computing Machinery and Intelligence' (1950) 59 *Mind* 433–460 doi: 10.1093/mind/LIX.236.433 accessed 20 October 2016.

³ McCarthy, 'What is Artificial Intelligence'.

⁴ Jack Copeland, 'What is Artificial Intelligence?' (*AlanTuring.net*, May 2000) http://www.alanturing.net/turing_archive/pages/reference%20articles/what%20is%20ai.html accessed 01 February 2016.

⁵ Tom M Mitchell, *Machine Learning* (New York, 1st edn, McGraw-Hill Inc., 1997) XV.

⁶ Arthur Samuel (1959) quoted in Andres Munoz, 'Machine Learning and Optimization', https://www.cims.nyu.edu/~munoz/files/ml_optimization.pdf accessed 15 June 2016.

⁷ 'Amazon Machine Learning' <https://aws.amazon.com/machine-learning/> accessed 15 June 2016.

⁸ 'IBM Watson Developer Cloud' <http://www.ibm.com/smarterplanet/us/en/ibmwatson/watson-cloud.html> accessed 15 June 2016.

⁹ 'Google Cloud Prediction API Documentation' <https://cloud.google.com/prediction/docs/> accessed 15 June 2016.

¹⁰ Microsoft Azure, 'Machine Learning' <https://azure.microsoft.com/en-gb/services/machine-learning/> accessed 15 June 2016.

¹¹ Catherine Wah, 'Crowdsourcing and its applications in computer vision' (*UC San Diego*, 26 May 2011) http://vision.ucsd.edu/~cwah/files/re_cwah.pdf accessed 18 August 2016.

¹² 'Artificial artificial intelligence' (*The Economist Technology Quarterly* Q2, 2006) <http://www.economist.com/node/7001738> accessed 15 June 2016; See also 'Amazon Mechanical Turk' <https://www.mturk.com/mturk/welcome> accessed 15 June 2016.

extracting diagnostic information from free-form physician notes,¹³ predictive analytics (a branch of data mining),¹⁴ and deep learning which ‘let[s] computers “see” and distinguish objects and texts in images and videos’.¹⁵

One of the most widely publicised practical applications of machine learning is in the development of autonomous vehicles and, more specifically, driverless cars with a number of car manufacturing companies but also technology companies¹⁶ developing vehicles designed to operate autonomously on public roads. To limit the potential chilling factor of existing sector regulation, several EU governments have proposed updating the 1968 Vienna Convention on Road Traffic which specifies that ‘every moving vehicle or combination of vehicles shall have a driver’¹⁷ and ‘every driver shall at all times be able to control his vehicle’.¹⁸ As of 23 March 2016, automated driving technologies which influence the way a vehicle is driven are allowed in traffic provided they conform with the UN vehicle regulations.¹⁹ Part of the justification provided by the governments of Austria, Belgium, France, Germany and Italy was that not everyone is a good driver and that the main cause of traffic accidents is human error.²⁰

Moreover, human decision making is often influenced by behaviours such as stereotyping and prejudice (both conscious and unconscious), and even by metabolism. For example, a study of judges’ behaviour at a parole board in Israel revealed that it was much more likely for a parole application to be granted in the

¹³ Laura Hamilton, ‘Six Novel Machine Learning Applications’ (*Forbes*, 6 January 2014) <http://www.forbes.com/sites/85broads/2014/01/06/six-novel-machine-learning-applications/#43331b4967bf> accessed 19 January 2016.

¹⁴ ‘Data mining is the process of analysing data from different perspectives and summarising it into useful new information. (...) Technically, data mining is the process of finding correlations or patterns among dozens of fields in large relational databases. It is commonly used in a wide range of profiling practices, such as marketing, surveillance, fraud detection and scientific discovery’ European Data Protection Supervisor, <https://secure.edps.europa.eu/EDPSWEB/edps/EDPS/Dataprotection/Glossary/pid/74> accessed 01 July 2016.

¹⁵ Bernard Marr, ‘A Short History of Machine Learning—Every Manager Should Read’ (*Forbes*, 19 February 2016) <http://www.forbes.com/sites/bernardmarr/2016/02/19/a-short-history-of-machine-learning-every-manager-should-read/#232defd0323f> accessed 15 June 2016.

¹⁶ Including Tesla, Google, Audi, Mercedes, Rolls Royce, Microsoft and Volvo; See, for example, Google <https://www.google.com/selfdrivingcar/> accessed 15 June 2016; Zachary Hamed, ‘12 Stocks To Buy If You Believe In Driverless Cars’ (*Forbes*, 21 January 2015) <http://www.forbes.com/sites/zacharyhamed/2015/01/21/driverless-stocks/3/#32cc8e27e853> accessed 15 June 2016; Victor Luckerson, ‘Microsoft Is Developing Driverless Car Technology With Volvo’ (*Time*, 20 November 2015) <http://time.com/4122084/microsoft-diverless-car-volvo/> accessed 15 June 2016.

¹⁷ Article 8(1) UN Vienna Convention on Road Traffic (Vienna, 8 November 1968).

¹⁸ Article 8(5) Vienna Convention on Road Traffic.

¹⁹ A new paragraph, 5bis, will be inserted into Article 8 of the Vienna Convention. ‘UNECE paves the way for automated driving by updating UN international convention’ (UNECE Press Releases, 23 March 2016) <https://www.unece.org/info/media/presscurrent-press-h/transport/2016/unece-paves-the-way-for-automated-driving-by-updating-un-international-convention/doc.html> accessed 11 July 2017.

²⁰ United Nations Economic and Social Council, Economic Commission for Europe, Working Party on Road Traffic Safety, ‘Report of the sixty-eighth session of the Working Party on Road Traffic Safety’ (Geneva, 24–26 March 2014) 9, 11. However, automated driving systems that are not in conformity with the UN vehicle regulations will be allowed if they can be overridden or switched off by the driver, UN Working Party on Road Traffic Safety, 9.

early morning or after the judges had had a break for lunch than in the middle of the day, when the judges were hungry.²¹ Another study, in a public school in Florida, revealed that Black and Hispanic students were nearly half as likely as white students to be recognised by parents and teachers as gifted, but when the school introduced a universal screening test, the share of Hispanic students identified as such tripled. The researchers found that—potentially for a variety of reasons—‘teachers and parents were less likely to refer high-ability blacks and Hispanics, as well as children learning English as a second language, for I.Q. testing. The universal test levelled the playing field.’²²

As a result of their perceptions of our abilities, our personal interests, our reliability, and so on, other people—consciously or subconsciously, and with or without objective evidence—may place us in categories of personal characteristics that are, in effect, human ‘profiles’. People may make particular decisions or take particular actions based on the characteristics of the profile they perceive. ‘Evidence’ may be inaccurate, incomplete, or even absent, derived only from stereotyping and prejudice, but humans continue to profile each other every day as a ‘way to deal with the growing complexities of life’.²³ In the context of online activities and other data-intensive environments such as the Internet of Things,²⁴ profiling is increasingly carried out by machines, with decreasing amounts of human involvement. Machine learning can be used for mining available data to ‘discover valuable knowledge from large commercial databases containing equipment maintenance records, loan applications, financial transactions, medical records, and the like’²⁵ and make predictions based on such data.

According to Ralf Herbrich of Amazon, ‘machine learning is the science of algorithms that detect patterns in data in order to make accurate predictions for future data.’²⁶ On that basis, it seems appropriate to use machine learning algorithms for profiling purposes, as profiles are ‘patterns resulting of a probabilistic processing of data.’²⁷

²¹ Proceedings of the National Academy of Sciences paper cited in ‘I think it’s time we broke for lunch ...’ (*The Economist*, 14 April 2011) <http://www.economist.com/node/18557594> accessed 16 June 2016.

²² Susan Dynarski, ‘Why Talented Black and Hispanic Students Can Go Undiscovered’ (*The New York Times*, 8 April 2016) http://www.nytimes.com/2016/04/10/upshot/why-talented-black-and-hispanic-students-can-go-undiscovered.html?_r=0 accessed 21 June 2016.

²³ Mireille Hildebrandt, ‘Defining Profiling: A New Type of Knowledge?’ in Mireille Hildebrandt and Serge Gutwirth (eds), *Profiling the European Citizen* (Netherlands, Springer, 2008), 24.

²⁴ For an overview of the legal and security considerations arising at the intersection of the Internet of Things and cloud computing, see the following papers; W. Kuan Hon, Christopher Millard and Jatinder Singh, ‘Twenty Legal Considerations for Clouds of Things’ (*Queen Mary School of Law Legal Studies Research Paper* No. 216/2016, January 2016) doi: 10.2139/ssrn.2716966 accessed 19 August 2016 and Jatinder Singh et al, ‘Twenty security considerations for cloud-supported Internet of Things’ (*IEEE Internet of Things Journal*, 23 July 2015) doi: 10.1109/JIOT.2015.2460333 accessed 19 August 2016.

²⁵ Mitchell, *Machine Learning*, 1.

²⁶ ‘Session with Ralf Herbrich’ (Director of Machine Learning and Managing Director of Amazon Development, Germany) (*Quora*, 5 March 2016) <https://www.quora.com/profile/Ralf-Herbrich-session/106/> accessed 16 March 2016.

²⁷ Serge Gutwirth and Mireille Hildebrandt, ‘Some caveats on profiling’ in Serge Gutwirth et al. (eds) *Data Protection in a Profiled World* (Netherlands, Springer, 2010), 32.

In this chapter, we look at the concepts of ‘profiling’ and ‘automated decision-making’ as defined in the EU General Data Protection Regulation (GDPR)²⁸ and consider the impact of using machine learning techniques to conduct profiling of individuals. Even though the terms ‘automated decision-making’ and ‘profiling’ are used together, they are separate to one another. ‘Profiling’ is a sub-category of automated processing which involves the creation of descriptive profiles relating to individuals or the categorization of individuals in pre-determined profiles and the application of decisions based on those profiles whereas ‘automated decision-making’ refers to decisions based on automated processing which may or may not involve profiling.

In this chapter, we look at the right that individual data subjects have not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning them or significantly affects them. We delve into more detail on what the process of ‘profiling’ entails and we focus on machine learning as the means of carrying out profiling due to its unique technological characteristics described above. In addition, we also look at data subjects’ right to be informed about the existence of automated decision-making, including profiling, and their right to receive meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing.

Further, the purpose of this chapter is to explore how the first data protection principle (requiring that processing be lawful, fair, and transparent) may or may not be complied with when machine learning is used to carry out profiling. We argue that using machine learning for profiling may complicate data controllers’ compliance with their obligations under the GDPR but at the same time it may lead to fairer decisions for data subjects.

II. Lawfulness

A. Profiling as a Type of Processing

One of the fundamental principles of EU data protection law explored already in relation to the Data Protection Directive²⁹ is that personal data shall be processed

²⁸ Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) (‘GDPR’), OJ L119/1, 4 May 2016.

²⁹ Directive 95/46/EC of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (Data Protection Directive), OJ L181/31, 23 November 1995; For a discussion on automated individual decisions under the Data Protection Directive, see Lee Bygrave, ‘Automated Profiling, Minding the Machine: Article 15 of the EC Data Protection Directive and Automated Profiling’ (2001) 17 (1) *Computer Law & Security Review*, 17, 24.

lawfully, fairly and in a transparent manner.³⁰ In this section, we look at what ‘lawfulness’ means in the context of using machine learning technologies either to carry out automated processing, including profiling, or to make automated decisions based on such processing. The underlying principle protected in the Data Protection Directive, that ‘fully automated assessments of a person’s character should not form the sole basis of decisions that significantly impinge upon the person’s interests’,³¹ seems also to be reflected in Article 22 of the GDPR. This gives a data subject the right not to be subject to decision-making based solely on automated processing, including profiling, which produces legal effects concerning the data subject or similarly affects him / her.³²

As processing refers to any operation performed on personal data, whether or not automated, ‘profiling’ is a sub-category of automated processing which, according to the GDPR, consists of,

‘the use of personal data to evaluate certain personal aspects relating to a natural person, in particular to analyse or predict aspects concerning that natural person’s performance at work, economic situation, health, personal preferences, interests, reliability, behaviour, location or movements.’³³

On the face of it, this definition of ‘profiling’ covers only the stage at which an individual’s ‘personal aspects’ are ‘evaluated’. However, to understand the process of ‘profiling’ it may be more appropriate to break it down into a number of elements, especially when machine learning models are involved. In 2013, the Article 29 Working Party suggested that Article 22 GDPR on ‘automated individual decision-making, including profiling’ (at the time, Article 20 of the proposed GDPR) should not only cover a decision that produces legal effects or significantly affects data subjects but also the ‘collection of data for the purpose of profiling and the creation of profiles as such’.³⁴ This is unsurprising given that decision-making is only the final part of the profiling process and for a decision to be lawful and fair, it has to be based on a lawful and fair process.

i. The Elements of the Profiling Process

It may be helpful to disaggregate the profiling process into three elements; data collection, model development (through use of machine learning algorithms), and decision making.³⁵ Data collection will not necessarily precede algorithmic

³⁰ Article 5(1)(a) GDPR.

³¹ Bygrave, ‘Automated Profiling’ 21.

³² Article 22(1) GDPR.

³³ Article 4(4) GDPR.

³⁴ Article 29 Working Party (WP29), ‘Advice paper on essential elements of a definition and a provision on profiling within the EU General Data Protection Regulation’ 13 May 2013, 3 http://ec.europa.eu/justice/data-protection/article-29/documentation/other-document/files/2013/20130513_advice-paper-on-profiling_en.pdf accessed 3 June 2016.

³⁵ A similar disaggregation of the profiling process in the context of group profiling has been suggested by Wim Schreurs, Mireille Hildebrandt et al., ‘Cogitas, Ergo Sum. The Role of Data Protection

processes, but it makes sense to consider data collection first because machine learning algorithms learn models from data.

The collection of personal data (whether directly from the data subject or not) should comply with the data protection principles and the requirement that there be a lawful ground for processing. Personal data should only be collected for specified, explicit, and legitimate purposes and should not be processed subsequently in a manner that is incompatible with those purposes. Important factors in relation to compatibility are likely to include the nature of the data, the way in which they are processed, and the potential impact of such processing on data subjects.³⁶ According to Article 21(1) of the GDPR, data subjects have the right to object at any time to the processing of their personal data which is based on Article 6(1)(e) and (f),³⁷ including profiling based on those provisions.

A machine learning algorithm may develop a profile from data that has been provided either by the data controller or by a third party or by both. Cloud will often be useful³⁸ given that the process may require significant resources in terms of computational power and/or storage. It may also be that profiles are constructed in real time. Depending on the nature of the application, this might take place locally on the data controller's machines while at the same time a copy of the 'real time data' is sent to the cloud to continue the dynamic training of the algorithm.

Individuals' personal data are not only processed to create descriptive profiles about them but also to 'check [their profiles] against predefined patterns of normal behaviour'³⁹ and determine whether they fit or deviate from them.⁴⁰ This stage of profile construction, which is covered by the definition of 'profiling' discussed above, will be subject to the GDPR rules governing the processing of personal data including the legal grounds for processing and the data protection principles.⁴¹

The final text of Article 22 of the GDPR refers to a 'data subject' and not a 'natural person' (as was the original wording of the Commission's proposal in 2012).⁴² This could be interpreted to mean that the protection against solely automated

Law and Non-discrimination Law in Group Profiling in the Private Sector' in Mireille Hildebrandt and Serge Gutwirth (eds) *Profiling the European Citizen* (Netherlands, Springer, 2008), 241–256.

³⁶ WP29, 'Opinion 03/2013 on purpose limitation,' 00569/13/EN, WP 203, 2 April 2013, 69 http://ec.europa.eu/justice/data-protection/article-29/documentation/opinion-recommendation/files/2013/wp203_en.pdf accessed 2 July 2016.

³⁷ Article 6(1)(e) GDPR and Article 6(1)(f) GDPR.

³⁸ Alex Woodie, 'Five Reasons Machine Learning is Moving to the Cloud' '4.ML Workloads are Highly Variable' (*datanami*, 29 April 2015) <https://www.datanami.com/2015/04/29/5-reasons-machine-learning-is-moving-to-the-cloud/> accessed 8 August 2016.

³⁹ Fanny Coudert, 'When video cameras watch and screen: Privacy implications of pattern recognition technologies' (2010) 26 *Computer Law and Security Review* 377, 377.

⁴⁰ Coudert, 'When video cameras watch and screen' 377.

⁴¹ Recital 72 GDPR.

⁴² European Commission, 'Proposal for a Regulation of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (General Data Protection Regulation)' Article 20, COM(2012) 11 final, Brussels, 25.1.2012.

decision-making might not apply if the data processed are anonymised.⁴³ If anonymised data, however, on their own or combined with other data, allow an individual to be 'singled out' (albeit anonymously),⁴⁴ or for information to be inferred about that individual and be used for taking decisions that have significant effects on him/her (particularly using secret algorithms),⁴⁵ that further use might be incompatible with the purpose for which the data were originally collected and data controllers may breach the 'purpose limitation' principle.⁴⁶ For example, personal data collected through tracking technologies (such as cookies) may then be aggregated, anonymised and combined with other data (personal or not) in 'advanced data-mining techniques in order to discover associations and connections between demographic characteristics and preferences for products, or to predict consumers' reactions to changes in price or special deals.'⁴⁷ Nevertheless, if profiling does not involve the processing of data relating to identifiable individuals, the protection against decisions based on automated profiling may not apply, even if such profiling may impact upon a person's behaviour or autonomy.⁴⁸

As Article 22 of the GDPR seems only to apply to profiling of individual data subjects and not groups, the question arises of whether data subjects are protected against decisions that have significant effects on them but are based on group profiling. Group profiling might be based on profiling of already existing groups (for example, all the students in a specific course), but it may also involve the categorisation of people into groups based on shared characteristics without them realising that they are members of the same group, or indeed in cases where people are not actually members of an 'assumed' group. Alessandro Montelero compares the members of an assumed group to the 'consumers' protected under consumer law and explains that 'data subjects [are] not aware of the identity of other members of the group / have no relationship with them and have limited perception of

⁴³ Andrej Savin, 'Profiling and Automated Decision Making in the Present and New EU Data Protection Frameworks' (paper presented at 7th International Conference Computers, Privacy & Data Protection, Brussels, Belgium, 2014), 9.

⁴⁴ WP29, 'Opinion 05/2014 on Anonymisation Techniques' WP216, 0829/14/EN, 10 April 2014, m 3, http://ec.europa.eu/justice/data-protection/article-29/documentation/opinion-recommendation/files/2014/wp216_en.pdf accessed 10 August 2016.

⁴⁵ WP29, 'Opinion 05/2014 on Anonymisation Techniques' 11; WP29, 'Opinion 03/2013 on purpose limitation' 69.

⁴⁶ WP29, 'Opinion 03/2013 on purpose limitation', 69.

⁴⁷ Alexander Furnas, 'Everything You Wanted to Know About Data Mining but Were Afraid to Ask' (*The Atlantic*, 3 April 2012), <http://www.theatlantic.com/technology/archive/2012/04/everything-you-wanted-to-know-about-data-mining-but-were-afraid-to-ask/255388/> accessed 21 June 2016 in Akriva A. Miller, 'What do we worry about when we worry about price discrimination? The Law and Ethics of using personal information for pricing' (2014) 19 *Journal of Technology Law & Policy* 41, 49 http://www.journaloftechlaw.org/uploads/7/5/6/8/75689741/6-a._miller.pdf accessed 5 March 2017.

⁴⁸ Schreurs, Hildebrandt et al, 'Cogitas, Ergo Sum' 241–256; Gutwirth and Hildebrandt, 'Some caveats on profiling' 37.

their collective issues'.⁴⁹ An example might be membership of an 'assumed' group of individuals deemed to have a specific credit risk profile based merely on their residence within a particular postcode area. In those cases, it could be argued that the protection against such decisions under Article 22 of the GDPR would be applicable, as the provision covers the decision-making step rather than the profiling process as such.

The final element of the profiling process is making determinations and conclusions about data subjects based on such profiles. In other words, profile application refers to applying the profile that a data controller has constructed on a person through a decision, which includes a measure that produces legal effects or significantly affects them.⁵⁰ It could be argued that whether that decision is ultimately fair for the data subject is a question for anti-discrimination laws and not primarily for data protection law. However, Recital 71 of the GDPR explicitly mentions that in order to ensure fairness and transparency of processing, the data controller has an obligation to take appropriate technical, organisational and security measures to prevent a decision having discriminatory effects on natural persons on the basis of racial or ethnic origin, political opinion, religion or beliefs, trade union membership, genetic or health status or sexual orientation or to prevent any measures that have such an effect. The principle of 'fairness' in the context of machine learning in automated decision-making is discussed further in part III of this chapter.

B. The Decision and its Effects

Does 'automated individual decision-making' only cover situations where a machine makes decisions without any involvement by human actors?⁵¹ For example, if a company wanted to decide which of its employees should have access to specific internal operations or resources, it could use machine learning to make predictions about different employees' eligibility instead of having humans making such a decision.⁵² While this looks like automated decision making, this does

⁴⁹ Alessandro Montelero, 'Personal data for decisional purposes in the age of analytics: From an individual to a collective dimension of Data Protection' (2016) 32 (2) *Computer Law & Security Review* 238, 251; For a discussion on group profiling also see Schreurs, Hildebrandt et al, 'Cogitas, Ergo Sum' 241–270.

⁵⁰ According to the European Commission, the concept of 'measure' could include, for example, 'the targeted marketing of specific medical products against cancer based on the search made by an individual on the internet', EU Commission, 'The EU data protection Regulation: Promoting technological innovation and safeguarding citizens' rights' (SPEECH 14/175, 4 March 2014) http://europa.eu/rapid/press-release_SPEECH-14-175_en.htm?locale=en accessed 8 August 2016.

⁵¹ For a discussion of how machine learning may be incorporated into wider workflows and processes, see Jatinder Singh and Ian Walden, 'Responsibility and Machine Learning: Part of a Process' (SSRN, 28 October 2016) 13 onwards https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2860048 accessed 12 March 2017.

⁵² See the example of Amazon in Laura Hamilton, 'Six Novel Machine Learning Applications'.

not necessarily mean that there would not be any human involvement in any stage of the process. In fact, human actors would probably, in building the machine, provide as input the factors / criteria necessary for an employee to satisfy the eligibility condition and human actors may also be involved in assessing the machine's output before making a final decision. As some human intervention is likely to occur at some point in the automated decision-making process it has been argued that the scope of the protection is broader than only covering wholly automated decision-making.⁵³ Arguably, human intervention would have to be actual and substantive, i.e. humans would have to exercise 'real influence on the outcome of a particular decision-making process',⁵⁴ in order to lead to the inapplicability of the protection provided in Article 15 of the Data Protection Directive (and in future Article 22 of the GDPR). So, for example, where a human decision depends completely on the belief that the machine and its code are always accurate, reliable, and objective, and where humans do not critically assess the machine's outputs but they, for example, only tick a box on a form, this action is unlikely to amount to the exercise of 'real influence' over a particular decision.⁵⁵

However, Article 22 of the GDPR does not specify whether the decision against which data subjects are protected has to be the final decision or merely an interim or individual step taken during the automated processing. In the context of the Data Protection Directive it has been argued that a 'decision' has to be interpreted broadly and Recital 71 of the GDPR clearly states that 'decision' may include a 'measure'. One of the critical elements under the Data Protection Directive was that 'the decision to which a person may object must be based on a profile of that person',⁵⁶ but under the GDPR the decision or the measure may be based on any form of automated processing, even if no profile has been created, as long as it produces legal effects or similarly significantly affects data subjects.

In addition, the GDPR does not specify whether the 'real influence' exercised by the human decision-maker can take place at some point during the decision process or it should take place at the very end, the moment when the decision is made. For example, in a medical context, a diagnostics machine might conclude that there is a 90 per cent probability that a data subject has a particular type of tumour and that taking a specific drug or starting chemotherapy may be time sensitive. Even if one or more humans are involved in the design, training and testing of this system, if the machine is tasked with deciding a treatment plan without a human decision maker critically evaluating the diagnostic assessment, this decision will

⁵³ Bygrave, 'Automated Profiling' 20.

⁵⁴ Bygrave, 'Automated Profiling' 20.

⁵⁵ See Commission of the European Communities, 'Amended Proposal for a Council Directive on the protection of individuals with regard to the processing of personal data and on the free movement of such data' (COM(92) 422 final—SYN 287, 15 October 1992, 26; 'the result produced by the machine, using more and more sophisticated software, and even expert systems, has an apparently objective and incontrovertible character to which a human decision-maker may attach too much weight, thus abdicating his own responsibilities' <http://aei.pitt.edu/10375/1/10375.pdf> accessed 7 July 2016.

⁵⁶ Bygrave, 'Automated Profiling' 20.

be subject to Article 22, even if such a decision was merely an interim preparatory measure before a final decision on an operation, for example, was made.

Another important element of the decision is that it has to produce legal effects or similarly significantly affect the data subject. Such decisions include an ‘automatic refusal for an online credit application or e-recruitment practices without human intervention’.⁵⁷ The effects can be both material and / or immaterial, potentially affecting the data subject’s dignity or reputation. It has been argued that the requirement that ‘effects’ be ‘legal’ means that a decision must be binding or that the decision creates legal obligations for a data subject.⁵⁸

On the other hand, what constitutes a ‘significant’ effect might be less straightforward and might depend on what a ‘considerable number of other persons’ think is reasonably significant.⁵⁹ The Article 29 Working Party (WP29) has also suggested that what constitutes a ‘significant’ effect might be the result of a balancing exercise between the ‘possible and actual impacts of profiling technologies on the rights and freedoms of data subjects’⁶⁰ and the legitimate interests of the controllers.⁶¹ The advice from the WP29 seems to reflect the principles of necessity and proportionality, two principles that data controllers also have to follow when carrying out a data protection impact assessment to assess the risk of processing data subjects’ personal data for profiling purposes.⁶²

C. Data Protection Impact Assessments (DPIA)

According to Article 35(1) of the GDPR, where ‘a type of processing ... is likely to result in a high risk to the rights and freedoms of natural persons, the controller shall, prior to the processing, carry out an assessment of the impact of the envisaged processing operations on the protection of personal data.’ The Article provides that this will apply ‘in particular’ where the processing will be ‘using new technologies’. As discussed in the introduction to this chapter, machine learning is not a new technology as such. However, in undertaking a risk assessment, the controller must take into account ‘the nature, scope, context and purposes of the processing’ and it may be that the way in which a particular machine learning process is developed and deployed may trigger the requirement to carry out a DPIA, whether or not it constitutes a ‘new technology’. Moreover, a DPIA will always be required in the case of ‘a systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including

⁵⁷ Recital 71 GDPR.

⁵⁸ Bygrave, ‘Automated Profiling’ 19.

⁵⁹ Bygrave, ‘Automated Profiling’ 19.

⁶⁰ WP 29, 2013, ‘Advice paper on essential elements of a definition and a provision on profiling within the EU General Data Protection Regulation’ 5.

⁶¹ WP29, 2013, ‘Advice paper’ 5.

⁶² Article 35(7)(b) GDPR.

profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person.’⁶³ A DPIA must also be undertaken where sensitive (‘special category’) data are to be processed on a large scale, where data relating to criminal convictions and offences are to be processed, or in the case of ‘a systematic monitoring of a publicly accessible area on a large scale.’⁶⁴ It will thus be important to consider the specific facts of each machine learning scenario in order to determine whether a DPIA is required.

Under the GDPR, the DPIA must cover, among other things, the security measures aimed at ensuring the protection of personal data and the compliance with the Regulation.⁶⁵

Even though not explicitly mentioned in this provision, the ‘security measures’ mentioned here could require data controllers to implement the principles of data protection by design and by default both at the time of the determination of the means of processing (for example, when deciding to use machine learning algorithms to process personal data) and at the time of processing itself.⁶⁶ A recent report by the Council of Europe suggests that such technical solutions embedded with the principles of privacy by design should first be tested in a simulation environment to identify problems with biases in the data and mitigate potential negative outcomes before being used on a larger scale.⁶⁷ Moreover, aspects of a machine learning system may have been designed by a party other than the data controller, input data may be derived from a range of separate data providers, and machine learning processes may run in a cloud environment that may itself involve multiple service providers.⁶⁸ Therefore, the data controller may struggle to implement the appropriate technical and organisational measures required by the GDPR to comply with the data protection principles. Complying with the principle of data minimisation, even at the time of the processing itself, may be particularly problematic given that the effectiveness of many machine learning algorithms is dependent on the availability of large amounts of data.

Safeguards might include appropriate contractual commitments from the designers and service providers offering machine learning components and capabilities, and the implementation of practical measures to ensure that data subjects’ personal data, including any profiles created from the use of such data, are inaccessible to service providers except where strictly necessary for the provision of a

⁶³ Article 35(3)(a) GDPR.

⁶⁴ Article 35(3)(c) GDPR.

⁶⁵ Article 35(7)(d) GDPR.

⁶⁶ Article 25(1) GDPR.

⁶⁷ Council of Europe Consultative Committee of the convention for the protection of individuals with regard to automatic processing of personal data, ‘Guidelines on the protection of individuals with regard to the processing of personal data in a world of Big Data’ T-PD(2017)01, Strasbourg, 23 January 2017, 4 <https://rm.coe.int/CoERMPublicCommonSearchServices/DisplayDCTMContent?documentId=09000016806ebe7a> accessed 2 March 2017.

⁶⁸ For example a hospital might use the IBM Watson service in the cloud to mine its own patient data and/or health data from a third party provider for epidemiological purposes.

service. The data controller might also decide to set a high threshold of probability as a requirement for any automated decision that might have significant adverse effects on data subjects.

D. Derogations from the Rule

Some types of decisions based on automated decision-making, including profiling, are expressly permitted under the GDPR. This is the case if the decision:

- (a) is necessary for entering into, or performance of, a contract between the data subject and a data controller;
- (b) (...)
- (c) is based on the data subject's explicit consent.⁶⁹

However, in cases (a) and (c) above, the data controller 'shall implement suitable measures to safeguard the data subject's rights and freedoms and legitimate interests, at least the right to obtain human intervention on the part of the controller, to express his or her point of view and to contest the decision'.⁷⁰

An in-depth analysis of the different cases where decisions based on automated decision-making, including profiling, are allowed is outside the scope of this chapter. However, since in cases (a) and (c) above the data controller has an obligation to implement suitable safeguards for the data subjects' rights and freedoms, we will look at one issue that could arise in a machine learning context that might hinder or alter the implementation of such safeguards.

Under the GDPR, data subjects have a right to insist on human intervention on the part of the controller, and they have the right to express their point of view and to contest the decision. As the data controller must allow the data subjects to express their point of view prior to a decision being made (or a measure being taken), it follows that in a machine learning context the data controller should implement appropriate measures to prevent any machine learning driven-process from making a final decision before the data subject is consulted. This may be very difficult in situations where decisions are taken in response to data in real time. If data subjects want to contest the decision, it is unclear who they must appeal to for a hearing or a review. As discussed above, the GDPR does not specify whether the decision has to be made by a human or can also be made by a machine. Moreover, the GDPR does not specify that a data subject contesting the decision has to appeal to a human. It appears, however, from the underlying approach taken in Article 22 that there must be at least the possibility of human intervention in the decision-making process and that, if requested by the data subject, a human should be tasked with reviewing the decision. Having said that, in a machine learning context, it is not clear who this 'human' should be and whether

⁶⁹ Article 22(2) GDPR.

⁷⁰ Article 22(3) GDPR.

he / she will be able to review a process that may have been based on third party algorithms, pre-learned models or data sets including other individuals' personal data or on opaque machine learning models. Nor is it clear whether the human reviewer could be the same person who made the decision in the first place, still potentially subject to the same conscious or subconscious biases and prejudices in respect of the data subject.

Considering all the uncertainty involved in appeals by data subjects to a human to contest a decision that has significantly adversely affected them, might it perhaps be fairer for individuals to have a right to appeal to a machine instead? This may sound strange at first, as machines are designed by humans and may carry within them the values and subjectivity of their designers in a way that may make them as unsuitable as humans to review such decisions. However, machine learning algorithms have the potential to achieve a high level of objectivity and neutrality, whereby learning techniques can be made to disregard factors such as age, race, ethnicity, religion, nationality, sexual orientation, etc., if instructed to do so, more effectively than humans, as shown in part one of this chapter. This does not mean that indirect biases cannot find their way into the algorithmic decision-making process, as discrimination can also result from subtle correlations (e.g. we may infer a person's ethnicity from their name), but to suggest that there is a possibility that algorithms may be more effective than humans in disregarding such inferences, perhaps more so when embedded with data protection by design.⁷¹ Moreover, it might be appropriate for the machine-learned models through which decisions are formulated to be reviewed subsequently by other algorithms designed to facilitate auditing.⁷²

E. Potential Consequences of Non-Compliance

It is important to bear in mind that if data controllers infringe data subjects' rights under Article 22, they shall 'be subject to administrative fines up to 20,000,000 EUR, or in the case of an undertaking, up to 4 % of the total worldwide annual turnover of the preceding financial year, whichever is higher'.⁷³ In the face of potential penalties of this magnitude and considering the complexities of machine learning, data controllers may be reluctant to use the technology for automated decision making in certain situations. Moreover, data controllers may insist that contractual arrangements with providers in the machine learning supply chain contain very specific provisions regarding the design, training, testing, operation and outputs of the algorithms, and also the relevant technical and organisational security measures.

⁷¹ Council of Europe, 'Guidelines on the protection of individuals with regard to the processing of personal data in a world of Big Data' 4.

⁷² Singh and Walden, 'Responsibility and Machine Learning' 14, 19–20.

⁷³ Article 83 (5)(b) GDPR.

III. Fairness

Whether personal data will be processed in a fair way or not may depend on a number of factors. Machine learning processes may be made 'biased' so as to produce the results pursued by their designer.⁷⁴ Externally, the quantity and quality of data used to train the algorithm, including the reliability of their sources and labelling may have a significant impact on the construction of profiles by introducing a direct or indirect bias into the process.

A case of indirect bias might arise when machine learning processes use data that embed past prejudices, and thus lead to inaccurate and unreliable outputs. This might, for example, arise where data relate to a minority group that has been treated unfairly in the past in such a way that the group is underrepresented in specific contexts or overrepresented in others. As Kroll et al. observe, 'in a hiring application, if fewer women have been hired previously, data about female employees might be less reliable than data about male employees'.⁷⁵

In addition, bias may exist in the criteria or technical policy that the designer instructs the algorithm to follow when answering a specific question or reaching a specific goal. A direct bias in this case might be to direct the algorithm to develop a model that filters people by race, gender, or religion where there is no justification for doing so. Alternatively, an algorithm might take into account more subtle and seemingly irrelevant factors, such as assessing minority status by profiling postal codes or assessing gender by looking for 'specific magazine subscriptions'.⁷⁶

Asking the right questions may be a difficult task and designers may need help from domain experts to formulate questions and to assess the appropriateness of outputs from machine learning processes, particularly during engineering phases. Such assessments might then be fed back into the algorithm to retrain it and improve its performance. Setting the top level goal that the algorithm has to reach

⁷⁴ Kathleen Chaykowski, 'Facebook News Feed Change Prioritizes Posts From Friends Users Care About' (*Forbes*, 29 June 2016) <http://www.forbes.com/sites/kathleenchaykowski/2016/06/29/facebook-tweaks-news-feed-algorithm-to-prioritize-posts-from-friends-you-care-about/#1eaad1412598> accessed 5 July 2016; another example is building a deliberately bad classifier for distinguishing between pictures of wolves and huskies. The training involved showing all pictures of wolves in a snowy background and all pictures of huskies without snow. The classifier predicted 'wolf' in any picture with snow and 'husky' in any other picture regardless of whether it depicted a different animal, Marco Tulio Ribeiro, Sameer Singh, and Carlos Guestrin, 'Why Should I Trust You? Explaining the Predictions of Any Classifier' (paper presented at the KDD '16 Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining, New York, 3 August 2016).

⁷⁵ Joshua A Kroll et al, 'Accountable Algorithms' (2017) 165 *University of Pennsylvania Law Review* 633, 681 http://scholarship.law.upenn.edu/penn_law_review/vol165/iss3/3/ accessed 10 March 2017.

⁷⁶ Kroll et al., 'Accountable Algorithms' (2016) SSRN version 1, 33 https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2765268 accessed 20 October 2016.

is also very important. According to Demis Hassabis, co-founder of DeepMind Technologies,

‘We need to make sure the goals are correctly specified, and that there’s nothing ambiguous in there and that they’re stable over time. But in all our systems, the top level goal will still be specified by its designers. It might come up with its own ways to get to that goal, but it doesn’t create its own goal.’⁷⁷

In setting that goal, the algorithm will carry the values and culture of its designers. Hassabis comments that, as this is inevitable, ‘we have to think very carefully about values.’⁷⁸ Embedding into the algorithm fundamental values and ethics that stay stable over time (if that is possible!) could be more important than correctly specifying the algorithm’s goals, as the latter are subject to continuous change due to emerging societal needs and technological developments. Indeed, a recent paper by the UK Information Commissioner’s Office (ICO) on Big Data, artificial intelligence, machine learning and data protection suggests that ethics boards might be established to check and review the deployment and outputs of machine learning algorithms to ensure the continuous application of ethical principles.⁷⁹

Locating and understanding biases in the data or the algorithmic models may also be the key to differentiating between correlation and causation when using algorithms in data mining procedures. Data mining is ‘a procedure by which large databases are mined by means of algorithms for patterns of correlations between data’⁸⁰ and it is used ‘in a wide range of profiling practices, such as marketing, surveillance, fraud detection and scientific discovery’.⁸¹ The correlations identified by the algorithms point to some type of relation between different data but without necessarily providing an explanation as to what that relation is, nor whether there is a causal link between the data.⁸² So, for example, in the employment case above, based on the available data it may be predicted that a female candidate may be less likely to be suitable for a CEO position but the cause for this may be that fewer women than men have had the opportunity to reach that executive level.

Uncovering and understanding causal links between data may be very important in some contexts, such as when trying to establish liability, but may be less significant in other contexts, such as medicine, where mere correlations may justify precautionary measures and decisions, without waiting for causation to be

⁷⁷ Demis Hassabis interviewed by Clemency Burton-Hill, ‘The superhero of artificial intelligence: can this genius keep it in check?’ (*The Guardian*, 16 February 2016) http://www.theguardian.com/technology/2016/feb/16/demis-hassabis-artificial-intelligence-deepmind-alphago?CMP=tw_t_gu accessed 16 June 2016.

⁷⁸ Demis Hassabis interviewed by Clemency Burton-Hill.

⁷⁹ Information Commissioner’s Office (ICO), ‘Big data, artificial intelligence, machine learning and data protection’ (*ICO website*, 2017) 77, 88 <https://ico.org.uk/media/for-organisations/documents/2013559/big-data-ai-ml-and-data-protection.pdf> accessed 10 March 2017.

⁸⁰ Hildebrandt, ‘Defining Profiling: A New Type of Knowledge?’ 18.

⁸¹ EDPS website <https://secure.edps.europa.eu/EDPSWEB/edps/EDPS/Dataprotection/Glossary/pid/74> accessed 1 July 2016.

⁸² Hildebrandt, ‘Defining Profiling: A New Type of Knowledge?’ 18.

demonstrated.⁸³ Indeed, as Mireille Hildebrandt has noted, sometimes ‘profilers are not very interested in causes or reasons, their interest lies in a reliable prediction, to allow adequate decision making’.⁸⁴

Nevertheless, reliability will depend, among other factors, on the techniques used. Moreover, machine learning techniques often perform better through access to large amounts of data,⁸⁵ provided we do not sacrifice quality for quantity. In addition, as the algorithm is tasked with finding patterns within data, and specifically for profiling purposes to assess data subjects based on such profiles, providing the algorithm with more data about data subjects could lead to a clearer and more representative picture of them. However, this may collide with the data minimisation principle in EU data protection law, a strict interpretation of which is that ‘the data collected on the data subject should be strictly necessary for the specific purpose previously determined by the data controller’.⁸⁶ What is ‘strictly necessary’ will of course depend on the nature, scope and context of the specific processing purpose and it might be that processing a large amount of data is sometimes justified as strictly necessary to achieve the purpose. For our discussion, data controllers may have to decide, at the time of collection, which personal data they are going to process for profiling purposes. Then, they will also have to provide the algorithm with only the data that are strictly necessary for the specific profiling purpose, even if that leads to a narrower representation of the data subject and possibly a less fair decision for him/her. In the present context, however, complying with the data minimisation principle could prevent algorithms from uncovering dubious correlations between data about a data subject’s personal attributes or specific aspects of their behaviour, where such data were not necessarily relevant to the specific processing purposes. As the UK ICO points out, ‘finding the correlation does not retrospectively justify obtaining the data in the first place’.⁸⁷

In 2015, then FTC Commissioner Julie Brill urged companies to ‘do more to determine whether their own data analytics result in unfair, unethical, or discriminatory effects on consumers’,⁸⁸ without neglecting their obligation for transparent processing. In the EU, under the GDPR, data controllers will have to include such considerations and risk assessments regarding potential discriminatory effects in

⁸³ For example, the Zika virus was linked to microcephaly in babies before any causal link between the two had been established. See Donald McNeil Jr., ‘6 Reasons to Think the Zika Virus Causes Microcephaly’ (*The New York Times*, 3 May 2016) <http://www.nytimes.com/interactive/2016/04/01/health/02zika-microcephaly.html> accessed 5 July 2016.

⁸⁴ Hildebrandt, ‘Defining Profiling: A New Type of Knowledge?’ 18.

⁸⁵ Pedro Domingos, ‘A Few Useful Things to Know About Machine Learning’ (October 2012) 55 *Communications of the ACM* 78, 80, 84, doi:10.1145/2347736.2347755 accessed 6 September 2016.

⁸⁶ WP29, ‘Opinion 8/2014 on Recent Developments on the Internet of Things’ 14/EN, WP 223, 16 September 2014, 16 http://ec.europa.eu/justice/data-protection/article-29/documentation/opinion-recommendation/files/2014/wp223_en.pdf accessed 10 March 2017.

⁸⁷ ICO, ‘Big data, artificial intelligence, machine learning and data protection’ 41, 40.

⁸⁸ Quoted in Lauren Smith, ‘Algorithmic transparency: Examining from within and without’ (*IAPP Privacy Perspectives*, 28 January 2016) <https://iapp.org/news/a/algorithmic-transparency-examining-from-within-and-without/> accessed 17 March 2016.

their Data Protection Impact Assessments, as discussed above. In this context, we assume that ‘discriminatory’ effects refer to unfair discrimination, meaning ‘the unjust or prejudicial treatment of different categories of people’⁸⁹ as opposed to the neutral meaning of the word referring to ‘the recognition and understanding of the difference between one thing and another’.⁹⁰ As, by nature, machine learning algorithms ‘prioritize information in a way that emphasizes or brings attention to certain things at the expense of others’,⁹¹ it should be noted that there is a difference between ‘discrimination’ as prioritization or differentiation, and unfair discrimination which leads to prejudicial treatment on the basis of racial or ethnic origin, political opinion, religion or beliefs, trade union membership, genetic or health status or sexual orientation, which data controllers have an obligation to prevent according to Recital 71 of the GDPR.

IV. Transparency⁹²

It has been argued that ‘machine learning applies to problems for which encoding an explicit logic of decision-making functions very poorly’.⁹³ However, machine learning algorithms may be based on very different computational learning models. Some are more amenable to allowing humans to track the way they work, others may operate as a ‘black box’. For example, where a process utilises a decision tree it may be easier to generate an explanation (in a human-readable form) of how and why the algorithm reached a particular conclusion; though this very much depends on the size and complexity of the tree. The situation may be very different in relation to neural network-type algorithms, such as deep learning algorithms. This is because the conclusions reached by neural networks are ‘non-deductive and thus cannot be legitimated by a deductive explanation of the impact various factors at the input stage have on the ultimate outcome’.⁹⁴

Beyond the fact that some machine learning algorithms are non-transparent in the way they are designed, opacity might also be the consequence of online

⁸⁹ Montelero, ‘Personal data for decisional purposes in the age of analytics’ 9.

⁹⁰ Montelero, ‘Personal data for decisional purposes in the age of analytics’ 9.

⁹¹ Nicholas Diakopoulos, ‘Accountability in Algorithmic Decision Making’ (2016) 59 (2) *Communications of the ACM* 56, 57.

⁹² For a technical discussion on the opacity of algorithms, see Singh and Walden, ‘Responsibility and Machine Learning’ 4–7.

⁹³ Jenna Burrell, ‘How the machine “thinks”: Understanding opacity in machine learning algorithms’ (Jan–June 2016) *Big Data Society* (Original Research Article) 1, 6 <http://bds.sagepub.com/content/spbds/3/1/2053951715622512.full.pdf> accessed 28 April 2016.

⁹⁴ David R. Warner Jr, ‘A Neural Network-based Law Machine: the problem of legitimacy’ (1993) 2 (2) *Law, Computers & Artificial Intelligence* 135, 138; Geert-Jan Van Opdorp et al, ‘Networks at work: a connectionist approach to non-deductive legal reasoning’ (paper presented at the proceedings of The Third International Conference on Artificial Intelligence and Law, Charleston, USA, July 16–19, 1990) 278, 285.

learning in the sense that the algorithms can ‘update their model for predictions after each decision, incorporating each new observation as part of their training data. Even knowing the source code and data (...) is not enough to replicate and predict their behavior’.⁹⁵ It is also important to know the precise inputs and outputs to any machine learning system. Needless to say, analysing how a learned model works becomes even more difficult when either the code, its build process, the training data and/or the ‘live’ input data are hidden. Such opacity may result from the fact that certain algorithms are protected as trade secrets or that their design is based on a company’s proprietary code.

Opacity of machine learning approaches might have an impact on a data controller’s obligation to process a data subject’s personal data in a transparent way. Whether personal data are obtained directly from the data subject or from an indirect source, the GDPR imposes on the data controller the obligation to provide the data subject with information regarding:

‘the existence of automated decision making, including profiling, referred to in Article 22(1) and (4) and, at least in those cases, meaningful information about the logic involved, as well as the significance and the envisaged consequences of such processing for the data subject.’⁹⁶

Does this mean that whenever machine learning is used to conduct profiling the data controller must provide information regarding the existence and type of machine learning algorithms used? If so, to what does the term ‘logic’ refer and what would constitute ‘meaningful information’ about that logic? And how does this relate to the role of different service providers forming part of the ‘machine learning’ supply chain?

More specifically, does the term ‘logic’ refer to the data set used to train the algorithm, or to the way the algorithm itself works in general, for example the mathematical / statistical theories on which the design of the algorithm is based, or to the way the learned model worked in the particular instance when processing the data subject’s personal data? What about the specific policies and criteria fed into the algorithm, the variables, and the weights attributed to those variables? It has been suggested that Article 22 does not provide a ‘right to explanation’ because a data controller’s obligation to provide information about the logic covers only general information about the automated decision-making function and does not include an obligation to provide information on the reasoning behind a specific decision.⁹⁷ However, we would argue that data subjects do have a right to explanation under Article 13(2)(f) and Article 14(2)(g) of the GDPR because data controllers have a specific obligation to provide ‘meaningful’ information about the

⁹⁵ Kroll et al, ‘Accountable Algorithms’ 660.

⁹⁶ Art 13(2)(f) and Art 14(2)(g) GDPR.

⁹⁷ Sandra Wachter et al, ‘Why a right to explanation of automated decision-making does not exist in the General Data Protection Regulation’ (2017) 7 (2) *International Data Privacy Law* 76, 84 <https://doi.org/10.1093/idpl/ixp005> accessed 1 July 2017. Wachter, et al suggest that a ‘right to explanation’ of specific decisions should be added to Article 22 (3) to make it legally binding. This is highly unlikely to happen and, in any event, in our view it is not necessary.

logic involved in the automated decision making as well as the significance and the envisaged consequences of such processing 'for the data subject'. Inclusion of the phrase 'for the data subject' makes it clear that 'meaningfulness' should be assessed from a data subject's perspective and that information about the logic and the consequences of the decision have to be relevant to a specific decision. Mere provision of general information on a system's functionality would not be sufficient to satisfy the GDPR's 'meaningfulness' requirement.⁹⁸

A further issue concerns record keeping. In relation to the Data Protection Directive, Lee Bygrave has argued that the logic should:

'be documented and (...) the documentation be kept readily available for consultation and communication.(...) The documentation must set out, at the very least, the data categories which are applied, together with information about the role these categories play in the decision(s) concerned'.⁹⁹

Producing documentation of this kind might prove difficult with machine learning techniques that are 'black box' in nature, in which case the transparency obligation may slow down or preclude their deployment, even in cases where their use could potentially lead to fairer decision making or other improvements in outcomes for data subjects. In other cases, however, it may be feasible to describe (albeit in broad terms) the way in which the system was constructed, how the data were selected, the algorithms trained and tested, and the outputs evaluated.

As meaningfulness should be assessed from a data subject's perspective, revealing the underlying code of an algorithm, for example, might not be meaningful to the typical data subject if a lack of technical skills would prevent him / her from understanding how the code works.

The obligation to explain the logic may also have an impact on whether a data controller's or a third party's algorithm can remain a trade secret. According to Diakopoulos, there are in fact a number of elements of the algorithmic process that could be disclosed without risk of breaching any intellectual property rights. Information on human involvement, quality of data (e.g. information about how training data have been collected and labelled, reliability of sources, accuracy and timeliness), the model and variables of the algorithm, the inferencing (including the margin of error predicted), and information on whether an algorithm was indeed used could be disclosed instead.¹⁰⁰

In addition, data subjects' rights to access personal data and metadata processed by a data controller may place them in a better position to request correction or

⁹⁸ Moreover, notwithstanding the fact that Recital 71 refers only to the obligation to provide meaningful information in relation to Articles 22(1) [the general rule] and (4) [the special case of sensitive data], the transparency obligations appear to cover all cases covered by Article 22. This is supported by the inclusion in Articles 13(2)(f) and 14(2)(g) of the words 'at least in those cases', suggesting a broad scope.

⁹⁹ Bygrave, 'Automated Profiling' 20.

¹⁰⁰ Diakopoulos, 'Accountability in Algorithmic Decision Making' 60.

erasure of any personal data that might be used to create a profile about them. What happens, though, when the data controller has already created a profile based on the personal data collected? According to GDPR Recital 72, it appears that creating profiles is also subject to the requirement that there be a legal ground for processing and the obligation to comply with the data protection principles. In relation to the Data Protection Directive, the Article 29 Working Party advised in 2013 that ‘data subjects should also have the right to access, to modify or to delete the profile information attributed to them’.¹⁰¹ Indeed, when such profiles have been created using machine learning algorithms, the UK ICO has suggested that individuals can also be allowed to review the outputs of the algorithms and correct any inaccurate label attached to their profile.¹⁰² If this is correct, then, as a prerequisite to exercising such rights, data subjects have the right to know what profiles have been created about them and the right to object to their personal data being processed for such profiling purposes.¹⁰³

The exercise by individuals of rights to rectification of inaccurate or incomplete personal data¹⁰⁴ or to erasure of personal data¹⁰⁵ may have complex ‘knock-on’ impacts on machine learning processes. For example, an individual may become aware, whether because information has been provided proactively or in response to a subject access request, that his or her personal data have been incorporated into a machine learning model. The individual may then decide to exercise the right to request erasure or correction of some or all of that data. That may in turn have an impact on the legal basis for continuing to use the model to the extent that it still incorporates the personal data in question. In particular, might a data controller then be obliged either to stop using the model or to go back and retrain the model either without including the data that have been removed or using only the modified version of the data?

Under the GDPR, the onus is clearly on the data controller to provide data subjects with meaningful information about the logic involved in automated processing, including profiling. However, various components of the machine learning supply chain, including the algorithms and pre-learned models, may have been designed by one or more third parties. For example, a number of companies now provide cloud-based machine learning services, which data controllers of all enterprise sizes can access and use, often without a requirement for in-house expertise in relation to machine learning. It will still be important for such controllers to know how those algorithms and models have been designed, whether their initial training data set was based on personal or anonymised data, and the sources of such data. It may also be important for data controllers to have some

¹⁰¹ WP29, 2013, ‘Advice paper’ 3.

¹⁰² ICO, ‘Big data, artificial intelligence, machine learning and data protection’ 88.

¹⁰³ The right to object is limited to processing of personal data based on Art 6(1) (e) or (f) GDPR, including profiling based on those provisions.

¹⁰⁴ Article 16 GDPR.

¹⁰⁵ Article 17 GDPR.

information about the learning processes and how outputs are utilised, as under the GDPR data controllers should use appropriate statistical procedures for profiling to ensure fair and transparent processing.¹⁰⁶ Even though such information may not be helpful to data subjects and, thus, may not need to be disclosed to them, data controllers might be required to disclose it to regulators in the context of an audit or investigation.

For data controllers, where they collect data subjects' personal data directly from them, a further level of complexity may arise from the obligation to provide information about the logic involved in automated decision making at the time when they obtain data subjects' personal data. Machine learning may be a highly dynamic process, and this may mean that a 'decisional rule itself emerges automatically from the specific data under analysis, sometimes in ways that no human can explain'.¹⁰⁷ In such an environment, data controllers may not be able to predict and explain at the time when personal data are collected what logic may subsequently be followed by the algorithms.

Due to all these complexities, it has been argued that transparency might not be the most appropriate way of seeking to ensure legal fairness but that compliance should be verified, for instance, through the use of technical tools,¹⁰⁸ for example to show 'blindness to a particular attribute like the use of race in credit decisions or the requirement that a certain class of analysis be applied for certain decisions'.¹⁰⁹ This might also be achieved by testing the trained model for unfair discrimination against a number of 'discrimination testing' datasets, or by assessing the actual outcomes of the machine learning process to prove that they comply with the lawfulness and fairness requirements.¹¹⁰

V. Conclusions

According to Article 22 of the GDPR, data subjects have a right not to be subject to a decision based solely on automated processing, including profiling that produces legal effects concerning them or significantly affects them. In parallel, data controllers must, among other things, comply with the first data protection principle of lawful, fair and transparent processing. This may be difficult to achieve due to the way in which machine learning works and / or the way it is integrated

¹⁰⁶ Recital 71 second paragraph GDPR.

¹⁰⁷ Kroll et al, 'Accountable algorithms' 638.

¹⁰⁸ Kroll et al, 'Accountable algorithms' 662 onwards.

¹⁰⁹ Kroll et al, 'Accountable algorithms' (SSRN version), 5.

¹¹⁰ For a discussion on testing and evaluating a trained model, see Singh and Walden, 'Responsibility and Machine Learning' 8–9.

into a broader workflow that might involve the use of data of different origins and reliability, specific interventions by human operators, and the deployment of machine learning products and services, including MLaaS (Machine Learning as a Service).

To be compliant, data controllers must assess how using machine learning to carry out automated processing affects the different elements of profiling and the level of risk to data subjects' rights and freedoms. In some cases where automated processing, including profiling, is permitted by law, data controllers still have to implement suitable measures to safeguard the data subjects' rights, freedoms and legitimate interests. Such measures will include preventing machines making decisions before data subjects can express their point of view, allowing for substantive human review when a decision is made by a machine, and ensuring that data subjects can contest the decision. The underlying objective in the Data Protection Directive (and apparently in the GDPR) is that a decision significantly affecting a person cannot just be based on a fully automated assessment of his or her personal characteristics. In machine learning, however, we contend that, in some cases, it might be more beneficial for data subjects if a final decision is, indeed, based on an automated assessment.

Whether a decision about us is being made by a human or by a machine, at present the best we can hope for is that a decision that produces legal effects or significantly affects us will be as fair as humans can be. An interesting possibility, however, is that machines may soon be able to overcome certain key limitations of human decision makers and provide us with decisions that are demonstrably fair. Indeed, it may already in some contexts make sense to replace the current model, whereby individuals can appeal to a human against a machine decision, with the reverse model whereby individuals would have a right to appeal to a machine against a decision made by a human.

In relation to 'fair' processing, it is important to distinguish between the concept of discrimination as classification or prioritisation of information, which are at the heart of machine learning, and unfair discrimination that leads to prejudicial treatment. Unfair discrimination in a machine learning environment may result from deficiencies in the quality and quantity of the data available to train and test the algorithm, as well as problems with sources, labelling, and direct or indirect bias in such data. Algorithms working on incomplete or unrepresentative data may generate spurious correlations that result in unjustifiable decisions.

Finally, in order to comply with their transparency obligations, data controllers have to consider what the terms 'logic' of automated decision making and 'meaningful' information about that logic mean in a machine learning context and from a data subject's perspective. The opaque nature of certain algorithms or models, the fact that their underlying code may be protected via trade secrecy or even the fact that machine learning algorithms and the models they produce may be incomprehensible to a typical data subject may make it difficult for data controllers to comply with their obligation of transparent processing.

References

- Amazon, 'Amazon Machine Learning' and 'Amazon Mechanical Turk'.
- Amended Proposal for a Council Directive on the protection of individuals with regard to the processing of personal data and on the free movement of such data (COM(92) 422 final—SYN 287. Brussels, 15 October 1992.
- Article 29 Working Party (WP29), 'Advice paper on essential elements of a definition and a provision on profiling within the EU General Data Protection Regulation' 13 May 2013.
- , 'Opinion 05/2014 on Anonymisation Techniques' WP216 0829/14/EN, 3.
- , 'Opinion 03/2013 on purpose limitation,' 00569/13/EN, WP 203, 69.
- , 'Opinion 8/2014 on Recent Developments on the Internet of Things' 14/EN, WP 223, 16 September 2014.
- 'Artificial artificial intelligence' (*The Economist Technology Quarterly*, Q2 2006).
- Burrell, J, 'How the machine "thinks": Understanding opacity in machine learning algorithms' (*Big Data Society*, 2016) 1–12.
- Burton-Hill, C, 'The superhero of artificial intelligence: can this genius keep it in check?' (*The Guardian*, 16 February 2016).
- Bygrave, L, 'Automated Profiling, Minding the Machine: Article 15 of the EC Data Protection Directive and Automated Profiling' (2001) 17 (1) *Computer Law & Security Review* 17–24.
- Chaykowski, K, 'Facebook News Feed Change Prioritizes Posts From Friends Users Care About' (*Forbes*, 29 June 2016).
- Commission of the European Committees, 'Amended Proposal for a Council Directive on the protection of individuals with regard to the processing of personal data and on the free movement of such data' (COM(92) 422 final—SYN 287, 15 October 1992, 1–130.
- Copeland, J, 'What is Artificial Intelligence?' (*AlanTuring.net*, 2000).
- Coudert, F, 'When video cameras watch and screen: Privacy implications of pattern recognition technologies' (2010) 26 *Computer Law and Security Review* 377–384.
- Council of Europe Consultative Committee of the convention for the protection of individuals with regard to automatic processing of personal data. 'Guidelines on the protection of individuals with regard to the processing of personal data in a world of Big Data' T-PD(2017)01, Strasbourg, 23 January 2017, 4.
- Diakopoulos, N, 'Accountability in Algorithmic Decision Making' (2016) 59 (2) *Communications of the ACM* 56–62.
- Directive 95/46/EC of the European Parliament and of the Council on the protection of individuals with regard to the processing of personal data and on the free movement of such data (Data Protection Directive), O.JL 181/31, 23 November 1995.
- Domingos, P, 'A Few Useful Things to Know about Machine Learning' (2012) 10 *Communications of the ACM* 78–87.
- Dynarski, S, 'Why Talented Black and Hispanic Students Can Go Undiscovered' (*The New York Times*, 8 April 2016).
- EU Commission, 'The EU data protection Regulation: Promoting technological innovation and safeguarding citizens' rights'.
- Furnas, A, 'Everything You Wanted to Know About Data Mining but Were Afraid to Ask' (*The Atlantic*, 13 April 2012).
- Google, 'Google Cloud Prediction API Documentation'.

- Gutwirth, S, Hildebrandt, M, 'Some Caveats on Profiling' in Gutwirth, S, Poullet, Y and De Hert, P (eds) *Data Protection in a Profiled World* (The Netherlands, Springer, 2010) 31–41.
- Hamed, Z, '12 Stocks To Buy If You Believe In Driverless Cars' (*Forbes*, 21 January 2015).
- Hamilton, L, 'Six Novel Machine Learning Applications' (*Forbes*, 6 January 2014).
- Hildebrandt, M, 'Defining Profiling: A New Type of Knowledge?' In Hildebrandt, M and Gutwirth, S (eds) *Profiling the European Citizen* (The Netherlands, Springer, 2008) 17–45.
- Hon, W. K, Millard, C, and Singh, J, 'Twenty Legal Considerations for Clouds of Things', (January 2016) *Queen Mary School of Law Legal Studies Research Paper* No. 216/2016, 1–47.
- IBM. 'Watson Developer Cloud'.
- Information Commissioner's Office (ICO), 'Big data, artificial intelligence, machine learning and data protection' (Paper, *ICO website*, 2017) 1–113.
- 'I think it's time we broke for lunch ...' (*The Economist*, 14 April 2011).
- Kroll, J.A, Huey, J, Barocas, S, Felten, EW, Joel R. Reidenberg, JR, Robinson, DG, and Harlan, Y, 'Accountable Algorithms' (2017) 165 *University of Pennsylvania Law Review* 633–705. An earlier version of the article is available at SSRN (2016) 1–59.
- Luckerson, V, 'Microsoft Is Developing Driverless Car Technology With Volvo' (*Time*, 20 November 2015).
- Marr, B, 'A Short History of Machine Learning-Every Manager Should Read' (*Forbes*, 19 February 2016).
- McCarthy, J, 'What is Artificial Intelligence' (*Stanford University* 12 November 2007).
- McNeil Jr., D G, '6 Reasons to Think the Zika Virus Causes Microcephaly' (*The New York Times*, 3 May 2016).
- Microsoft Corporation, 'Microsoft Azure, Machine Learning'.
- Miller, A A, 'What do we worry about when we worry about price discrimination? The Law and Ethics of using personal information for pricing' (2014) 19 *Journal of Technology Law & Policy* 41–104.
- Mitchell, Tom M, *Machine Learning*, (New York, McGraw-Hill Inc., 1997).
- Montelero, A, 'Personal data for decisional purposes in the age of analytics: From an individual to a collective dimension of Data Protection' (2016) 32 (2) *Computer Law & Security Review* 238–255.
- Munoz, A, 'Machine Learning and Optimization'.
- Quora, 'Session with Ralf Herbrich', 4 March 2016.
- Regulation (EU) 2016/679 of the European Parliament and of the Council on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation) 27 April 2016 OJ L119/1: 4 May 2016.
- Ribeiro, M T, Singh, S, and Guestrin, C, 'Why Should I Trust You? Explaining the Predictions of Any Classifier' (Paper presented at the KDD '16 Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining', New York, 2016).
- Savin, A, 'Profiling and Automated Decision Making in the Present and New EU Data Protection Frameworks' (Paper presented at 7th International Conference Computers, Privacy & Data Protection, Brussels, Belgium, 2014).

- Schreurs, W, Hildebrandt, M, Kindt, E and Vanfleteren, M, 'Cogitas, Ergo Sum. The Role of Data Protection Law and Non-discrimination Law in Group Profiling in the Private Sector' In Mireille Hildebrandt and Serge Gutwirth (eds) *Profiling the European Citizen* 241–270 (The Netherlands, Springer, 2008).
- Singh, J, Pasquier, T, Bacon, J, Ko, H and Eysers, D, 'Twenty security considerations for cloud-supported Internet of Things' (2015) 3 (3) *IEEE Internet of Things Journal* 269–284.
- Singh J, and Walden, I, 'Responsibility and Machine Learning: Part of a Process' (2016) SSRN.
- Smith, L, 'Algorithmic transparency: Examining from within and without' (*IAPP Privacy Perspectives*, 28 January 2016) Accessed March 17, 2016.
- Turing, A, 'Computing Machinery and Intelligence' (1950) *Mind* 433–460.
- 'UNECE paves the way for automated driving by updating UN international convention' (UNECE Press Releases, 23 March 2016).
- United Nations Economic and Social Council, Economic Commission for Europe, Working Party on Road Traffic Safety, 'Report of the sixty-eighth session of the Working Party on Road Traffic Safety' Geneva, March 24–26, 2014.
- United Nations Vienna Convention on Road Traffic. Vienna, 8 November 1968.
- Van Opdorp, G-J., Walker, RF, Shcrickx, J, Groendijk, G & Van den Berg, PH, 'Networks at work: a connectionist approach to non-deductive legal reasoning' Paper presented at the Proceedings of The Third International Conference on Artificial Intelligence and Law, Charleston, USA, 16–19 July 1990.
- Wachter, S, Mittelstadt, B, and Floridi, L, 'Why a right to explanation of automated decision-making does not exist in the General Data Protection Regulation' (2017) 7 (2) *International Data Privacy Law* 76, 84 <https://doi.org/10.1093/idpl/ix005> accessed 1 July 2017.
- Wah, C, 'Crowdsourcing and its applications in computer vision' (2011) UC San Diego, 1–15.
- Warner Jr, David R., 'A Neural Network-based Law Machine: the problem of Legitimacy' (1993) 2 (2) *Law, Computers & Artificial Intelligence* 135–147.
- Woodie, A, 'Five Reasons Machine Learning is Moving to the Cloud' (*datanami*, 29 April 2015).

Bridging Policy, Regulation and Practice? A Techno-Legal Analysis of Three Types of Data in the GDPR^{*}

RUNSHAN HU, SOPHIE STALLA-BOURDILLON, MU YANG,
VALERIA SCHIAVO AND VLADIMIRO SASSONE

Abstract. The paper aims to determine how the General Data Protection Regulation (GDPR) could be read in harmony with Article 29 Working Party's Opinion on anonymisation techniques. To this end, based on an interdisciplinary methodology, a common terminology to capture the novel elements enshrined in the GDPR is built, and, a series of key concepts (i.e. sanitisation techniques, contextual controls, local linkability, global linkability, domain linkability) followed by a set of definitions for three types of data emerging from the GDPR are introduced. Importantly, two initial assumptions are made: 1) the notion of identifiability (i.e. being identified or identifiable) is used consistently across the GDPR (e.g. Article 4 and Recital 26); 2) the Opinion on Anonymisation Techniques is still good guidance as regards the classification of re-identification risks and the description of sanitisation techniques. It is suggested that even if these two premises seem to lead to an over-restrictive approach, this holds true as long as contextual controls are not combined with sanitisation techniques. Yet, contextual controls have been conceived as complementary to sanitisation techniques by the drafters of the GDPR. The paper concludes that the GDPR is compatible with a risk-based approach when contextual controls are combined with sanitisation techniques.

I. Introduction

In recent years, the debate about personal data protection has intensified as a result of an increasing demand for consistent and comprehensive protection of personal data leading to the adoption of new laws in particular in the

^{*} The research for this paper was partly funded by the European Union's Horizon 2020 research and innovation programme under grant agreements No 700542 and 732506. This paper reflects only the authors' views; the Commission is not responsible for any use that may be made of the information it contains.

European Union (EU). The current EU data protection legislation, Data Protection Directive 95/ 46/EC (DPD),¹ is to be replaced by the General Data Protection Regulation (GDPR)² from 25 May 2018, which, being a self-executing norm, will be directly applicable in all the Member States in the EU. This legislative reform has generated repeated discussions about its potential impact on business processes and procedures as the GDPR contains a number of new provisions intended to benefit EU data subjects and comprises a strengthened arsenal of sanctions, including administrative fines of up to 4% of total worldwide annual turnover of the preceding financial year, for non-compliant data controllers and processors.

One key question is to what extent the GDPR offers better tools than the DPD to frame or confine data analytics as well as data sharing practices. Addressing this issue requires first of all delineating the scope of data protection law. Second, it necessitates examining key compliance techniques, such as pseudonymisation, of which the *raison d'être* is to enable data controllers to strike an appropriate balance between two distinct regulatory objectives: personal data protection and data utility maximisation. Not to be misleading, these challenges are not specific to the GDPR and will arise each time law-makers are being tasked with designing a framework aimed at marrying a high degree of personal data protection with some incentives to exploit the potential of data.

Within the GDPR, Articles 2 and 4 are starting points in order to demarcate the material scope of EU data protection law. Under Article 4(1), personal data means:

any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person.

Recital 26 further expands upon the notion of identifiability and appears to draw a distinction between personal data and anonymous information, with anonymous information being excluded from the scope of the GDPR. It is true that this key distinction was already present in the DPD. Nonetheless, the GDPR goes further than the DPD in that it indirectly introduces a new category of data as a result of Article 4,³ ie data that has undergone pseudonymisation, which we will name pseudonymised data, to use a shorter expression, although the former is more

¹ Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the Protection of Individuals with Regard to the Processing of Personal Data and on the Free Movement of Such Data, 1995 O.J. (L 281) 23/11/1995, p. 31- 50 (EU), at Recital 26 [hereinafter DPD].

² Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), 2016 O.J. (L 119) 4.5.2016, p. 1–88 (EU), at Recital 26 [hereinafter GDPR].

³ GDPR, *supra* note 2, at Article 4(5).

accurate than the latter for it implies that the state of the data is not the only qualification trigger.⁴ Under Article 4(5) pseudonymisation means:

the processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.

While the final text of the GDPR does not seem at first glance to create an ad hoc regime with fewer obligations for data controllers when they deal with pseudonymised data, Recital 29 specifies:

In order to create incentives to apply pseudonymisation when processing personal data, measures of pseudonymisation should, whilst allowing general analysis, be possible within the same controller when that controller has taken technical and organisational measures necessary to ensure, for the processing concerned, that this Regulation is implemented, and that additional information for attributing the personal data to a specific data subject is kept separately.

Furthermore, Article 11 of the GDPR is worth mentioning as it seems to treat with favours a third category of data, which we name Art.11 data for the sake of the argument. Art.11 data under Article 11⁵ of the GDPR, is data so that 'the [data] controller is able to demonstrate that it is not in a position to identify the data subject.' Examining the GDPR a couple of questions therefore emerge: whether and when pseudonymised data can become anonymised data and whether and when pseudonymised data can be deemed to be Art. 11 data as well.

A number of legal scholars have been investigating the contours of personal data under EU law, and have proposed refined categories, creating on occasion a spectrum of personal data, more or less complex.⁶ The classifications take into account the intactness of personal data (including direct and indirect identifiers)⁷ and legal controls to categorise data. For instance, with masked direct identifiers and intact indirect identifiers, data is said to become 'protected pseudonymous

⁴ S Stalla-Bourdillon and Alison Knight, 'Anonymous data v. Personal data—A false debate: An EU perspective on anonymisation, pseudonymisation and personal data,' (2017) *Wisconsin International Law Journal* 284, 311.

⁵ GDPR, *supra* note 2, at Article 11. It is true that Article 11 adds that if the data subject 'provides additional information enabling his or her identification,' Articles 15 to 20 become applicable. As the data subject is described as the one in possession of the additional information (and not the data controller), Art. 11 data and pseudonymised data should not necessarily be equated.

⁶ K El Emam, E Gratton, J Polonetsky and L Arbuckle, 'The Seven States of Data: When is Pseudonymous Data Not Personal Information?', <<https://fpf.org/wp-content/uploads/2016/05/states-v19-1.pdf>> [accessed March 13, 2017]. [hereinafter *The Seven States of Data*]; J Polonetsky, O Tene and K Finch. 'Shades of Gray: Seeing the Full Spectrum of Practical Data De-Identification.' (2016) 56 *Santa Clara Law Review* 593; M Hintze, 'Viewing The GDPR Through A De-Identification Lens: A Tool For Clarification And Compliance', (2017) <https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2909121> [accessed March 13, 2017]. See also PM Schwartz and DJ Solove, 'The PII problem: Privacy and a new concept of personally identifiable information' (2011) 86 *NYUL rev.* 1814; K El Emam 'Heuristics For De-Identifying Health Data' (2008) 6, 4 *IEEE Security & Privacy Magazine* 58.

⁷ T Dalenius 'Finding a needle in a haystack or identifying anonymous census records' (1986) 2, 3 *Journal of official statistics* 329.

data' when legal controls are put in place.⁸ We suggest in this paper that these approaches logically rely upon a pre-GDPR understanding of 'pseudonymisation,' which should not be confused with GDPR Article 4 definition and thereby have not necessarily derived the implications of the new legal definitions emerging from the GDPR.

The Article 29 Data Protection Working Party (Art. 29 WP) did provide a comprehensive analysis of data anonymisation techniques⁹ in the light of the prescriptions of the DPD. For this purpose, Art. 29 WP identified three common risks and tested the robustness of data anonymisation techniques against these risks. However, as aforementioned this was done in 2014 against the background of the DPD and the relationship between these techniques and the data categories defined in the GDPR have not been analysed yet.

The objective of this paper is therefore to derive the implications of the new legal definitions to be found more or less explicitly in the GDPR and determine how the GDPR could be read in harmony with Art. 29 WP's position, in order to inform the work of researchers, practitioners, and ultimately policy and law-makers. To this end, we built a common terminology to capture the novel elements enshrined in the GDPR and thereby introduce a series of key concepts -sanitisation techniques, contextual controls, local linkability, global linkability, domain linkability- followed by a set of definitions for the three types of data emerging from the GDPR developed on the basis of these key concepts. The methodology implemented to create this terminology is interdisciplinary in nature. It combines a systematic analysis of hard law and soft law instruments -the GDPR, the DPD, Court of Justice of the European Union (CJEU) case law, Art. 29 WP opinion- with a review and assessment of key techniques available to data scientists. We conclude that, assuming the trichotomy of re-identification risks enumerated by Art. 29 WP should still guide the analysis post-GDPR, the GDPR makes the deployment of a risk-based approach possible as long as contextual controls are combined with sanitisation techniques and a relativist approach to data protection law is adopted.

Consequently, the main contributions of the paper are the following:

- (a) We offer a granular analysis of the three types of risks to be taken into account in order to assess the robustness of sanitisation techniques. The risks include singling out, linkability and inference, with linkability being split into local, global and domain linkability.
- (b) We propose a classification of data sanitisation techniques and contextual controls in relation to the three categories of data found in the GDPR.
- (c) We derive criteria for selecting sanitisation techniques and contextual controls, based on the three types of risks in order to assess the feasibility of a risk-based approach.

⁸ The Seven States of Data, *supra* 6, at 6.

⁹ Article 29 Data Protection Working Party, Opinion 05/2014 on Anonymisation Techniques (European Comm'n, Working Paper No. 216, 0829/14/EN, 2014) [hereinafter Opinion on Anonymisation Techniques].

Importantly, the two premises of the paper are the following: 1) we assume that the notion of identifiability (i.e. being identified or identifiable) is used consistently across the GDPR (e.g. in Article 4 and in Recital 26); 2) we assume that the Opinion on Anonymisation Techniques is still good guidance as regards the distinction drawn between the three types of re-identification risks and the description of sanitisation techniques. Obviously, both of these premises can be criticised as the GDPR has not been litigated yet and the Opinion on Anonymisation Techniques has been appraised critically for several reasons.¹⁰ However, we suggest that even if these two premises seem to lead to an over-restrictive approach, this holds true as long as contextual controls are not combined with sanitisation techniques. Yet, contextual controls such as technical and organisational measures have been conceived as complementary to sanitisation techniques by the drafters of the GDPR. Contextual controls, including confidentiality obligations, are thus crucial to move towards a workable risk-based approach as well as a relativist approach to data protection law in general.

Structure of the paper. In Section 2 we sketch the new EU data protection legal framework, ie the GDPR, give an overview of three risks identified by Art. 29 WP in relation to identification and identifiability, and define the key components of our common terminology. In Section 3, we unfold our risk-based approach for characterising the three types of data emerging from the GDPR and thereby derive an additional set of definitions. The classification of data sanitisation techniques and contextual controls is then realised in Section 4, followed by our conclusions in Section 5.

II. The Three Types of Data

As aforementioned, three types of data seem to emerge from the analysis of the GDPR. We define them in section 2.1 and then conceptualise the three types of risks identified by Art. 29 WP to assess data anonymisation and masking techniques, which we include within the broader category of sanitisation techniques in section 2.2 and distinguish from contextual controls.

A. The GDPR Definitions

The definitions presented in this section are derived from the GDPR, including Recital 26 for Anonymised data, Article 4 for Pseudonymised data, and Article 11 for Art.11 data.

- **‘Anonymised data’** means data that ‘does not relate to an identified or identifiable natural person or to personal data rendered anonymous in such a manner that the data subject is not or no longer identifiable.’¹¹

¹⁰ See in particular K El Emam and C Álvarez, ‘A critical appraisal of the Article 29 Working Party Opinion 05/2014 on data anonymization techniques’ (2015) 5, 1 *International Data Privacy Law* 73.

¹¹ GDPR, *supra* note 2, at Recital 26.

- ‘**Pseudonymised data**’ means personal data that have been processed ‘in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.’¹²
- ‘**Art.11 data**’ means data so that the data controller is ‘not in a position to identify the data subject’¹³ given such data.

The notions of ‘identified’ and ‘identifiable’ thus appear of paramount importance to distinguish the different types of data and determine whether a category should be considered personal data. An individual is usually considered identified if the data can be linked to a unique real world identity.¹⁴ As per Recital 26, account should be ‘taken of all the means reasonably likely to be used either by the [data] controller or by another person directly or indirectly.’¹⁵ The term ‘identifiable’ refers to the capability to identify an individual, who is not yet identified, but is described in the data in such a way that if research is conducted using additional information or background knowledge she can then be identified. Arguably, following the GDPR, the same ‘means test’ (of Recital 26) should apply here as well. The foregoing explains why pseudonymised data is still (at least potentially) considered to be personal data. Recital 26 specifies that ‘[p]ersonal data which have undergone pseudonymisation, which could be attributed to a natural person by the use of additional information should be considered to be information on an identifiable natural person.’

While the two concepts of pseudonymised data and Art.11 data overlap (so as Art.11 data and anonymised data as it will be explained below), in order to test the extent to which they actually overlap it is necessary to start by conceiving them differently. Besides, Article 11 does not expressly refer to pseudonymisation.

Sticking to the words of GDPR Article 4, we therefore suggest that in order to characterise data as pseudonymised data, one has to determine whether individuals are identifiable once the additional information has been isolated and separated from the dataset. Furthermore, to determine whether individuals are identifiable once the additional information has been isolated and separated from the dataset, only the dataset at stake should be considered. This is why, as it will be explained below, the concept of pseudonymised data is intimately linked to that of local linkability.¹⁶

¹² GDPR, *supra* note 2, at Article 4(5).

¹³ GDPR, *supra* note 2, at Article 11.

¹⁴ The Seven States of Data, *supra* 6.

¹⁵ GDPR, *supra* note 2, at Recital 26.

¹⁶ For a critical assessment of the concept of pseudonymisation in the GDPR see S Stalla-Bourdillon and A Knight, ‘Anonymous data v. Personal data—A false debate: An EU perspective on anonymisation, pseudonymisation and personal data’ (2017) *Wisconsin International Law Journal* 284, 300–301.

On the other hand, in order to characterise data as Art.11 data, one has to determine whether a data controller is in a position to identify individuals, ie whether individuals are identifiable given the data controller's capabilities, which should require considering all the datasets in the possession of the data controller; but the data controller's capabilities only (therefore to the exclusion of third parties' capabilities). This is the reason why we suggest that the concept of Art.11 data is intimately linked to that of domain linkability.

Consequently, following this logic we argue that to characterise data as pseudonymised data or Art.11 data it is not enough to point to the fact that the individuals are not directly identified within the dataset at stake. As a result, data controllers should not be entitled not to comply with Articles 15 to 20 simply based on the fact that they have decided not to collect direct identifiers for the creation of the dataset at stake.

i. Additional Information

As hinted above, the concept of 'additional information' is closely related to that of pseudonymised data. Indeed, it can make data subjects identified or identifiable if combined with pseudonymised data. The GDPR requires it to be kept separately and be subject to technical and organisational measures. A typical example of additional information is the encryption key used for encrypting and decrypting data such as attributes: the encrypted data thus becomes pseudonymised data when the key is separated and subject to technical and organisational measures such as access restriction measures.

Two other important concepts related to additional information are that of 'background knowledge' and 'personal knowledge'.¹⁷ In order to analyse re-identification risk properly, it is crucial to draw a distinction between additional information, background knowledge and personal knowledge. As per GDPR Article 4, additional information, is the information that can be kept separately from the dataset by technical and organisational measures, such as encryption key, hash function etc.

We distinguish additional information from background knowledge and personal knowledge. Background knowledge, is understood as different in kind from additional information as it corresponds to knowledge that is publicly accessible to an average individual who is deemed reasonably competent to access it, therefore, most likely including the data controller himself. It comprises information accessible through the Web such as news websites or information found in public profiles of individuals or traditional newspapers. While this kind of knowledge can potentially have a high impact on re-identification risks, it cannot be physically separated from a dataset. Therefore, we exclude it from additional

¹⁷ Information Commissioner's Office, *Anonymisation: Managing Data Protection Risk Code Of Practice*, (2012).

information. However, and this is important, we take it into account when we analyse the three types of data by acknowledging that the potential existence of background knowledge makes it necessary to include singling out as a relevant risk for pseudonymised data within the meaning of the GDPR because as a result of a pseudonymisation process, the data shall not be attributable to an identifiable data subject as well. The same is true for Art. 11 data.¹⁸

Personal knowledge, is assessed through the means of a subjective test (as opposed to background knowledge, which is assessed through the means of an objective test) and varies from one person to another.¹⁹ It comprises information that is not publicly accessible to an average individual who is deemed reasonably competent to access it, but only to certain individuals because of their special characteristics. For example, a motivated intruder A has the knowledge that B is currently in hospital, as she is B's neighbour and she saw that B was picked up by an ambulance. When combined with anonymised data, this kind of subjective personal knowledge could obviously result in re-identification. However, for the purposes of this paper we assume that the likelihood that a motivated intruder has relevant personal knowledge is negligible, which partly depends upon his/her willingness to acquire this relevant personal knowledge and his/her estimation of the value of the data at stake and thereby the degree of data sensitivity. We recognise, however, that further sophistication would be needed for scenarios in which the likelihood that a motivated intruder has relevant personal knowledge is high. In particular, this would mean considering with care the equivalence of sanitisation techniques and contextual controls. With this said, we note that Art. 29 WP wrote in 2007 that 'a mere hypothetical possibility to single out the individual is not enough to consider the person as "identifiable"'.²⁰

ii. *Direct and Indirect Identifiers*

As described in the ISO/TS document, a direct identifier is 'data that can be used to identify a person without additional information or with cross-linking through other information that is in the public domain.'²¹ Direct identifiers contain explicitly identifying information, such as names and social security numbers that are uniquely linked to a data subject. In contrast, sets of attributes, which can be combined together to uniquely identify a data subject, are called indirect identifiers.

¹⁸ It might be that a less restrictive approach would be preferable but the purpose of this paper is to show that the restrictiveness of the approach can ultimately be mitigated with contextual controls.

¹⁹ Information Commissioner's Office, *Anonymisation: Managing Data Protection Risk Code Of Practice* (2012).

²⁰ Article 29 Data Protection Working Party, Opinion 04/2007 on the concept of personal data (European Comm'n, Working Paper No. 136, 01248/07/EN), p. 15. And the following reference should be added to bibliography Article 29 Data Protection Working Party, Opinion 04/2007 on the concept of personal data, European Comm'n, Working Paper No. 136, 01248/07/EN (2014)].

²¹ International Organization for Standardization, *ISO/TS 25237:2008 Health Informatics—Pseudonymization*, 2008 <<https://www.iso.org/standard/42807.html>> [accessed 13 March 2017].

They include age, gender, zip code, date of birth and other basic demographic information. No single indirect identifier can identify an individual by its own; however, the re-identification risks appear when combining indirect identifiers together, as well as, as aforementioned, when combining records with additional information or with background knowledge. Notably, the list of direct and indirectly identifiers can only be derived contextually.

iii. Data Sanitisation Techniques

Data sanitisation techniques process data in a form that aims to prevent re-identification of data subjects. Randomisation and generalisation are considered as two main families of sanitisation techniques.²² There is a wide range of techniques including masking techniques, noise addition, permutation, k-anonymity, l-diversity and differential privacy, etc. Noise addition refers to general techniques that make data less accurate by adding noise usually bounded by a range, e.g., [-10, 10]. We differentiate it from differential privacy as the latter offers more rigorous guarantee. Masking or removal techniques are applied to direct identifiers to make sure the data subjects are not identified anymore and then additional techniques (including masking techniques) are then used to further process indirect identifiers. It is true that k-anonymity, l-diversity, and differential privacy are more commonly described as privacy models rather than techniques as such. However, as we built upon the Opinion on Anonymisation Techniques we use a similar terminology to simplify the arguments.

iv. Contextual Controls

Contextual controls comprise three sets of controls. First, legal and organisational controls such as obligations between parties and/or internal policies adopted within one single entity (one party) aimed at directly reducing re-identification risks, e.g. obligation not to re-identify or not to link. Second, security measures (including legal, organisational and technical controls) such as data access monitoring and restriction measures, auditing requirements as well as additional security measures, such as the monitoring of queries, all of them aimed at ensuring the de facto enforcement of the first set of controls. Third, legal, organisational and technical controls relating to the sharing of datasets aimed at ensuring that the first set of legal controls are transferred to recipients of datasets. They include obligations to share the datasets with the same set of obligations or an obligation not to share the datasets, as well as technical measures such as encryption to make sure confidentiality of the data is maintained during the transfer of the datasets.

These measures are used to balance the strength of data sanitisation techniques with the degree of data utility. In this sense, they are complementary to data sanitisation techniques. On one hand, they reduce residual risks, which remain

²² Opinion on Anonymisation Techniques, *supra* note 9, at 12.

after implementing data sanitisation techniques; on the other hand, they make it possible to preserve data utility while protecting the personal data of data subjects. In practice, the selection of contextual controls depends on specific data sharing scenarios.

B. Re-Identification Risks

The re-identification risks relate to ways attackers can identify data subjects within datasets. Art. 29 WP's Opinion on Anonymisation Techniques²³ describes three common risks and, examines the robustness of data sanitisation techniques against those risks.²⁴ Underlying this risk classification is the premise that the means test is a tool to 'assess whether the anonymisation process is sufficiently robust.' [There should be a footnote referring to Opinion on Anonymisation Techniques, *supra* note 9, at 8.]

- **'Singling out'**, which is the 'possibility to isolate some or all records which identify an individual in the dataset.'²⁵
- **'Linkability'**, which is the 'ability to link at least two records concerning the same data subject or a group of data subjects (either in the same database or in two different databases).'²⁶
- **'Inference'**, which is the 'possibility to deduce, with significant probability, the value of an attribute from the values of other attributes.'²⁷

In cases in which there is background knowledge, singling out makes an individual identifiable. The connection between identifiability and linkability or inference is less straightforward. Adopting a restrictive approach one could try to argue that if background knowledge exists so that it is known that an individual belongs to a grouping in a dataset, the inferred attribute(s) combined with background knowledge could lead to identification or at the very least disclosure of (potentially sensitive) information relating to an individual. Art. 29 WP categorised data sanitisation techniques into 'randomisation', 'generalisation' and 'masking direct identifiers',²⁸ where randomisation and generalisation are viewed as methods of anonymisation but masking direct identifiers or pseudonymisation (to use the words of Art. 29 WP) as a security measure. It should be clear from now that the GDPR definition of pseudonymisation is more restrictive than merely masking direct identifiers. Masking direct identifiers is conceived as a security measure by

²³ Opinion on Anonymisation Techniques, *supra* note 9, at 11–12.

²⁴ As hinted above, it maybe that this classification needs to be re-thought as for example it does not distinguish between attribute disclosure and identity disclosure. This not, however, the purpose of this paper.

²⁵ Opinion on Anonymisation Techniques, *supra* note 9, at 11.

²⁶ Opinion on Anonymisation Techniques, *supra* note 9, at 11.

²⁷ Opinion on Anonymisation Techniques, *supra* note 9, at 12.

²⁸ Opinion on Anonymisation Techniques, *supra* note 9, at 12.

Art. 29 WP because it does not mitigate the three risks aforementioned; or rather, it simply removes/masks the direct identifiers of data subjects.

‘Noise addition’, ‘permutation’ and ‘differential privacy’ are included within the randomisation group as they alter the veracity of data. More specifically, noise addition and permutation can reduce linkability and inference risks, but fail to prevent the singling out risk. Differential privacy is able to prevent all the risks up to a maximum number of queries or until the predefined privacy budget is exhausted but queries must be monitored and tracked when multiple queries are allowed on a single dataset. As regards the generalisation category, ‘K-anonymity’²⁹ is considered robust against singling out, but linkability and inference risks are still in presence. ‘L-diversity’³⁰ is stronger than K-anonymity provided it first meets the minimum criterion of k-anonymity, as it prevents both the singling out and inference risks.

Although Art. 29 WP has provided insights for the selection of appropriate data sanitisation techniques, which are relevant in the context of personal data sharing, these techniques ought to be examined in the light of the GDPR. To be clear, the purpose of this paper is not to question the conceptualisation of re-identification risks undertaken by Art. 29 WP, but to deduce its implications when interpreting the GDPR in context.

III. A Risk-based Analysis of the Three Types of Data

In this section, we refine the concept of linkability and further specify the definitions of the three categories of data emerging from the GDPR using a risk-based approach.

A. Local, Global and Domain Linkability

Analysing in a more granular fashion the linkability risk defined by Art. 29 WP, it is possible to draw a distinction between three scenarios. The first scenario focuses on a single dataset, which contains multiple records about the same data subject. An attacker identifies the data subject by linking these records using some additional information. In the second scenario, the records of a data subject are included in more than one datasets, but these datasets are held within one entity. An attacker links the records of a data subject if she can access all the datasets

²⁹ L. Sweeney ‘K-Anonymity: A Model For Protecting Privacy (2002) 10, 5 *International Journal Of Uncertainty, Fuzziness And Knowledge-Based Systems* 557.

³⁰ A Machanavajjhala et al ‘L-Diversity’ (2007) 1, 1 *ACM Transactions On Knowledge Discovery From Data*.

inside the entity, e.g., insider threat.³¹ The third scenario also involves more than one datasets, but these datasets are not necessarily held within one entity. Based on these three scenarios, we distinguish between three types of linkability risks:

- **‘Local Linkability’**, which is the ability to link records that correspond to the same data subject within the same dataset.
- **‘Domain linkability’**, which is the ability to link records that correspond to the same data subject in two or more datasets that are in the possession of the data controller.
- **‘Global Linkability’**, which is the ability to link records that correspond to the same data subject in any two or more datasets.

Based on this granular analysis of the linkability risk and assuming the concept of identifiability is used consistently across the GDPR, we suggest one way to derive the main characteristics of anonymised, pseudonymised and Art. 11 data within the meaning of the GDPR.

B. Anonymised Data

Anonymised data, according to the GDPR definition, is a state of data for which data subjects are not identified nor identifiable anymore, taking into account all the means reasonably likely to be used by the data controller as well as third parties. While strictly speaking the legal test to be found in Recital 26 of the GDPR does not mention all of the three risks aforementioned (i.e. singling out, linkability and inference), we assume for the purposes of this paper that for anonymised data to be characterised, singling out, local linkability, domain linkability, global linkability and inference should be taken into account. As aforementioned, whether the three re-identification risks should be re-conceptualised is a moot point at this stage. Suffice it note that not all singling out, linkability and inference practices lead to identifiability and identification. A case-by-case approach is therefore needed.

C. Pseudonymised Data

Pseudonymised data, being the outcome of the pseudonymisation process defined by the GDPR in its Article 4, is a state of data for which data subjects can no longer be identified or identifiable when examining the dataset at stake (and only the dataset at stake). Nevertheless, the foregoing holds true on the condition that data controllers separate the additional information and put in place “technical and

³¹ T Marianthi et al, ‘The Insider Threat To Information Systems And The Effectiveness Of ISO17799’ (2005) 24, 6 *Computers & Security* 472.

organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person.”

As a result, it appears that pseudonymisation within the meaning of the GDPR is not tantamount to masking direct identifiers. In addition, although a number of studies stress the importance of legal controls,³² there are different routes to pseudonymised data depending upon the robustness of the sanitisation technique implemented, as it is explained below.

One important element of the GDPR definition of pseudonymisation is the concept of additional information, which can identify data subjects if combined with the dataset. The definition specifies that such additional information is kept separately and safeguarded, so that the risks relating to the additional information can be excluded. This seems to suggest that in this context the notion of identifiability should only relate to the dataset at stake. Based on this analysis, we define pseudonymised data as a data state for which the risks of singling out, local linkability and inference should be mitigated. At this stage, the domain and global linkability risks are not relevant and the data controller could for example be in possession of other types of datasets.

In order to mitigate the singling out, local linkability and inference risks at the same time, data sanitisation techniques must be selected and implemented on the dataset. As aforementioned, Art. 29 WP has examined several sanitisation techniques in relation to re-identification risks.³³ We build on the upshot of the Opinion on Anonymisation Techniques, and find that K-anonymity, L-diversity and other stronger techniques can prevent these risks, but masking direct identifiers, noise addition, permutation alone are insufficient to reasonably mitigate the singling out, local linkability and inference risks.

The example below illustrates the mitigation of these three risks using K-anonymity.

Example. Table 1 shows a sanitised dataset with k-anonymity guarantee ($k = 4$) released by hospital A in May. Suppose an attacker obtains relevant background knowledge from a news website that a famous actor Bob was recently sent to hospital A and that by checking the time it can be deduced that Bob is in the dataset at stake. Suppose as well that the attacker has no access to additional information (e.g. the raw dataset). Since each group of this dataset has at least 4 records sharing the same non-sensitive attribute values, the attacker cannot distinguish his target Bob from other records. This prevents the risks of singling out and local linkability. Moreover, the attacker is not able to infer the sensitive attribute of Bob because she is not sure to which group Bob belongs. Therefore, this dataset is pseudonymised within the meaning of the GDPR.

³² See eg The Seven States of Data, *supra* 6; J Polonetsky, O Tene and K Finch ‘Shades of Gray: Seeing the Full Spectrum of Practical Data De-Identification’ (2016) 56 Santa Clara Law Review 593.

³³ Opinion on Anonymisation Techniques, *supra* note 9, at 13–21.

Table 1: An example of Pseudonymised data using k-anonymity (k = 4)

	Non-Sensitive			Sensitive
	Zip code	Age	Nationality	Diagnosis
1	250**	<30	*	Cancer
2	250**	<30	*	Viral Infection
3	250**	<30	*	AIDS
4	250**	<30	*	Viral Infection
5	250**	3*	*	Cancer
6	250**	3*	*	Flu
7	250**	3*	*	Cancer
8	250**	3*	*	Flu

D. Art. 11 Data

Art. 11 data, by definition, focuses on the ability of a data controller to identify data subjects to the exclusion of third parties. More specifically, the data controller should be able to demonstrate that she is ‘not in a position to identify the data subject’.³⁴ First, this implies that direct identifiers (e.g. names, social security number etc.) have been removed or have never been collected. In other words, Art. 11 data is either sanitised by a certain process or not. Second, ‘not being in a position to identify the data subject’ should also imply that the combination of indirect identifiers does not lead to identification. There also exist situations where the data controller only collects indirect identifiers but a very rich list of indirect identifiers for which arguably, and this is crucial, no accessible relevant background knowledge exists and the data controller is not in a possession of other datasets which could be linked to the first one, e.g. dynamic IP addresses, browsed websites and search terms, transactions ... in order to create profiles and ultimately make decisions about individuals. We suggest that while an approach purely based on a re-identification risks approach would lead to exempting data controllers from Articles 15 to 20 in these situations, this would not necessarily be consistent with the spirit of the GDPR, which aims to strengthen the protection of data subjects in cases of profiling. As a result, in order to determine whether data is personal data and the full data protection regime applies two scenarios must be taken into account: 1) whether re-identification risks have been appropriately mitigated and 2) whether profiling and decisions about individuals are made.

Importantly, the Art. 11 definition requires that to determine whether the data is Art. 11 data, all the means of the data controller should be considered to the exclusion of third parties’ means. As a result, Art. 11 data can be interpreted as a state of data for which there are no risks of singling out, domain linkability and

³⁴ GDPR, *supra* note 2, at Article 11.

inference. The protection applied to Art. 11 data is therefore stronger than the protection applied to pseudonymised data because the former requires mitigating the domain linkability rather than local linkability risk. This does not mean that pseudonymised data cannot be transformed into Art. 11 data. The example below illustrates the difference between Art. 11 and pseudonymised data.

Example. Suppose two hospitals H_1 and H_2 located in a same city publish patient data frequently, e.g., weekly. Table 2(a) is the dataset sanitised and published by H_1 using k -anonymity ($k = 4$). The dataset achieves the state of pseudonymised data as no record in the table can be attributed to a specific data subject without using additional information. Furthermore, H_1 claims that it is not able to identify any data subject using any other information within the domain/access of H_1 . This other information could be the datasets previously published by H_1 and H_2 . One week later, H_2 publishes its own patient dataset. It sanitises the data using k -anonymity ($k = 6$) and achieves the state of pseudonymised data, as shown in Table 2(b). Now H_2 wants to determine whether the dataset (Table 2(b)) is also Art. 11 data. H_2 is in possession of other information (different from the concept of additional information) comprising Table 2(a), and background knowledge deriving from a news website (which has been read by many people in the city) saying that a 28-year-old celebrity living in zip code 25013 has been sent to both H_1 and H_2 to seek a cure for his illness. H_2 thus goes through the medical records of each patient. With the other information, H_2 knows that the celebrity must be one of the four records in Table 2(a) and one of the six records in Table 2(b). H_2 is therefore able to identify the celebrity by combining Table 2(a) and Table 2(b), because only one patient was diagnosed with the disease that appears in both tables, i.e., cancer. As a result, H_2 can be sure that the celebrity matches the first record of both tables, and the celebrity has cancer. Therefore, Table 2(b) comprises pseudonymised data but not necessarily Art. 11 data.

Table 2(a): 4-anonymous patient data from H_1

	Non-Sensitive			Sensitive
	Zip code	Age	B_city	Diagnosis
1	250**	<30	*	Cancer
2	250**	<30	*	Viral Infection
3	250**	<30	*	AIDS
4	250**	<30	*	Viral Infection
5	250**	3*	*	AIDS
6	250**	3*	*	Heart Disease
7	250**	3*	*	Heart Disease
8	250**	3*	*	Viral Infection
9	250**	≥ 40	*	Cancer
10	250**	≥ 40	*	Cancer
11	250**	≥ 40	*	Flu
12	250**	≥ 40	*	Flu

Table 2(b): 6-anonymous patient data from H₂

	Non-Sensitive			Sensitive
	Zip code	Age	B_city	Diagnosis
1	250**	<35	*	Cancer
2	250**	<35	*	Tuberculosis
3	250**	<35	*	Heart Disease
4	250**	<35	*	Heart Disease
5	250**	<35	*	Flu
6	250**	<35	*	Flu
7	250**	≥35	*	Heart Disease
8	250**	≥35	*	Viral Infection
9	250**	≥35	*	Flu
10	250**	≥35	*	Flu
11	250**	≥35	*	Flu
12	250**	≥35	*	Flu

We summarise the three types of data based on the risks aforementioned in the following table.

Table 3: Risk-based interpretation for three types of data

	Singling out	Local linkability	domain linkability	Global linkability	Inference
Anonymised data	No	No	No	No	No
Art. 11 data	No	No	No	N/A	No
Pseudonymised data	No	No	N/A	N/A	No

IV. Data Sanitisation Techniques and Contextual Controls

We now examine the robustness of data sanitisation techniques against the five types of re-identification risks. Taking into account data sharing contexts, we present a hybrid assessment comprising both contextual controls and data sanitisation techniques.

A. Effectiveness of Data Sanitisation Techniques

We build upon the table of data sanitisation techniques presented by Art. 29 WP³⁵ by splitting the linkability risk into local and global linkability.

³⁵ Opinion on Anonymisation Techniques, supra note 9, at 24.

At this stage, domain linkability is not explicitly shown in the table as it is included in global linkability. The table below summarises the results.

Table 4: Robustness of data sanitisation techniques

	Is singling out still a risk?	Is local linkability still a risk?	Is domain/global linkability still a risk?	Is inference still a risk?
Masking direct identifiers	Yes	Yes	Yes	Yes
Noise Addition	Yes	May not	May not	May not
Permutation	Yes	Yes	Yes	May not
Masking indirect identifiers	Yes	Yes	Yes	May not
K-anonymity	No	No	Yes	Yes
L-diversity	No	No	Yes	May not
Differential privacy	May not	May not	May not	May not

Note that domain linkability is in the same column as global linkability, because for both situations external datasets need to be taken into account and the listed data sanitisation techniques are not able to distinguish between different types of domains. While one should revert to explanations provided by Art. 29 WP³⁶ for the analysis of the singling out and inference risks, we then discuss the robustness of sanitisation techniques in relation to local, domain and global linkability risks.

Masking direct identifiers. Applying the techniques, such as encryption, hashing and tokenisation on direct identifiers, can reduce linkability between a record and the original identity of a data subject (e.g., name). However, it is still possible to single out data subjects' records with the pseudonymised attributes. If the same pseudonymised attribute is used for the same data subject, then records in one or more datasets can be linked together. If different pseudonymised attributes are used for the same data subject and there is at least one common attribute between records, it is still possible to link records using other attributes. Therefore, the local, domain and global linkability risks exist in both situations.

Noise Addition. This technique adds noise to attributes, making the values of such attributes inaccurate or less precise. However, this technique cannot mitigate local, domain and global linkability risks. Indeed, this technique only reduces the reliability of linking records to data subjects as the values of attributes are more ambiguous. Records may still be linked using wrong attribute values.

Permutation. Permutation is a technique that consists in shuffling values of attributes within a dataset. More specifically, it swaps values of attributes among

³⁶ Opinion on Anonymisation Techniques, *supra* note 9, at 13–21.

different records. It can be considered as a special type of noise addition³⁷ though it retains the range and distribution of the values. Therefore, it is still vulnerable to the local, domain and global linkability risks based on the shuffled values of attributes, although such linking may be inaccurate as an attribute value may be attached to a different subject.

K-anonymity. As the main technique of the generalisation family, K-anonymity is applied to prevent singling out. They group a data subject with at least $k-1$ other individuals who share a same set of attribute values.³⁸ These techniques are able to prevent local linkability, because the probability of linking two records to the same data subject is no more than $1/k$. However, they are not able to mitigate the domain and global linkability risks. As shown in our example of the two hospitals, records relating to the celebrity can be linked together via an intersection attack.³⁹

L-diversity. Compared with K-anonymity, the significant improvement of L-diversity is that it ensures the sensitive attribute in each equivalence class has at least L different values.⁴⁰ Thus, it prevents the risk of inference to the probability of no more than $1/L$. However, like K-anonymity, it cannot prevent domain and global linkability as shown in our example of two hospitals because it is still possible to link records together if they have the same sensitive attribute values.

Differential privacy. Differential privacy is one of the randomisation techniques that can ensure protection in a mathematical way by adding a certain amount of random noise to the outcome of queries.⁴¹ Differential privacy means that it is not possible to determine whether a data subject is included in a dataset given the query outcome. In the situation where multiple queries on one or more datasets are allowed, the queries must however be tracked and the noise should be tuned accordingly to ensure attackers cannot infer more information based on the outcomes of multiple queries. Therefore, “May not” is assigned for the risks depending on whether queries are tracked.

Masking indirect identifiers. As described before, encryption, hashing and tokenisation are the techniques for masking direct identifiers. They can also be implemented on indirect identifiers. We observe that these techniques are not able to mitigate the risks of local, domain and global linkability. Taking a dataset with three quasi-identifiers—gender, address and date of birth, for example, a hash function encrypts the combination of the three quasi-identifiers. If there are two records in the dataset (or different datasets) corresponding to a same data subject, then they will have the same hashed values for these three attributes.

³⁷ Opinion on Anonymisation Techniques, *supra* note 9, at 13.

³⁸ Latanya Sweeney, ‘K-Anonymity: A Model For Protecting Privacy,’ (2002) 10/05 *International Journal Of Uncertainty, Fuzziness And Knowledge-Based Systems* 557.

³⁹ Srivatsava Ranjit Ganta, Shiva Prasad Kasiviswanathan and Adam Smith, ‘Composition Attacks And Auxiliary Information In Data,’ *Proceeding Of The 14Th ACM SIGKDD International Conference On Knowledge Discovery And Data Mining—KDD 08*, (2008).

⁴⁰ Ashwin Machanavajjhala and others, ‘L-Diversity,’ *ACM Transactions On Knowledge Discovery From Data*, 1/1 (2007): 3-es.

⁴¹ Cynthia Dwork, ‘Differential Privacy: A Survey Of Results,’ in *In International Conference On Theory And Applications Of Models Of Computation* (Berlin Heidelberg, 2008) 1.

We now combine our risk-based interpretation of three types of data (Table 3) with the foregoing analysis of the robustness of data sanitisation techniques (Table 4), in order to classify the output of different techniques into three types of data.

Table 5: The results of data sanitisation techniques

Techniques	Pseudonymised data	Art. 11 data	Anonymised data
Masking direct identifiers	Not	Not	Not
Noise Addition	Not	Not	Not
Permutation	Not	Not	Not
Masking indirect identifiers	Not	Not	Not
K-anonymity	Not	Not	Not
L-diversity	Yes	Not	Not
Differential Privacy	Maybe	Maybe	Maybe

As the first four techniques are not able to mitigate the risk of singling out, the outcome of these four techniques cannot be pseudonymised data, Art. 11 data, or anonymised data. For K-anonymity, it cannot produce any of these three data types because it only mitigates singling out and local linkability to the exclusion of inference when additional information is isolated and safeguarded. Notably, background knowledge is taken into account. Data after implementing L-diversity is pseudonymised data because it can mitigate singling out, local linkability, and inference, but not domain linkability or global linkability. As for Art. 11 data, L-diversity does not mitigate against the fact that data controllers have within their domain other datasets, which can be used to link records together. Hence, “Not” is assigned. Differential privacy can guarantee Art. 11 data, pseudonymised data or anonymised data if only single query on one dataset is allowed or multiple queries are tracked.

So far, we have classified data sanitisation techniques with respect to the three types of data. It is worth mentioning that data sanitisation techniques are often combined in practice. Table 5 derives the sanitisation outcome in situations where two or more techniques are implemented. For example, (K, L)—anonymity⁴² combining K-anonymity and L-diversity, ensures that each equivalent class has at least K records, and their sensitive attributes have at least L different values. (K, L)—anonymity guarantees that there are no risks of singling out, local linkability and inference.

⁴² J-W Byun et al ‘Privacy-Preserving Incremental Data Dissemination’ (2009) 17, 1 *Journal Of Computer*: 43.

B. Improving Data Utility with Contextual Controls

Maintaining an appropriate balance between data utility and data protection is not an easy task for data controllers. As discussed in Section 4.1, K-anonymity, L-diversity and differential privacy are the sole potential techniques that can make data pseudonymised, Art. 11 or anonymised data. However, these techniques could introduce undesired distortion on data, making data less useful for data analysts. Contextual controls are thus crucial to complement data sanitisation techniques and reduce risks.⁴³ Obviously, the strength of the contextual control to add should depend upon the type of data sharing scenarios at hand.

In order to take into account the variety of data sharing scenarios, we distinguish between two types of contextual legal controls: ‘**inter-party**’ and ‘**internal controls**’. The former category comprises obligations between parties (i.e. data collector/data releaser and data recipient), and the latter comprises internal policies adopted within one entity, i.e. one party. As shown in Table 6, the top rows of controls are meant to directly address the re-identification risks. The middle rows list the controls used to ensure that the first set of controls are actually implemented. More specifically, security measures are measures that relate to location of storage, access to data, auditing, training of staff and enforcement of internal policies. Additional security measures are associated with differential privacy only and are required to guarantee differential privacy mitigates all the risks. The third set of controls is essential when data are shared in order to make sure recipients of datasets put in place the necessary controls to maintain the dataset within its initial category: depending upon the sensitivity of the data they take the form of obligations/policies not to share the data or an obligation to share the data alike, i.e. with the same controls. Technical measures, such as encryption, can complement these obligations to make sure confidentiality of the data is maintained during the transfer of the dataset to the recipients.

Table 6: Inter-party (obligations) and Internal (policies) controls

1. Mitigating risks directly	<i>Singling out risk</i>
	— Obligation/Policy to isolate info to de-mask direct identifiers with security measures in relation to location of storage, access to formula, training of staff and enforcement of rules
	— Obligation/Policy not to identify from indirect identifiers
	<i>Local linkability risk</i>
	— Obligation/Policy not to link records in the same dataset
	<i>domain linkability risk</i>
	— Obligation/Policy not to link with other datasets within the same domain

(continued)

⁴³ Leibniz Institute for Educational Trajectories (LifBi), *Star Ng Cohort 6: Adults (SC6) SUF Version 7.0.0 Anonymiza On Procedures Tobias Koberg*, (2009) <https://www.neps-data.de/Portals/0/NEPS/Datenzentrum/Forschungsdaten/SC6/7-0-0/SC6_7-0-0_Anonymization.pdf> [accessed 13 March 2017].

Table 6: (Continued)

	<i>Global linkability risk</i> — Obligation/Policy not to link with other datasets
	<i>Inference risk</i> — Obligation/Policy not to infer attributes from existing attributes
2. Enforcing the mitigation	<i>Security measures</i> — Obligation/Policy to implement security measures in relation to location of storage, access to dataset, auditing, training of staff and enforcement of internal policy rules
	<i>Additional security measures</i> — Obligation/Policy to monitor queries and query outcome after applying differential privacy
3. Transferring controls	— Obligation/Policy not to re-share or to re-share with the same set of obligations — Obligation/Policy to share data in an encrypted state, e.g., through an encrypted communication channel

It is now time to combine data sanitisation techniques and contextual controls to determine when and how it is possible to maintain data utility. This is the objective of Tables 7 and 8.

Two types of actors are distinguished to take into account the implications of data sharing scenarios: *data collectors*, who collect original data and transform the data in certain data types before sharing the data; and *data recipients*, who receive processed data and may have to implement controls in order to ensure the data remain within the desired data category. Table 7 only concerns data collectors. This is why no inter-party controls are considered.

Table 7: Sanitisation options when data are in the hands of data collectors

Desired data type	Sanitisation options
Pseudonymised data	— Masking direct identifiers + Policies on singling out, local linkability and inference risks + Security measures — K-anonymity + Policy on inference risk + Security measures — L-diversity + Security measures
Art. 11 data	— Masking direct identifiers/Collecting only indirect identifiers + Policies on singling out, domain linkability risks + Security measures — K-anonymity + Policies on inference and domain linkability risks + Security measures — L-diversity + Policy on domain linkability risk + Security measures

(continued)

Table 7: *(Continued)*

Desired data type	Sanitisation options
Anonymised data	— Masking direct identifiers + Policies on singling out, local, global linkability and inference risks + Security measures — K-anonymity + Policies on inference and global linkability risks + Security measures — L-diversity + Policies on global linkability risk + Security measures — Differential privacy + Security measures + Additional security measures

In the first row of the table, data fall into the category of pseudonymised data when the singling out, local linkability and inference risks have been mitigated. When implementing a weak sanitisation technique only, i.e. masking direct identifiers, those risks still persist as explained above and contextual controls are therefore needed. Stronger data sanitisation techniques, such as K-anonymity and L-diversity, mitigate more risks, which explains why fewer and/or weaker contextual controls are needed. For instance, when L-diversity is implemented, only security measures are required for achieving pseudonymised data.

In the end the selection of data sanitisation techniques and contextual controls should depend on the type of data sharing scenario pursued (closed or open) given both the sensitivity and the utility of the data. Data in the second category, i.e. Art. 11 data, implies that the data controller is able to demonstrate that she is not in a position to identify data subjects. The listed options ensure that there are no singling out, domain linkability and inference risks. Data in the final category is anonymised data, which require the strongest protection, i.e. that no singling out, local and global linkability and inference risks exist. Differential privacy is one of the options, and only security measures are required when differential privacy is implemented.

Table 8 concerns data recipients. As for data recipients who receive processed data, they should take into account (i) the data sanitisation techniques that have been implemented on the received data, and (ii) the obligations imposed by data releasers.

Table 8 provides a number of sanitisation options that data recipients can select to meet their data protection and utility requirements. We take pseudonymised data as an example. Suppose a data recipient receives data that were processed with K-anonymity techniques and she aims to keep the data in a pseudonymised state. The data recipient has thus two options. Either she does not change the data and simply adopt policies and security measures; or she further processes the data with L-diversity, and adopt different types of policies as well as security measures.

Another consideration is worth mentioning. If the data collector keeps the original raw dataset, the original raw dataset should be conceived as falling within the category of additional information for the purposes of characterising personal

Table 8: Sanitisation options when data are in the hands of data recipients

Desired data type	Sanitisation techniques implemented on received data	Obligations imposed upon data recipients	Sanitisation options
Pseudonymised data	Masking direct identifiers	Obligations on singling out, local linkability and inference risks + obligation on implementing security measures	— Policies on singling out, local linkability and inference risks + Security measures — K-anonymity + Policy on inference risk + Security measures — L-diversity + Security measures
	K-anonymity	Obligation on inference risk + obligation on implementing security measures	— Security measures — L-diversity + Security measures
	L-diversity	Obligation on implementing security measures	— Security measures
Art. 11 data	Masking direct identifiers	Obligations on singling out, inference, local and domain linkability risks + obligation on implementing security measures	— Policies on singling out, inference, local and domain linkability risks + Security measures — K-anonymity + Policies on inference, domain linkability risks + Security measures — L-diversity + Policy on domain linkability risk + Security measures
	K-anonymity	Obligations on inference and domain linkability risks + obligation on implementing security measures	— Policies on inference and domain linkability risks + Security measures — L-diversity + Policy on domain linkability risk + Security measures

(continued)

Table 8: *(Continued)*

	L-diversity	Obligation on domain linkability risk + obligation on implementing security measures	— Policy on domain linkability risk + Security measures
Anonymised data	Masking direct identifiers	Obligations on singling out, local, global linkability and inference risks + obligation on implementing security measures	— Policies on singling out, local, global linkability and inference risks + Security measures — K-anonymity + Policies on inference and global linkability risks + Security measures — L-diversity + Policy on global linkability risk + Security measures — Differential privacy + Security measures + Additional security measures
	K-anonymity	Obligations on inference and global linkability risks + obligation on implementing security measures	— Policies on global linkability and inference risks + Security measures — L-diversity + Policy on global linkability risk + Security measures — Differential privacy + Security measures + Additional security measures
	L-diversity	Obligation on global linkability risk + obligation on implementing security measures	— Policy on global linkability risk + Security measures — Differential privacy + Security measures + Additional security measures
	Differential privacy	Obligation on implementing security measures	— Security measures + Additional security measures

data and within the category of the data controller's domain for the purposes of characterising Art. 11 data. As regards anonymised data, Art. 29 WP seems to suggest that as long as the raw dataset is not destroyed the sanitised dataset cannot be characterised as anonymised data.⁴⁴ Applying a risk-based approach of the type developed in this paper would lead to the opposite result. This said, and this is essential, this would not mean that the data controller transforming and releasing the raw dataset into anonymised data would not be subject to any duty anymore. It would actually make sense to impose upon the data controller a duty to make sure recipients of the dataset put in place the necessary contextual controls. This duty could be performed by imposing upon recipients an obligation not to share the dataset or to share the dataset alike, depending upon data sensitiveness and data utility requirements. Ultimately, the data controller would also be responsible for choosing the appropriate mix of sanitisation techniques and contextual controls as the anonymisation process as such is still a processing activity governed by the GDPR. Data controllers could thus be required to monitor best practices in the field even after the release of the anonymised data.

Finally it should be added that the foregoing analysis implies a relativist approach to data protection law, which would require determining the status of a dataset on a case-by-case basis and thereby for each specific data sharing scenario.

C. Improving Data Utility with Dynamic Sanitisation Techniques and Contextual Controls

Re-identification risks are not static and evolve over time. This should mean that data controllers should regularly assess these risks and take appropriate measures when their increase is significant. Notably, adapting sanitisation techniques and contextual controls over time can help reduce re-identification risks. At least one dynamic sanitisation technique is worth mentioning here: changing pseudonyms over time for each use or each type of use as a way to mitigate linkability.⁴⁵ Besides, techniques like k-anonymity and l-diversity can also be conceived as dynamic techniques as deploying k or l on the same dataset for new recipients can provide stronger protection when the data controller observes that re-identification risks increase.

At the same time, data recipients should be aware of the limits imposed upon the use of the data, even if the data is characterised as anonymised. This is a logical counterpart to any risk-based approach and necessarily implies that data

⁴⁴ Opinion on Anonymisation Techniques, *supra* note 9, at 10.

⁴⁵ M Hintze and G LaFever 'Meeting Upcoming GDPR Requirements While Maximizing The Full Value Of Data Analytics' (2017) <https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2909121> [accessed March 13, 2017]. See also J Almeida et al 'Big Data In Healthcare And Life Sciences Anonos Bigprivacy Technology Briefing' (2017) <https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2941953> [accessed April 12, 2017].

controllers and data recipients are in continuous direct contact, at least when differential privacy is not opted for. Indeed, contextual controls put in place for mitigating risks directly (in order to preserve data utility) could be coupled with confidentiality obligations and/or confidentiality policy, be it relative (i.e. formulated as an obligation to share alike) or absolute (i.e. formulated as a prohibition to share). Importantly, taking confidentiality obligations seriously would then make it possible to then assess the likelihood of the singling out, linkability and inference risks leading to re-identification and could make certain types of singling out, linking and inferring practices possible, as long as the purpose of the processing is not to re-identify data subjects and there is not a reasonable likelihood that the processing will lead to re-identification. It is true, nevertheless that the choice of confidentiality obligations coupled with weak sanitisation techniques can prove problematic if datasets are shared with multiple parties, even if each receiving party agrees to be bound by confidentiality obligations and adopt internal policies for this purpose. Obviously, access restrictions techniques and policies are a crucial means to make sure confidentiality obligations and policies are performed and/or implemented in practice.

Notably, while in the Breyer case of 2016 the CJEU interpreting the notion of ‘additional data which is necessary in order to identify the user of a website’ considered the information held by the user’s internet access provider, the CJEU recognised the importance of legal means in order to characterise personal data.⁴⁶ We suggest contractual obligations should be taken seriously into consideration in particular when they are backed up by technical measures such as measures to restrict access and dynamic measures to mitigate linkability.

V. Conclusion

The purpose of this paper was to test the possibility of interpreting the GDPR and Art. 29 WP’s Opinion on Anonymisation Techniques together, assuming the concept of identifiability has two legs (identified and identifiable), the three risks of singling out, linkability and inference are relevant for determining whether an individual is identifiable and the concept of identifiability is used consistently across the GDPR. On the basis of an interdisciplinary methodology, this paper therefore builds a common terminology to describe different data states

⁴⁶ CJEU, C-582/14, Patrick Breyer v Bundesrepublik Deutschland, 19 October 2016, EU:C:2016:779. See in particular paragraph 39 where the CJEU, interpreting the DPD, states: ‘Next, in order to determine whether, in the situation described in paragraph 37 of the present judgment, a dynamic IP address constitutes personal data within the meaning of Article 2(a) of Directive 96/45 in relation to an online media services provider, it must be ascertained whether such an IP address, registered by such a provider, may be treated as data relating to an ‘identifiable natural person’ where the additional data necessary in order to identify the user of a website that the services provider makes accessible to the public are held by that user’s internet service provider.’

and derive the meaning of key concepts emerging from the GDPR: anonymised data, pseudonymised data and Art. 11 data. It then unfolds a risk-based approach, which is suggested to be compatible with the GDPR, by combining data sanitisation techniques and contextual controls in an attempt to effectively balance data utility and data protection requirements. The proposed approach relies upon a granular analysis of re-identification risks expanding upon the threefold distinction suggested by Art. 29 WP in its Opinion on Anonymisation Techniques. It thus starts from the three common re-identification risks listed as relevant by Art. 29 WP, i.e. singling out, linkability and inference and further distinguishes between local, domain and global linkability to capture the key concepts of additional information and pseudonymisation introduced in the GDPR and comprehend the domain of Article 11 as well as the implications of Recital 26. Consequently, the paper aims to make it clear that even if a restrictive approach to re-identification is assumed, the GDPR makes the deployment of a risk-based approach possible: Such an approach implies the combination of both contextual controls and sanitisation techniques and thereby the adoption of a relativist approach to data protection law. Among contextual controls, confidentiality obligations are crucial in order to reasonably mitigate re-identification risks.

References

- Almeida, J, Clouston, S. LaFever, G. Myerson, T and S Pulim 'Big Data In Healthcare And Life Sciences Anonos Bigprivacy Technology Briefing', (2017) Available at https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2941953.
- Article 29 Data Protection Working Party, Opinion 05/2014 on Anonymisation Techniques, European Comm'n, Working Paper No. 216, 0829/14/EN(2014).
- Byun, J-W, Li, T Bertino, E Li, N and Y Sohn 'Privacy-Preserving Incremental Data Dissemination' (2009) 17, 1 *Journal Of Computer Security*: 43–68.
- Dalenius, T, 'Finding a needle in a haystack or identifying anonymous census records' (1986) 2, 3 *Journal of official statistics*: 329–336.
- Dwork, C 'Differential Privacy: A Survey Of Results' *International Conference On Theory And Applications Of Models Of Computation* (Berlin Heidelberg, 2008): 1–19.
- Hintze, M 'Viewing The GDPR Through A De-Identification Lens: A Tool For Clarification And Compliance' (2017) Available at https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2909121.
- Hintze, M and G LaFever 'Meeting Upcoming GDPR Requirements While Maximizing The Full Value Of Data Analytics' (2017) Available at https://papers.ssrn.com/sol3/papers.cfm?abstract_id=2909121.
- El Emam, K 'Heuristics For De-Identifying Health Data (2008) 6, 4' *IEEE Security & Privacy Magazine*: 58–61.
- El Emam, K and C Álvarez 'A critical appraisal of the Article 29 Working Party Opinion 05/2014 on data anonymization techniques' (2015) 5, 1 *International Data Privacy Law*: 73–87.

- El Emam, K Gratton, E Polonetsky, J and L Arbuckle 'The Seven States of Data: When is Pseudonymous Data Not Personal Information?' Available at <https://fpf.org/wp-content/uploads/2016/05/states-v19-1.pdf>.
- Information Commissioner's Office, *Anonymisation: Managing Data Protection Risk Code Of Practice* (2012).
- International Organization for Standardization, *ISO/TS 25237:2008 Health Informatics—Pseudonymization*, 2008 Available at <https://www.iso.org/standard/42807.html>.
- Leibniz Institute for Educational Trajectories (LifBi), Star Ng Cohort 6: Adults (SC6) SUF Version 7.0.0 Anonymiza On Procedures Tobias Koberg, (2009) Available at https://www.neps-data.de/Portals/0/NEPS/Datenzentrum/Forschungsdaten/SC6/7-0-0/SC6_7-0-0_Anonymization.pdf.
- Machanavajjhala, A, Kifer, D, Gehrke, J and M Venkitasubramaniam, 'L-Diversity (2007) 1, 1 *ACM Transactions On Knowledge Discovery From Data*.
- Marianthi, T, Kokolakis, S, Karyda, M and E Kiountouzis 'The Insider Threat To Information Systems And The Effectiveness Of ISO17799' (2005) 24, 6 *Computers & Security*: 472–484.
- Polonetsky, J Tene, O and K Finch 'Shades of Gray: Seeing the Full Spectrum of Practical Data De-Identification' (2016) 56, 3 *Santa Clara Law Review*: 593–629.
- Ranjit G Kasiviswanathan, S and A Smith 'Composition Attacks And Auxiliary Information In Data Privacy (2008) *Proceeding Of The 14Th ACM SIGKDD International Conference On Knowledge Discovery And Data Mining—KDD 08*.
- Schwartz, PM. and DJ Solove 'The PII problem: Privacy and a new concept of personally identifiable information' (2011) 86 *New York University Law Review*: 1814–1894.
- Stalla-Bourdillon, S and A Knight 'Anonymous data v. Personal data—A false debate: An EU perspective on anonymisation, pseudonymisation and personal data' (2017) *Wisconsin International Law Journal*: 284–322.
- Sweeney, L 'K-Anonymity: A Model For Protecting Privacy' (2002) 10, 5 *International Journal Of Uncertainty, Fuzziness And Knowledge-Based Systems*: 557–570.

6

Are We Prepared for the 4th Industrial Revolution? Data Protection and Data Security Challenges of Industry 4.0 in the EU Context

CAROLIN MOELLER

Abstract. The focus of this paper is to assess the relevance of data in the Industry 4.0 (IND 4.0) context and its implications on data protection and data security. IND 4.0 refers to the rearrangement of industrial production processes where single devices, machines and products themselves are increasingly interconnected via the internet and autonomously communicate with each other along the production chain. IND 4.0 primarily presents two data protection challenges. The first challenge exists along the producer-consumer nexus. For example, in some cases smart factories process customer data generated by products to directly influence the production process. The second data protection challenge exists along the employer-employee nexus. To optimise processes and to secure the company's network, new monitoring mechanisms are introduced in smart companies, which make use of vast amounts of data generated by humans and machines. Ultimately, IND 4.0 also presents data security challenges. While data security is an aspect of data protection, it also goes beyond that since data security measures also protect non-personal data. The latter is especially relevant for smart factories since trade secrets are protected and competitiveness can be maintained. Thus, data security is critical to the success of IND 4.0.

Key words: *Industry 4.0—smart machines—cyber-physical systems—GDPR—NIS Directive.*

I. Introduction

The emergence of the Internet of Things (IoT) led to widespread discussions among the public and the academic community about possible privacy concerns. The often-quoted example of the 'smart home' exemplifies the widespread concern about the amount of personal and sensitive data that 'things' are able to collect and process. The aim of this paper is to focus on Industry 4.0 (IND 4.0), which

can be considered to be a manufacturing-related subset of IoT. More specifically, IND 4.0 constitutes an incremental paradigm change in the manufacturing sector, which already started but is perceived to further evolve over the next two decades. While legal regulation is still at its infancy, the concept refers to the rearrangement of industrial production processes where single devices, machines and the products themselves are increasingly interconnected via the internet and autonomously communicate with each other along the production chain. While communicating with each other, the so-called 'smart machines' do not only exchange information -which is the case for Electronic Data Interchange- but also steer each other autonomously and trigger actions independently. Companies that apply this new form of organising production processes have been termed 'smart factory' and operate with cyber-physical systems. 'Cyber-physical systems' are systems where physical systems -such as machines, devices and products- are linked to each other through communication networks. While in traditional systems physical devices and machines are locally operated and controlled mostly by humans, in cyber-physical networks they are coupled by communication networks. This allows not only remote operation and control by humans but also the increasing control of machines by machines. In smart factories, this implies a restructuring of the interaction between humans, machines and networks. This not only has an impact on technology itself, but revolutionises companies according to three other parameters: data, business models and legal frameworks.

The focus of this paper is to assess the increasing relevance of data in the IND 4.0 context and its implications on data protection and data security in the EU context. Industry 4.0 primarily presents two data protection challenges. The first challenge exists along the customer-producer nexus: for example, in some cases smart factories process customer data to directly influence the production process. The second data protection challenge exists along the employer-employee nexus. To optimise processes and to secure a smart factory's network, new monitoring mechanisms are introduced, which make use of vast amounts of data generated by humans and machines. Ultimately, IND 4.0 also presents data security challenges. While data security can be regarded as an aspect of data protection, it also goes beyond that since it also protects non-personal data. The latter is especially relevant for protecting trade secrets, which EU legislation acknowledges as an important tool to foster innovation and competitiveness in the internal market.¹ The close relation of both concepts needs to be minded. As will be explained in section 3, the security of personal and non-personal data is critical to the success of IND 4.0.

This paper is divided into four main parts. As IND 4.0 is a broad and new concept that is linked to several other concepts, the second section provides a definition of IND 4.0. The third section discusses the relevance of data protection for customers and employees in the IND 4.0 context and establishes which new threats to privacy

¹ Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets) against their unlawful acquisition, use and disclosure.

emerge and how they are addressed on the EU level. The fourth section discusses data security challenges related to IND 4.0 and how they are addressed on EU level. Both the third and the fourth section discuss the current and the future regulatory framework. Ultimately a conclusion sums up the findings of this chapter.

II. Defining IND 4.0—The Regulatory Use and Key Features of a Sui Generis Concept

A. IND 4.0 as a Regulatory Tool and as a Sui Generis Concept

IND 4.0 is a regulatory concept that originated in Germany whilst at the same time being a *sui genesis* concept. This differentiation is important since it implies that not only German manufactures are concerned due to national regulatory priorities, but also manufacturers in other EU countries can be affected by IND 4.0.

Industrial policy has regained prominence in the last years on national and EU levels particularly since it is regarded as a promising way out of the financial crisis. However, regulatory efforts need to take the new realities of industrial policy into account. Accordingly, recent policy initiatives have emphasised the impact of technological advancement on the manufacturing sector. While in several countries—such as the US,² the UK,³ Spain,⁴ Austria⁵ and France⁶—policy measures and industry-driven initiatives have been adopted to address the “technologisation” of the manufacturing sector, Germany is an example of a country with a very profound approach. The term IND 4.0 is believed to have appeared for the first time in the German government’s 2006 High Tech Strategy.⁷ Subsequently, multiple characteristics of Industry 4.0 were spelt out in Germany’s industrial policy in 2010⁸ and in 2012 the government declared

² In the US, several industry-led initiatives on “Advanced manufacturing” emerged, such as the “Manufacturers Alliance for Productivity and Innovation” (MAPI), the Smart Manufacturing Leadership Coalition (SMLC) and the Industrial Internet Consortium (IIC).

³ In the UK, several governmental and industry-led initiatives have been adopted: For instance: The Future of Manufacturing: A new era of opportunity and challenge for the UK’ (2013). Project report. The Government Office for Science, London. See also: Manufacturing Britain’s Future (2015). Report for the Manufacturers Organisation.

⁴ Spanish Strategy for Science and Technology and Innovation. Available at: http://www.idi.mineco.gob.es/stfls/MICINN/Investigacion/FICHEROS/Spanish_Strategy_Science_Technology.pdf.

⁵ In June 2015, the Ministry founded together with various industrial umbrella organisations a platform called “Industrie 4.0 Österreich—die Plattform für intelligente Produktion” (Industry 4.0 Austria—The platform for intelligent production).

⁶ La Nouvelle France Industrielle (2013). Retrieved from: <http://www.economie.gouv.fr/>.

⁷ K Bledowski, *MAPI The Internet of Things: Industrie 4.0 vs. The Industrial Internet*, 2015.

⁸ Federal Ministry of Economics and Technology, *In focus: Germany as a competitive industrial nation. Building on strengths—Overcoming weaknesses—Securing the future*, 2010.

IND 4.0 to be a future project under the German High-Tech Strategy.⁹ Based on that, the German Ministry of Education and Research set up a working group consisting of representatives from industry, academia, and science. In 2013, the working group published a final report outlining eight priorities of an IND 4.0 strategy including, among others, the delivery of a comprehensive broadband infrastructure for industry, safety and security as critical factors for the success of IND 4.0, and a sound regulatory framework.¹⁰

While rooted in Germany, IND 4.0 is also indirectly a regulatory priority at EU level, where it is dealt with under EU industrial policy.¹¹ While not specifically referring to IND 4.0, the EU Commission discusses industrial innovation by arguing that advanced manufacturing systems can provide the basis for new processes and new industries and ultimately enhance competitiveness.¹² Furthermore, it has been stressed that ‘the integration of digital technologies in the manufacturing process will be a priority for future work in light of the growing importance of the industrial internet. The use of big data will be increasingly integrated in the manufacturing process.’¹³ Most recently, IND 4.0 was also scrutinised in a study conducted by the European Parliament.¹⁴

In light of the regulatory importance granted to IND 4.0 on both national and EU levels, it can be considered to be a normative *regulatory* concept in that it describes ‘(...) the framework for a range of policy initiatives identified and supported by government and business representatives that drive a research and development programme.’¹⁵

Besides being a regulatory tool, IND 4.0 can also be described as a series of disruptive innovations in production and leaps in industrial processes resulting in significantly higher productivity.¹⁶ In fact, the reason for labelling the concept ‘IND 4.0’ is related to its revolutionary character. More specifically, IND 4.0 is deemed to be the fourth revolution in the history of industrialisation, following the first industrial revolution (resulting from the combination of steam power and mechanical production), the second industrial revolution (resulting from the combination of electricity and assembly lines), and the third industrial revolution

⁹ Bundesregierung, *Die neue Hightech-Strategie. Innovationen für Deutschland*, 2014.

¹⁰ http://www.acatech.de/fileadmin/user_upload/Baumstruktur_nach_Website/Acatech/root/de/Material_fuer_Sonderseiten/Industrie_4.0/Final_report__Industrie_4.0_accessible.pdf p. 39.

¹¹ Article 173 TFEU.

¹² Communication from the Commission to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions. An Integrated Industrial Policy for the Globalisation Era Putting Competitiveness and Sustainability at Centre Stage COM(2010) 614 final, p.13 Reiterated in: Communication (EC) No. 582 final, *A Stronger European Industry for Growth and Economic Recovery* Industrial Policy Communication Update, 2012.

¹³ Communication (EC) For a European Industrial Renaissance, COM/2014/014 final, p. 10.

¹⁴ *Industry 4.0*. Study prepared by the Centre for Strategy and Evaluation Services for the ITRE Committee. Directorate General for Internal Policies Policy Department A: Economic and Scientific Policy. Available at: www.europarl.europa.eu/studies. Hereinafter, “EP Study on Industry 4.0 (2016)”.

¹⁵ EP Study on Industry 4.0 (2016).

¹⁶ EP Study on Industry 4.0 (2016); see also: German Federal Ministry of Education and Research, *Project of the Future: Industry 4.0*.

(resulting from the combination of electronics/IT and globalisation). The fourth one is marked by the combination of intelligent factories with every part of the production chain.¹⁷ Thus, IND 4.0 is also the mere conceptualisation of a manufacturing *trend* that has started around 2010¹⁸ and is constantly evolving and defining itself. As such, IND 4.0 is not a completely new concept, which is distinct from industrial developments over the last two decades. It is rather an incremental evolution, where data slowly but steadily gained relevance in manufacturing. Based on the foregoing analysis, IND 4.0 can be considered to be both a *sui generis* evolution and a *normative*, regulatory concept. It has to be noted that in this paper a dual meaning is applied by minding on the one hand the *sui generis* character of IND 4.0 in order to stress the relevance of IND 4.0 beyond Germany and on the other hand by minding its regulatory value, which is important for regulating such a dynamic concept as IND 4.0. In the subsequent section a more detailed explanation of the practical meaning of IND 4.0 is provided.

B. Conceptual Features of IND 4.0

When outlining the key characteristics of IND 4.0, it is important to keep in mind that these features are a conglomerate of observations of the current manufacturing environment as well as elements that ought to be features of a fully operational IND 4.0 environment. As such, the following description of the conceptual features of IND 4.0 need to be understood both as factual and normative. IND 4.0 describes a 'set of technological changes in manufacturing and sets out priorities of a coherent policy framework with the aim of maintaining global competitiveness (...).'¹⁹ Furthermore, IND 4.0 describes the 'organisation of production processes based on technology and devices autonomously communicating with each other along the value chain.'²⁰ This means that the manufacturing industry increasingly integrates information and communication technology (ICT) in the production process blurring the boundaries between the real and the virtual world. This hybrid operating system functions in a similar way as a social network, where the nodes of the network are social machines that communicate with each other via a network.²¹ Whilst being applied by modern manufacturers, the hybrid operating system has been called cyber-physical production systems (CPPSs).²²

¹⁷ *ibid.*

¹⁸ S Harris, *Industry 4.0: the next industrial revolution*, (The engineer, 11 July 2013). Retrieved 16.03.2016 from: <http://www.theengineer.co.uk/industry-4-0-the-next-industrial-revolution/>.

¹⁹ EP Study on Industry 4.0 (2016).

²⁰ EP Study on Industry 4.0 (2016).

²¹ Forschungsunion & acatech, *Umsetzungsempfehlungen für das Zukunftsprojekt Industrie 4.0 Abschlussbericht des Arbeitskreises Industrie 4.0, 2013*. Retrieved 16.03.2016 from: https://www.bmbf.de/files/Umsetzungsempfehlungen_Industrie4_0.pdf, p. 66.

²² *Industry 4.0—Challenges and Solutions for digital transformation and use of exponential technologies*. Retrieved 03.02.2016 from <http://www2.deloitte.com/content/dam/Deloitte/ch/Documents/manufacturing/ch-en-manufacturing-industry-4-0-24102014.pdf>.

Through the networked approach CPPSs can be managed in real time, and if necessary, remotely while the communication between social machines is also able to make decentralised decisions based on self-organisation mechanisms.²³ In regard to the former, it is also important to point out that IND 4.0 can lead to new business models. More specifically, as explained in section III.A below, remote management of CPPSs might lead to a blurred boundary between the service and manufacturing sector since consumer orders can directly be sent to the manufactures without the need for intermediaries. Thus, consumer requests can be directly and immediately integrated and modify the production process.

Besides the interactive and interconnected nature of machines within a smart factory, another key characteristic of IND 4.0 is the constant generation, evaluation and usage of different kinds of data in the production process. In an IND 4.0 environment new types of data are generated that did not exist before.²⁴ In practical terms, data produced and used in the IND 4.0 context are data generated by machines for instance on the design or key characteristics of a product or data on cost efficient production chains. Furthermore, measurement data are generated by sensors which is immediately used in the production process. For example, sensors measuring temperature during the production might be essential to calculate the required amount of cooling water. Besides that, data related to suppliers (i.e. location data) as well as customer data (i.e. product preferences) also directly feed into the production process to increase in-time management during production and swift delivery to customers. Furthermore, data are generated through the interaction of employees and smart machines. As explained later, the smart glove for instance generates data both on the production process as well as on the individual. All of these different data sets are autonomously produced by different devices within and outside of the company and used by smart machines without the need of a central coordination.

Having explained the core characteristics of IND 4.0, concerns can be raised on how novel IND 4.0 in fact is, due to its close correlation to other concepts such as the 'Internet of Things' (IoT) and 'the Internet of Services' (IoS). While the concept IoT has already been used in 1998 and subsequently been discussed widely among practitioners and academics,²⁵ it is not specifically tailored to describe the transformation of the manufacturing industry. Instead IoT refers more generally to the connection of objects with the internet which then cooperate and communicate

²³ EP Study on Industry 4.0 (2016); See also: Forschungsunion/acatech, *Securing the future of German manufacturing industry Recommendations for implementing the strategic initiative INDUSTRIE 4.0*, 2013. Retrieved 16.03.2016 from http://www.acatech.de/fileadmin/user_upload/Baumstruktur_nach_Website/Acatech/root/de/Material_fuer_Sonderseiten/Industrie_4.0/Final_report__Industrie_4.0_accessible.pdf.

²⁴ G Giersberg, *Die Daten der Industrie werden zum Milliardengeschäft*, 2015. Retrieved 16.03.2016 from <http://www.faz.net/aktuell/wirtschaft/unternehmen/industrie-4-0-die-daten-der-industrie-werden-zum-milliardengeschaeft-13619259.html>.

²⁵ See for example: PN Howard, *Sketching out the Internet of Things trendline*, 2015. Retrieved from: <http://www.brookings.edu/blogs/techtank/posts/2015/06/9-future-of-iot-part-2> See also: M Maras, 'Internet of Things: security and privacy implications', 2015 vol 5 (2) *International Data Privacy Law*.

with other objects and with humans. Thus, IoT is a very broad concept that could be relevant for the industrial context as well as a non-industrial context.²⁶ Therefore, IND 4.0 includes a narrower meaning of IoT by only referring to a manufacturing-related subset of IoT where a link to the process of manufacturing ought to exist in all cases. Similarly, IND 4.0 also includes some elements of IoS. However, ‘the basic idea of the Internet of Services is to systematically use the Internet for new ways of value creation in the services sector.’²⁷ As such it is also not specifically tailored for the manufacturing process either.

III. Data Protection Challenges of IND 4.0 and the EU Legal Context

The aim of this section is to outline the main data protection challenges arising in the IND 4.0 context. Examples of such challenges relating to both customers and employees are provided. In both cases the chapter first provides examples of when and how personal data is relevant in the IND 4.0 environment. Subsequently, the chapter assesses whether and in which way the current EU legal framework addresses challenges in regard to how the personal data are processed. The analysis compares the provisions of the relevant instrument that is currently in force, Data Protection Directive 95/46/EC (DPD) and the provisions of the General Data Protection Regulation (GDPR)²⁸ which has been adopted in 2016 and which will be enforceable from 25 May 2018 onwards.

A. Data Protection Challenges in regard to Customer Data in the IND 4.0 Context

As mentioned before, IND 4.0 leads to a blurred boundary between service providers and industry since orders can be sent directly to the manufacturers, without the need for intermediaries.²⁹ For example, IND 4.0 enables customers of the sportswear producer *Adidas* to send requests for individualised football jerseys

²⁶ Note that especially literature on data protection implications of IoT often refers to the nexus between the virtual world and objects after the production process is concluded (e.g. smart homes).

²⁷ L. Terzidis, D. Oberle and K. Kadner, *The Internet of Services and USDL*, (2011). Retrieved 03.02.2016 from <https://www.w3.org/2011/10/integration-workshop/p/USDLPositionPaper.pdf>.

²⁸ Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC OJ L119/2 (General Data Protection Regulation).

²⁹ Forschungsunion/acatech, *Securing the future of German manufacturing industry Recommendations for implementing the strategic initiative INDUSTRIE 4.0*, 2013, http://www.acatech.de/fileadmin/user_upload/Baumstruktur_nach_Website/Acatech/root/de/Material_fuer_Sonderseiten/Industrie_4.0/Final_report__Industrie_4.0_accessible.pdf.

directly to the production plant where the order is processed and the product is produced in real time.³⁰ While this has interesting implications on copyright law, it also means that personal data in relation to the order is directly integrated in the production process.³¹

Another example of where personal data of customers are relevant is if the end product incorporates data processing components.³² Whilst the aim of these components might have initially only been intended for the manufacturing process, '(...) they may eventually come into the possession of end customers who use them for purposes for which they were not originally intended.'³³ This requires that the capabilities of the built-in components are strictly limited for their purpose to avoid unwanted side effects. An example is where a component of the final product includes a GPS element. The primary use of the GPS, included in the component, might have been to efficiently manage production since some components of the final product are manufactured independently. More specifically, locating the various components might help to forecast the estimated delivery time and can thus inform the process of assembling the single components into the final product. However, if the GPS function is not disabled in the final product, it might be able to track the movements of its new owner. Combining data of customers and the location tracking can lead to the creation of detailed customer profiles in an IND 4.0 context.

Ultimately, another example of where customer data are part of IND 4.0 is when the end product intentionally incorporates data processing components for the purposes of instant maintenance and to inform and optimize the production process. For instance, if a smart car is connected to the production plant so that any problems related to the functioning of the smart car can directly inform/change the production process of future cars, personal data of the car owners might be at stake. Thus, while currently manufacturers are mostly not dealing directly with the end consumer, this might change with IND 4.0. The difference with, for instance, regular e-commerce is that personal data are now in a highly inter-operational environment where smart machines use data as they see fit creating problems such as proper compliance with the purpose limitation principle. To illustrate this, an interesting example relates to the use of a BMW smart car that generated a surprisingly precise customer profile. A user of a car-sharing platform was involved in an accident. Upon request by a court, BMW provided a precise profile of the car-sharing user, leading to his conviction. The data included information such

³⁰ M Kuom, *Internet of Things & Services in Production: Industrie 4.0. Presentation prepared for: European Co-operation on innovation in digital manufacturing*, 2015. For more information, see: <https://ec.europa.eu/digital-single-market/en/news/european-co-operation-innovation-digital-manufacturing>.

³¹ From a copyright perspective it raises the question on whether the customer or the company holds the copyrights of the final product.

³² Forschungsunion & acatec, *Umsetzungsempfehlungen für das Zukunftsprojekt Industrie 4.0 Abschlussbericht des Arbeitskreises Industrie 4.0*, 2013. Retrieved 16.03.2016 from: https://www.bmbf.de/files/Umsetzungsempfehlungen_Industrie4_0.pdf, p. 64.

³³ Ibid.

as detailed data on the route of the user, a speed profile and temperature data. It also included location data of the phone used to book the car.³⁴ According to BMW, cars used for car-sharing platforms are equipped with a so-called ‘car-sharing module’ (CSM), which helps to determine the time and location of the rental agreement for billing purposes but does not allow the creation of customer profiles.³⁵ This raises the question on how such a precise dataset could be delivered to the court? It is likely that the combination of datasets generated by the car itself and data held about by the customer is responsible for the profiling. Interestingly, BMW mentioned in a previous discussion on customer profiling that this type of profiling is technically not possible.³⁶ This raises concerns in how far companies are aware about how cyber-physical systems autonomously generate and process data. Ultimately this can (like in this case) have a negative impact on legal certainty as the user was not initially informed about the potential profiling when using the car-sharing platform.

Having assessed the scenarios where customer data might be affected in an IND 4.0 context, a starting point in assessing the adequacy of the current legal framework is to examine how the provisions of the DPD and GDPR address these challenges. First of all, both DPD and GDPR stipulate that lawful processing presupposes that the data subject has given his consent or that processing is necessary for the performance of a contract.³⁷ In the example where customers directly influence the production process or where instant maintenance is at stake, consent, legitimate interest and necessity for performing a contract would be equally valid conditions to make processing legitimate. It is likely that manufacturers have an interest in processing data beyond the purpose of performing the contract with an individual. For instance, this may be the case if the processing of customer data supports market analyses. In regard to the Adidas example, the manufacturer might be interested to analyse personal data in order to assess trends and patterns of consumption in correlation to characteristics of consumers and other criteria such as product price. Furthermore, in the smart car example, manufacturers might be interested to further process personal data to assess current maintenance patterns which might help to rectify flaws in the production. If the manufacturer intends to use data for these additional purposes that are not necessary for the performance of the contract, the data subjects have to give consent to the processing of their personal data.³⁸ In the BMW example, it however seems that the company itself was not aware of what data are collected (and consequently what additional purposes it may serve) and could thus not ask for consent when the contract was made.

³⁴ “Welche Daten Ihr Drive Now-Auto sammelt und was damit passieren kann.” Article retrieved from http://www.focus.de/auto/experten/winter/bmw-drive-now-ueberwachung-funktioniert-bei-harmlosen-buergern-in-carsharing-autos-wird-ihr-bewegungsprofil-gespeichert_id_5759933.html.

³⁵ *ibid.*

³⁶ “So wehren Sie sich gegen die Daten-Schnüffelei der Autohersteller”. Article retrieved from: http://www.focus.de/auto/experten/winter/bmw-speichert-kunden-daten-wer-noch-wie-autos-uns-ausspaehen-und-was-man-dagegen-tun-kannbmw_id_5178515.html.

³⁷ Article 7 DPD and Article 6 GDPR.

³⁸ Article 7 (a) DPD and Article 6 (1) a GDPR.

Both the DPD and GDPR set out basic data protection principles that apply to the processing of personal data.³⁹ So far, the situation does not seem to differ from personal data processing in a non-IND 4.0 environment. Nevertheless, when it comes to the purpose limitation principle, companies operating in an IND 4.0 context might be faced with the difficulty of complying. Both the DPD and the GDPR stipulate that personal data shall be ‘collected for specified, explicit and legitimate purposes and not further processed in a way incompatible with those purposes.’⁴⁰ The only exceptions where further processing is possible relates to historical, statistical or scientific purposes⁴¹ and for statistical or archiving purposes in the public interest.⁴² The Article 29 WP has interpreted ‘statistical purposes’ broadly by arguing that it covers commercial purposes such as big data applications aimed at market research.⁴³ It is not clear whether additional purposes such as ‘process optimisation’ or ‘market analysis’ -which is mainly at stake at IND 4.0- could also fall under the exception of ‘statistical purposes’. It could be argued that both aspects could fall under the ‘statistical purposes’ exception since in both cases data could facilitate economic growth and (in some cases also environmental protection) which are important EU values to be minded next to the protection the data of individuals.⁴⁴ Nevertheless, due to the complexity, it has been argued that the purpose limitation principle might need to be interpreted more broadly in specific cases.⁴⁵

In an IND 4.0 context, the problem is not only the mass availability of large sets of personal and non-personal data (‘big data’) but also that smart machines partially take autonomous decisions based on data generated during the production process and thus might further process and use personal data that was not originally foreseen when the data were collected. Thus, processing data in the IND 4.0 context can be a case of autonomous machine learning and subsequent automated decision-making. Both the DPD and the GDPR start from the assumption that automated decision-making is prohibited if it produces legal effects for the data subject. Interestingly, neither the DPD, nor the GDPR, specify however what

³⁹ Principles set out in DPD and GDPR such as: lawful and fair processing, non-excessiveness, adequate data security in place, availability of data subject rights, such as the right to rectification and the access to redress mechanisms, etc.

⁴⁰ Article 6 (1) b, DPD and Article 5 (1) b, GDPR.

⁴¹ Article 6 (1) b, DPD and Article 5 (1) b, GDPR.

⁴² Article 5 (1) b, GDPR.

⁴³ Article 29 WP Opinion 03/2013 on purpose limitation. Retrieved 16.03.2016 from: http://ec.europa.eu/justice/data-protection/article-29/documentation/opinion-recommendation/files/2013/wp203_en.pdf p. 29.

⁴⁴ Article 3 (3) TFEU mentions that the single market “(...) shall work for the sustainable development of Europe based on balanced economic growth and price stability, a highly competitive social market economy, aiming at full employment and social progress and a high level of protection and improvement of the quality of the environment”.

⁴⁵ Bundesverband der Deutschen Industrie e.V. & Noerr, *Industrie 4.0—Rechtliche Herausforderungen der Digitalisierung. Ein Beitrag zum politischen Diskurs*, 2015. Retrieved 16.03.2016 from: http://bdi.eu/media/presse/publikationen/information-und-telekommunikation/201511_Industrie-40_Rechtliche-Herausforderungen-der-Digitalisierung.pdf.

counts as “legal effect” which might lead to a variety of interpretations across the EU.⁴⁶ Both instruments allow automated decision making under certain circumstances. Article 15 DPD stipulates that a person may be subjected to automated decision-making if “it is taken in the course of entering into or performance of a contract, provided the request for the entering into the performance of the contract, lodged by the data subject, has been satisfied or that there are suitable measures to safeguard his legitimate interests, such as arrangements allowing him to put his point of view.”⁴⁷ Article 20 of the GDPR is more explicit by providing that automated individual decision-making is possible if it is:

- i Necessary for entering into, or performance of, a contract between the data subject and a data controller;
- ii Authorized by Union or Member State law to which the controller is subject and which also lays down suitable measures to safeguard the data subject’s rights and freedoms and legitimate interests; or
- iii Based on the data subject’s explicit consent.⁴⁸

In the case that manufacturers want to apply automated decision making for purposes which are not necessarily required for the performance of a contract, the basis to legitimise automated processing has to be via the explicit consent of the data subject. Nevertheless, even if the data subject was initially informed about and has consented to the fact that his/her data was integrated in big data environment, it is likely that they would not fully understand the implications the consent might have.⁴⁹

Furthermore, it might also be difficult for manufactures to grant the individual specific safeguards such as ‘arrangements allowing him to put his point of view’ as they might not necessarily have an overview on what exactly happens to the data.

A simple solution to avoid any type of compliance problem in regard to automated processing of personal data is to anonymise data, since that renders data protection laws inapplicable.⁵⁰ However, anonymisation might not always be feasible and desirable. The difficulty of proper anonymisation is related to striking a balance between removing all features of a data set that could enable re-identification and retaining as much of the underlying information to maintain usefulness of the data. While a more detailed technical analysis of the feasibility of anonymisation is beyond the scope of this paper it suffices to mention that for the above-mentioned reason common anonymisation techniques such as randomisation and generalisation have several shortcomings.⁵¹ Besides feasibility concerns, the limited usefulness of fully

⁴⁶ Article 15 DPD and Article 20 GDPR.

⁴⁷ Article 15, DPD.

⁴⁸ Article 22 (2) GDPR.

⁴⁹ Article 29 WP Opinion 03/2013 on purpose limitation. Retrieved from: http://ec.europa.eu/justice/data-protection/article-29/documentation/opinion-recommendation/files/2013/wp203_en.pdf Annex 2.

⁵⁰ Recital 26 GDPR. Similar provisions in recital 26 DPD.

⁵¹ An overview of these shortcomings can be found in: The Article 29 WP Opinion 05/2014 on Anonymisation Techniques (Adopted on 10 April 2014).

anonymised data, makes this solution often undesirable. Thus, to grant companies more flexibility, the GDPR introduces the concept of ‘pseudonymisation’. This term has been defined as ‘(...) processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information, provided that such additional information is kept separately and is subject to technical and organisational measures to ensure that the personal data are not attributed to an identified or identifiable natural person’.⁵² In practice, this means that pseudonymisation is not a method of anonymisation. ‘It merely reduces the linkability of a dataset with the original identity of a data subject, and is accordingly a useful security measure.’⁵³

After defining the concept of pseudonymisation, Article 6 of the GDPR stipulates that data processing for another purpose than originally sought is lawful if it is based on appropriate safeguard such as pseudonymisation.⁵⁴ However, after pseudonymisation has taken place, data shall still be considered as information on an identifiable natural person. To determine whether a person is identifiable ‘account should be taken of all the means reasonably likely to be used, such as singling out, either by the controller or by any other person to identify the individual directly or indirectly’.⁵⁵ Since pseudonymisation still bears the risk of intended or unintended re-identification, the use of the other data protection safeguards mentioned in the GDPR is not precluded.⁵⁶ Respectively, while originally the intention behind introducing the concept of pseudonymisation was to provide more flexibility to companies, the text in its current form seems to remove this flexibility.⁵⁷ This view disregards that pseudonymisation provides companies the opportunity and flexibility to make use of personal data even if beyond the original purpose if adequate safeguards are in place.

In contrast to the DPD, the GDPR adds two additional data protection safeguards which are relevant for the IND 4.0 context: data protection *by design* and *by default*.⁵⁸ These safeguards are suitable for the particularities of IND 4.0 since smart machine function within one networked framework. Thus, privacy by design is intended to mitigate risks to privacy emerging from every element of the smart company including the overall network and the operating machines. Therefore, privacy by design encourages manufactures to include data protection features when IND 4.0 machines and applications are designed and built.

In summary, while the high interoperability and autonomous decision-making in an IND 4.0 environment might lead to complex data protection challenges, the DPD and the GDPR provisions offer a certain degree of flexibility to companies

⁵² Article 4 (5) GDPR.

⁵³ Article 29 WP Opinion 05/2014 on Anonymisation Techniques, p. 3. Retrieved from: http://www.cnpd.public.lu/fr/publications/groupe-art29/wp216_en.pdf.

⁵⁴ Article 6 (4e). GDPR.

⁵⁵ GDPR, recital 26.

⁵⁶ GDPR, recital 28.

⁵⁷ C Burton et al, *The Final European Union General Data Protection Regulation*, 2016. Retrieved 16.03.2016 from <http://www.bna.com/final-european-union-n57982067329/>.

⁵⁸ GDPR, Article 25.

in using customer data while simultaneously addressing risks to data subjects. More specifically, both instruments allow for certain exceptions to the purpose limitation principle as well as exceptions to the general prohibition of automated decision-making. In contrast to the DPD, the GDPR also includes promising new concepts such as pseudonymisation, privacy by design and privacy by default. Thus, the current legal framework seems to adequately address the data protection challenges outlined at the beginning of the paper. Therefore, rather than focusing governmental efforts on revising or tailoring legal instruments for the IND 4.0 environment, efforts should mainly concentrate on raising awareness among companies on how to correctly interpret existing and new (GDPR) rules.⁵⁹ Furthermore, other actions could include the adoption of sector specific recommendations on data protection implication as well as the requirement of companies to certify that they comply with the necessary standards as spelled out in the GDPR.

B. Data Protection Challenges in relation to Employee Data in an IND 4.0 Context

IND 4.0 also has implications for personal data of employees due to a business model where remote working is simplified and encouraged and due to an increasing virtualisation, where vast amounts of data are collected at the workplace itself. Most of the concerns in regard to employee data are not specific to IND 4.0 and could instead apply to modern office environments in general.⁶⁰ Therefore, the following examples take the particularities of IND 4.0 environment into account, but could also apply to other sectors.

Remote working in an IND 4.0 environment includes remote maintenance and remote machine control since technicians do no longer need to manually connect to machines.⁶¹ Integrated knowledge platforms, videoconferencing, tools and enhanced engineering methods can be used to perform control over machines via mobile devices.⁶² This aspect of IND 4.0 may lead to a situation where some employees in the manufacturing sector will be crucial for the operation of a company whilst working from home, blurring the boundary between working and private life.

Furthermore, an increased culture of surveillance at the workplace can be observed in the IND 4.0 context. As the interaction between employees and cyber-physical systems (CPSs) increases, the volume and detail of personal information

⁵⁹ It has been argued that often SMEs lack of awareness of how to protect personal data. MacInnes, B. (2013). SMEs often lack effective IT security, retrieved 16.03.2016 from <http://www.microscope.co.uk/feature/SMEs-often-lack-effective-IT-security>.

⁶⁰ For example, technology scrutinising the presence and working hours of employees are increasingly being used in different sectors.

⁶¹ Forschungsunion & acatech, 'Umsetzungsempfehlungen für das Zukunftsprojekt Industrie 4.0 Abschlussbericht des Arbeitskreises Industrie 4.0', 66.

⁶² Ibid.

of the employee also increases. This is the case in regard to assistance systems recording employee location data and quality of their work which might impact the employees' right to informational self-determination.⁶³ This is particularly concerning where the IND 4.0 environment has an international dimension, since employee data might be sent to countries with a lower data protection standard than the laws within the EU.

A more practical example of surveillance of employees is the 'smart glove'⁶⁴. Being a wearable tool, it uses sensing technology to pick up or transmit information from whatever a worker is handling.⁶⁵ The founder of the smart glove mentioned: '(...) if you could create a way to use track and sense what people's hands were doing at work, you could gain vital information to help train workers and monitor productivity.'⁶⁶ The smart glove is an example of how increasing interaction between machines and humans can lead to comprehensive profiling and surveillance of workers. This is particularly problematic because it could create omnipresent surveillance of workers which might lead to an asymmetry of power between employers and employees.

Privacy at the workplace is particular, since it can be regarded as hybrid between private and public life. This has been noted, in *Niemitz v. Germany*, where the ECtHR held that a certain degree of privacy is necessary at the workplace to be able to build relationships but 'it is not always possible to distinguish clearly which of an individual's activities form part of his professional or business life and which do not.'⁶⁷ The judgment shows that employees can expect privacy at the workplace. However, this needs to be balanced with the legitimate interest of the employer to ensure diversity, to monitor the performance of staff, ensure health and safety at work and protect property.

While international instruments take the special nature of privacy in the employment sector into account,⁶⁸ on the EU level there is no specific law dealing with privacy at the workplace, since discussions on a potential measure were eventually abandoned. The DPD only refers on one occasion specifically to data protection of employees. In Article 8 it is mentioned that the processing of sensitive data⁶⁹ shall be prohibited, unless 'processing is necessary for the purposes of carrying out the obligations and specific rights of the controller in the field of employment law in so far as it is authorized by national law providing for adequate

⁶³ Ibid., 64.

⁶⁴ Further information about Smartglove: <http://www.proglove.de/>.

⁶⁵ Retrieved from: <http://iq.intel.com/smart-gloves-let-fingers-talking/>.

⁶⁶ Ibid.

⁶⁷ *Niemitz v. Germany* (23 November 1992, Series A n° 251/B, par. 29), 13710/88, [1992] 16 EHRR 97, [1992] ECHR 80.

⁶⁸ Protection of workers' personal data. An International Labour Organisation code of practice (1997) and Recommendation No. R (89) 2 of the Committee of Ministers to Member States on the Protection of Personal Data used for Employment Purposes.

⁶⁹ ie personal data revealing racial or ethnic origin, political opinions, religious or philosophical beliefs, trade-union membership, and the processing of data concerning health or sex life (Article 8 (1) DPD).

safeguards.⁷⁰ In contrast to the DPD, the GDPR acknowledges the fact that data protection in the employment context may require a different treatment than data protection in other fields. Respectively, Article 88 GDPR mentions that Member States may provide by law or by collective agreements more specific rules on data protection in employment law for purposes such as recruitment, health and safety at work or management of work.⁷¹ The article further states that national rules shall safeguard the data subject's human dignity, legitimate interests and fundamental rights '(...) with particular regard to the transparency of processing, the transfer of data within a group of undertakings or group of enterprises and monitoring systems at the work place'.⁷²

Obviously, the GDPR leaves a large leeway to the Member States on how and in which form to regulate privacy and data protection in employment law. This is problematic since it might lead to a wide variety of national laws and practices undermining the harmonisation efforts of the GDPR and posing difficulty for EU-wide operating companies. As already mentioned, in an IND 4.0 environment remote machine control will increase, whereas technicians will not need to be based within the factory and not even within direct proximity. It is thus likely that machine control might increasingly happen on a cross-border basis. One specific problem of diverging laws is the onward transfer to third countries. For example, 'German data protection law places strict restrictions on the outsourcing of the analysis of data captured in smart factories to companies located outside [Europe] or the disclosure outside Europe of corporate data containing personal information about employees'.⁷³ In the absence of more specific rules, other EU countries might have more flexible data protection rules in the employment sector. This could result in more severe constraints for globally networked value chains in countries like Germany as opposed to other EU countries. As a consequence, competition within the EU would be affected.

Besides the negative impact of diverging law on companies, the lack of a systemic approach to privacy of employees could have a negative effect on the free movement of workers and the right to privacy of employees. While it is certainly a step in the right direction that the GDPR stipulates that any national measure needs to take the 'data subject's human dignity, legitimate interests and fundamental rights'⁷⁴ into account, at least three more practical challenges remain unaddressed.

First, not all EU Member States have employment legislation covering data protection, and in some cases employee rights are spread across employment law,

⁷⁰ DPD, Article 8 (2) b, same provision in Article 9 (2) b GDPR. However, Article 9 (2) b GDPR adds specifically that sensitive data can be processed if processing is necessary for the purposes of assessment of the working capacity of the employee.

⁷¹ Article 88 (1), GDPR.

⁷² Article 88 (2), GDPR.

⁷³ Forschungsunion & acatech, 'Umsetzungsempfehlungen für das Zukunftsprojekt Industrie 4.0 Abschlussbericht des Arbeitskreises Industrie 4.0'.

⁷⁴ Article 88 (2), GDPR.

telecommunications law, criminal law and soft law (such as trade-union code of conducts).⁷⁵ ‘The interaction of these relevant provisions, so far as their application in the employment context is concerned, is often not clear and the situation is, in some cases, quite controversial.’⁷⁶ An interesting example in this regard was the revelation that the German discount supermarket LIDL installed cameras in its stores all over Germany due to a general suspicion that employees steal products. While this case was widely discussed by the media, and worker associations threatened with legal actions, ultimately LIDL was not sued, since according to German law it is proportionate to monitor employees for the purpose of crime prevention. This example shows the lack of legal certainty and ultimately might also lead to a lack of access to redress mechanisms. This situation even aggravates in an international work environment, where employees are not only faced by fragmented national law but also by different laws across the EU.

Secondly, it is also not clear whether certain forms of monitoring are regulated differently than others or require additional safeguards.⁷⁷ For instance, monitoring of the content of electronic communication as well as the processing of telecommunication traffic and location other than for billing purposes is prohibited under the ePrivacy Directive.⁷⁸ However, some national laws allow for monitoring of work emails. With the increasing amalgamation of private and work life there is a need to spell out the boundary of which communication as well as data can and which cannot be monitored. For instance, in *Halford v. the United Kingdom*, as well as in *Copland v. the United Kingdom*, it was held that the applicant had not been informed that calls made on the company system would be liable to interception. Therefore, the applicants had a reasonable expectation of privacy for calls.⁷⁹ It thus seems that notification has been the key consideration for legitimacy of surveillance of communication at work. In regard to tracking, particularly in an IND 4.0 context, location data might be generated (eg smart glove) and directly used for managing applications. This creates particularly a problem if this function is used from a company-remote location where surveillance cannot be targeted sufficiently to work life itself and instead captures also aspects of private life. In addition to that, tools like the smart glove do not only generate and monitor data but also create data linkages that might provide conclusions that were not sought or in a worst-case scenario are wrong.

⁷⁵ DG EMPL, second stage consultation of social partners on the protection of workers’ personal data. Retrieved 16.03.2016 from: <http://ec.europa.eu/social/BlobServlet?docId=2504&langId=en>.

⁷⁶ *ibid.*

⁷⁷ G Buttarelli, *Do you have a private life at your workplace?* Speech held at 31st international conference of data protection and privacy commissioners 2009. Retrieved 16.03.2016 from https://secure.edps.europa.eu/EDPSWEB/webdav/shared/Documents/EDPS/Publications/Speeches/2009/09-11-06_Madrid_privacy_workplace_EN.pdf.

⁷⁸ Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector, Article 9 and Article 6.

⁷⁹ *Halford v. the United Kingdom* of 27 May 1997, (20605/92) [1997] ECHR 32 (25 June 1997). Similar findings are restated in: *Copland v. UK Application no. 62617/00*, 3 April 2007. See also: *Bărbulescu v. Romania, Application no. 61496/08*, 12 January 2016.

Thirdly, another consideration refers to the difficulty to define consent to surveillance in the employment law context. On the one hand the role of consent in legitimising surveillance in the employment context is controversial because of the dependent and subordinate role of the worker.⁸⁰ It can thus be expected that consent is not freely given. On the other hand, it is questionable how informed consent can be, particularly in the IND 4.0 context marked by complex interaction of data and machines in an IND 4.0 environment. As a consequence, the fact that an employee consented to surveillance might potentially not be sufficient as legitimisation of surveillance. More importantly it seems that notification needs to be connected with other safeguards.⁸¹

In summary, neither the DPD nor the GDPR establish a legal framework on data protection in the employment sector. This could lead to a divergence of national legal frameworks, which might ultimately have a negative effect on the internal market. Furthermore, a lack of legal provisions might also negatively affect employees particularly in an IND 4.0 environment since it introduces new monitoring instruments and since it further blurs the boundary between private and work life. Therefore, the current legislative framework is not sufficiently developed to account for data protection challenges of employees working in the IND 4.0 sector or in other sectors where a culture of surveillance at the workplace is created by technological means.

IV. Data Security Challenges of IND 4.0 and the EU Legal Context

In an IND 4.0 environment not only personal but also non-personal has to be protected. For the purpose of this paper “non-personal data” is data on the functioning of smart machine in the production process, data on the production process and data on the final product. There are four main reasons why IND 4.0 is particularly vulnerable regarding data security. First, as explained in section II of this paper, the transition to IND 4.0 is not a transformation that happens from one day to the other. Instead it is an incremental process whereby some machines, which were designed at a time when TPC/IP protocols were not used, have been connected to the factory-wide network retrospectively. Thus some of the elements of a smart factory are obsolete and are therefore a main cause for the high

⁸⁰ Second stage consultation of social partners on the protection of workers’ personal data, Retrieved 16.03.2016 from: <http://ec.europa.eu/social/BlobServlet?docId=2504&langId=en>, p. 11. See also: Article 29 Working Party opinion on the processing of personal data in the employment context. Retrieved 16.03.2016 from http://ec.europa.eu/justice/data-protection/article-29/documentation/opinion-recommendation/files/2001/wp48sum_en.pdf.

⁸¹ See UK case on notification: *Copland v United Kingdom* (2007) as well as *Halford v. the United Kingdom*.

vulnerability of the whole system.⁸² Secondly, in the IND 4.0 environment, not only every device within a smart company is connected to the network, but also several external partners (such as suppliers, distributors, etc.).⁸³ This means that security risks not only emerge due to weaknesses within the company, but also due to external factors.⁸⁴ Thirdly, current policy on data security is well suited to deal with software vulnerabilities. However, this is usually not the case for equipment although this is key in an IND 4.0 environment.⁸⁵ Ultimately, due to the fact that the business paradigm for manufacturers has only started to change recently, they are largely unaware of the new risks leading to poor data security strategies.⁸⁶

There are also four areas showing the crucial role of data and network security for IND 4.0. First and most obviously, data and network security is crucial for the operability of single smart machines and the production process as a whole. In case that, for instance, a network or machine is infected with malware the whole production process could be impeded or incapacitated leading to vast costs. Three instances of how malware targeted ICT components and influenced the operability of companies have been reported in the press: Stuxnet,⁸⁷ HAVEX,⁸⁸ and Black-Energy. In addition, the 2014 report of the German National Agency of Computer Security (BSI) mentions an attack on a German steel plant causing damage to machinery of the factory.⁸⁹ Second, data security ensures the protection of intellectual property and thus the competitiveness of a smart factory. Data generated and used in the manufacturing industry contains distinctive, inimitable information about the product and its manufacture. Thus, if this information is leaked the right equipment is sufficient to develop the counterfeit product.⁹⁰ Third, lack of data security can lead to environmental hazard. For instance, in 2014 a South Korean nuclear plant operator mentioned that its computer systems had been breached. The case has been treated as a cyber-terror attack from North Korean actors. Although only non-critical information was leaked, the incident shows the importance of data security if smart factories deal with environmentally hazardous materials.⁹¹ Ultimately, data security is also critical for the health and safety of

⁸² Forschungsunion & acatech, 'Umsetzungsempfehlungen für das Zukunftsprojekt Industrie 4.0 Abschlussbericht des Arbeitskreises Industrie 4.0', 50.

⁸³ Eberbacher Gespräch zur Sicherheit In Der Industrie 4.0. Fraunhofer SIT, October 2013, p. 12.

⁸⁴ Ibid.

⁸⁵ Ibid.

⁸⁶ Ibid.

⁸⁷ K Zetter, *An Unprecedented Look at Stuxnet, the World's First Digital Weapon* (Wired.com, 3 Nov 2014 Retrieved 16.03.2016 from: <http://www.wired.com/2014/11/countdown-to-zero-day-stuxnet/>).

⁸⁸ D Walker, 'Havex' malware strikes industrial sector via watering hole attacks (SC Media, 25 June 2014) Retrieved 16.03.2016 from <http://www.scmagazine.com/havex-malware-strikes-industrial-sector-via-watering-hole-attacks/article/357875/>.

⁸⁹ See further details: EP Study on Industry 4.0 (2016).

⁹⁰ EP Study on Industry 4.0 (2016); See also: *CeBIT Security tools for Industry 4.0*. Research News / 4.3.2014. Retrieved 16.03.2016 from <https://www.fraunhofer.de/en/press/research-news/2014/march/security-tools.html>.

⁹¹ J McCurry, *South Korean nuclear operator hacked amid cyber-attack fears*, (The Guardian, 22 Dec 2014). Retrieved 16.03.2016 from: <http://www.theguardian.com/world/2014/dec/22/south-korea-nuclear-power-cyber-attack-hack>.

the employees at a smart factory. For instance, at a Volkswagen production plant in Germany an employee was killed by a smart machine.⁹² While in this scenario the employee acted negligently by trespassing an area that was prohibited to humans, there could also be cases where robots are either wrongly programmed or where hackers deliberately influence the software of the robots.⁹³

Having outlined the importance of network and data security in the IND 4.0 context, the relevant EU legislation will now be assessed. First, the DPD and GDPR both lay down the regulatory framework on data security when personal data are concerned. Both instruments stipulate that ensuring security of personal data requires appropriate technical and organisational measures against accidental or unlawful destruction or accidental loss, alteration, unauthorized disclosure or access.⁹⁴ In contrast to its predecessor, the GDPR provides more details on the practical steps to be taken to secure data.⁹⁵ Furthermore, it establishes a stricter framework in regard to notifying data subjects and supervisory authorities if a breach took place.⁹⁶

While the security of personal data is obviously important, a large proportion of data in an IND 4.0 environment is non-personal data. Respectively, in July 2016 the Directive on the security of network and information systems (NIS Directive) was adopted.⁹⁷ The Directive can be regarded as first EU-wide effort addressing the growing concerns in regard to network and information security. The Directive imposes obligations on both the private and the public sector. In regard to the latter, it requires Member States to adopt a national NIS strategy,⁹⁸ to designate National Competent Authorities,⁹⁹ Single Points of Contact¹⁰⁰ and Computer Security Incident Response Teams.¹⁰¹ Furthermore, it requires EU-wide cooperation between these authorities. In regard to the private sector, the NIS Directive requires certain companies to adopt adequate cybersecurity strategies, to follow certain steps in case of a security incident and it establishes a reporting mechanism in case of a breach.¹⁰² Respectively, the Directive can be regarded as a broad instrument by being directed at the public and private sector and by combining operational and strategic provisions.

In regard to the scope of the Directive, it has to be noticed that it only applies to Operators of Essential Services (OoES) and Digital Service Providers (DSP).¹⁰³

⁹² E Dockterman, *Robot Kills Man at Volkswagen Plant* (Time, 1 July 2015) Retrieved 16.03.2016 from <http://time.com/3944181/robot-kills-man-volkswagen-plant/>.

⁹³ EP Study on Industry 4.0 (2016).

⁹⁴ Article 17 DPD and Article 32 GDPR.

⁹⁵ Article 32 (1) and (3), GDPR (see also recitals 49 and 71).

⁹⁶ Articles 33 and 35, GDPR.

⁹⁷ Directive 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union, OJ L 194/1.

⁹⁸ Article 7, NIS Directive.

⁹⁹ Article 8, NIS Directive.

¹⁰⁰ *ibid.*

¹⁰¹ Article 9, NIS Directive.

¹⁰² See: Chapters IV and V of the NIS Directive.

¹⁰³ See: Chapters IV and V of the NIS Directive.

An OoES is a public or private entity where the following criteria are met: (i) it provides a service which is essential for the maintenance of critical societal and/or economic activities, (ii) provision of the service depends on network and information systems, and (iii) a security incident would have decisive negative effects on the provision of the service.¹⁰⁴ In Annex II of the Directive a list of services specifies whose providers can qualify as OoES (ie banking, energy, transport, financial market infrastructure, health, drinking water and digital infrastructure). Thus, the Directive provides some indication on the definition of OoESs, but ultimately it is the task of the Member States to name all OoESs in their territory until the 9th of November 2018.¹⁰⁵ In addition, the Directive defines a DSP as “any legal person that provides a digital service.”¹⁰⁶ The Annex specifies that this includes online marketplaces, online search engines and cloud services.¹⁰⁷

Some OoES could be operating in an IND 4.0 environment. For example, a pharmaceutical company producing medicines in an IND 4.0 environment will fall under the health definition. However, the scope of the Directive reveals that IND 4.0 is not a major consideration of the Directive. This is particularly clear since generally manufacturing is unrelated to most OoESs or DSP (which focus on digital services). The EU Commission also explicitly stated that the NIS Directive does not ‘interfere in industry supply chain arrangements.’¹⁰⁸ However, there are three main reasons why the NIS Directive could still be relevant in the context of IND 4.0. First, regulating cybersecurity on a European level is still in a rudimentary stage and thus it can be considered as a starting point. Accordingly, the Directive acknowledges that ‘[c]ertain sectors of the economy (...) may be regulated in the future by sector-specific Union legal acts that include rules related to the security of networks and information systems.’¹⁰⁹ It is not unconceivable that a future regulatory framework for industry might take a similar form as the NIS Directive. In addition, it could serve as standard setter within the industry.

Second, the NIS Directive applies to cloud service providers, which are often essential third parties contracted to provide data storage capacities to IND 4.0 companies. As such, higher information and network security standards for cloud-service providers are a good foundation for a secure IND 4.0 environment. Third, the Directive requires that Member States establish so-called Computer Security Incident Response Teams (CSIRTs) “covering *at least* the sectors referred to in Annex II and types of digital services providers referred to in Annex III.”¹¹⁰ CSIRTs are responsible for handling incidents and risks ‘according to a well-defined process.’¹¹¹ This gives a margin to Member States as to whether also other sectors

¹⁰⁴ Article 4 (4) and Article 5 (2) NIS Directive.

¹⁰⁵ Article 5 (1) NIS Directive.

¹⁰⁶ Article 4 (6), NIS Directive.

¹⁰⁷ Annex III, NIS Directive.

¹⁰⁸ AS Ronnlund, *Cyber-insurance and the NIS Directive*. Presentation held at CSP Forum workshop Risk assessment and cyber-insurance 27.04.2015.

¹⁰⁹ Recital 9; NIS Directive.

¹¹⁰ Article 9 (1), NIS Directive. Emphasis added by author.

¹¹¹ Ibid.

might contact CSIRTs in case a security incident is taking place. This could be a positive aspect for IND 4.0 companies based in Member States that provide access to CSIRTs. However, the fact that some Member States may decide to grant access only to OoES might lead to a distortion of competition.

The Directive is arguably too broad since it mainly requires companies to conduct risk assessments and then implement appropriate measures. Therefore, there is the risk that the competent regulatory authorities will not be in a position to successfully identify risks.¹¹² Apart from these concerns the Directive can be considered as a valuable starting point acknowledging the relevance of cyber security in the technology-driven era. Since the Directive is not directly addressed at the IND 4.0 context, some more sector-specific aspects would be required such as security by design. Nevertheless, for now the Directive could still be regarded as a valuable template for an industry-driven standard setting.

In summary, this section assessed the data security challenges related to IND 4.0 as well as the reasons why data security is crucial to the success for IND 4.0. Subsequently, it has been illustrated that the regulatory framework on data security is still in its infancy. More specifically, the only instrument is the NIS Directive which has only recently been adopted and is not in force, yet. While not directly addressed at manufactures the instrument could be of relevance for IND 4.0 by establishing overarching standards, by covering cloud service providers and by establishing CSIRTs. Nevertheless, more sector-specific regulation will be useful to support manufactures in improving risk prevention as well as in reacting to security incidents.

V. Conclusion

The aim of this paper was to assess data protection and data security challenges arising from IND 4.0 and to evaluate the adequacy of the current and future EU legislative frameworks. The second section provided an explanation of the concept of IND 4.0 by establishing that it is a regulatory tool, on the one hand and a *sui generis* concept, on the other. Subsequently the key data protection challenges have been outlined. In regard to customer data, three scenarios were illustrated in which companies operating in an IND 4.0 environment process personal data according to its initial and other purposes. It has been argued that particularly the GDPR provides a flexible framework allowing companies to use personal data beyond its original purpose while ensuring a certain level of protection for the data subject. In regard to employee data, it has been shown that IND 4.0 blurs the boundary between private and work life through the increased possibility to work

¹¹² See: <http://www.scmagazineuk.com/industry-sceptical-of-new-nis-directive-passed-today/article/464813/>.

remotely. Furthermore, IND 4.0 creates new ways of surveillance at work through devices like the smart glove. Neither the DPD nor the GDPR sufficiently address data protection at the workplace. It has been shown that this can have negative impacts on the internal market as well as on fundamental rights protection of employees. Ultimately, the paper also discusses the data security challenges related to IND 4.0. Although relevant to personal data as stipulated in the DPD and the GDPR, this section also focused on the protection of non-personal data. The section first of all explained why data security is relevant for the IND 4.0 context and subsequently assessed the relevance of the NIS Directive. While the NIS Directive does in most cases not apply to IND 4.0, it is still relevant since it applies to cloud service providers who often cooperate with IND 4.0 companies. Furthermore, the NIS Directive could serve as reference point for companies on how to secure their networks and data.

Minding the concerns raised in this paper, it needs to be seen to which extent and how they will in fact materialise since IND 4.0 is still in early stages and is expected to become a reality only incrementally over the coming years. In any case, it will be crucial to ensure that industry stakeholders will be well informed about the risks both in respect to personal and non-personal data to mitigate the risks mentioned in this paper.

References

- Article 29 Data Protection Working Party Opinion 08/2001 on the processing of personal data in the employment context, adopted on 13 September 2001.
- , Opinion 03/2013 on purpose limitation, adopted on 2 April 2013.
- , Opinion 05/2014 on Anonymisation Techniques, adopted on 10 April 2014.
- Bledowski, K *The Internet of Things: Industrie 4.0 vs. The Industrial Internet*, 2015. Retrieved from: <https://www.mapi.net/forecasts-data/internet-things-industrie-40-vs-industrial-internet>.
- Bundesregierung. 2014. Die neue Hightech-Strategie. Innovationen für Deutschland. Retrieved from http://www.acatech.de/fileadmin/user_upload/Baumstruktur_nach_Website/Acatech/root/de/Material_fuer_Sonderseiten/Industrie_4.0/Final_report_Industrie_4.0_accessible.pdf.
- Bundesverband der Deutschen Industrie e.V. & Noerr, *Industrie 4.0 – Rechtliche Herausforderungen der Digitalisierung. Ein Beitrag zum politischen Diskurs*, 2015. Retrieved from: http://bdi.eu/media/presse/publikationen/information-und-telekommunikation/201511_Industrie-40_Rechtliche-Herausforderungen-der-Digitalisierung.pdf.
- Burton, C. et al., *The Final European Union General Data Protection Regulation*, 2016. Retrieved from <http://www.bna.com/final-european-union-n57982067329/>.
- Buttarelli, G, *Do you have a private life at your workplace?* Speech held at 31st international conference of data protection and privacy commissioners 2019. Retrieved from https://secure.edps.europa.eu/EDPSWEB/webdav/shared/Documents/EDPS/Publications/Speeches/2009/09-11-06_Madrid_privacy_workplace_EN.pdf.

- CeBIT Security tools for Industry 4.0*. Research News / 4.3.2014. Retrieved from <https://www.fraunhofer.de/en/press/research-news/2014/march/security-tools.html>.
- Directive (EU) 2016/943 of the European Parliament and of the Council of 8 June 2016 on the protection of undisclosed know-how and business information (trade secrets) against their unlawful acquisition, use and disclosure. OJ L L 157/1.
- Directive 2002/58/EC of the European Parliament and of the Council of 12 July 2002 concerning the processing of personal data and the protection of privacy in the electronic communications sector. OJ L 201, 31.7.2002.
- Directive 2016/1148 of the European Parliament and of the Council of 6 July 2016 concerning measures for a high common level of security of network and information systems across the Union. OJ L 194/1.
- Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data. OJ L 281/31.
- Dockterman, E, *Robot Kills Man at Volkswagen Plant* (Time 1 July 2015) Retrieved 16.03.2016 from <http://time.com/3944181/robot-kills-man-volkswagen-plant/>.
- Commission (EC), Communication for a European Industrial Renaissance, COM/2014/014 final.
- , Communication. A Stronger European Industry for Growth and Economic Recovery 2012, No. 582 final.
- , Communication to the European Parliament, the Council, the European Economic and Social Committee and the Committee of the Regions. An Integrated Industrial Policy for the Globalisation Era Putting Competitiveness and Sustainability at Centre Stage COM(2010) 614 final.
- Commission (EC) (DG EMPL) second stage consultation of social partners on the protection of workers' personal data. Retrieved from: <http://ec.europa.eu/social/BlobServlet?docId=2504&langId=en>.
- Eberbacher Gespräch zur Sicherheit In Der Industrie 4.0. Fraunhofer SIT, October 2013. Retrieved from: https://www.sit.fraunhofer.de/fileadmin/dokumente/studien_und_technical_reports/Eberbach-Industrie4.0_FraunhoferSIT.pdf.
- Federal Ministry of Economics and Technology (2010). In focus: Germany as a competitive industrial nation. Building on strengths—Overcoming weaknesses—Securing the future. Retrieved from: <http://195.43.53.114/English/Redaktion/Pdf/germany-industry-nation,property=pdf,bereich=bmwi,sprache=de,rwb=true.pdf>.
- Forschungsunion & acatech, *Umsetzungsempfehlungen für das Zukunftsprojekt Industrie 4.0 Abschlussbericht des Arbeitskreises Industrie 4.0*, 2013. Retrieved from: https://www.bmbf.de/files/Umsetzungsempfehlungen_Industrie4_0.pdf.
- Forschungsunion/acatech, *Securing the future of German manufacturing industry Recommendations for implementing the strategic initiative INDUSTRIE 4.0*, 2013. Retrieved from http://www.acatech.de/fileadmin/user_upload/Baumstruktur_nach_Website/Acatech/root/de/Material_fuer_Sonderseiten/Industrie_4.0/Final_report__Industrie_4.0_accessible.pdf.
- German Federal Ministry of Education and Research, *Project of the Future: Industry 4.0*.
- Giersberg, G, *Die Daten der Industrie werden zum Milliardengeschäft*, 2015. Retrieved from <http://www.faz.net/aktuell/wirtschaft/unternehmen/industrie-4-0-die-daten-der-industrie-werden-zum-milliardengeschaeft-13619259.html>.
- Harris, S. *Industry 4.0: the next industrial revolution* (The engineer, 11 July 2013). Retrieved from: <http://www.theengineer.co.uk/industry-4-0-the-next-industrial-revolution/>.

- Howard, P.N. *Sketching out the Internet of Things trendline* (Brookings Institute, 2015). Retrieved from: <http://www.brookings.edu/blogs/techtank/posts/2015/06/9-future-of-iot-part-2>.
- Industry 4.0—Challenges and Solutions for digital transformation and use of exponential technologies. Retrieved from <http://www2.deloitte.com/content/dam/Deloitte/ch/Documents/manufacturing/ch-en-manufacturing-industry-4-0-24102014.pdf>.
- Industry 4.0. Study prepared by the Centre for Strategy and Evaluation Services for the ITRE Committee. *Directorate General for Internal Policies Policy Department A: Economic and Scientific Policy*. Available at: www.europarl.europa.eu/studies.
- Kuom, M. *Internet of Things & Services in Production: Industrie 4.0*. 2015. Presentation prepared for: European Co-operation on innovation in digital manufacturing. Retrieved from: <https://ec.europa.eu/digital-single-market/en/news/european-co-operation-innovation-digital-manufacturing>.
- La Nouvelle France Industrielle (2013). Retrieved from: <http://www.economie.gouv.fr/>.
- MacInnes, B. *SMEs often lack effective IT security* (Microscope, May 2013). retrieved from <http://www.microscope.co.uk/feature/SMEs-often-lack-effective-IT-security>.
- Maras, M, 'Internet of Things: security and privacy implications' (2015) vol. 5 (2) *International Data Privacy Law*.
- McCurry, J. *South Korean nuclear operator hacked amid cyber-attack fears* (*The Guardian*, 22 December 2014). Retrieved from: <http://www.theguardian.com/world/2014/dec/22/south-korea-nuclear-power-cyber-attack-hack>.
- Protection of workers' personal data. An International Labour Organisation code of practice (1997) and Recommendation No. R (89) 2 of the Committee of Ministers to Member States on the Protection of Personal Data used for Employment Purposes.
- Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC.
- Ronnlund, AN, *Cyber-insurance and the NIS Directive*. Presentation held at CSP Forum workshop Risk assessment and cyber-insurance 27.04.2015.
- So wehren Sie sich gegen die Daten-Schnüffelei der Autohersteller. Article retrieved from: http://www.focus.de/auto/experten/winter/bmw-speichert-kunden-daten-wer-noch-wie-autos-uns-ausspaehen-und-was-man-dagegen-tun-kannbmw_id_5178515.html.
- Spanish Strategy for Science and Technology and Innovation. Retrieved from http://www.idi.mineco.gob.es/stfls/MICINN/Investigacion/FICHEROS/Spanish_Strategy_Science_Technology.pdf.
- Terzidis, L, Oberle, D, and K Kadner, *The Internet of Services and USDL*. Retrieved from <https://www.w3.org/2011/10/integration-workshop/p/USDLPositionPaper.pdf>.
- UK Government Office for Science (2013) *The Future of Manufacturing: A new era of opportunity and challenge for the UK*, retrieved from: <https://www.gov.uk/government/publications/future-of-manufacturing/future-of-manufacturing-a-new-era-of-opportunity-and-challenge-for-the-uk-summary-report>.
- Walker, D, 'Havex' malware strikes industrial sector via watering hole attacks (*SC Media*, 25 June 2014). Retrieved from <http://www.scmagazine.com/havex-malware-strikes-industrial-sector-via-watering-hole-attacks/article/357875/>.
- Welche Daten Ihr Drive Now-Auto sammelt und was damit passieren kann. Retrieved from: http://www.focus.de/auto/experten/winter/bmw-drive-now-ueberwachung-funktioniert-bei-harmlosen-buergern-in-carsharing-autos-wird-ihr-bewegungsprofil-gespeichert_id_5759933.html.
- Zetter, K. *An Unprecedented Look at Stuxnet, the World's First Digital Weapon* (*Wired.com*, 3 Nov 2014). Retrieved from: <http://www.wired.com/2014/11/countdown-to-zero-day-stuxnet/>

Reasonable Expectations of Data Protection in Telerehabilitation— A Legal and Anthropological Perspective on Intelligent Orthoses

MARTINA KLAUSNER AND SEBASTIAN GOLLA

Abstract. Combining insights from legal studies and anthropology, this paper looks at the expectations of future users of telerehabilitation technologies and the importance of these expectations for the privacy and data protection-friendly development of the technologies at hand. Against the background of the concepts of ‘reasonable expectations’ and ‘privacy by design’ in the GDPR, an ethnographic study in a research project developing intelligent orthoses for the treatment of scoliosis brings light to the actual expectations of a group of young patients.

Keywords: *Reasonable Expectations—Privacy by Design—E-Health—Information Preserves—Legal Anthropology*

I. Introduction

In our research, we have been looking at the expectations of data subjects and their relationship with data processors to enable the development of data protection and privacy-friendly technologies in telerehabilitation. We used an interdisciplinary approach combining legal and anthropological methods. One important issue in the field of telerehabilitation is the increasing use and development of assistant systems for therapy purposes, which can also be referred to as ‘intelligent therapy machines’.

A. Telerehabilitation: A Challenge for Data Protection

The applications of telemedicine and telerehabilitation which enable medical treatment or therapy from a distance are becoming more and more sophisticated.

Those technologies carry many promises; one important aspect is the supply of rural areas with healthcare services. Needless to say, those data-intensive technologies also challenge privacy and data protection. First, they entail an increase of data acquisition and processing. Second, new actors get in touch with the personal data of patients.¹ Among others, this includes technicians and engineers who are supplying the new technologies. The appearance of new actors modifies the classical relationship between doctors or therapists and patients. Third, the relationships between actors are changed by the increasing use of intelligent assistant systems in rehabilitation therapy. Supplied with sophisticated algorithms, therapy systems shall be enabled to automatically adapt to patients' individual needs. The use of these assistant systems can have benefits for the patients, but can also create an environment which does not do justice to individual cases.

B. Research Context and Methods

We carried out our research in the interdisciplinary research cluster BeMobil,² funded by the German Ministry of Education and Research. The research cluster focuses on the development and improvement of rehabilitation technologies and therapeutic systems for patients with limited mobility after a stroke or due to amputation or scoliosis. One central aspect is the development of intelligent therapy systems. Those systems provide the technical basis to be used in telecare settings, that is, in patients' homes.

Addressing issues of data protection and privacy was indicated from the beginning of the project. Elaborating on these issues is part of an accompanying research focusing on the 'ethical, legal, and social implications' (ELSI) of the technological developments. While in the German context ELSI research is mainly executed by ethicists/philosophers, this particular ELSI-project is based on an anthropological approach and empirical research with potential users and technology developers. The overall aim of this ELSI approach is to provide an empirical analysis of the actual therapeutic practices (before the implementation of new technologies) and expectations of users regarding those developments and to confront those findings with the technologies in the development process. While there are similarities with usability research, our concern is less on improving the design of technologies but on raising more fundamental questions concerning the potential implications of those developments. To tackle issues of data protection and privacy, the research is carried out in a collaboration of law and anthropology,

¹ Cf. B Berger Kurzen, *E-Health und Datenschutz* (Zürich, Schulthess, 2004), 48; R Klar and E Pelikan, Stand, Möglichkeiten und Grenzen der Telemedizin in Deutschland' (2009) 52 *Bundesgesundheitsblatt* 263, 266. Additionally existing actors might change their roles when technologies of telerehabilitation are used. For instance, medical practitioners increasingly become data subjects if technologies are monitoring their interaction with the patient.

² Full title 'Bewegungsfähigkeit und Mobilität wiedererlangen—Regaining motivity and mobility', more information available under <http://www.bemobil.net>.

combining questions of legal standards and their implementation in the development process and qualitative research on the practice of data protection by potential users and their expectations regarding the technologies to be developed. The aim is to provide our colleagues from the technical and medical sciences with strategies to implement ‘privacy by design’.

We attended to and evaluated the development proceedings in an ongoing process. Besides general support for the whole research cluster we selected three projects out of eleven to attend to data protection issues in more specific ways. In these three projects, we carried out fieldwork in the working processes, interviewed developers and evaluated so-called application scenarios which we discussed with the development teams. The aim of this evaluation process is to sensitize developers for privacy and data protection from the beginning and to ensure that data protection issues were implemented during the whole process.

As part of the larger anthropological ELSI approach, we investigated the practices and experiences of users in data protection and their expectations of privacy. The aim is to provide feedback to the developers concerning privacy issues from the perspective of the users³—and not only legal requirements. We argue that users’ perception of potential risk to their privacy could result in the rejection of technologies; and—since telerehabilitation and automated systems are still not widely implemented in German health care—there is a need to work out best practice examples. Methods in our empirical research include fieldwork in therapeutic practice in rehabilitation centres and hospitals, and qualitative semi-open interviews with patients, therapists and caregivers.

In our work, we aim to merge two perspectives: a legal approach considering the normative basis of data protection and the respective implementation and an anthropological approach focussing on practices and expectations of potential users. Beyond the specific project our common concern is to experiment with a collaborative approach of law and anthropology: ‘co-laboration’, as discussed by Niewöhner, is a specific mode of working together: a ‘temporary joint epistemic work’⁴ with different disciplinary vanishing points. One way of engaging in this ‘epistemic work’ is to focus on concepts which to some degree play a role in both disciplines albeit with different meanings. In this paper, we elaborate on the concept of ‘reasonable expectations’ and will provide a disciplinary contextualization of the term.

C. Research Focus: The Orthoses Project

For this purpose, we will focus on one project entitled ‘Motivation Strategies in Orthosis Therapy’. In this particular project engineers, psychologists, software

³ In this context, users are not only patients but also therapists, doctors, nurses, family, and other care givers of the patient.

⁴ J Niewöhner, ‘Epigenetics: localizing biology through co-laboration’ (2015) 34 *New Genetics and Society* 219, 242, 235.

developers, and technicians work on the improvement of therapy for children and teenagers suffering from scoliosis, a three-dimensional deformity of the spine. Scoliosis in its milder variant can be treated with a brace or orthosis. This rigid plastic brace ‘presses’ children into the upright position. Depending on the degree of the deformation, children must wear the brace between 16 and 23 hours a day and for a period of several years. Little surprisingly, children and teenagers have troubles in fulfilling this therapeutic advice. Improving compliance is the goal of the project. The basic assumptions of the project are that children and teenagers have a hard time to realistically estimate the hours of wearing the brace and that a feedback of an objective measurement of their wearing performance would motivate them to fulfil therapeutic goals.

Therefore, the project develops a so-called multi-sensor-monitoring-system. A system of sensors is built into the brace: sensors capture temperature, moisture, pressure and increase of velocity. Based on the sensor data and processed by an algorithm, the children are provided with a visual feedback showing their results via an App on their smartphone. Besides feedback on wearing performance, the App provides information on scoliosis and therapy, accounts of other patients, videos with exercises, a quiz, and other features.

So far, access to the monitoring data is restricted to the development team. While it was originally planned that doctors could regularly access those data during the therapeutic process, the medical practitioners actually declined that approach due to the lack of time capacity to evaluate those monitoring data. There is however an interest from the medical field to use the monitoring system in clinical studies to compare therapy performance and clinical outcome.

The data base management will be handled by a company specialized in developing medical products. While the development team states that data will not be accessed by third parties besides the technicians managing the database, this is not all that clear for the future. To be regularly used in therapy, the developing companies are interested to have contracts with health insurance companies to pay for those devices. And already, insurance companies have displayed great interest in data concerning therapy performance and compliance rate. How the emergence of new actors in telerehabilitation will affect data protection measurement in the future therefore is an important question.

II. The Legal Angle: Reasonable Expectations and Privacy by Design

From a legal perspective, the orthoses project raises various issues. Those include the specific requirements for consent in processing the data of minors, the question if all sensor data in the orthoses project is to be regarded as health data and other questions of Data Protection Law, but also questions of Medicine Law.

In this paper, we will focus on the legal requirements of privacy by design against the background of the reasonable expectations of the patients who will use the technology and become data subjects. For that purpose, we will first give an introduction to the concepts of ‘reasonable expectations’ and ‘privacy by design’ in the GDPR. Then we will illustrate the possibility to specify the concept of ‘reasonable expectations’ by interdisciplinary research looking at the experience in US-American Privacy Law. Finally, we will point out how the use of intelligent systems in telerehabilitation is important regarding reasonable expectations.

A. Reasonable Expectations and Privacy by Design in the GDPR

In European Data Protection Law, especially Art. 6 and Art. 25 GDPR provide the legal basis for our approach. While Art. 6 GDPR contains general rules for the lawfulness of the processing of personal data, Art. 25 GDPR sets a legal standard for data protection by design and by default. Under the GDPR, the perspective of the data subject becomes more important than ever in European Data Protection Law to determine whether the use of a technology processing personal data is legitimate.

The concept of ‘reasonable expectations’ is introduced in the GDPR by Art. 6 para 1 (f) GDPR in conjunction with the corresponding Recital 47. While Art. 6 para 1 (f) GDPR cannot justify the processing of health data,⁵ its criteria set general standards for the processing of personal data considering the expectations of data subjects in their relationship with data processors. We will argue that those criteria can also be drawn upon as a help to determine whether a technology meets the requirements of Art. 25 GDPR.

According to Art. 6 para 1 (f) GDPR, the processing of personal data shall be lawful if it is necessary for the purposes of the legitimate interests pursued by the controller or a third party, except where such interests are overridden by the interests or fundamental rights and freedoms of the data subject which require protection of personal data. To determine whether there are overriding interests according to Recital 47 S. 1 GDPR, the reasonable expectations of data subjects based on their relationship with the controllers have to be taken into consideration. Those expectations take a central part in the balance of interests under Art. 6 para 1 (f) GDPR.⁶

‘Reasonable expectations’ also become relevant for the interpretation of Art. 25 para. 1 GDPR. This provision sets a new legal standard for privacy by design

⁵ Cf. Art. 4 para. 15, Art. 9 GDPR.

⁶ N Härtling, *Datenschutz-Grundverordnung: Das neue Datenschutzrecht in der betrieblichen Praxis* (Köln, Otto Schmidt, 2016), § 434.

and is regarded as one important innovation of the GDPR.⁷ It requires data processors to ‘implement appropriate technical and organisational measures, [...] which are designed to implement data-protection principles (...) in an effective manner and to integrate the necessary safeguards into the processing in order to meet the requirements of this Regulation and protect the rights of data subjects’. To determine whether measures are appropriate, the context of the processing has to be taken into account. Among other things, this requires a look at the reasonable expectations of potential data subjects in their relationship with the controller. This goes hand in hand with the basic idea that privacy design is supposed to be ‘user-centric’ and should be ‘consciously designed around the interests and needs of individual users’.⁸

This connection between the reasonable expectations and the principle of ‘privacy by design’ is also acknowledged in other legal systems outside of Europe. For instance, Art. 103 (1) (A) of the US Commercial Privacy Bill of Rights Act of 2011 requires to consider ‘the reasonable expectations of such individuals regarding privacy’ as a basis for measures of privacy by design.

Therefore, the concept of ‘reasonable expectations’ has the potential to contribute to a better understanding of the lawfulness of processing personal data based on legitimate interests and the appropriate measures of privacy by design. However, it has to be noticed that ‘reasonable expectations’ can only exist if a technology and its direct and indirect privacy implications are understandable for the data subject. The transparency and understandability of data processing systems are important prerequisites to apply the concept of ‘reasonable expectations’.

B. Gaining Legal Certainty with ‘Katz Content’

Both Art. 6 para. 1 (f) and Art. 25 GDPR are rather vague provisions. Their application in a specific case is difficult since their legal requirements leave a lot of room for interpretation. We will show that interdisciplinary research in legal and anthropological/social sciences can help to specify the requirements of these provisions and therefore to achieve more legal certainty, especially taking into account the reasonable expectations of data subjects. To do this, we will take a closer look at the term reasonable expectations in the GDPR and the US-American experience with the reasonable expectations of privacy test. We are aware that the US-American reasonable expectations of privacy test regarding the Fourth Amendment to the United States Constitution emanates from a completely different context than the

⁷ M Hildebrandt and L Tieleman, ‘Data protection by design and technology neutral law’ (2013) 29 *Computer Law & Security Review* 509–521; G Skouma and L Léonard, ‘On-line Behavioral Tracking: What May Change After the Legal Reform on Personal Data Protection’ in S Gutwirth, R Leenes, and P De Hert (eds), *Reforming European Data Protection Law* (Dordrecht, Springer, 2015) 35, 56.

⁸ A Cavoukian, *Privacy by Design: The 7 Foundational Principles* (Ontario, Office of the Information & Privacy Commissioner of Ontario, 2009).

GDPR and has no direct relevance for its interpretation. However, the experiences from the application of this test and interdisciplinary efforts to put some life into it can also be valuable for the interpretation of the GDPR.

The criterion 'reasonable expectations' in the GDPR, which is based on a proposal by the European Parliament,⁹ bears an obvious resemblance to an important instrument of US-American Privacy Law. Since its *Katz* Judgement in 1967 (*Katz v. United States*, 389 U.S. 347) the US Supreme Court uses the 'reasonable expectations of privacy test' to determine whether the privacy protections of the Fourth Amendment to the United States Constitution apply. The test invented by the US Supreme Court knows two criteria: First, a person (data subject) must 'have exhibited an actual (subjective) expectation of privacy'. Second, this expectation must 'be one that society is prepared to recognize as reasonable'. While the first criterion refers to an individual point of view and is thereby subjective, the second criterion is an objective one to be judged from the view of society or a group within society. Following the *Katz* decision, the US-American 'reasonable expectations of privacy test' influenced jurisdictions all over the world.¹⁰ In this context, it is noteworthy that the European Court of Human Rights has also used the criterion of 'reasonable expectations of privacy' to determine the protection of privacy under Art. 8 European Convention of Human Rights, however without developing it in much detail.¹¹ The recent case of *Bărbulescu v. Romania* seems to imply that the Court emphasises the subjective element of the concept of 'reasonable expectations' more strongly than its objective element.¹² The US-American jurisprudence can offer some help to understand what can be considered as reasonable expectations in the context of the GDPR. Certainly, the Supreme Court's test was drafted from the background of the constitutional law and a different legal tradition. However, the context of the term reasonable expectations in Recital 47 GDPR provides grounds for a similar basic interpretation. Similar to the US test, the term under the GDPR consists of both a subjective and an objective element, although the subjective element in the GDPR seems to be much more important than in the US-American test. While the element 'reasonable' suggests that an expectation would have to be supported at least by a group of people, the requirement to

⁹ JP Albrecht, 'The EU's New Data Protection Law—How A Directive Evolved Into A Regulation' (2016) 17 *Computer Law & Security Review* 33, 37.

¹⁰ T Gómez-Arostegui, 'Defining Private Life Under the European Convention on Human Rights by Referring to Reasonable Expectations' (2005) 35 *California Western International Law Journal* 153 ff.

¹¹ ECtHR, *Uzun v. Germany*, Application no. 35623/05, 2 September 2010, § 44; ECtHR, *von Hannover v. Germany*, Application no. 59320/00, 24 June 2004, § 51; ECtHR, *Perry v. The United Kingdom*, Application no. 63737/00, 17 July 2003, § 37; ECtHR *Halford v. The United Kingdom*, Application no. 20605/92, 25 June 1997, § 45.

¹² ECtHR, *Bărbulescu v. Romania*, Application no. 61496/08, 12 January 2016, § 37 ff.; cf. Partly Dissenting Opinion of Judge Pinto de Albuquerque, § 5 ('In my view, the 'reasonable expectation' test is a mixed objective-subjective test, since the person must actually have held the belief (subjectively), but it must have also been reasonable for him or her to have done so (objectively). This objective, normative limb of the test cannot be forgotten.').

consider the relationship with the controller seems to require looking at the individual circumstances of a data subject.

Also, the US-American experience shows that the ‘reasonable expectations’ approach enables interdisciplinary research to help to determine the legal requirements of data processing and privacy by design with empirical methods. In the US privacy scholars criticized the reasonable expectations test because the protected expectations had not been researched/investigated by courts in a proper manner.¹³ There are, however, several attempts to ‘make the test come alive’ consulting social sciences and empirical research.¹⁴ Specifically noteworthy here is the work by Nissenbaum who elaborates on the framework of ‘contextual integrity’ to highlight the fundamentally context-dependent quality of privacy.¹⁵ Nissenbaum emphasises that individuals’ as well as societal understandings of privacy are deeply rooted in social norms and values which vary according to the context of a situation of information dissemination. Critically discussing the notion of ‘reasonable expectations’ and some of its implications she pleads for a grounding of ‘reasonable expectations’ in specific contexts. Deciding whether the use of certain information technologies, the collection of personal data and its processing ‘violates expectations of privacy should not merely assess how common the technologies and how familiar people are with them, but how common and how familiar they are in context, and if this is known, whether the particular application in question violates or conforms the relevant context-relative informational norms’¹⁶ This further specifies how to operationalize ‘reasonable expectations’ and invites for thorough empirical research in specific contexts.

C. Reasonable Expectations and the Use of Intelligent Systems in Telerehabilitation

One special aspect which has to be considered for the reasonable expectations of data subjects concerning telerehabilitation technologies is the use of intelligent systems. In the BeMobil cluster various projects focus on the development of intelligent systems with ‘Assist-as-needed’ functions. In the orthoses project it

¹³ HF Fradella, WJ Morrow, RG Fischer, and C Ireland, ‘Quantifying Katz: Empirically Measuring “Reasonable Expectations of Privacy” in the Fourth Amendment Context’ (2011) 38 *American Journal of Criminal Law*, 289, 293.

¹⁴ Fradella, Morrow, Fischer, and Ireland, ‘Quantifying Katz: Empirically Measuring “Reasonable Expectations of Privacy” in the Fourth Amendment Context’; M McAllister, ‘The Fourth Amendment and New Technologies: The Misapplication of Analogical Reasoning’ (2012) 36 *Southern Illinois University Law Journal* 475 ff.; C Slobogin and JE Schumacher, ‘Reasonable Expectations of Privacy and Autonomy in Fourth Amendment Cases: An Empirical Look at “Understandings Recognized and Permitted by Society”’ (1993) 42 *Duke Law Journal* 727 ff.

¹⁵ H Nissenbaum, *Privacy in Context: Technology, Policy, and the Integrity of Social Life* (Stanford University Press, 2009).

¹⁶ Nissenbaum, *Privacy*, 235.

is planned to use sensor data to evaluate the wearing performance. There were also ideas to develop an automatic assistance system to correct the carrier's body posture, but this aspect of the development was put on hold for technical reasons.

The use of intelligent systems is important when we look at reasonable expectations because it automatically affects the relationship of the data subject with the controller. It seems likely that especially in medical practice and therapy, patients will only expect and understand the use of assistant systems processing personal data up to a certain point. It is an issue of privacy by design to make the use of intelligent systems comprehensible for all users of the technology. Additionally, the use of these technologies has to be made transparent to get a valid consent from the patients for the processing of personal data. However, a privacy-friendly technology cannot be achieved by transparency in data processing alone. It additionally requires a system that is aiming to afford privacy.

Additionally, the use of intelligent systems in medical practice and therapy is limited by specific rules of Data Protection and Medical Law. In Data Protection Law Art. 22 para. 1 GDPR limits the possibilities of automated decision making. The provision states that '[t]he data subject shall have the right not to be subject to a decision based solely on automated processing, including profiling, which produces legal effects concerning him or her or similarly significantly affects him or her'. The right not to be made an 'object' of automated decisions can also be seen as an element of the guarantee of Human Dignity in Art. 1 EU Charter of Fundamental Rights. However, in the case of the adaption and monitoring of the orthoses Art. 22 para. 1 GDPR will not apply due to lack of the requirement that the automated decision 'produces legal effects concerning' the data subject 'or similarly significantly affects him or her'. The monitoring and the measurement of the wearing performance alone are not to be regarded as an automatic decision. Beyond that, the slight automatic adaptations planned in the project will not have a significant impact on the data subject. The question if an effect is severe enough to 'similarly significantly affect' a data subject can be answered by looking at the affected interests of the data subject in each individual case. By identifying the affected interests, it can be determined whether the specific effect in the case is comparable to a legal effect. In our scenario, the applied technology does not enable any form of adaptations that would have perceptible physical effects on the data subject.

It is likely that therapy systems with stronger automated elements will be developed in the near future. In emergency medicine, assistant systems which make decisions about life-saving measures¹⁷ are imaginable. These are likely to have a stronger impact on the interests of individuals and would fall under Art. 22 para. 1 GDPR.

In Medical Law, the duties of medical practitioners and therapists to treat their patients personally restrict the possibilities to use intelligent systems.

¹⁷ Eg by choosing between different measures.

For instance, the Model Professional Code for Physicians in Germany includes duties not to accept any instructions from non-physicians (Art. 2 para. 4), to provide medical treatment in such a way that human dignity is preserved (Art. 7 para. 1), personally and not exclusively via print and communications media (Art. 7 para. 4).¹⁸ As an absolute limit, it would not be legal to substitute a practitioner's work completely with an intelligent system. On the other hand, the automatic adaption of single therapy elements does not constitute a violation of the practitioners' duties.

III. The Anthropological Angle: Reasonable Expectations of Minors in Brace Therapy

A. Methods and Overview of Findings

In the following section, we will take up the concept of 'reasonable expectations' from an anthropological angle. The aim of our ethnographic research was to elaborate on patterns and contexts of 'reasonable expectations' as expressed by potential users of the system. During our research, we have interviewed 44 children and teenagers (10 children at the age between 9 and 13 and 34 teenagers between 14 and 18 years old), ten of them together with a parent. We interviewed 8 male and 36 female patients which is in accordance with the higher prevalence of scoliosis among girls (5:1). The sample of interviewees is based on an opportunity sampling, as we approached children and teenagers only because of their scoliosis therapy in a paediatric orthopaedics hospital and at a brace-manufacturer, both in Berlin. We conducted semi-structured open interviews, so duration and depth of the interviews varied. The interviews did not exclusively focus on issues of data protection and privacy, but covered a range of topics: experience of scoliosis and therapy, everyday routines and the use of the brace, the role of family and friends, experience in the use of digital technologies. The interview focusing on data protection was preceded by an interview on the use of digital technologies and questions regarding the potential use of monitoring data in therapy and the future sensor system and app. The questions explicitly addressing data protection issues covered the following topics: 1) general knowledge of data protection, 2) specific data protection practices, individual experiences), 3) significance and expectations.

Generally, our findings correspond with conclusions of other research on youth, their use of digital technologies and data protection knowledge and practice and

¹⁸ Cf in more detail SJ Golla, 'Arzt, Patient und Assistenzsystem' (2015) 3 *InTeR* 194 ff.

concerns on privacy.¹⁹ Most of our interviewees regularly use digital technologies, possess a smartphone, and are frequent users of social networking sites; most teenagers were informed on data protection on a general level and had knowledge of basic principles. However, actual data protection practices were diverse, ranging from very low interest in and engagement with those issues to high sensitivity and elaborated practices. What was especially relevant for our research were the expectations (and practices) handling data concerning health. It first surprised us that our interviewees very rarely expressed concerns specifically regarding data concerning health and the planned sensor-monitoring-system that should be implemented in the orthoses. A closer look revealed that the interviewees' general idea about what is to be regarded as sensitive data indeed differs from legal definitions. It is very much related to the specific context of the situation where data is shared. The disclosure of data concerning health as planned in the system in development was interpreted as unproblematic as it was regarded similar to experiences with sharing data with a physician/therapist. Nevertheless, there were shared concerns about other data which was regarded sensitive. Here the focus was on narratives on strategies of keeping control over one's data and protecting 'privacy'. We propose to take the practices of these children and teenagers as a starting point to elaborate on an analytical framework for data protection measurements that conveys reasonable expectations to data protection and privacy as a situational, culturally and socially embedded phenomenon.

B. Analytical Framework: The Concept of 'Territories of the Self' (Erving Goffman)

In line with much work in legal anthropology, we consider law as both an embedded and emergent feature of social life.²⁰ To elaborate on the experiences and expectations of data protection these are to be more generally considered as part of social order and collective practices. Ewick and Silbey, for example, argue to take 'legality'—the subjective meaning and practice of law—as an emergent structure of the social which is enacted in mundane practices.²¹ This resonates well with

¹⁹ d boyd, *It's Complicated! The Social Lives of Networked Teens* (Yale University Press, 2014); M Madden, A Lenhart, S Cortesi, U Gasser, M Duggan, A Smith, and M Beaton, 'Teens, Social Media, and Privacy' (2013) 21 *Pew Research Center* 2–86; AE Marwick, DM Diaz, and J Palfrey, *Youth, Privacy and Reputation: Literature Review* (Cambridge, The Berkman Center for Internet & Society at Harvard University, 2010); DIVSI (Deutsches Institut für Vertrauen und Sicherheit im Internet), *U25-Studie: Kinder, Jugendliche und junge Erwachsene in der digitalen Welt* (2014); Ito, M, et al., *Hanging Out, Messing Around, and Geeking Out: Kids living and learning with new media* (Cambridge, MIT Press, 2009).

²⁰ L Nader, *Law in Culture and Society* (Oakland, University of California Press, 1997 [1967]); S Falk Moore, *Law As Process. An Anthropological Approach* (Münster, LIT Verlag, 2000); M Valverde, *Law's Dream of a Common Knowledge* (Princeton, Princeton University Press, 2003).

²¹ P Ewick and S Silbey, *The Common Place of Law: Stories from Everyday Life* (Chicago, University of Chicago Press, 1998).

the line of argument by Nissenbaum on 'contextual integrity' introduced above which highlights the need to evaluate concerns about privacy as centrally shaped by social norms and values in specific contexts. Yet, Nissenbaum's concern is to provide a framework to analyse a variety of new technologies and critical public debates and concerns related to them and is therefore situated more on a middle-range analysis. While her framework serves us as an important backdrop, for the analysis of our empirical data we will rather draw from another source (to which Nissenbaum also refers to as a theoretical source). To scrutinize the 'legality' of privacy and data protection in our specific case, we will use the concept of 'territories of the self' as it was introduced by the US-American sociologist Erving Goffman in 1971 in his book *Relations in Public: Microstudies of the Public Order*.²² Before we elaborate on some necessary modifications of the concept for addressing privacy in the digital age and to present our empirical findings we want to introduce Goffman's original concept here. Goffman's aim was to identify and classify different ways of social interaction and to work out orders of everyday behaviour in public. One central question was how human beings interact according to established boundaries of self and others and how these interactions are bound to claims of physical and social integrity. Here, the concept of 'territories of the self' plays a crucial role as it describes a simultaneously physical and social space over which a person can expect to command use as well as to make claims to rights to privacy. In his 'Microstudies of the Public Order' Goffman identified eight so called preserves: from the person-centred space surrounding a person physically, the body's sheath as the most intimate preserve to other preserves which are more location or situation-bound. One of Goffman's proposed preserves is in particular relevant for our discussion: the information preserve.

According to Goffman, the information preserve is: 'The set of facts about himself to which an individual expects to control access while in the presence of others. [Footnote by Goffman: Traditionally treated under the heading of 'privacy'.] There are several varieties of information preserve, and there is some question about classing them all together. There is the content of the claimant's mind, control over which is threatened when queries are made that he sees as intrusive, nosy, untactful. (...) There are biographical facts about the individuals over the divulgence of which he expects to maintain control. And most important for our purposes, there is what can be directly perceived about an individual, his body's sheath and his current behaviour, the issue here being his right not to be stared at or examined'.²³

Reconsidering what we discussed above from a legal angle, it seems fair to claim that Goffman's definition relates closely to the discussed explanations of

²² E. Goffman, *Relations in Public: Microstudies of the Social Order* (New Brunswick, Transaction Publishers, 2009 [1971]).

²³ Goffman, *Microstudies*, 38 ff.

reasonable expectations of privacy and data protection. In a similar way, he emphasizes an individual's situation which is at the same time always situated in a larger social context and collective meanings.

We will take up Goffman's proposal to elaborate on different kinds of information preserves specifically addressing data protection in the digital age: When, in which context, for which purpose is the access to personal data by a third party accepted and when is it considered illegitimate? Similar to the temporary acceptance of physical proximity in an elevator, we argue, that the acquisition and processing of personal data, and specifically health-related data, are considered legitimate in specific social contexts while in others are seen as a fundamental violation. This approach enables us to develop a framework that regards data protection and privacy issues as a collective social practice and to provide a basis to further elaborate on the concept of 'reasonable expectations' as one core aspect of data protection measurements.

This has at least two important implications: First, from this perspective data protection is not looking at an individual's practice, but is fundamentally understood as a collective and ongoing social practice. In a similar way Dourish and Anderson for example argue that conventional data protection concepts are based on a concept of the rational individual actor while they plea for taking privacy and security as fundamental social and cultural phenomena: 'Privacy is not simply a way that information is managed but how social relations are managed.'²⁴ There is no objective state of 'privacy' or 'security' of personal data. Those are negotiated social orders, to refer to Goffman again and 'context-relative informational norms' as Nissenbaum terms it. Specifically the notion of privacy has been critically addressed by a variety of other scholars, which provide various attempts to define and differentiate it.²⁵ Yet, few of them—among them Nissenbaum and Dourish and colleagues—have provided concepts which focus on the socially negotiated, collective and context-relative character of privacy.

Second, the concept of the territory or the preserve introduces a spatial and material dimension, asking to take physical context and material affordances into consideration. While Goffman emphasized that 'territories of the self' are simultaneously material and ideal, the concept was for obvious reasons limited to the physical co-presence of actors. In the digital era physical co-presence is not self-evidently given anymore. We therefore need to modify Goffman's approach: to consider various kinds of information preserves it is necessary to also consider the material affordances of technologies and their technical hinterland (infrastructures, databases, networks) as co-productive of those preserves. The technical

²⁴ P Dourish and K Anderson, 'Collective information practice: exploring privacy and security as social and cultural phenomena' (2006) 21.3 *Human-computer interaction* 319, 342, here 327.

²⁵ There is no space to discuss them in detail. For excellent overviews of the different approaches and a critical discussion see for example Nissenbaum, *Privacy* (n 15) and C Ochs, 'Die Kontrolle ist tot—lang lebe die Kontrolle! Ein Plädoyer für ein nach-bürgerliches Privatheitsverständnis' (2015) 4.1 *Mediale Kontrolle unter Beobachtung*.

hinterland which most often remains invisible to the individual user of a system creates specific affordances for data protection practices, and shapes meanings and expectations of privacy.²⁶

C. Discussion of Empirical Findings

In recent years there has been an increased interest in children's and teenagers' use of digital technologies, especially social media networks and other digital communication channels.²⁷ Critically engaging with the notion 'digital natives' which is supposed to highlight the competences and skills of those born in the 'digital age', those studies carefully examine the complex practices of children and teenagers regarding digital technologies and their diverging attitudes concerning privacy and data protection. We will refer to findings in those studies along the discussion of our sample.

In what follows, we first introduce the different attitudes of minors towards data protection and privacy issues. This is followed by an analysis of three different types of data preserves which refer to data described as the most sensitive by our interviewees. These findings serve to contextualize our main argument focusing on data concerning health and the expectations of our interviewees on this matter.²⁸

²⁶ For our underlying concept of infrastructures, we refer to G Bowker and SL Star, *Sorting Things Out. Classifications and its Consequences* (Cambridge, MIT Press, 2000).

²⁷ d boyd, *It's Complicated!* (n 19); Madden et al., *Teens* (n19); Ito et al., *Hanging Out* (n19); S Livingston, 'Taking Risky Opportunities in Youthful Content Creation: teenagers' use of social networking sites for intimacy, privacy and self-expression' (2008) 10.3 *New Media & Society* 393,411; T McPherson, *Digital Youth, Innovation, and the Unexpected* (Cambridge, MIT Press, 2008).

²⁸ Given the size of our sample a correlation of those attitudes and practices with socioeconomic and family backgrounds or a generalization of the impact of personal context on attitudes towards privacy and data protection practices proved not to be feasible. While we have asked our interviewees general questions concerning their parents professional background, their school-type and their family structure and also more specifically about their parents educational style, there were few indices for generalization. Age seemed to play a role as older teenagers frequently reflected more intensely on their data sharing practices; but again, some of the younger ones were highly informed and some of the older interviewees displayed little consideration on the topic. What complicated the matter even more was that part of the children and teenagers who have shown high knowledge and reflection on data protection and privacy nevertheless engaged heavily in data dissemination in practice. Also with growing age, the peer group seemed to play an increasing role in data sharing practices. The German Institute for Trust and Security in the Internet (DIVSI) introduced a so-called 'internet-milieu' approach, with a typology of internet users based on a combination of socioeconomic status, intensity of use, attitudes towards the Internet and more general value orientations which seems to be a promising direction. (DIVSI, *Milieu-Studie zu Vertrauen und Sicherheit im Internet* (2012)). Two studies concerning the use of the internet by children (DIVSI, *U9-Studie: Kinder in der digitalen Welt* (2015)) and the young generation (DIVSI, *U25-Studie: Kinder, Jugendliche und junge Erwachsene in der digitalen Welt* (2014)) give some insights in potential impact of life-worlds on those practices in Germany.

i. Attitudes Regarding Data Sharing

We have identified four general attitudes of teenagers²⁹ regarding the disclosure of personal data.³⁰ These mainly concern the general use of digital media and the decision to use or not to use certain services or features. What is important to note here is that the routine use of specific services and networking sites itself does not say much about the attitudes and practices of children and teenagers concerning data protection.

a) Minimization of Data Disclosure

Some teenagers were generally uneasy and cautious about sharing personal data in digital media. Even when using social networking sites they claimed to be rather passive, browsing others' accounts, but rarely actively posting information about themselves. They were also very concerned to whom they disclosed personal information. Particular emphasis was laid on the differentiation between people one knows 'in real life' and people only met in digital media. They also mentioned worries about the limited possibility to really delete pictures or posts.

b) Data-Sharing as Trade-Off

Most of our interviewees had a rather pragmatic or mainly positive approach towards sharing personal data. As one teenager, 16 year old Sasha,³¹ explained:

'I see it like that: you need to sacrifice something. I think that yes, my privacy is important. But, technologies and the possibilities, if we talk about smartphones and apps for example, this increases my quality of life. And I am ready to give away some of my privacy to enjoy more quality of life.'

The possibility to connect with other people, to use messenger services, to have easy procedures for shopping and so on were considered as positives effects in the lives of our interviewees. They did not indicate to share personal information carelessly, but were overall focused on the potentials that were offered by the used technologies. Some also considered their data as not being interesting to third parties or at least did not consider the processing of their data by others could cause any serious harm.

²⁹ As our central concern is to describe patterns of experiences and practices and our overall sample is too small to make any quantitative claims, we refrain from giving absolute numbers of interviewees for each attitude. Suffice to state that attitude b) was the largest portion, while the others were evenly distributed. In some interviews there were also mixtures, so the four attitudes should not be regarded as clearly bounded but rather covering a range.

³⁰ For similar findings regarding attitudes towards security in ubiquitous and mobile technology use see Dourish et. al 2003. Explicitly dealing with privacy attitudes of teenagers and coming up with a similar categorization is Grant (2006, as cited in Marwick et al. p. 12) differentiating between 'naïve dabblers', 'open-minded liberals' and 'cynical concealers'.

³¹ All names of interviewees are pseudonyms.

c) Impracticality of Controlling Personal Data

Some interviewees were more critical on the potential consequences of disclosing personal information but nevertheless considered it a necessary trade-off. As Aisha, a 15 year old teenager, explained:

‘I don’t like it that my own life is being spied out. But it is a decision you make in that moment, what is more important. I want to use something and so I accept the trade-off, because else I have no other possibility to participate.’

Typically, teenagers with this attitude considered privacy statements as too complicated and not aiming at really elucidating the interests and procedures of data processing. Another frequent problem indicated was that at the end there is little choice not to agree if one wants to participate in collective communication practices.

d) Data-Sharing without Concern

Not all children and teenagers we interviewed did reflect on data protection and privacy in a profound way. Some simply did ‘what others do’. When talking about data protection this was mostly limited to handle passwords in a careful manner. There was no awareness about potential risks. The focus was on easy access and participation.

ii. *Information Preserves Concerning ‘Data Especially Worthy of Protection’*

While we have already provided some insights in the practices of our interviewees we will now provide a deeper analysis of this practice specifically focusing on what is considered to be ‘data especially worthy of protection’ by our interviewees.

While the attitudes described above focus more generally on the decision to (not) participate in data disclosure, the following analysis shows how those interviewees who once decided to use a specific service practice data protection during the routine use. In our analysis three ‘information preserves’ emerged which we have termed location preserve, image preserve, and reputation preserve.

The location preserve: When talking about data protection practice much concern was raised by our interviewees regarding data on their physical location. For example, location detection by GPS or functions of the mobile phone were seen as highly problematic. This concern did not immediately result in switching those functions off or avoiding systems which use it, as it was a condition for using services in some cases. Location data as referred to by our interviewees included information about their address, school or temporary location like a café or other places they visit. Those who said they would post a specific location clearly differentiated between situations when this was considered appropriate and when not. In general, the interviewees showed a high sensitivity regarding the management of any data which could enable strangers to reach them in ‘real life’.

The image preserve: Many of our interviewees discussed the handling of pictures on social networking sites and explicated diverse strategies how to use them in the right way. Very few (usually younger interviewees) were generally avoiding uploading pictures of themselves. For example, some used pictures that never showed their face (or at least not their eyes) or used images of animals or cartoons in their profiles on Facebook or similar social media networks. Overall, the distribution of pictures very much depended on the social context and was mostly limited to people whom one knows in person outside of social networking sites.

The reputation preserve: The just mentioned handling of pictures was in many cases related to the more general handling of one's reputation. Pictures or posts that for example disclosed a person's party performance were considered risky. Many of the teenagers recalled stories where themselves or others made bad experiences sharing information that showed them in embarrassing or unfavourable situations. Also sharing intimate topics (such as being (un)happily in love) were seen as extremely sensitive and in need for carefully managing.

In all of the three preserves being conscious about the sensitivity of data did not simply result in rigid restriction or general avoidance of sharing those data. Many children and teenagers described how they weighed the pros and cons of disclosing personal data. This was mostly related to the 'necessity' of using a specific service or social networking site. Other studies, especially on the use of social media networks, have shown similar findings and state that the use of those platforms and sharing personal information 'does not in itself mean that they find privacy irrelevant'.³² Rather children and teenagers engage in various practices to control the dissemination of data appearing sensitive to them.³³

Once the general decision of using a certain device, service or starting a social media account was made balancing potentials and risks was often about managing access: With whom would they share specific data and how much information would they disclose in which context? Is that person real or fake, have I met a person physically, is she or he close to me, with whom is she or he friends, what is his/her social network, what are her/his intentions, can I trust him/her? Much handling of the particular sensitive data was managed along the differentiation of people personally known and those they were only in contact in the online-world. West et al. discussed similar findings in their study of students' practices of privacy on Facebook and stated that the decision when and with whom to share or not to share personal data was not based on a conception 'of there being two distinct realms of the public and the private', but rather along a differentiation 'of groups of "friends"'.³⁴ Similarly, boyd describes in detail the complex practices of

³² CJ Hoofnagle, J King, S Li, and J Turow, 'How different are young adults from older adults when it comes to information privacy attitudes and policies?' (2010) Retrieved from http://repository.upenn.edu/asc_papers/399, here 5.

³³ cf. Madden et al., *Teens* (n19); d boyd and E Hargittai, Facebook privacy settings: Who cares?, (2010), First Monday.

³⁴ A West, J Lewis, and P Currie, 'Students' Facebook 'friends': public and private spheres. (2009), *Journal of Youth Studies* 12(6), 615, 627, here 624.

teenagers in the US of delineating with whom to share or not to share personal information. In her examples much of the practices concerned with achieving privacy were about limiting or avoiding surveillance by authority figures such as parents or teachers.³⁵ Interestingly, her interviewees showed a similar indifference regarding 'organizational actors'.³⁶ In our interviews it also became obvious that in the everyday practice of sharing data, concerns about the interests of third parties diminished. Limitations to disclosed data were not based on the risk of potential abuse through third parties, but substantially on the idea of data disclosure as a social interaction with other persons.

However, there was one important distinction made that explicitly dealt with the format 'digital media': the awareness of the potentially unlimited distribution once something is shared and the potentially unlimited storage. Teenagers described how they had to learn to anticipate future events, for example looking for a job when grown up and how personal data shared now could then still be accessed by potential employers. In the following we want to bring in the one group of data which is specifically relevant for the research project and also legally defined as 'data especially worthy of protection': data concerning health.

iii. Attitudes and Expectations of Handling Data Concerning Health

Interestingly, only a small number of the 44 children and teenagers we interviewed considered health-related data as specifically sensitive. We did explain them that data concerning health was considered a special category of personal data in Data Protection Law³⁷ and this was part of the reason why we conducted the interviews. Still, for most of them it seemed rather unclear why this should be the case.

However, handling data concerning health was generally seen as problematic in four interviews: here posting information concerning their own health on the internet was regarded inappropriate. One reason for that was the need to anticipate future life conditions and the potential harm of data shared now, just as discussed above. Jenny, a 17-year old teenager who has been wearing her brace for more than three years, stated:

'I wouldn't post that I have scoliosis (...) or something like that. It doesn't have to have direct consequences, but then the other person knows about my scoliosis and you can't control anymore who gets that information and so on. In a face-to-face situation, I can always decide if I want to tell it someone, but when I posted it once then it's out there and everyone knows. I am still young and who knows how things will change, the employment market and so. And if this gets stuck on you just because you posted it when you were young and things were different, this is just really bad.'

³⁵ d boyd, *It's Complicated!* (n19).

³⁶ d boyd, *It's Complicated!* (n19); see also Madden et al. *Teens* (n19).

³⁷ Cf. Art. 4 para. 15, Art. 9 GDPR.

Another reason was related to potential stigmatization by peers because of revealing health problems such as scoliosis. Again, this fits well to our general findings that the disclosure of personal data is managed along principles of social interaction in general.

We further asked our interviewees how they viewed the system to be developed regarding the possibility of being monitored by others. Would it be a motivation or would it rather feel like a problematic control?³⁸ Some of the teenagers did say they would not use the monitoring, but simply because they didn't feel that they needed any assistance in pursuing the therapeutic advice. Others said they might try it out but were rather sceptical that it was of use to them. The majority of our interviewees however displayed a high interest in using such a monitoring system themselves. We first asked them generally if and how they would use it. And then: What kind of data should or should not be monitored? Who should have access to the data? We will present an extract of one interview with 15 year old Lena which is representative for the most answers given by our interviewees:

'That sounds really good to me. I can really imagine using it, especially since many times I do not know how many hours I really wore the brace on that day, if it was really enough. And I guess for others, who are maybe not that motivated, that they could say: okay I haven't worn it enough yesterday, but today I did better ... To know that you improved. And that you actually see it, at once ... Well, it sounds rather good to me.'

After being asked if she would feel under surveillance through the monitoring system, Lena answered:

'Well yes, a little bit, I guess. But I see it this way: the doctor or whoever, they see anyhow if I wore it or not. I realized that. I can't really prevent that he [the doctor] realizes how much I wear it; they see it, they know from looking at you. It's not possible to hide it anyhow.'

Most answers were very similar to the quoted interview. Some emphasised that knowing to be controlled would actually motivate them to comply. When asked who should have access to the data, almost all of the interviewees wanted the doctors to have access. Similar to the interview extract above the main explanation was: they (doctors, therapists) know it anyhow. And: they are here to help. They need to see it to decide if something needs to be done. The hope was that ultimately the monitoring would help reducing the hours that they had to wear the brace, because it could be individually adjusted. Right now, patients meet their doctor once or twice year (depending on the phase of therapy). Another explanation was that everyone in the medical field needs to comply to 'medical confidentiality'. As 14-year old René explained: 'And I think this information is confidential anyhow, to those professionals. I don't see any risk there. Because it is part of their

³⁸ We tried to formulate questions in a neutral way that would allow our interviewees to give their own interpretation. Still we are aware that our connection with the development project could have triggered rather positive answers in the situation of the interview and created a bias in our findings.

duty to handle it confidentially.’ The app was expected to act in a similar way as a ‘confidant’ as another teenager summarized it.

Opinions diverged on the question if parents should have access. A part of the teenagers saw no problem in allowing their parents to see the monitoring data on their therapeutic performance for similar reasons as concerning the doctors: ‘they know it anyhow’ and ‘they help me’. Others were very clear they would not want their parents to be ‘part of the monitoring system’, explaining it with experiences of conflicts happening. In one case the interviewee reasoned on the possibility to prove to the parents the brace was worn according to the therapeutic advice.

The first main reason our interviewees gave for allowing others to have access was that it was part of a therapeutic assistance that even when not pleasant sometimes was important for them to ‘get straight again’. The second one was that NOT allowing them access to the data did not seem to make a difference as doctors, therapists and also parents would ‘know anyhow’. Similar to our findings on information preserves concerning ‘data especially worthy of protection’ disclosing data concerning health was based profoundly on the experiences of teenagers in handling those data in face-to-face interaction. The known situations of sharing information with doctors, therapists and parents were also considered private anyhow. As several studies on the attitudes of teenagers and children towards privacy highlight, they display a rather nuanced understanding of the reasonable dissemination of personal data, rather than simply equating data sharing with ‘making things public’.³⁹ This raises important questions on the need for transparency in who is actually having access to those data. From the perspective of the teenagers, medical professionals were seen as the legitimate experts to deal with the data, based on the trust that this was for the patients’ therapeutic interest.

There was one interesting particularity that emerged in interviews with children and teenagers who described themselves as less compliant to wearing times or were defined as non-compliant by their doctors. While most of them also agreed that their doctors/therapists should have access to the monitoring data, it was only in these interviews that an explicit limitation of access through third parties was brought up as a central theme. Especially the parents of the patients were not only very interested in further assistance for increasing compliance of their children but also expected data to be categorically protected from access by health insurance companies. They expressed high concerns of potential financial punishment, e.g. having to pay for the brace therapy if it becomes clear the child is not wearing it as advised. Here, having information and also control over data storage and processing and the possibility to delete data were discussed in much length. While from a legal point of view, the (current) risk of German health insurers using data for financial discrimination (e.g. for increasing insurance rates based on therapeutic

³⁹ S Livingston, ‘Taking Risky Opportunities in Youthful Content Creation: teenagers’ use of social networking sites for intimacy, privacy and self-expression’ (2008) 10.3 *New Media & Society* 393–411.

compliance) is unfeasible these expressed concerns demonstrate again the shaping of 'reasonable expectations' by specific experiences made. In the cases where complying to therapeutic advice was more or less unproblematic, sharing data concerning therapy and health was also regarded as unproblematic. Yet, in those cases where the lack of therapeutic compliance had produced conflict and negative feedback from doctors, patients and parents were more concerned about sharing those data. As the monitoring system explicitly addresses patients with potential compliance problems, it is necessary to take these worries into consideration. We will come back to this in the conclusion.

IV. Conclusion

In general, ethnographic research proved to be a valuable tool to learn about the attitudes of the potential users of the new technology towards privacy and data protection. However, it is a more difficult task to figure out specific expectations for a new technology still in development. The conducted interviews showed that expectations were often based on a comparison to an existing scenario in the 'offline world'—in our case the relationship between the young patients and their doctors or therapists. While the comparison with a seemingly similar scenario might be a first step for users to classify the technology and to build up expectations, it cannot be their only basis. Therefore, forming expectations of privacy and data protection appears to be a learning process which needs to be enabled and fostered by the technologies.⁴⁰ This is especially true for the group of our sample, children and teenagers which are often referred to as the 'digital natives', as the generation born in times when digital technologies have already evaded all parts of everyday life and their use is being considered self-evident. Yet, as critical discussion on the term 'digital natives' have emphasised, there is a need for a more differentiated analysis.⁴¹ On a general level, a caution towards generalization across a whole generation, their skills, interest, practices and specific personal backgrounds should be considered elementary. Concerning the development of new technologies and potentially new data dissemination procedures, children and teenagers' limitations in risk assessment and anticipation of potential consequences in the future due to their age need to be taken into account. Parents or other care givers need to be part of the evaluation of 'reasonable expectations' of privacy and data protection.

⁴⁰ Cf. U Pagallo, 'The Impact of Domestic Robots on Privacy and Data Protection, and the Troubles with Legal Regulation by Design' in S Gutwirth, R Leenes, and P De Hert (eds), *Data Protection on the Move* (Dordrecht, Springer, 2016) 383, 399.

⁴¹ S Bennett, K Maton, and L Kervin, 'The 'digital natives' debate: A critical review of the evidence' (2008) 39.5 *British Journal of Educational Technology* 775 ff.; EJ Helsper, and R Eynon, 'Digital Natives: Where is the Evidence?' (2010) 36.3 *British Educational Research Journal* 503–520.

Against this background, the transparency of new technologies and the involved interests for their users is a prerequisite to determine reasonable expectations. To meet this prerequisite, it is important to know which factors influence the users' attitude towards the processing of personal data. In our case, the ethnographic research showed that potential users of the new technologies especially considered which actors with which interests got in touch with their personal data. This finding suggests that expectations have to be re-evaluated especially if new actors come into the play with the use of a new technology. As seen above, this is also the case with technologies of telerehabilitation. To specifically regard the appearance of new actors also corresponds with the requirement to consider 'the reasonable expectations of data subjects based on their relationship with the controller' in Recital 47 S. 1 GDPR. When new actors become involved, privacy issues need to be fundamentally reconsidered and not only by way of an 'update' of privacy statements. Addressing privacy issues as a socially embedded phenomenon means it is a 'new' phenomenon once the context differs. Concerning the potential future scenario of health insurance companies gaining access to the data, the question of 'reasonable expectations' of data protection and privacy would have to be evaluated anew. In a way, it is then a new system and not simply a new feature.

The transparency of data processing procedures and the involved actors can be facilitated in various ways. The first step to transparency is an informed consent in processing. This consent and the additional illustration of data protection procedures can also be implemented in the technology. In this way, the users' expectations can also be shaped by a technology. Consequently, we can identify a 'positive feedback' effect between reasonable expectations and privacy by design. On the first level, users' expectations are to be considered to design a privacy friendly technology. For example, telerehabilitation technologies could allow us to withdraw a given consent by including a switch that makes it easy to turn off the monitoring system at any time. On a second level, the technology itself can support a learning process concerning the reasonable expectations. This especially relates to the technical hinterland of the monitoring system. This could be reached for example by visualizing the network of involved actors and access by third parties to the data. Overall, the processing of data should not sink into the infrastructural background but be kept visible to the concerned person.

From the ethnographic-research we did for our project, we can also point out that the consideration of 'reasonable interest' can add a new dimension to Data Protection Law and compliance. Our findings show, that expectations do not necessarily overlap with general legal principles. In our case for example, data subjects regarded location data as more sensitive than data concerning health, which does not correspond to the general valuation in Art. 9 para 1 GDPR.

Finally, the results of the research can be practically applied in the design of technologies. In fact, they have already affected the design of the orthoses developed in the project where our research took place. The ongoing exchange with the engineers on the one hand and the potential users on the other hand enabled us

to transfer and ‘translate’ expectations into the development process. Especially specific desires of potential users to understand (who will be in touch with the data?), control (the possibility to deactivate the monitoring), and limit access by others (through local processing and timely limited storage of data) will be considered further in the design. Due to the very specific group of potential users and the features of the technology in this case, the general applicability of the presented findings will be limited. However, the findings might be of interest for the development of other telerehabilitation-technologies designed for a similar group of data subjects. Our study especially highlights the necessity to address privacy concerns of vulnerable groups to prevent discriminatory effects of data dissemination. Those who for various reasons have difficulties in complying to therapeutic advice need to be protected from yet unforeseeable consequences in the future.

References

- Albrecht, JP, ‘The EU’s New Data Protection Law—How A Directive Evolved Into A Regulation’ (2016) 17 *Computer Law & Security Review* 33–43.
- Berger Kurzen, B, *E-Health und Datenschutz* (Zürich, Schulthess, 2004).
- Bennett, S, Maton, K, and Kervin, L, ‘The ‘digital natives’ debate: A critical review of the evidence’ (2008) 39.5 *British Journal of Educational Technology* 775–786.
- Bowker, G and Star, SL, *Sorting Things Out. Classifications and its Consequences* (Cambridge, MIT Press, 2000).
- boyd, d, *It’s Complicated! The Social Lives of Networked Teens* (Yale University Press, 2014).
- boyd, d and E Hargittai, Facebook privacy settings: Who cares?, (2010), First Monday.
- Cavoukian, A, *Privacy by Design: The 7 Foundational Principles* (Ontario, Office of the Information & Privacy Commissioner of Ontario, 2009).
- DIVSI (Deutsches Institut für Vertrauen und Sicherheit im Internet), *Internet-Milieus 2016: Die digitalisierte Gesellschaft in Bewegung* (2016).
- DIVSI (Deutsches Institut für Vertrauen und Sicherheit im Internet), *U9-Studie: Kinder in der digitalen Welt* (2015).
- DIVSI (Deutsches Institut für Vertrauen und Sicherheit im Internet), *U25-Studie: Kinder, Jugendliche und junge Erwachsene in der digitalen Welt* (2014).
- DIVSI (Deutsches Institut für Vertrauen und Sicherheit im Internet), *Milieu-Studie zu Vertrauen und Sicherheit im Internet* (2012).
- Dourish, P, and Anderson, K, ‘Collective information practice: exploring privacy and security as social and cultural phenomena’ (2006) 21.3 *Human-computer interaction* 319–342.
- Dourish, P, Grinter, RE., Delgado de la Flor, J, and Joseph, M, ‘Security in the wild: user strategies for managing security as an everyday, practical problem’ (2004) 8(6) *Personal and Ubiquitous Computing* 391–401.
- Ewick, P and Silbey, S, *The Common Place of Law: Stories from Everyday Life* (Chicago, University of Chicago Press, 1998).

- Falk Moore, S, *Law As Process. An Anthropological Approach* (Münster, LIT Verlag, 2000).
- Fradella, HF, Morrow, WJ, Fischer, RG, and Ireland, C, 'Quantifying Katz: Empirically Measuring "Reasonable Expectations of Privacy" in the Fourth Amendment Context' (2011) 38 *American Journal of Criminal Law* 289–373.
- Goffman, E, *Relations in Public: Microstudies of the Social Order* (New Brunswick, Transaction Publishers, 2009 [1971]).
- Golla, SJ, 'Arzt, Patient und Assistenzsystem' (2015) 3 *InTeR* 194–197.
- Gómez-Arostegui, T, 'Defining Private Life Under the European Convention on Human Rights by Referring to Reasonable Expectations' (2005) 35 *California Western International Law Journal* 153–202.
- Härtling, N, *Datenschutz-Grundverordnung: Das neue Datenschutzrecht in der betrieblichen Praxis* (Köln, Otto Schmidt, 2016).
- Helsper, EJ, and Eynon, R, 'Digital Natives: Where is the Evidence?' (2010) 36.3 *British Educational Research Journal* 503–520.
- Hildebrandt, M, and Tielemans, L, 'Data protection by design and technology neutral law' (2013) 29 *Computer Law & Security Review* 509–521.
- Hoofnagle, CJ, King, J, Li, S, and Turow, J, 'How different are young adults from older adults when it comes to information privacy attitudes and policies?' (2010) Retrieved from http://repository.upenn.edu/asc_papers/399.
- Hugger, KU, *Digitale Jugendkulturen* (Wiesbaden, VS Verlag für Sozialwissenschaften, 2010).
- Ito, M, et al., *Hanging Out, Messing Around, and Geeking Out: Kids living and learning with new media* (Cambridge, MIT Press, 2009).
- , *Living and Learning with New Media: Summary of findings from the Digital Youth Project* (Cambridge, MIT Press, 2009).
- Klar, R, and Pelikan, E, 'Stand, Möglichkeiten und Grenzen der Telemedizin in Deutschland' (2009) 52 *Bundesgesundheitsblatt* 263–269.
- Livingstone, S, 'Taking Risky Opportunities in Youthful Content Creation: teenagers' use of social networking sites for intimacy, privacy and self-expression' (2008) 10.3 *New Media & Society* 393–411.
- Madden, M, Lenhart, A, Cortesi, S, Gasser, U, Duggan, M, Smith, A, and Beaton, M, 'Teens, Social Media, and Privacy' (2013) 21 *Pew Research Center* 2–86.
- Marwick, AE, Diaz, DM, and Palfrey, J, *Youth, Privacy and Reputation: Literature Review* (Cambridge, The Berkman Center for Internet & Society at Harvard University, 2010).
- McAllister, M, 'The Fourth Amendment and New Technologies: The Misapplication of Analogical Reasoning' (2012) 36 *Southern Illinois University Law Journal* 475–529.
- McPherson, T, *Digital Youth, Innovation, and the Unexpected* (Cambridge, MIT Press, 2008).
- Nader, L, *Law in Culture and Society* (Oakland, University of California Press, 1997 [1967]).
- Niewöhner, J, 'Epigenetics: localizing biology through co-laboration' (2015) 34 *New Genetics and Society* 219–242.
- Nissenbaum, H, *Privacy in Context: Technology, Policy, and the Integrity of Social Life* (Stanford University Press, 2009).
- Ochs, C, 'Die Kontrolle ist tot—lang lebe die Kontrolle! Ein Plädoyer für ein nach-bürgerliches Privatheitsverständnis' (2015) 4.1 *Mediale Kontrolle unter Beobachtung*.
- Pagallo, U, 'The Impact of Domestic Robots on Privacy and Data Protection, and the Troubles with Legal Regulation by Design' in S Gutwirth, R Leenes, and P De Hert (eds), *Data Protection on the Move* (Dordrecht, Springer, 2016) 383–410.

- Skouma, G, and Léonard, L, 'On-line Behavioral Tracking: What May Change After the Legal Reform on Personal Data Protection' in S Gutwirth, R Leenes, and P De Hert (eds), *Reforming European Data Protection Law* (Dordrecht, Springer, 2015) 35–60.
- Slobogin, C, and Schumacher, JE, 'Reasonable Expectations of Privacy and Autonomy in Fourth Amendment Cases: An Empirical Look at "Understandings Recognized and Permitted by Society"' (1993) 42 *Duke Law Journal* 727–775.
- Valverde, M, *Law's Dream of a Common Knowledge* (Princeton, Princeton University Press, 2003).
- West, A, Lewis, J and Currie, P, 'Students' Facebook 'friends': public and private spheres. (2009), *Journal of Youth Studies*, 12(6), 615–627.

Considering the Privacy Design Issues Arising from Conversation as Platform

EWA LUGER AND GILAD ROSNER

Abstract. Conversational agents have become a commonplace technology. They are present in our mobile devices, within the operating systems we use, and increasingly in other objects such as purpose-built artefacts and even children's toys. Whilst they promise the opportunity for more 'natural' interactions with the systems we use, they come with notable privacy challenges. Low levels of user awareness of such systems, the implications of unwitting third party use, algorithmic opacity, and limited user comprehension of system intelligence all result in systems where consent and privacy are weakened. Locating such systems in the home and other such intimate settings further problematize their use. This paper explores some of the emerging interactional and privacy challenges posed by conversation-based systems and calls for further and rapid investigation of how we might address the growing power imbalance between user and system so that privacy might be preserved.

Keywords: *Privacy—machine intelligence—internet of things—algorithms—conversational agents—smart toys—child surveillance*

I. Introduction

Unbroken surveillance and pervasive monitoring have been cast as a defining dynamic of contemporary society.¹ This perspective highlights a power imbalance; one that places the most data-rich organisations in unprecedented positions of influence within all spheres of life. The presence of new and emerging sensing technologies, within both public and previously private domains, has come to disrupt informational contexts and allow for weakly contested capture of data.

¹ J Anderson and L Ranie, 'The Internet of Things Will Thrive by 2025: The Gurus Speak' (2014) Pew Research Center. Available at <http://pewrsr.ch/2cFqMLJ>.

Since the development of voice activated devices, privacy issues have been repeatedly flagged within the media, raising concerns around product features and their potential privacy implications. Much of this detail has been hidden in plain sight, within the text of the underpinning product terms and conditions and privacy statements. For example, in their privacy policy, Samsung warned customers that they should not discuss personal information in front of their Smart TVs: "Please be aware that if your spoken words include personal or other sensitive information, that information will be among the data captured and transmitted to a third party".² This one mere example illustrates how contextual norms, privacy, and personal safety may all be perturbed by emerging voice-centric devices. Yet these issues are suppressed or underplayed as such technologies enter our homes with alarming rapidity.

Corporate responsibility and user control are key to ensuring our protection, though they are in tension with the appropriate level of user comprehension and the granularity of user control afforded by a system. The rise in range and availability of sensors, and increases in data storage capabilities and processing power, have meant that ever more aspects of our previously private endeavours are recorded. Therefore, whilst users are eventually exposed to potential privacy threats posed by new technologies, any gleaned understanding is outpaced by the technological development itself. For example, the power of algorithmic inference has resulted in protected attributes being predicted on the basis of unrelated data items, such as location and Facebook 'Likes'.³ This is arguably an inference that was unlikely to be anticipated by users as they 'liked' particular pages or shared their location data.

Indeed, even where personally identifiable information is deliberately obfuscated, as in pixelating faces in video, advances in machine intelligence create ever new privacy challenges. For example, Google's neural network technology now has the ability to reconstitute pixelated faces through prediction.⁴ The technology is not always accurate, but such developments potentially contravene existing privacy preserving solutions and pose increasingly complex models for users to understand. Whilst we are fast becoming sensitised to technologies like recommender systems and other intelligent services, there are interactional changes afoot. Though direct manipulation of devices is still the dominant paradigm, we are seeing the steady adoption of a new form of complementary interaction—the Natural User Interface (NUI). The 'Natural' in NUI suggests that our understanding of the system is somehow innate, but this may not be the case. Whilst it might be considered natural to speak to a technology and have it respond by voice, our

² The Week, "Samsung warns customers not to discuss personal information in front of smart TVs" (9 Feb, 2015) Available at <http://theweek.com/speedreads/538379/samsung-warns-customers-not-discuss-personal-information-front-smart-tvs>.

³ M Kosinski, D Stillwell and T Greapel, 'Private traits and attributes are predictable from digital records of human behaviour' (2013) 110, 15 *PNAS*, 5802.

⁴ A Hern, 'Real life CSI: Google's new AI system unscrambles pixelated faces' (*Guardian Online*, 8th Feb, 2016) Available at <https://www.theguardian.com/technology/2017/feb/08/google-ai-system-pixelated-faces-csi>.

understanding of such interactions is limited to human-human dialogue; we have not yet developed a similar interactional or privacy model for such dialogue with machines.

The notion of a Natural User Interface is not new. As early as 1990, academics argued that once speech and language interfaces achieved a more ‘natural’ form of conversation, they would be able to sit alongside direct manipulation of an interface.⁵ The idea that we might interact with our technology in ways that seem natural to us drives much of the design behind the majority of emerging IoT developments. Gesture, for example, is a burgeoning mechanism of interaction, extending to new technologies, such as the mid-air ‘pinch’ gesture required by Microsoft’s HoloLens; and the spoken “Hey Siri” to activate Apple’s ubiquitous voice-based agent. Specifically, we can understand such natural interfaces as ones that “enable two-way interactions among their users and the electronics embedded in their surroundings” via gestures such as facial expressions, voice, brain patterns and eye-movements,⁶ raising the promise of an interactional experience that blends further seamlessly into our everyday lives.

An emergent subset of these systems is the *conversational agent*, which has been used to describe many types of voice-based systems. The term can become imprecise though, describing an “interface agent, embodied conversational agent, virtual assistant, autonomous agent, [or] avatar... often synonymously”.⁷ In the context of this paper, we can understand such an agent as one that carries out tasks,⁸ similar to a virtual/digital assistant or butler,⁹ as distinct from those systems that merely mimic conversation, have no memory, or any knowledge of context. Specifically, we employ the term ‘conversational agent’ to describe the “emergent form of dialogue system that is becoming increasingly embedded in personal technologies and devices”.¹⁰ In terms of conversation, under the hood such systems require at least a speech recogniser, a dialogue manager (controller) through which interactions with the user are achieved, and a way for information to be communicated to the user; usually either speech or text output.¹¹ In terms of agency, conversational agents

⁵ SE Brennan, “Conversation as direct manipulation: An iconoclastic view”. In BK Laurel (ed) *The Art of Human-Computer Interface Design* (Reading, MA: Addison-Wesley, 1990).

⁶ JK Zao, C-T Lin, L-W Ko, H-C She, L-R Dung, B-Y Chen, ‘Natural User Interfaces: Cyber-Physical Challenges and Pervasive Applications’ (2014) Panel Discussion at *2014 IEEE International Conference on Internet of Things (iThings 2014)*, Green Computing and Communications (GreenCom 2014), and Cyber-Physical-Social Computing (CPSCom 2014): 467.

⁷ AM Von der Pütten, NC Krämer, J Gratch & S-H Kang, ‘It doesn’t matter what you are! Explaining Social Effects of Agents and Avatars’ (2010) *26 Computers in Human Behaviour*: 1641.

⁸ Y Wilks, ‘Is a companion a distinctive kind of relationship with a machine?’ (2010) *Proceedings of the 2010 Workshop on Companionable Dialogue Systems (CDS ‘10)*. Association for Computational Linguistics, Stroudsburg, PA, USA, 13.

⁹ S Payr, ‘Virtual Butlers and Real People: Styles and Practices in Long Term Use of a Companion’. in Robert Trappi (ed) *Your Virtual Butler: The Making-of* (Dordrecht: Springer, 2012), 134.

¹⁰ E Luger and A Sellen, “Like Having a Really bad PA”: The Gulf between User Expectation and Experience of Conversational Agents’ (2016) *Proc. CHI’16*. ACM, 5289.

¹¹ JR Glass, ‘Challenges for Spoken Dialogue Systems’ (1999) *The Proceedings of IEEE Workshop on Automatic Speech Recognition and Understanding*. (ASRU).

are algorithmically-driven, based upon sensed data or data generated through interaction and then processed in the cloud, and result in actions (or speech) performed for the user resulting from direct command or inference.

In this paper, we explore some of the interactional challenges of conversational agents with regard to privacy, intelligibility, and consent considerations. We first discuss conversation as a platform for user interactions, and then present a case study of child privacy failures from voice-responsive toys. We then move onto meta-ethical concerns related to the wider class of intelligent systems, with particular emphasis on system opacity and the effects on consent, before returning to an example of the current design challenges arising from dialogue systems in everyday use.

II. Conversation as Platform

In keeping with the Internet of Things (IoT) paradigm, voice interfaces are increasingly being integrated into mobile and worn technologies and are constantly connected to the cloud, portending a sea change in both social networking and Human Computer Interaction (HCI).¹² The rise of voice-based interfaces is very much the vanguard of the natural interface. Over the past five years we have seen an increase in the prominence of conversational agents as global technology companies vie to dominate the market. The main offerings are Apple's Siri, Google's Google Now, Amazon's Alexa and Microsoft's Cortana. Whilst initially such products were to some extent in the background in terms of their visibility, Siri and Cortana are now embedded within their respective operating systems and, in a much more direct campaign, Alexa is the primary interface for the multi-purpose Amazon Echo and Amazon Dot products, and is being integrated into additional contexts such as cars. These developments have enabled conversation as a platform by which users can use voice as a primary means of system access and interface. Whilst Siri, Cortana and Google Assistant experienced slow user uptake, Amazon built upon their modest success to hit the ground running, offering a more compelling use proposition: retail purchasing. Equally, where other companies failed to consider that hands-free was the most likely use-case for voice-based systems,¹³ Amazon recognized this and moved beyond the handset to embody Alexa within a self-contained, purpose-built artefact that could be positioned anywhere in the home—a form now being replicated by their competitors.

These developments are not occurring in isolation. Rather, they are representative of an emerging class of technologies that have caused waves within academic

¹² Zao, Lin, Ko, She, Dung, Chen, 'Natural User Interfaces: Cyber-Physical Challenges and Pervasive Applications'.

¹³ Luger and Sellen, "Like Having a Really bad PA".

and legal communities, the media, regulation, and the public. We are entering an era where we can hold conversations with the artefacts in our lives. Our homes, pockets and public spaces are awash with such devices, and yet we understand very little about their operation or the long-term effects of sharing our intimacies with intelligent, ambient, autonomous ‘things’.

Indeed, it is the unremarkable nature of these things that contributes to the problem—they are unremarkable by design. That is, the intention of designers is to create a system that does not jar, is sensitive to context, and frees the user from the burden of daily concerns to enable them to consider less mundane pursuits. For example, Google-owned Nest has created a range of products with the specific intent of freeing users from the worry of whether they have turned off their lights or set their thermostat correctly. Nest ‘learns’ from data generated by the user in order to predict their needs. In their own words: ‘when products work with Nest, you don’t have to tell them how to connect. Or what to do. They just work. In real homes, for real people.’¹⁴ Such statements reveal an intended unobtrusiveness.

From an interactional perspective, this unobtrusiveness has the effect of decoupling users from devices.¹⁵ Although it is true to say that there exists an interactional relationship between the system, the user, and the data they generate, this relationship is not explicit nor immediately visible. Consider how different this is to the interactions of old. When desktop computers were the sole point of access to the Internet, there were clear seams; lines of demarcation. One would push a button to turn on the computer, its fan would obligingly whirl into life and one would note changes on the screen as the system booted up; and who could forget the screech emitted when one ‘dialed up’ to the internet? Equally, turning the system off could be as simple as hitting the power button again. Our online privacy and security were explicit concerns with explicit signifiers, such as the padlock icon at the start of a URL indicating an encrypted connection. Compare this now to current devices and one might ask what is the functional equivalent of the padlock for an intelligent system? We no longer possess the tools to navigate and comprehend our interactions with regard to privacy.

An orthogonal point is made by Harper et al, who argue that meaningful interaction with a system requires robust metaphors and abstractions, such as the metaphor of the file or desktop. They argue that the concept of a ‘file’—a ‘boundary object’ between users and engineers allowing meaningful interaction—requires revision as it fails to reflect all actions one might perform within contemporary systems.¹⁶ The notion of a ‘boundary’ object is one that allows both users and developers to “orient to a shared object or set of objects, even though the tasks

¹⁴ Nest, ‘Works with Nest’ (2017) Available at <https://nest.com/works-with-nest/>.

¹⁵ J Hong, E Suh, S-J Kim, ‘Context-aware systems: A literature review and classification’ (2009) 36 *Expert Systems with Applications*, 8509.

¹⁶ R Harper, S Lindley, E Thereska, R Banks, P Gosset, G Smyth, W Odom and E Whitworth, ‘What is a file?’ *Proceedings of the 2013 conference on Computer supported cooperative work (CSCW ‘13)*. ACM, New York, NY, USA, 2013, 1125.

they have in mind are in many respects quite distinct”.¹⁷ So, the file means different things, depending upon one’s orientation, but allows for effective communication or interaction. In effect, it simplifies and makes meaningful and coherent one’s actions in the digital world. However, such concepts are not static. As systems change, so too should the abstractions we use to communicate their operation. For example, in the context of contemporary systems, the notion of the file has been said to be outdated. Users no longer simply create and store content. Instead, they engage in activities such as sharing, over-writing, duplicating and editing, sharing editorial-rights and ownership. Even the notion of what it is to ‘own’ digital content has come into question—so, does the file metaphor still afford the robust conceptual anchoring that once it did?

This argument could be easily transposed to privacy. If we are to ensure privacy is both usable and the product of interactional dialogue between users and engineers, what might the ‘boundary objects’ be in this case, and where might such boundaries exist? One such construct is the idea of the ‘wake word’ where a word or phrase is used to (re)activate a system, such as “Alexa”, “OK Google,” or “Hey Siri.” Our conceptual understanding of what happens when we say ‘hello’ should here be married to what the architects then offer through system operation. Socially, we understand that saying ‘hello’ begins a dialogue. We know, if they respond, that the person we are addressing is attending. However, at this developmental stage of conversational technology, such boundaries are not clearly delineated by system architects. A recent example of a child using Alexa to accidentally order a dollhouse shows how these boundaries might easily be breached.¹⁸ This breach was further replicated and amplified outside the boundary of the home when a television presenter reporting the story inadvertently set off a melee of Alexa-triggered dollhouse purchases across San Diego.

Such stories of inadvertent and indirect use portend a further challenge: when systems are ambient and interactions are extensions of natural behaviour the implications of third-party use are dramatically raised. Whilst the mass purchase of toys was an amusing if costly byproduct of unintended interactions, it raises far more serious issues of consent to the use of sensed data. Clearly, the child in the Alexa example was incapable of giving consent to the use of the data they generated, but what of the accidental interactions of the incognizant adult? Such systems are, by their very nature, socially-embedded. The binary relationship between data subject and data controller via systems design is something of the past. As technology relies ever more upon data derived from socially-situated and socially-sensitive contexts, so the potential for consent violations and unintended consequences raises privacy challenges. A core issue is that systems such as Alexa are framed as ‘always on’, resulting in negative perceptions and poor user understanding of what

¹⁷ Harper et al, What is a file?, 1126.

¹⁸ S Nichols, “TV anchor says live on-air ‘Alexa, order me a dollhouse’—guess what happens next” (*The Register*, 7 Jan, 2017) Available at https://www.theregister.co.uk/2017/01/07/tv_anchor_says_alexa_buy_me_a_dollhouse_and_she_does/.

that means in a technical sense. The value of immediate responsiveness comes at a cost of persistent monitoring of the social environment, though the question of whether we are prepared to pay the price or how we might negotiate is as yet unresolved. As seen in the media recently, voice-based systems can present numerous privacy issues. This is never more provocative than in the context of young children. To illustrate our wider points, we consider some of the emerging challenges within this space.

III. The Privacy Impact of Sensed Conversation; A Focus on Child-Facing Technology

The first order concern here, from which all privacy issues stem, is power inequity and the subsequent insulation from observability that data subjects might bring to bear. From the user perspective, intelligent systems are unpredictable and opaque with respect to the decisions they reach. The power to support privacy-preserving practices lies not in the hands of users, but with those organisations who have the datasets, computational power and specialised skillsets required to develop such systems. This argument alone is sufficient to attract consideration of how one might deal with conversational systems within sensitive settings, or those where there is an expectation of privacy. Add to this the potential implication of vulnerable subjects and those otherwise unable to consent to data transactions, and we find the problem ever more pressing.

Microphones are starting to proliferate in public and private spaces. Of course, this trend began fully with the advent of mobile phones, but microphones are now appearing in more and diverse devices in the human environment. They are being embedded into televisions, watches, toys, speakers, and the aforementioned dedicated hardware such as the Amazon Echo. In December of 2016, US and European privacy and consumer protection advocates filed multiple complaints to regulators about Genesis Toys and Nuance Communications, who supplied voice recognition technology to Genesis. The complaint to the US Federal Trade Commission stated:

This complaint concerns toys that spy. By purpose and design, these toys record and collect the private conversations of young children without any limitations on collection, use, or disclosure of this personal information. The toys subject young children to ongoing surveillance and are deployed in homes across the United States without any meaningful data protection standards.¹⁹

¹⁹ Electronic Privacy Information Center, et al., Complaint and Request for Investigation, Injunction, and Other Relief in the Matter of Genesis Toys and Nuance Communications. (2016 Dec 6). Available at <https://epic.org/privacy/kids/EPIC-IPR-FTC-Genesis-Complaint.pdf>.

The complaint requested the FTC to investigate Genesis Toys for several troubling issues with their My Friend Cayla and i-Que toys, ranging from easy unauthorized Bluetooth connections to the toys, to surreptitious advertising, to the difficulty of locating the Terms of Service. The complaint alleges violation of the Children's Online Privacy Protection Act and FTC rules prohibiting unfair and deceptive practices. These include collection of data from children younger than 13, vague descriptions of voice collection practices in the Privacy Policies, and contradictory or misleading information regarding third-party access to voice data.

In February of 2017, the online magazine Motherboard reported that Cloud-Pets, makers of an internet-connected teddy bear that allows parents and children to exchange voice messages, leaked over 2 million voice recordings by storing them insecurely in the cloud.²⁰ And, at the end of 2016, interest in a murder case from 2015 was rekindled when police sought data from the accused's Amazon Echo device to assist in the investigation.²¹ Amazon refused the request, arguing that the police must use higher subpoena standards and greater judicial oversight to gain access, though ultimately they turned over the data when the accused gave explicit permission in an effort to bolster his claim of innocence.²²

The Genesis case is different from the CloudPets and murder investigation cases, though all three raise significant concerns. In the case of Genesis Toys, there wasn't a concern with the security of the stored data—rather, it was a threat of active audio surveillance of children, surreptitious advertising, and inappropriate downstream use of children's voice recordings. In the case of CloudPets, weak data security was the key issue. In the murder investigation, neither security nor inappropriate use was at issue; the central concern is the legal environment in which audio recordings may be obtained by law enforcement. Internet-connected toys with microphones for audio interaction pose privacy problems because the following reasons:

A. Privacy of Child and Adult Communications

Communications between family members, in particular between adults and children, are sensitive and deserving of protection, although the legal landscape for this is quite variable depending on location, state, or country. Companies trafficking the intimate communications of family members have a duty to secure audio recordings, especially of children. Exposure of family communications risks

²⁰ L Franceschi-Bicchierai. Internet of Things Teddy Bear Leaked 2 Million Parent and Kids Message Recordings. (Motherboard, Feb 27, 2017). Available at https://motherboard.vice.com/en_us/article/internet-of-things-teddy-bear-leaked-2-million-parent-and-kids-message-recordings.

²¹ C Mele, 'Bid for Access to Amazon Echo Audio in Murder Case Raises Privacy Concerns' (New York Times, 28 Dec, 2016) Available at <https://www.nytimes.com/2016/12/28/business/amazon-echo-murder-case-arkansas.html>.

²² EC McLaughlin. 'Suspect OKs Amazon to hand over Echo recordings in murder case' (CNN, 7th Mar, 2017). Available at <http://edition.cnn.com/2017/03/07/tech/amazon-echo-alexabentonville-arkansas-murder-case/>.

embarrassment, stigmatisation, economic loss, and danger from predators. Violations of an expectation of privacy between family members due to poor security or sharing with third parties (see below) is tantamount to a violation of contextual integrity.²³

B. Privacy of Children's Play

Children are encouraged to form bonds with toys, and as such to utter personal and intimate information. Toys that listen and respond capture intimate exchanges. In the world of 'dumb' toys that cannot see, hear or reply, these exchanges would be privy only to people near the child playing. The introduction of microphones and, more importantly, the third parties who manufactured and provide live service to the toys, intrudes upon the heretofore privacy of children's play. Two American legal scholars, Schmuely and Blecher-Prigat, argue for broad recognition of children's privacy rights, especially within the home and, somewhat controversially, a right of privacy in regard to parents in certain cases.²⁴ They cite the United Nations Convention on the Rights of the Child's Article 16, which states, 'No child shall be subjected to arbitrary or unlawful interference with his or her privacy, family, or correspondence ...'.²⁵ While international policy and jurisprudence have yet to absorb this principle, it still has weight as a social consideration to be negotiated by individual families. The private nature of children's play and their utterances therein remains a very open question; one that toys that listen implicate directly.

C. Inappropriate Use

Another concern raised by the Genesis/Nuance complaint is that the My Friend Cayla Doll surreptitiously markets to children:

Researchers discovered that My Friend Cayla is pre-programmed with dozens of phrases that reference Disneyworld and Disney movies. For example, Cayla tells children that her favorite movie is Disney's *The Little Mermaid* and her favorite song is "Let it Go," from Disney's *Frozen*. Cayla also tells children she loves going to Disneyland and wants to go to Epcot in Disneyworld ... This product placement is not disclosed and is difficult for young children to recognize as advertising. Studies show that children have a significantly harder time identifying advertising when it's not clearly distinguished from programming.²⁶

²³ H Nissenbaum, *Privacy in Context: Technology, Policy and the Integrity of Social Life* (Stanford: Stanford University Press, 2010).

²⁴ B Shmuely and A Blecher-Prigat, 'Privacy for Children' (2011) 42, 3 *Columbia Human Rights Law Review*, 759.

²⁵ UN General Assembly, *Convention on the Rights of the Child*, United Nations, Treaty Series, vol. 1577, 1989: 3.

²⁶ Electronic Privacy Information Center, et al., Complaint and Request for Investigation, Injunction, and Other Relief in the Matter of Genesis Toys and Nuance Communications. (2016 Dec 6). Available at <https://epic.org/privacy/kids/EPIC-IPR-FTC-Genesis-Complaint.pdf>.

Indeed, the American Psychological Association Task Force on Advertising and Children state that children under 4–5 years do not consistently distinguish programs from commercials, and children younger than 7–8 do not recognize the persuasive intent of advertising.²⁷ As a result, the Task Force concludes that ‘advertising targeting children below the ages of 7–8 years is inherently unfair because it capitalizes on younger children’s inability to attribute persuasive intent to advertising’.²⁸ The makers of Hello Barbie, another interactive doll, go out of their way to quash this concern, stating in one privacy notice: ‘There is no advertising content within Hello Barbie. Your children’s conversations are not used to advertise to your child.’²⁹

D. Introduction of Third Parties

As the above sections show, conversant toys and virtual assistants introduce third parties into human-computer and parent-child relationships. These third parties can of course be benign, but their stockpiling of sensitive utterances or exchanges poses a collection risk, implying risks of unauthorized access, loss, unanticipated downstream use, and inappropriate use. These third parties invariably introduce commercial relationships and logic into the private and sensitive communications of families and children, which become data for such third parties, to be used in product improvement, marketing, and in some cases, are sold on to partners. Again, the commercial nature and downstream uses of personal communications is not new, but the proliferation of smart toys and voice-enabled virtual assistants is a change in scale, scope, and distressingly portends the normalisation of commercialised child surveillance.

IV. The Problem of Intelligent Systems

Machine intelligence has pervaded virtually all spheres of human life,³⁰ and with this has come a level of dependency on, and acceptance of, the idea that a system might reason and act on our behalf. Core to this idea of machine intelligence is the algorithm. Advances in machine or algorithmic learning have been a core driver of the development of the systems that now pervade our lives. The drive towards

²⁷ B Wilcox, D Kunkel, J Cantor, P Dowrick, S Linn and E Palmer, *Report of the APA Task Force on Advertising and Children* (2004). Available at <http://www.apa.org/pi/families/resources/advertising-children.pdf>.

²⁸ Wilcox et al, *Report of the APA*, 7.

²⁹ Mattel. ‘Privacy Commitment’ (2017) Available at <http://hellobarbiefaq.mattel.com/privacy-commitment/>.

³⁰ P Domingos, *The Master Algorithm. How the Quest for the ultimate learning machine will remake our world*. (London: Penguin, 2015).

pervasive, ambient, artificial intelligence has precipitated something of an arms race, with ever-shifting goals and parameters.³¹ Where it was once enough for a computer to perform a task as well or as convincingly as a human, we are now driving towards ‘general’ artificial intelligence—where a computer can interpret and reason in a general context. Prior to this point, developments in machine learning were set within clear parameters, such as the context of playing rule-based games like Chess or Go, and so the stakes have been relatively low.³² However, when such intelligence is deployed in broad contexts with complex social components, as with driverless cars, the stakes are noticeably raised.

One dominant privacy concern here is prediction, a core function of intelligent technology. In order for systems to respond in ways that we’d like, they first need to model humans based on the data we generate, and then predict our most likely behaviours, or those aligned to a predefined value; e.g., most pleasing, most beneficial or least costly. This technology, once expensive and elite, is now increasingly accessible, suggesting that areas previously not subject to predictive algorithms will open up³³ impacting upon areas of life protected by anti-discrimination law, such as credit scoring, employment, education, criminal justice, and advertising.³⁴

Whilst this may seem unproblematic, it is becoming clear that machine intelligence is not neutral in application. Based upon large human-derived datasets, we are seeing evidence of the algorithmic reflection and exacerbation of existing biases and the introduction of new ones, thereby encoding discrimination within decisions and predictions. One oft-cited example is the 2015 case of Google image search mistakenly tagging two black Americans as gorillas.³⁵ The problem here is that a “vetted methodology for avoiding discrimination against protected attributes [such as gender, race, disability] in machine learning is lacking.”³⁶ In the context of privacy, and consent, this poses a particular problem: whilst the intelligence that underpins such systems remains opaque, the opportunities to knowingly agree to processing of personal data are affected, as is our ability to decide or gauge which predictions might impact our private lives or disclose protected aspects of our identity. This is likely to exacerbate over time. As machine learning

³¹ G Lewis-Krauss, ‘The Great AI Awakening’ (The New York Times Magazine, 14 Dec, 2016) Available at <http://mobile.nytimes.com/2016/12/14/magazine/the-great-ai-awakening.html>.

³² House of Commons Science and Technology Committee. ‘Robotics and Artificial Intelligence; Fifth Report of Session 2016–17’ (2016), Available at <http://www.publications.parliament.uk/pa/cm201617/cmselect/cmsstech/145/145.pdf>.

³³ A Agrawal, J Gans, and A Goldfarb, ‘The Simple Economics of Machine Intelligence’ (Harvard Business Review, 17 Nov, 2016). Available at https://hbr.org/2016/11/the-simple-economics-of-machine-intelligence?utm_source=twitter&utm_medium=social&utm_campaign=harvardbiz.

³⁴ M Hardt, E Price and N Srebro, ‘Equality of opportunity in supervised learning’ (2016) *Advances in Neural Information Processing Systems*, 3315.

³⁵ J Brogan, ‘Google Scrambles After Software IDs Photo of Two Black People as “Gorillas”’ (Future Tense, 30 June, 2015). Available at http://www.slate.com/blogs/future_tense/2015/06/30/google_s_image_recognition_software_returns_some_surprisingly_racist_results.html.

³⁶ M Hardt, E Price and N Srebro, ‘Equality of opportunity in supervised learning’ (2016) *Advances in Neural Information Processing Systems*, 3315.

moves away from Bayesian modelling techniques towards neural networks and ‘deep learning’, the challenges of predictability and accountability of algorithms are amplified as the functions are ‘probabilistic and emergent by design’.³⁷

A. Learning, Error and the Importance of Social Context

In order for a system to become sufficiently intelligent to act, it must first learn and then test such learning. There is a limit to how much of this preparatory work can be done in the lab. Once systems are deployed in the world, they can impact directly on the human population. The notion of error within the learning journey—‘learning from our mistakes’—is an accepted part of the process. However, when machines learn, they do so in relatively constrained ways and so the resulting errors are likely to be quite different to those made by humans. For example, at this point of development they can be fooled in ways that humans cannot³⁸—such as Microsoft’s Twitter chatbot, Tay,³⁹ which when deployed in the real world learned to replicate racist and anti-Semitic views. Currently, there are no mechanisms to teach systems like conversational agents what discussions might be private, and which changes in sensed context might mean that whilst the dialogue is ongoing, the social context has changed. Imagine, for example, Alexa reminding you of your gynaecological appointment as your guests or boss enter the room. Whilst this type of privacy is not the focus of this paper, the ability of a system to understand and learn privacy parameters will become critical to user trust and ongoing adoption, and to treat social intimacy with respect. Equally, from this perspective it is insufficient to think of the underpinning algorithms as mere mathematical formulae. Rather, they are tightly tied to the social world and, as such, must be framed within that broader context.

In response to this, Ananny frames algorithms as ‘Networked Information Algorithms’ (NIAs); ‘assemblages of institutionally situated code, practices, and norms with the power to create, sustain, and signify relationships among people and data through minimally observable’ semiautonomous action’.⁴⁰ This definition moves beyond algorithms as purely mathematical or computational mechanisms for task accomplishment, into complex socio-technical systems. The issue here is not only the opacity of algorithms, but the lack of algorithmic visibility within the sociotechnical context, becoming visible only at the point of failure

³⁷ A Tutt, ‘An FDA for Algorithms’ (2016) 69, 1 *Administrative Law Review*, 90.

³⁸ J Bossman, “Top 9 Ethical Issues in Artificial Intelligence. World Economic Forum” (2016). <https://www.weforum.org/agenda/2016/10/top-10-ethical-issues-in-artificial-intelligence/>.

³⁹ M Murgia, “Microsoft’s racist bot shows we must teach AI to play nice and police themselves” (Telegraph Online, 29 Mar, 2016) Available at <http://www.telegraph.co.uk/technology/2016/03/25/we-must-teach-ai-machines-to-play-nice-and-police-themselves/>.

⁴⁰ M Ananny, ‘Toward an Ethics of Algorithms Convening, Observation, Probability, and Timeliness’ (2016) 41, 1 *Science, Technology & Human Values*, 93.

or unexpected function. Looking back to our earlier examples of toys that sense, it is clear that the form a system takes strongly dictates both the expectations of the user, in terms of the flow of data, and the use of that system. In other words, if an intelligent system looks like a doll then, without other indicators of system state and function, one might reasonably expect that the doll behaves like toys of old. The fact that the doll now functions as a window into our private sphere is not evident through its form. Whilst this is a desirable feature from an interaction perspective, in that we want users to engage with the products in predictable ways, it is clearly problematic in terms of privacy. Nissenbaum describes such breaches as breaches of contextual integrity—disrupting either norms of appropriateness (e.g. might one expect data to be collected in this context) or norms of information flow (e.g. is the data being viewed/used by those whom we might not expect to have such access).⁴¹ Moving beyond form, even the function of such systems is relatively unpredictable. The algorithms that drive such systems do not make decisions in the same way as humans. As such, users are left to imagine how their data is processed and the decision is reached. This issue is further compounded by the issue of algorithmic opacity.

B. Opacity, Comprehension and Informing

Algorithms are opaque ‘in the sense that if one is a recipient of the output of the algorithm (the classification decision), rarely does one have any concrete sense of how or why a particular classification has been arrived at from inputs,’⁴² and this opacity is the key driver of concerns regarding algorithmic classification; i.e. the ways in which an algorithm classifies, or makes decisions based upon data. This has raised concerns over the accountability of systems that rely upon such machine intelligence. Intelligent systems are not designed within notions of inspectability and redress at the forefront. The absence of this level of detail means that there are no grounds upon which any algorithmic determination, or perceived harm, might be contested by those impacted.

In order for something to be accountable, its operation must be revealed and its processes made traceable. However, in the context of machine intelligence, the notion of revealing system operation, or making the algorithms transparent, is highly problematic. When considering human interactions with algorithmically-driven systems, the two key contributing difficulties are their predictability and explainability. These measures relate to how difficult an algorithm’s *outputs* are to predict and explain, thereby problematizing *accountability* and the tracing of

⁴¹ H Nissenbaum, *Privacy in Context: Technology, Policy and the Integrity of Social Life*. (Stanford: Stanford University Press, 2010).

⁴² J Burrell ‘How the Machine “Thinks:” Understanding Opacity in Machine Learning Algorithms’ (2016) 3, 1 *Big Data & Society*, 1.

decision trees.⁴³ Even if it were possible, making the algorithmic process transparent to the user/subject is very much a blunt instrument. According to Nissenbaum there exists a *transparency paradox* in that revealing how an algorithm works, even if it were possible to predict consistently, would mean ‘revealing information handling practices in ways that are relevant and meaningful to the choices individuals must make’.⁴⁴ Even if one did so, describing ‘every flow, condition, qualification and exception’⁴⁵ would neither be read nor understood by the user. Equally, even if such a goal were achievable in the context of supervised machine learning, the complexity of deep learning systems make this far from possible.

When considering explainability, the issue of how one might make a system intelligible to the individual, to support informed use, is a core problem. Equally, it is likely that explainability will mean different things in the context of different audiences. For example, everyday users will require different levels of information from lawyers and regulators, and for different means. The matter, therefore, of what might constitute ‘meaningful transparency’⁴⁶ is in the early stages of formation.

Reasons for algorithmic opacity have been classified into three distinct groups.⁴⁷ The first classification relates to proprietary information, industrial competitiveness and the concealment this necessitates. In this context, opacity stems from a desire to protect ‘trade secrets’ by not exposing the detail of an algorithm’s operation to one’s competitors. The second classification of opacity relates to the specialist skillset required to both create and understand the operation of a complex logical formula and the associated notations and practice of code generation. Here, the issue is that of ‘technical illiteracy’ and the need for an understanding of ‘computational thinking’ in order to have hopes of comprehension. Lastly, the third classification relates to the opacity resulting from scale and complexity of the algorithm itself. Whilst related to the second classification, this extends to the ability even of specialists to ‘untangle the logic of the code within a complicated software system’.⁴⁸ This final category is the most challenging to the practice of audit and accountability, and given developments in the field, such algorithms likely to be the basis of the intelligent systems of the future.

Returning again to our theme of voice agents, it is already becoming clear that there are a number of design aspects that raise concerns. A study conducted in 2016 using Siri, Google Now, and Cortana explored conversational agents in

⁴³ K Crawford ‘Can an Algorithm be Agnostic? 10 Scenes from Life in Calculated Publics’ (2016) 41, 1 *Science, Technology & Human Values*, 77.

⁴⁴ H Nissenbaum, ‘A Contextual Approach to Privacy Online’ (2011) 140, 4 *Daedalus*: 36.

⁴⁵ Nissenbaum, A Contextual Approach, 36.

⁴⁶ House of Commons Science and Technology Committee. “Robotics and Artificial Intelligence; Fifth Report of Session 2016–17” (2016) Available at <http://www.publications.parliament.uk/pa/cm201617/cmsselect/cmsstech/145/145.pdf>.

⁴⁷ Burrell, ‘How the Machine “Thinks”’, 1.

⁴⁸ Burrell, ‘How the Machine “Thinks”’, 7.

everyday use.⁴⁹ It found that user interactions with the system were very much affected by the feedback from, and affordances of, those systems. What was interesting here was that users first engaged with these systems through play, often with their children, much like the toys in our case study. Questions such as ‘how long is a piece of string’ and ‘what’s the meaning of life’ were among the initial interactions for all participants. Whilst the system responses proved amusing, they also had the effect of setting unrealistic expectations of system capability and intelligence. This not only proved disappointing in the context of ongoing use, but also served to hinder user understanding of system operation. This included uncertainty over (a) what the system could do, (b) what it was doing (c) how it was doing it, (d) whether or not its capabilities altered over time, (e) whether user interactions affected system state, (f) if it was listening, (g) if it was learning from the individual or wider dataset, (h) if data was processed elsewhere. These issues were compounded by there being no ‘natural’ means to interrogate the system and therefore limited ability to assess its capability or state. Overall, it was clear that users had poor comprehension of how a conversational agent worked, and the using the systems failed to bridge the gap between user expectation and system operation. To compound the problem, poor understanding was reinforced by lack of meaningful feedback and an ongoing inability for users to assess system intelligence.

C. User Consent

From an interaction design perspective, one of the core privacy-related issues arising from system opacity is that of consent. If a user cannot secure a reasonable high-level understanding of system operation, how can they be said to consent to the resulting data use? In broad terms, consent should be voluntary, competent, informed and comprehending. It has been described as the primary means by which individuals protect their privacy and exercise their autonomy online.⁵⁰ More specifically, consent enables data subjects to waive certain rights, under particular conditions, and is the mechanism by which data collection, storage and processing is legitimised. More specifically, ‘each user interaction with a system, whether experimental or embedded within the fabric of life, necessarily relies upon some form of user agreement or acceptance; some transactional behaviour that (a) opens with an offering, (b) relies upon an appropriate level of awareness and (c) understanding, and (d) is completed by a signal of assent’.⁵¹

⁴⁹ Luger and Sellen, “Like Having a Really bad PA”.

⁵⁰ L Curren and J Kaye, ‘Revoking Consent: A “blind spot” in data protection law?’ (2010) 26 *Computer Law & Security Review*, 273.

⁵¹ E Luger and T Rodden, ‘An Informed View on Consent for Ubicomp’ (2013) *Proc. Ubicomp’13*. ACM Press, 530.

Whilst reliance on terms and conditions of service and privacy policies, as mechanisms for informing, is already a known point of failure, sensing, voice-based systems question such approaches yet further.

Technically, it can be said that all products explicate the terms of service within the standard terms and conditions and privacy policies. So, from an operational and legal perspective, consent is given—the assumption being that such terms are read, understood and remembered throughout the course of product use. However, a number of issues arise. First is the question of whether in-home products, particularly those that rely on data from children's play, blur the boundary of what might be considered legitimate ongoing consent. The assumptions underpinning the model of 'consent as agreement' (to terms of service) impoverish our social understanding of the concept. In social terms, my consent changes the moral relations between myself and the consent-seeker. Made plain, this means that actions considered illegitimate or inappropriate, prior to consent, may become allowable if both parties agree. One need only look to our understandings of sexual consent to see how this works in practice. From the social perspective, contexts and values shift. Therefore, what I consent to today may not be agreeable to me tomorrow. This is where legal and social definitions sit uncomfortably alongside each other. Whilst the operational, or legal, definitions of consent may have worked in the context of static products or those that were understood by the user, it is clear that voice based systems are neither understood, nor are they static. If systems are pervasive, embedded within private settings, 'naturally' interacted with, and changing in terms of their capabilities and interactional grammar (rules), how can users be said to consent to the ongoing use of their data?

More practically, how can one be sure that the consent-giver is able to agree or predict the context of use? Here, several issues arise. Firstly, the person agreeing at the point of purchase is not necessarily the ongoing data subject; this is especially true in the case of 'family household' devices. Secondly, even if one assumes that use of the product continues to be monitored by an adult, the likelihood (particularly with toys) is that there will be some times when the child plays alone, and there are currently no settings to stop a child activating the systems alone. Indeed, the notion of play assumes a relationship between the child and the toy. Arguably, on this basis, it is clear that the emerging class of voice systems actively fail to support effective consent.

V. Conclusions and Recommendations

The rise of conversational agents generally, and in increasingly intimate settings, necessitates discussion of their opacity. The interactional challenges implied by the agents—lack of awareness of when they are listening, weakened ability to understand their inner workings, their always-on nature, the variable degree of intelligence they possess, and the identities of third parties introduced—are both

significant and troubling. Such technologies are being increasingly woven into our social fabric. The design of such systems is not only unobtrusive, but formed to reflect existing artefacts, relying upon user preconceptions of similar items to lead them to appropriate interactions. The artefacts arising from this emerging class of systems conflate the social, technology and data, blur our public and private boundaries, implicate and invisibly interact with third parties, read our data as behaviours, make decisions about us and act on those decisions. More worryingly, they do this in ways that are not immediately visible or even inspectable, and this trend is set to continue. Subsequently, we have no cognitive models of how such systems work, and no clear boundary objects or metaphors, like the file system on desktop PC, upon which to hinge user understanding.

While unobtrusiveness is a valued characteristic of devices that house conversational agents, ambiguity and the aforementioned interactional challenges amplify the core problem with privacy erosion and lack of intelligibility: the large power imbalance between users and the makers of devices. If indeed ‘someone is always looking over your shoulder’ in a world of ambient listening devices, then much discussion is warranted regarding the interplay of the social, legal, and, importantly, commercial forces that are reified by these devices. As the case study of child privacy challenges illustrated, we are in danger of creating a commercial surveillance fabric that will blanket not only adults, who are ostensibly able to consent, but children, whom much of the world sees as unable to do so. In light of these issues, we would like to offer some nascent research recommendations to be considered when moving forward with the development of sensing, voice-activated systems.

A. Rethinking the Design of Consent Mechanism for Conversational Systems

It is clear that, when systems function in complex social settings, operational approaches to consent are decreasingly salient as ‘changes in the context of data can cause ruptures in both user expectations and understanding.’⁵² More specifically, they completely fail to inform a user to the ongoing data demands of pervasive NUI systems. The broader question here may be, after years of being the gold standard, whether consent can continue to be robust grounds for data-processing.

To support a more socio-technical model of consent, systems should redesign informing mechanisms to better suit the interface norms. So, if one speaks to a system, and therefore this is the user’s interactional model, then consideration of how one might use voice to query or interrogate the system about data use, or what data is held/known, seems a reasonable extension. Further to this, systems should look beyond securing to *sustaining* consent (*ibid*), allowing users to review

⁵² Luger and Rodden, ‘An Informed View on Consent for Ubicomp’, 537.

or withdraw their data through dialogue, and offer some means by which they might develop robust mental models of system operation.

B. Create New Boundary Objects and Privacy Grammars to Support User Understanding and Trust

The types of boundary objects, and grammars used to support interaction with systems, have long been fairly static and relied very much on direct manipulation interfaces; e.g. the desktop computer or touchscreen. The rise of new forms of technology, and our uneven understanding of such systems, necessitates a revision of what boundary objects might support user understanding of privacy and security. One need only think of the padlock in the url field, as a mechanism for supporting user security and trust, to know that such objects are core to our social understanding of systems. Whilst the wake word offers one form of boundary object, our analysis shows that this is easily disrupted, and therefore insufficiently robust to be applied to privacy. More work is needed to fully understand (a) existing user mental models of conversational systems (b) the appropriate (non-anthropomorphic) metaphors to explain system operation, and (c) appropriate boundary objects that reflect both user and engineer interactional requirements. Equally, the grammar (or rule set) one applies to traditional interfaces no longer makes sense in the context of pervasive, data-driven systems. Exploratory research is required to better understand what interactional rules might be supported in order to better enable user agency and privacy protection.

C. Undertake Research on the Potential Increase and Normalisation of Child Surveillance

The continuing introduction of intelligent, networked, sensing, listening toys has tremendous implications for children's privacy—are these toys the vanguard of normalised child surveillance in the home or in the broader context of play? The time to investigate such concerns—who is listening, what can be heard and seen, how long are child utterances stored, and what can they be used for—is now, before there are large numbers of surveillant toys in the marketplace. And, since some of these toys talk back, some of them are already beginning to advertise to children of varying ages, some known to be too young to understand they are being actively persuaded. Research on child advertising is known to be focused mainly on television, but there is a lack of research investigating more modern digital channels (Chester and Montgomery, 2008).⁵³ There is a clear need to monitor the market

⁵³ J Chester and K Montgomery. "Digital marketing to youth: an emerging threat" 18 6 (2008) *Consumer Policy Review*.

for evolution in child advertising practices within the networked, intelligent toy sector and the in-home voice assistant sector. Such monitoring should feed continued refinement of industry codes of practice and government regulation.

Further research and discourse on the personal, political and physical risk of the introduction of voice-enabled technologies is merited. Specifically, we call for a research agenda that focuses on the privacy challenges presented by voice-based systems questioning and rethinking, in particular, traditional conceptual models of interaction such as consent and design for privacy in this context. Finally, we would note that, without the development of appropriate cognitive models and boundary objects, some consideration of what constitutes usable privacy within dialogue systems, and a desire to redress the power and control imbalance between system and user, we are likely to see further and potentially more harmful violations, as our private conversations become data to be mined and, potentially, used against us.

References

- Ananny, M, 'Toward an Ethics of Algorithms Convening, Observation, Probability, and Timeliness' (2016) 41, 1 *Science, Technology & Human Values*, 93–117.
- Brennan, SE, 'Conversation as direct manipulation: An iconoclastic view'. in BK Laurel (ed) *The Art of Human-Computer Interface Design* (Reading, MA: Addison-Wesley, 1990).
- Burrell, J, 'How the Machine "Thinks:" Understanding Opacity in Machine Learning Algorithms' (2016) 3, 1 *Big Data & Society*, 1–12.
- Chester, J and K Montgomery, 'Digital marketing to youth: an emerging threat' (2008) 18 6 *Consumer Policy Review*.
- Crawford, K, 'Can an Algorithm be Agnostic? 10 Scenes from Life in Calculated Publics' 41, 1 (2016) *Science, Technology & Human Values*, 77–92.
- Curren, L and J Kaye, 'Revoking Consent: A 'blind spot' in data protection law?' 26 (2010) *Computer Law & Security Review*, 273–283.
- Domingos, P, *The Master Algorithm. How the Quest for the ultimate learning machine will remake our world* (London: Penguin, 2015).
- Glass, JR, 'Challenges for Spoken Dialogue Systems' (1999) *The proceedings of IEEE Workshop on Automatic Speech Recognition and Understanding*. (ASRU), Colorado, USA.
- Hardt, M Price, E and N Srebro, 'Equality of opportunity in supervised learning' (2016) *Advances in Neural Information Processing Systems*, 3315–3323.
- Harper, R Lindley, S Thereska, E Banks, R Gosset, P Smyth, G Odom, W and E Whitworth, 'What is a file?' (2013) *Proceedings of the 2013 conference on Computer supported cooperative work* (CSCW '13). ACM, New York, NY, USA, 1125–1136.
- Hong, J Suh, E and S-J Kim, 'Context-aware systems: A literature review and classification' 36 (2009) *Expert Systems with Applications*, 8509–8522.
- Kosinski, M. Stillwell, D. and T. Greapel, 'Private traits and attributes are predictable from digital records of human behaviour' (2013) 110, 15 *PNAS*, 5802–5805.
- Luger, E and T Rodden, 'An Informed View on Consent for Ubicomp' (2013) *Proc. Ubicomp'13*. ACM Press, 529–538.

- Luger, E and A Sellen, “Like Having a Really bad PA”: The Gulf between User Expectation and Experience of Conversational Agents’ (2016) *Proc. CHI’16*. ACM, 5289–5297.
- Nissenbaum, H, ‘A Contextual Approach to Privacy Online’ (2011) 140, 4 *Daedalus*, 32–48.
- , *Privacy in Context: Technology, Policy and the Integrity of Social Life*. (Stanford: Stanford University Press, 2010).
- Payr, S, ‘Virtual Butlers and Real People: Styles and Practices in Long Term Use of a Companion’. in Robert Trappl (ed) *Your Virtual Butler: The Making-of*. (Dordrecht: Springer, 2012), 134–178.
- Rosner, G, *Privacy and the Internet of Things*. (Sebastopol: O’Reilly, 2017).
- Shmueli, B and A Blecher-Prigat, ‘Privacy for Children’ (2011) 42, 3 *Columbia Human Rights Law Review*, 759–796.
- Tutt, A, ‘An FDA for Algorithms’ (2016) 69 (1) *Administrative Law Review*, 83–123.
- UN General Assembly, *Convention on the Rights of the Child*, United Nations, Treaty Series, (1989).
- Von der Pütten, AM, Krämer, NC, Gratch, J & S-H Kang, ‘It doesn’t matter what you are! Explaining Social Effects of Agents and Avatars’ (2016) 26 *Computers in Human Behaviour*, 1641–1650.
- Wilks, Y, ‘Is a companion a distinctive kind of relationship with a machine?’ (2010) *Proceedings of the 2010 Workshop on Companionable Dialogue Systems (CDS ‘10)*. Association for Computational Linguistics, Stroudsburg, PA, USA, 13–18.
- Zao, JK Lin, CT, Ko, L-W She, H-C Dung, L-R and B-Y Chen, ‘Natural User Interfaces: Cyber-Physical Challenges and Pervasive Applications’ (2014) Panel Discussion at *2014 IEEE International Conference on Internet of Things (iThings 2014)*, Green Computing and Communications (GreenCom 2014), and Cyber-Physical-Social Computing, 467–469.

9

Concluding Remarks at the 10th Computers, Privacy and Data Protection Conference: 27 January 2017

GIOVANNI BUTTARELLI



Ladies and gentlemen,

Happy 10th birthday to CPDP!

An esteemed New York Times journalist has just published a book about the speed of technological change.

The title of Thomas Friedman's book is "Thank you for being late".

(As an Italian I can approve of this!).

The book says that 2007 was one of the biggest moments for technology. Android and the iPhone were launched, Twitter and Facebook went global, AirBnB was founded.

So, you see, CPDP anticipated this by one year. And its short life has charted perhaps the most extraordinary decade for society and technology.

My sincere congratulations and thanks to Paul and all the team who have put this together. The biggest ever CPDP.

1020 participants.

Many new young people.

A new beautiful fringe venue in Maison d'Autrique for discussing risk-based approaches, data capitalism and reflections about integrity and sponsoring privacy conferences.

Here in the main building, rooms have been full from 8.45am to 6pm or and even later with Side panels on voter-privacy and ethics and robot agency.

It is an honour for my institution to have been part of CPDP from the start.

This conference uniquely reaches out beyond the confines of traditional policy circles.

And now you can carry CPDP around with you anytime, anywhere, because you can watch the panel sessions online.

The CPDP organisers have allowed space for an extraordinary cacophony of problems and trends in technology, in the commercial space and in government.

And the panels have been orchestrated into a magnificent symphony of potential solutions.

Everyone is able to rub shoulders and learn from each other on a neutral platform and on an equal footing.

...

You might recall that last year I invited you to prepare for Star Wars.

The epic film franchise seemed to epitomise the Zeitgeist of privacy and humanity at the beginning of 2016.

This year, I would love to promise you a future in La La Land.

But of course, the world is far from being a romantic musical.

Big moments in our lives are not punctuated with pretty tunes.

And few of us have the opportunity to dance in front of a purple sunset seemingly painted by Van Gogh.

We are in a very uncertain place.

It's easy to forget that 2016 provided cause for celebration for those of us who have fought and laboured hard for modernised rules on data protection in the EU.

We have continued to see countries around the world emulating the approach taken by the Council of Europe and the EU.

The courts have continued to uphold and deepen our understanding of the correct application of principles of human rights.

Alongside the trends of adopting personal data and privacy laws with effective enforcement bodies, there are counter trends around the world—the construction of enormous databases of personal and sensitive information, either with too little control over who can access, or with too much control by state actors.

We have also seen a reversal in many countries of their protection of human rights and the freedom of civil society to advocate the rights of the weak and the vulnerable.

I predict that connected people around the world will soon begin to understand why we have data minimisation and purpose limitation, and now accountability, as essential principles of data protection.

People will realise that the limitless accumulation of personal data, including the most intimate genetic and biometric data, creates the risk of a tsunami (to use Caspar Bowden's analogy).

We cannot assume that the hands which use the data will be as benign as the hands which collected it.

I hope we do this the easy way, not the hard way.

...

Now is the time to think about values and turn them into reality on the ground.

In the EU, regulators like me, and controllers have 483 days to become fully ready to enforce or to comply with the GDPR and the directive on data protection in law enforcement and criminal justice, plus—I expect and hope—the EPrivacy Regulation and the Regulation on data processing by EU bodies.

That is, 322 working days—assuming you have the occasional day off!

As for my institution, we are approaching the half-way point of our mandate.

So, in May this year we will be relaunching our strategy, with a fresh focus on getting the EU institutions ready for the new data protection and ePrivacy rules.

In collegiality with fellow independent DPAs, we will be preparing the new EDPB.

And we will take a truly global outlook.

To reflect this, we will shortly have a new look website—if you go to our website you will find a short video about it.

And I can announce today that in the week of 25 September this year, in Hong Kong, together with the UN Special Rapporteur for Privacy, Joe Cannataci, we will be hosting a major conference on Prospects for Global Privacy, with experts from all regions of the world, to take stock of where we are, and where we should be going.

This will be a side event to the International Conference of Privacy Commissioners. And I hope many of you will be able to contribute.

A lot of discussion on ethics and accountability this week.

But we need to start to internalise the notion of accountability, far more important than box ticking compliance.

And we need to apply these principles to international data flows.

I cannot predict the fate of the Privacy Shield. But this is just one bridge among many which need to be built in today's global society.

...

Here is one clear lesson from the events of 2016:

We have to start speaking a different and more direct language. Not always easy for lawyers.

And we have to start thinking about the real impact which current practices is having on ordinary women, men and children.

People who have no interest in the details of human rights or data protection law, but who know what it feels like when their rights are infringed.

People don't talk about their data protection rights.

They talk about their freedom to do what they want and to be left alone.

That is the big challenge for this year.

To escape La La Land, and get our hands dirty with the reality of people trying to navigate the digitised world which they are increasingly expected to inhabit.

Today we mark Data Protection Day, or Data Privacy Day, or European Data Protection Day—we should really try to harmonise the description next year!

But today something much more important and solemn is happening.

It is Holocaust Memorial Day. It is a reminder that totalitarianism did not happen overnight.

A reminder to all of us how fragile freedom and dignity are.

Because it's easy to weaken one right, and when you weaken one right it makes it even easier to weaken another one. And so on.

So we assembled here today are issuing a new decree to be heard in every city, in every foreign capital and in every hall of power—from this day forward, we have a new vision:

It's going to be only fundamental rights first.

Fundamental rights first.

So, people, let's build those privacy bridges.

It's gonna be big. It's gonna be so beautiful.

And together we will make privacy great again.

...

Here's to the next 10 years of CPDP.

Thank you for listening.

I wish you all a very safe journey home.

INDEX

accountability

- algorithms 204, 205–6
- Article 29 Working Party (WP29) 44–5, 54
- controller responsibility 34–6, 44–5
- health 75–6
- risk-based approach 34–6, 41–2, 50, 52

addictive products 81

additional information 121–2, 125, 127, 133–4, 140

advertising

- algorithms 77, 203
- codes of practice 211
- digital channels 210–11
- imprecise use of data 69, 75
- picture without permission, using 64
- poorly targeted advertising 66
- regulation 211
- smart toys 200–2, 210–11

agents *see* **conversational agents**

Albrecht, Jan Philipp 22–3

Alexa (Amazon) 196, 198–9, 204

algorithms

- accountability 204, 205–6
- advertising 77, 203
- Bayesian modelling techniques 204
- bias 43–4
- calibration 80–1
- classification decisions 205–6
- community access 85
- concealment 206
- contested decisions 205
- conversational agents 195–6, 202–7
- design 107
- discrimination 102, 110, 203
- explainability 205–6
- fairness 103–5
- false positive and false negatives 80–1
- fixed algorithms 77
- GDPR 72–3, 75
- happy, making consumers 80–1
- harm 80, 82
- inferences 194
- insecure use and imprecise use of data 68–9, 70–5
- inspectability 205
- machine intelligence 202–5

machine learning for profiling,

- use of 92, 94–6, 100–10

Networked Information Algorithms (NIAs) 204

neural networks 106, 204

neutrality 102

objectivity 102

opacity 205–7

outputs, predictability and

- explainability of 205–6

ownership 83

personalised algorithms 68–9, 70–5

predictability 204, 205–6

quality and quantity of data 103, 111

reviews 82

risk-based approach 83–4

rogue algorithms 71

surveillance 82–3, 85

technical illiteracy 206

trade secrets 107, 206

transparency 71, 85, 106–8, 206

always on systems 198–9

Amazon

Alexa 196, 198–9, 204

algorithms 92

cloud computing 90

Dot 196

Echo 196, 199, 200

Mechanical Turk 90

regulation 84

search engines 77

Amsterdam Treaty 13

analytics 90–1, 116

Ananny, M 204

anonymised data

- Article 29 Working Party 118–19, 127, 139–41

definition 119, 126

GDPR 118–19, 124–30, 132–4, 136, 139–41

generalisation 124, 153–4

health 129–30

ICO's PIA Code of Practice 50

Industry 4.0 153–4

K-anonymity 125, 127–9, 132–4, 136, 139

machine learning for profiling,

- use of 95–6, 109–10

- personal data as distinct 116
- pseudonymisation 154
- randomisation 124, 153–4
- recipients of data 139–40
- re-identification 153–4
- sanitisation techniques 136
- techniques, opinion on 118–19
- Anderson, K** 179
- anthropology** *see* **legal anthropology**
- Apple's Siri** 195, 196, 206–7
- apps** 70, 170, 181
- Aristotle** 64
- Article 11 data (GDPR)** 117, 119–20, 126, 128–31, 133, 139, 141
- Article 29 Working Party**
 - accountability 44–5, 54
 - anonymisation, opinion on 118–19, 127, 139–41
 - controller responsibility 34–6
 - data protection authorities (DPAs) 18
 - data protection principles 35
 - GDPR 94, 118–19, 124–7, 139–41
 - machine learning for profiling, use of 94, 99, 109
 - Passenger Name Records (PNRs) 22
 - risk-based approach 39, 46, 48, 52, 54–7, 59–60
 - sanitisation techniques 125, 127, 130–1, 135
- artificial intelligence** *see also* **intelligent systems; machine intelligence**
 - artificial artificial intelligence 90
 - definition 90
 - ethics 104
 - general artificial intelligence 203
 - harm 65
 - machine learning for profiling, use of 90
- Assist-as-needed functions** 174–5
- audits** 75, 81, 84, 102, 206
- Austria** 91
- automated decision-making** 70–81 *see also* **algorithms**
 - anonymised data 153–4
 - appeals 102
 - association with attributes 78
 - benefits and risks 77–81
 - definition 93–111
 - effects 97–9
 - explanation, right to an 73
 - false positives and false negatives 63, 79–81
 - GDPR 81, 93–111
 - happy, making consumers 80–1
 - human intervention 97–9
 - Industry 4.0 152–5
 - insecure use and imprecise use of data 70–7
 - lawful processing 93–102
 - legal effects, definition of 152–3
 - machine learning for profiling, use of 93–111
 - measurement of benefits and risks 77–81
 - model surveillance system 78–9
 - net benefit of surveillance systems, estimating 79–80
 - net harm 80–1
 - observation of outcomes 78
 - propensities 78–80
 - reliability 105
 - right not to be subject to automated decision-making 73, 93, 94
 - search engines 77
 - surveillance 63, 77–84
 - telerehabilitation processes 175
 - test error rate 78–9
 - transparency 80
 - value creation 77
- autonomy** 1–2, 4, 74
- background knowledge** 121–2, 124, 128, 133
- Baldwin, R** 38
- Barocas, S** 43–4
- Bayesian modelling techniques** 204
- Belgium** 17, 91
- BeMobil** 168, 174–5
- better/cheaper services and products** 66
- Bezos, Jeff** 90
- bias** 43–4, 102–3, 111
- big data** 49, 104
- Binns, R** 49
- biometrics in national identity documents** 11
- Black, J** 49
- Blecher-Prigat, A** 201
- Bluetooth** 200
- boundary objects** 197–8
 - new, creation of 210
 - wake words 198, 210
- boyd, d** 183–4
- brace therapy** 170, 176–87
- Brandeis, Louis** 64–5
- breast cancer screening** 79–80
- Brexit** 15
- Brill, Julie** 105–6
- Burkert, H** 47
- Bygrave, Lee** 47–8, 108
- calibration of legal obligations** 38, 54, 58
- Canada** 74
- capitalism** 77
- causation and correlation** 104–5
- Centre for Information Policy Leadership (CILP)** 34, 38, 45, 47, 52
- Charter of Fundamental Rights of the EU (CFEU)** 13–17
 - binding nature 9, 15
 - CJEU 9, 11, 15
 - common law 15
 - domestic politics 13–17
 - economic and social rights 15

- enlargements 14
- GDPR 72
- institutions 17, 25
- integration 13–14, 17
- interpretation by CJEU 15
- Lisbon Treaty 9, 14, 15, 25
- Nice Treaty 14, 17
- risk-based approach 56
- sovereignty of member states 14–17
- telerehabilitation processes 176
- Treaty status 15
- United Kingdom 14–15
- child-facing technology** 196, 198–201, 208–9
 - adult-child communications,
 - privacy of 200–1
 - advertising 200–2, 210–11
 - consent 209
 - Convention on the Rights of the Child 1989 (UN) 201
 - inappropriate use 201–2
 - microphones 199–200, 201
 - monitoring 208
 - normalisation of surveillance 210–11
 - play, privacy of 201
 - research into increase in surveillance 210–11
 - sensed conversation 196, 198–9
 - smart toys 196, 198–202, 205, 210–11
 - surveillance 199–200, 210–11
 - third parties 201, 202
 - unfair and deceptive practices 200
 - voice recognition technology 199–200
- children** *see* **child-facing technology; children and teenagers and telerehabilitation processes**
- children and teenagers and telerehabilitation processes** 176–88
 - attitudes 184–7
 - brace therapy 176–87
 - data sharing, attitudes towards 181–2
 - digital natives 180, 187
 - future events, anticipating 184
 - monitoring 176–7, 185–7
 - parents, access to personal data by 186
 - personal data 174–88
 - reasonable expectations 184–8
 - scoliosis 170–1, 176–87
 - sensitive data 177, 183, 184
 - sharing data 181–4, 186–7
 - social media 180–1, 183–4
 - surveillance 184–5
- civic interests** 13–14, 25
- civil law tradition** 3–4
- CJEU** *see* **Court of Justice (CJEU)**
- cloud computing** 90, 95, 100, 162–3, 200
- CloudPets** 200
- collective ownership of data** 83–4
- collective social practices, law as**
 - part of 177, 179
- Commission** 6–7, 23, 36, 45, 146, 152, 162
- common law tradition** 3
- communitarisation** 19
- competitiveness** 80, 144, 146–7, 206
- computational thinking,**
 - understanding of 206
- Computer Security Incident Response Teams (CSIRTs)** 162–3
- Computers, Privacy and Data Protection Conference, 2017** 213–17
- confidentiality** 39, 56, 61, 134, 140–1, 185–6
 - see also* **trade secrets**
- consent**
 - accountability 75
 - children 209
 - complexity of information 74–5
 - consumer protection 74
 - conversational agents 196, 199, 207–10
 - definitions 208
 - design 209–10
 - employer-employee nexus 159
 - explicit consent 84
 - health 75–6, 84
 - Industry 4.0 151, 153
 - inform-and-consent procedure 47, 51
 - informed consent 68–9, 74–5, 207
 - insecure use and imprecise use of data 71–2, 74–6
 - news feeds, personalisation of 48
 - reasonable expectations 209–10
 - regulation 75–6
 - risk-based approach 42, 48
 - socio-technical model of consent 209–10
 - surveillance 84
 - sustaining consent 209–10
 - telerehabilitation processes 170–1, 176
 - third parties 68
 - trade-offs 75
 - transparency 176
 - voluntary consent 207
 - waiver of rights 207
- consistency** 20
- Constitutional Treaty of EU** 14
- consumers**
 - consent 74
 - GDPR 81
 - group profiling 96–7
 - happy, making consumers 81
 - insecure use and imprecise use of data 69, 76–7
 - ownership and control of data 76
 - producer-consumer nexus 144
 - protection 13, 74, 76–7
 - research mechanisms 76–7
 - separation from data protection 76
 - surveys 69
 - transparency 76

context

- confidentiality 119
- context-relevant informational norms 179
- contextual integrity 178
- controls 118–19, 122–4, 134–40
- fundamental rights 2
- GDPR 118–19, 122–4, 134–40
- historical institutionalism 7–8
- improving data utility 134–9
- internal controls 134
- inter-party controls 134
- legal and organisational controls 122, 134
- reasonable expectations 169
- re-identification risks 123–4, 134, 140
- relativist approach 118–19
- sanitisation techniques 118, 130, 135, 139–41
- social context 204–5
- strategic interests 2

contract

- controllers 93
- conversational agents 207–8
- Industry 4.0 151, 153
- machine learning for profiling, use of 102
- terms and conditions 207–8

controllers

- accountability 41
- compliance 93
- contracts 93
- correction and erasure, right to 108–9
- finances 102
- GDPR 34–7, 41–53, 135, 139–40
- harm prevention 41–2
- impact assessments 39–40
- logic used, meaningful information on 93, 107–9
- machine learning for profiling, use of 93–7, 100–2, 105–11
- responsibility 34–6, 39–53
- risk-based approach 34–53
- telerehabilitation processes 175
- transparency 107

conversational agents 193–211 *see also***child-facing technology**

- algorithms 195–6, 202–6
- always on systems 198–9
- boundary objects 197–8, 210
- capabilities, lack of understanding of 207
- consent 196, 199, 207–10
- definition 195–6
- design 197, 204, 206–7, 209–10
- discrimination 203
- error 204–5
- explainability 205–6
- feedback 207
- file, notion of the 197–8
- gestures 195
- grammars, creation of new 210

Human Computer Interaction (HCI) 196

- inferences 194
- inspectability 205
- intelligibility 196, 209
- Internet of Things (IOTs) 195–6
- learning 204–5
- location data 194
- machine intelligence 202–6
- meta-ethical concerns 196
- microphones 199–200, 201
- mobile technologies 196, 199
- murder investigations 200
- National User Interface (NUI) 194–5, 209
- observability, insulation from 199
- opacity 205–7, 208–9
- padlock system 197, 210
- platform, conversation as 196–8
- power inequity 199
- privacy policies 207–8
- reasonable expectations 199, 209–10
- review or withdrawal of data 209–10
- sensed conversation 196, 198–9
- smart toys 196, 198–202, 205, 210–11
- social context, importance of 204–5
- social media 196
- socially-embedded systems 198
- terms and conditions 207–8
- third parties 198, 208–9
- trust 210
- unobtrusiveness 197, 209
- unremarkability 197
- user understanding 207, 210
- worn technologies 196

corporate responsibility 52, 194**correlation and causation** 104–5**Court of Justice (CJEU)** 8–13

- activism 9, 12
- additional knowledge 140
- authority, construction and protection of 12–13
- challenges 8–11
- Charter of Fundamental Rights of the EU 9, 11, 15
- Data Retention Directive, invalidity of 10
- early challenges to authority 8–9
- European Convention on Human Rights, accession of EU to 9–10
- ECtHR, jurisprudence of 9–11
- fundamental rights 8–9, 13
- gap-filling 8–13
- GDPR 12, 118
- Germany 9, 11
- institutionalisation of fundamental rights 8–9
- interpretation 15, 21
- judicial policy-making 12
- jurisdiction, challenges to 9
- legitimacy 13

- neo-institutional theory 13
- norm entrepreneurship 6–7
- parameters, setting 12–13
- policy processes, influence on 12
- national interests 11
- Netherlands 11
- risk-based approach 56, 59
- search engine results, right to be de-listed from 10, 59
- status quo, challenges to 9–11
- strategic interests 11–13
- supremacy of EU law 9, 11, 12–13
- crime and dishonesty, preventing** 66, 158
- cyber-physical systems** 144, 147–8, 151, 155–6
- Czech Republic** 15
- data controllers** *see* **controllers**
- data mining** 43, 104
- data processing**
 - automatic processing 63
 - fair processing 74–6
 - false positive and false negatives 63
 - historical, statistical or scientific purposes, processing relating to 152
 - Industry 4.0 150, 152, 154
 - lawful processing 71, 151
 - limited processing 71
 - model of automated decision-making 63
 - outcomes of processing 63
 - poor implementation 63
 - probabilistic processing 92
 - specified, explicit, and legitimate purposes, processing for 95
 - statistical or archiving purposes, processing relating to 152
- data protection authorities (DPAs)** 17–18, 20
- Data Protection Directive (95/46)** 8, 15, 17–21
 - civic interests 25
 - CJEU, interpretation by 20
 - data protection authorities (DPAs) 17–18, 20
 - employer-employee nexus 156–7, 159
 - free flow of personal data 20, 23
 - fundamental rights 2, 25
 - GDPR 2, 116–17, 119
 - general notification obligations 40
 - historical background 25
 - implementation 23
 - Industry 4.0 149, 151–7, 159, 161
 - internal market 18–20
 - interpretation 21
 - legal basis 18–20
 - machine learning for profiling, use of 94, 98, 108–9, 111
 - market-making tool, as 2, 4, 5, 17–20, 25
 - policy 18
 - prescriptive rules 4
 - regional instruments 20
 - risk-based approach 34, 40, 53
 - standard-setting 2, 21
 - transparency 108
 - treaty-base games 17–20
- data protection principles (DPPs)**
 - Industry 4.0 152
 - machine learning for profiling, use of 93–110
 - risk-based approach 41, 47–59
- Data Retention Directive** 10, 19
- data security** *see* **security of data**
- data sharing** *see* **sharing data**
- data subjects, rights of**
 - access to data 47–8, 57
 - controllers 58–9
 - Industry 4.0 153
 - informed, right to be 93
 - insecure use and imprecise use of data 71–2
 - machine learning for profiling, use of 93–5, 101, 108–11
 - not to be subject to decisions based solely on automatic processing, right 93, 94
 - review and correct data, right to 71
 - risk-based approach 47–8, 53–9
 - transparency 108–9
- decision-making** *see* **automated decision-making**
- decision trees, tracing of** 205–6
- deep learning** 91, 106, 204, 206
- defence** 5, 19
- design**
 - algorithms 107
 - consent 209–10
 - conversational agents 197, 204, 206–7, 209–10
 - data protection by design 100, 102
 - European Political Community, institutional design of 4–5
 - GDPR 171
 - harm-based approach 41–2
 - Industry 4.0 154–5
 - institutions 25
 - machine learning for profiling, use of 100, 102
 - privacy by design 36, 100, 169–76
 - probabilistic and emergent by design 204
 - risk-based approach 36
 - telerehabilitation processes 169–76, 188–9
- development of EU data protection law** 20–4
- differential privacy** 123, 125, 131–5, 140
- digital natives** 180, 187
- Digital Service Providers** 161–2
- Digital Single Market** 23–4
- DIGITALEUROPE** 35, 37, 41
- dignity and reputation** 99

discrimination

- algorithms 102, 110, 205–6
- differentiation 106
- fairness 97
- GDPR 37, 72
- health insurance companies 186–7
- impact assessments 101–2
- insecure use and imprecise use of data 69, 73–4
- machine learning for profiling, use of 91–2, 97, 105–6, 110–11
- price 70
- prioritization 106
- public perceptions 66
- racism 203
- risk-based approach 38–9
- stereotyping and prejudice in human decision-making 91–2, 102
- telerehabilitation processes 189

domain linkability 118, 121, 125–6, 127–32, 134

Dot (Amazon) 196

Dourish, P 179

Echo (Amazon) 196, 199, 200

economic and social rights 3–4, 15

economic harms 66

Electronic Data Interchange (EDI) 144

electronic information-handling 47

emergency systems 175

employer-employee nexus 155–61

- asymmetry of power 156
- collective agreements 157
- consent 159
- Data Protection Directive 156–7, 159
- GDPR 156–7, 159
- Industry 4.0 144, 148, 155–61, 164
- international dimension 156–7
- location data 156, 158
- monitoring 158–9
- national laws 157–8
- personal data 155–9
- profiling 156
- remote working 155
- smart gloves 148, 156, 158
- surveillance 155–9, 164
- transparency 157
- virtualisation 155

encryption 121, 131, 132, 134

enlargement of EU 14

environmental protection 13

ePrivacy Directive 158

erasure 47–9, 57, 108–9

error 204–5

ethics 75–6, 84, 104, 168, 196

ethnography 187–9

European Communities (EC) 4

European Convention on Human Rights (ECHR)

- accession of EU 9–10
- ECtHR, jurisprudence of 9–11
- innovation 10
- sovereignty 15–16

European Data Protection Supervisor (EDPS) 44–5

European Defence Community (EDC)

Treaty 5

European Economic Community (EEC) 5

European Political Community, institutional design of 4–5

European Union *see also* Charter of Fundamental Rights of the EU (CFEU); Court of Justice (CJEU); Data Protection Directive (95/46); fundamental rights; General Data Protection Regulation (GDPR)

- Amsterdam Treaty 13
- Commission 6–7, 23, 36, 45, 146, 152, 162
- consumer protection 13
- development of EU data protection law 20–4
- enlargements 14
- ePrivacy Directive 158
- European Communities (EC) 4
- European Convention on Human Rights, accession to 9–10
- European Economic Community (EEC) 5
- European Parliament 18–19, 146
- European Political Community, institutional design of 4–5
- free movement 14
- global dominance 4
- Industry 4.0 149–63
- integration 7, 11, 13–15, 17
- internal market 13, 18–24
- Justice and Home Affairs (JHA) 19
- legal context 149–53
- Lisbon Treaty 5, 8–10, 13–14, 15, 19, 25
- Maastricht Treaty 13
- NIS Directive 161–3
- opt-outs 15
- pillar system 13
- opposition to policy initiatives 15
- prescriptive legal rules on privacy in EU 3
- US-EU Passenger Name Records (PNRs) 21–2

Ewick, P 177–8

explainability 205–6

explanation, right to an 7, 107–83

Facebook 65, 77, 84, 183, 194

fair processing

- algorithms 103–5
- appeals 102

- bias 103
- correlation and causation 104–5
- criteria or technical policy 103
- discrimination 97
- Fair Information Principles 41
- insecure use and imprecise use of data 74–6
- machine learning for profiling, use of 93–4, 97, 102, 103–6, 108, 110–11
- news feeds, personalisation of 48
- Outcomes 41
- risk-based approach 41, 48–9, 55, 58
- transparency 108
- underrepresentation or overrepresentation of goods 103
- false positives and false negatives** 63, 79–81
- feedback** 207
- file, notion of the** 197–8
- finance industry** 77
- fines** 50, 102
- financial crisis** 145
- fourth industrial revolution** 146–7
- framing** 19–20
- France** 17, 91
- fraud** 66, 68
- free movement** 14, 20, 23, 41
- Friedman, Thomas** 213
- fundamental rights** *see also* **Charter of Fundamental Rights of the EU; European Convention on Human Rights (ECHR)**
 - CJEU 8–9, 13
 - Constitutional Treaty, failure of 14
 - constitutionalisation 2, 3, 8, 9
 - Data Protection Directive 25
 - development of data protection law 21
 - economic and social rights 3–4, 15
 - economic efficiency, prevailing over 4
 - GDPR 37
 - historical background 4–5
 - institutionalisation 2, 8–9
 - Lisbon Treaty 9
 - Nice Treaty 14
 - parameters, setting 12
 - personal data, disclosure of 8
 - policy outcomes 2–4
 - political pragmatism 4–5
 - proceduralisation 47
 - risk-based approach 44, 47, 53, 55–6
- future events, anticipating** 184
- GDPR** *see* **General Data Protection Regulation (GDPR)**
- Gellert, R** 38, 40, 52, 54
- General Data Protection Regulation (GDPR)** *see also* **terminology in GDPR**
 - algorithms 72–3, 75
 - automated decision-making 72–3, 75, 81, 93–111
 - Charter of Fundamental Rights of the EU 72
 - controller responsibility 34–7, 41–53
 - costs of implementation 43
 - customer data 155
 - data analytics 116
 - Data Protection Directive (95/46) 2, 116
 - design, privacy by 171–2
 - Digital Single Market 23–4
 - development of EU data protection law 21–4
 - direct applicability 116
 - discrimination 37, 72
 - drafting 12, 22–3
 - economic or social disadvantage 72
 - electronic information-handling 47
 - employer-employee nexus 156–7, 159
 - fines 116
 - fundamental rights 23–4, 25, 37
 - harmonisation 157
 - implementation 43, 59
 - Industry 4.0 149, 151–7, 159, 161, 163
 - insecure use and imprecise use of data 71, 72–5
 - interpretation 43, 46, 48–9
 - legal basis 18
 - legal certainty 172–4
 - legal obligations 42–53
 - machine learning for profiling, use of 93–111
 - mankind, objective of personal data as serving 81
 - market-based reasoning 21–2
 - market-making 2, 4, 17, 24–5
 - objective element 173
 - policy 21, 24–5
 - pseudonymisation 154
 - reasonable expectations 171–2
 - right to data protection 72
 - risk-based approach 34–9, 41–55, 58–9
 - sanctions 116
 - scalable compliance measures 44–5
 - sharing data 116
 - sovereignty 15
 - subjective element 173
 - surveillance 82
 - technical and organisational measures 172
 - telerehabilitation processes 171–5, 188
 - theory and practice, link between 42–4
- gender** 176
- generalisation** 124–5, 132, 153–4
- Genesis Toys and Nuance Communications** 199–200, 201–2
- Germany**
 - CJEU 9, 11
 - data protection authorities (DPAs) 17
 - driverless cars 91
 - employer-employee nexus 157–8, 160–1

- ethical, legal, and social implications (ELSI) 168
 - High-Tech Strategy 145–6
 - industrial policy 145–6
 - Industry 4.0 145–6, 157–8, 160
 - Model Professional Code for Physicians 176
 - property restitution claims 15
 - security of data 160
 - supremacy of EU law 9
 - telerehabilitation processes 168, 176
- global linkability** 118, 125–6, 130–3, 135–6
- Goffman, Erving** 177–80
- Gonçalves, ME** 40, 54
- Google**
 - Assistant 196
 - cloud computing 90
 - Google Now 196
 - image search 203
 - Nest 197
 - neural network technology 194
 - Now 196, 206–7
 - ownership 83
 - racism 203
 - regulation 84
 - search results, distortion of 77
- governments**
 - agencies 39–40
 - civic interests 13
 - interference 3, 38
- GPS functions** 150, 182
- group profiling** 96–7
- harm**
 - algorithms 80, 82
 - automated decision-making 80–1
 - breast screening 80
 - controller responsibility 41–2
 - design obligations 41–2
 - happy, making consumers 80
 - insecure use and imprecise use of data 68–71
 - legislature, constitutional limitations on 65
 - loss of privacy 63, 64–71
 - market competition, effects of 80
 - materialised harm 41
 - medical diagnostics 80–1
 - net harm 80–1
 - output obligations 41–2
 - press intrusion 64–5
 - press regulation 65
 - public opinion 69
 - public perceptions of privacy related harm 65–8
 - risk-based approach 37, 41–2
 - self-driving cars 81
 - technological developments 64–5
 - transparency 63, 64–71, 81
- Harper, R** 197
- hash functions** 121
- hashing** 131, 132
- Hassabis, Demis** 104
- health** *see also telerehabilitation processes*
 - accountability 75–6
 - anonymised data 129–30
 - audits 84
 - breadth of data 82
 - breast cancer screening 79–80
 - consent 75–6, 84
 - diagnosis 69–70, 72–3, 78, 81, 91, 98–9, 128–30
 - education 77
 - ethics 75–6
 - explicit consent 84
 - false positive and false negatives 80
 - GMC advice 84
 - insecure use and imprecise use of data 68, 70
 - insurance companies 186–7
 - overt and covert testing 76
 - personally, duty to treat patients 175–6
 - psychological illnesses 70
 - recommendations, systems that make 80, 82
 - smoking 82
 - telemedicine 167–8
 - trust, development of 76
- health and safety** 13
- Herbrich, Ralf** 92
- Hildebrandt, Mireille** 105
- historical background** 1–3, 25
- historical institutionalism** 5, 7–8, 25
- historical, statistical or scientific purposes, processing relating to** 152
- honour** 2
- Hood, C** 38
- household and state, distinction between** 64
- Human Computer Interaction (HCI)** 196
- human dignity** 2, 176
- human intervention** 101–2
- human rights** *see fundamental rights*
- IBM** 90
- identifiability**
 - additional information, concept of 121–2
 - Article 29 Working Party (WP29) 118–19
 - consistency 119
 - direct identifiers 117–18, 122–4, 127–8, 131–2
 - encryption 131, 132
 - GDPR 116–22, 126–8, 131–2
 - hashing 131, 132
 - identifiable, notion of 120
 - identified, notion of 120
 - indirect identifiers 117–18, 122–5, 128, 132
 - intactness of personal data 117
 - masked direct identifiers 117–18, 124–5, 131

- pseudonymised data 117, 121–2, 126, 131
- technical and organisational measures 126–7
- tokenisation 131, 132
- identity** *see also* **identifiability; re-identification risks**
- biometrics in national documents 11
- theft 64–6, 68
- transnational European identity 14
- image and speech recognition** 90–1
- image preserve** 182
- image search (Google)** 203
- impact assessments** 36, 39–41, 45–53, 56, 99–102
- impartiality** 43–4, 100, 102–3, 111
- imprecise use of data** *see* **insecure use and imprecise use of data**
- individuality** 64
- industrial competitiveness** 206
- industrial policy** 145–6
- Industry 4.0** 143–64
 - anonymised data 153–4
 - automated decision-making 152–5
 - business models 144, 148
 - competitiveness 144, 146–7
 - conceptual features 147–9
 - consent 151, 153
 - contract 151, 153
 - customer data 149–55
 - cyber-physical production systems (CPPSs) 147–8
 - cyber-physical systems 144, 147–8, 151, 155–6
 - data protection challenges 149–59
 - Data Protection Directive 149, 151–7, 159, 161
 - definition 144, 145–9
 - design and default, data protection by 154–5
 - design, privacy by 155
 - employer-employee nexus 144, 148, 155–61, 164
 - EU legal context 149–63
 - fourth industrial revolution 146–7
 - GDPR 149, 151–7, 159, 161, 163
 - Internet of Services (IoS) 148
 - Internet of Things (IoT) 143–4, 148–9
 - legal frameworks 144
 - location data 150–1, 156, 158
 - machines by machines, control of 144
 - manufacturing sector, technologisation of 144–50, 153, 155, 160–3
 - new business models 148
 - NIS Directive 161–3
 - non-personal data 144, 152, 159
 - personal data 144, 149–52, 155–9, 161, 163
 - producer-consumer nexus 144
 - profiling 150–1, 156
 - pseudonymisation 154–5
 - purpose limitation 152, 155
 - regulation 145–9
 - research and development programmes 146
 - security of data 144, 159–64
 - sensitive data 143–4, 156–7
 - social machines, communication between 147–8
 - sui generis concept, key features of 145–9
 - trade secrets 143–4
- inferences** 122, 124–31, 133, 135–6, 140, 194
- inform-and-consent procedure** 47, 51
- information, applications designed to provide** 70
- Information Commissioner's Office PIA Code of Practice** 50
- information preserves**
 - image preserve 182
 - location preserve 182
 - reputation preserve 182
 - telerehabilitation processes 178–80, 182–4, 186
 - territories of the self, concept of 178–80, 182–4
 - worthy of protection, data especially 182–4
- innovation** 10, 144, 146
- insecure use and imprecise use of data** 68–77
 - algorithms, personalised 68–9, 70–5
 - consent 71–2, 74–6
 - consumer protection 76–7
 - data subjects, rights of 71–2
 - discrimination 69, 73–4
 - explanation, right to an 73
 - fair processing 74–6
 - GDPR 71, 72–5
 - harms 68–71
 - health applications 68, 70
 - information, applications designed to provide 70
 - informed consent 68–9, 74–5
 - lawful processing 71
 - limited processing 71
 - personal control over data 68
 - protection through data protection 71–7
 - public opinion 68–9, 72
 - regulation 75–6
 - transparency 3, 71–7
- inspectability** 205
- institutions**
 - Charter of Fundamental Rights of the EU 17, 25
 - data protection authorities (DPAs) 18
 - design 4–5, 25
 - European Political Community, institutional design of 4–5
 - fundamental rights 8–9
 - historical institutionalism 5, 7–8, 17, 25

- legitimacy 13
- neo-institutional approach 2, 6–7
- rational choice theory 17, 18
- insurance companies** 186–7
- integration** 7, 11, 13–15, 17
- integrity, principle of** 56
- intelligibility** 196, 209
- intelligent systems** 168, 174–6 *see also*
 - machine intelligence
- intelligent therapy machines** 167–8
- internal market** 13, 18–24
- Internet of Services (IoS)** 148
- Internet of Things (IoT)** 143–4, 148–9, 195–6
- interoperability** 154–5
- Irion, K** 39, 47, 49
- isolationism** 15–16
- Israel, parole applications in** 91–2
- Italy** 17, 91

- judicial policy-making** 12
- Justice and Home Affairs (JHA)** 19–20

- K-anonymity** 125, 127–9, 132–4, 136, 139
- know, right to** 109
- Koops, Bert-Jaap** 48
- Kroll, Joshua A** 103

- labelling** 90
- lawful processing** 55, 71, 93–102, 110–11, 151
- learning** *see also* **machine learning for profiling**, **use of**
 - deep learning 91, 106, 204, 206
 - machine intelligence 204–5
- legal anthropology** 176–87
 - collective social practices, law as part of 177, 179
 - embedded and emergent feature of social life 177
 - reasonable expectations 176–87
 - social order, law as part of 177
 - telerehabilitation processes 168–9, 174, 176–87
- legal certainty** 172–4
- legitimacy** 13, 47, 54, 58
- liberalisation of press** 2
- life-saving decisions** 175
- likeness, appropriation of someone's name or** 64
- limited processing** 71
- Lisbon Treaty** 5, 8–10, 13–14, 15, 19, 25
- local linkability** 118, 120, 125–7, 130–3
- linkability** 118, 120, 124–32, 134–6, 139–40
- location data** 150–1, 156, 158, 188, 194
- location preserve** 182
- logic**
 - controllers, information from 93, 107–9
 - explanations 107–8
 - meaningful information about the logic involved, right to receive 93, 107–9
 - loss of control over data** 66–7
 - Luchetta, G** 39, 47, 49
 - Luxembourg** 17
 - Lynskey, O** 21, 37

 - Maastricht Treaty** 13
 - McCarthy, John** 90
 - Macenaite, M** 37, 43
 - machine intelligence** 202–6
 - algorithms 202–7
 - conversational agents 202–7
 - discrimination 204
 - error 204–5
 - general artificial intelligence 203
 - informing 205–6
 - inspectability 205
 - learning 204–5
 - neutrality 203
 - social context, importance of 204–5
 - machine learning for profiling, use of** 89–111
 - algorithms 92, 94–6, 100–10
 - anonimised data 95–6, 109–10
 - Article 29 Working Party (WP29) 94, 99, 109
 - artificial intelligence (AI), definition of 90
 - automated decision-making 93–111
 - bias 102–3, 111
 - cloud computing 90, 95, 100
 - controllers 93–7, 100–2, 105–11
 - correlation and causation 104–5
 - criteria or technical policy 103
 - data collection 94–5
 - Data Protection Directive 94, 98, 108–9, 111
 - data protection principles 93–110
 - data subjects, rights of 93–5, 101, 108–11
 - decisions and their effects 97–9, 102, 105
 - derogations from the rule 101–2
 - discrimination 91–2, 97, 105–6, 110–11
 - elements of profiling process 94–7
 - fair processing 93–4, 97, 102, 103–6, 108, 110–11
 - GDPR 93–111
 - human intervention 101–2
 - image and speech recognition 90–1
 - impact assessments 99–102, 105–6
 - know, right to 109
 - lawful processing 93–102, 110–11
 - legal effects 99
 - logic, explanation of 107–8
 - meaningful information about the logic involved, right to receive 93, 107–9
 - metabolism in human decision-making, influence of 91–2
 - model development 94–5, 111
 - necessity 99
 - non-compliance, potential consequences of 102
 - not to be subject to decisions based solely on automatic processing, right 93, 94

- object, right of data subjects to 95, 109
- practical applications 90–1
- profiling, definition of 93, 94–5
- quality and quantity of data 103, 105, 111
- rectification and erasure, right to 108–9
- reliability 105, 108, 111
- safeguards 100–1
- security measures 100
- significant effects 99
- stereotyping and prejudice in human
 - decision-making 91–2, 102
- technical and organisational security
 - measures 97, 102
- transparency 93–4, 97, 106–11
 - type of processing, profiling as a 93, 99
- machines by machines, control of** 144
- manufacturing sector, technologisation of** 144–50, 153, 155, 160–3
- market-oriented approaches, policy outcomes of** 2–4
- marketing**
 - nuisance marketing 66, 69, 73
 - research 152
- Mechanical Turk (Amazon)** 90
- medicine** *see* **health**
- metabolism in human decision-making, influence of** 91–2
- microphones** 199–200, 201
- Microsoft**
 - cloud computing 90
 - Cortana 196, 206–7
 - Hololens 195
 - Tay 204
- Mill, John Stuart** 64
- minimisation of data** 42, 46, 52, 54–5, 100, 105, 181
- minority groups** 103
- mitigation** 127–9, 131–5, 139–40
- MLaaS (Machine Learning as a Service)** 111
- mobile technologies** 196, 199
- Model Professional Code for Physicians (Germany)** 176
- models**
 - Bayesian modelling techniques 204
 - business models 144, 148
 - machine learning for profiling, use of 94–5, 111
 - surveillance 78–9
- monitoring** 144, 158–9, 170, 175–7, 185–9, 208
- Montelero, Alessandro** 96
- Motivation Strategies in Orthosis Therapy** 169–70
- murder investigations** 200
- names** 64, 162
- national interests** 11
- national security** 77
- National User Interface (NUI)** 194–5, 209
- natural language processing (NLP)** 90–1
- necessity** 46, 59, 99, 183
- neo-institutional theory** 2, 6–7
- Nest (Google)** 197
- Network and Information Systems (NIS)**
 - Directive** 161–3
 - cloud services 162–3
 - Computer Security Incident Response Teams (CSIRTs) 162–3
 - Digital Service Providers 161–2
 - Industry 4.0 161–3
 - Operators of Essential Services (OoES) 161–3
- Netherlands** 11
- neural networks** 106, 194, 204
- neutrality** 102, 203
- news feeds, personalisation of** 48–9
- Nice Treaty** 14, 17
- Niewöhner, J** 169
- Nissenbaum, H** 174, 178–9, 205–6
- noise addition** 125, 127, 131–3
- non-governmental organisations (NGOs)** 13
- norm entrepreneurship** 6–7
- Now (Google)** 206–7
- nuisance marketing** 66, 69, 73
- observability** 199
- OECD** 71
- online services, sharing information with** 65
- opacity** 205–7, 208–9
- Operators of Essential Services (OoES)** 161–3
- Orthoses Project** 169–70, 174–5
- outcome-oriented approach** 37, 41–2
- ownership of data** 76, 83–5
- padlock system** 197, 210
- parents, access to personal data by** 186
- Parker, C** 52
- Passenger Name Record (PNR)** 21–2
- perceptions** *see* **public perceptions of privacy related harm**
- personal data** *see also* **sensitive personal data**
 - categories 117–19
 - children and teenagers 174–88
 - Charter of Fundamental Rights of the EU 14
 - employer-employee nexus 155–9
 - health insurance companies 186–7
 - Industry 4.0 144, 149–52, 155–9, 161, 163
 - institutionalisation 8
 - intactness of personal data 117
 - sharing data, attitudes to 65–9, 74, 181–4, 186–7, 197
 - telerehabilitation processes 168, 171–2, 174–88
 - trade-offs 66–8, 75, 181–2
- personal knowledge** 121–2
- personalisation** 48–9
- personality rights** 1–2
- photography** 2, 64

- play, privacy of** 201
- Poland** 15
- policing** 77
- policy** 2–5
 - conversational agents 207–8
 - defence policy 19
 - fundamental rights 2–4
 - GDPR 21, 24–5
 - historical institutionalism 8
 - industrial policy 145–6
 - intergovernmental competence 18
 - judicial policy-making 12
 - Lisbon Treaty 5, 13
 - market-oriented approaches 2–4
 - neo-institutional approach 6–7
 - opposition to EU policy initiatives 15
 - overspills 13
 - pillar system 13
 - power contests 2
 - privacy policies 207–8
 - risk-based approach 35, 52
 - supranational competence 18
 - temporal context 2
- politics**
 - Charter of Fundamental Rights of the EU 13–17
 - Digital Single Market 24
 - domestic politics 13–17
 - enlargement of EU, political conditionality for 14
 - European Political Community, institutional design of 4–5
 - political science analysis 2, 5–6, 25
- power** 2, 18, 156, 199
- precautionary measures** 104–5
- predictability** 204, 205–6
- predictive analytics** 90–1
- prejudice and stereotyping in human decision-making** 91–2, 102
- prescriptive principles/rules** 3, 4, 15
- price discrimination** 70
- principles-based regulation** 49
- prioritization** 106
- privacy paradox** 66–8
- producer-consumer nexus** 144
- profile pictures** 183
- profiling** 128, 150–1, 156 *see also* **machine learning for profiling, use of**
- proportionality** 34, 46–8, 53, 57, 59, 99
- Prosser, William** 64
- pseudonymisation**
 - additional information, concept of 121–2, 127
 - anonymisation 154
 - background knowledge 122
 - definition 120, 124–5, 126–7, 154
 - GDPR 116–18, 121–9, 133, 135–6, 141, 154
 - identifiability 117, 121–2, 126, 131
 - inference 127
 - Industry 4.0 154–5
 - local linkability 120, 127
 - mitigation 129, 139
 - personal data, as 120
 - protected data 117–18
 - pseudonymisation, definition 117–18
 - sanitisation techniques 135
 - singling out 127
 - technical and organisational measures 126–7
- public opinion** 68–9, 72
- public perceptions of privacy related harm** 65–8
- public services, improvements in** 77
- Puchalska, B** 16
- purpose limitation** 42, 54–5, 58, 96, 152, 155
- quality and quantity of data** 47, 51, 103, 105, 111
- racism** 203–4
- RAND Corporation** 37, 41
- randomisation** 124, 125, 132, 153–4
- rational choice theory** 2, 5–7, 17, 20, 25
- reasonable expectations**
 - children and teenagers 184–8
 - collective social practices, law as part of 179
 - consent 209–10
 - context 169
 - conversational agents 199, 209–10
 - definition 171–2
 - intelligent assistant systems 175
 - legal anthropology 176–87
 - telerehabilitation processes 167–89
 - territories of the self, concept of 178–9
- recommendations, systems that make** 80, 82
- rectification** 47–9, 57, 71, 108–9
- regulation**
 - advertising 211
 - agencies 39–40
 - deregulation 39–41
 - gaps 75
 - grey areas 52
 - harm 65
 - Industry 4.0 145–9
 - insecure use and imprecise use of data 75
 - lack of sufficient regulation 63
 - meta-regulation 36, 52
 - normative regulatory concept, as 146, 147
 - press 65
 - principles-based regulation 49
 - risk-based approach 36–41, 49–50, 52, 58–9
 - self-regulation 3–4

- single regulatory view 84
- surveillance 63, 81–4
- rehabilitation** *see* **telerehabilitation processes**
- re-identification risks**
 - anonymised data 153–4
 - Article 29 Working Party's Opinion on Anonymisation Techniques 124
 - background knowledge 121–2
 - classification 118–19
 - contextual controls 123–4, 134, 140
 - GDPR 124–5, 127–8, 140–1
 - indirect identifiers 123
 - inference 124
 - linkability 124, 130–1
 - mitigation 128
 - personal knowledge 122
 - sanitisation techniques 124, 130–3, 139
 - singling out 124
- relativism** 118–19, 139
- reliability** 63, 81–4, 105, 108, 111
- reliable information about impact of**
 - surveillance systems, ensuring 63, 81–5
- remote working** 155
- reputation** 99, 182, 183
- research and development programmes** 146
- retail industry** 77
- rights** *see* **data subjects, rights of;**
fundamental rights
- risk-based approach** 33–60
 - access, data subject's right to 47–8, 57
 - accountability 34–6, 41–2, 44–5, 50, 52
 - algorithmic systems, biases in 43–4
 - Article 29 Working Party (WP29) 34–6, 39, 44–6, 48, 52, 54–7, 59–60
 - compliance 45–9, 52–4, 58
 - confidentiality 39, 56
 - consent 42, 48
 - controller responsibility 34–53
 - controllers 40–53, 56–9
 - data processing 38–9, 41–3, 47–8, 52–9
 - Data Protection Directive 34, 40, 53
 - data protection principles 41, 47–59
 - data subjects, rights of 47–8, 53–9
 - discrimination 38–9
 - effectiveness 48
 - enforcement 39, 41, 50–2
 - European Data Protection Supervisor (EDPS) 44–5
 - ex post oversight 47
 - fairness 41, 48–9, 55, 58
 - fines 50
 - fundamental rights 44, 47, 53, 55–6
 - GDPR 34–9, 41–55, 58–9
 - government
 - agencies 39–40
 - interference 38
 - harm-based approach 37, 41–2
 - impact assessment 39–41, 45–53, 56
 - inform-and-consent procedure 47, 51
 - information and communication technologies (ICTs) 38
 - integrity, principle of 56
 - lawfulness, principle of 55
 - legitimacy 47, 54, 58
 - margin of discretion 58
 - minimisation of data 42, 46, 52, 54–5
 - mitigation 47, 51, 55
 - necessity 46, 59
 - negative impact on rights and freedoms of
 - natural persons 36–7
 - obligations requiring a risk-oriented effort 56, 58
 - obligations requiring a risk-oriented result 54–6, 58
 - obligations which are not risk-oriented 56–7
 - outcome-oriented approach 37, 41–2
 - principles-based regulation 49
 - procedural legitimacy 47
 - process orientated review 41
 - proportionality 34, 46–8, 53, 57, 59
 - purpose limitation 42, 54–5, 58
 - quality of data 47, 51
 - rectification and erasure 47–8, 57
 - regulation 36–41, 49–50, 52, 58–9
 - risk analysis 37–8, 40–2
 - risk-based regulation 37, 39
 - risk management 37–8, 40–2
 - risk regulation, distinguished from 37
 - role of risk 37–42
 - scalable compliance measures 44–5, 54–6
 - sensitive personal data 46
 - state of the art 43, 56–7
 - substantive protection against risks 45–50
 - taking into account the risks 44–52
 - technical and organisational measures 36, 43, 45–7, 56
 - theory and practice, link between 42–4
 - track of conversation 49–50
 - transparency 42, 54
- Rothstein, H** 38
- rural areas** 168
- Samsung** 194
- sanitisation techniques**
 - anonymised data 136
 - Article 11 data 135
 - Article 29 Working Party 125, 127, 130–1, 135
 - contextual control 118, 130, 135, 139–41
 - dynamic techniques 139–40
 - effectiveness 130–3
 - GDPR 118–19, 122–5, 127–8, 134–41
 - generalisation 124
 - masking direct identifiers 124, 131
 - pseudonymous data 135
 - randomisation 124

- re-identification 124, 130–3, 139
- results 133
- scalable compliance measures** 44–5, 54–6
- Schengen area** 17–19
- Schmueli, B** 201
- scientific purposes, access to data for**
 - 81–2, 85
- scoliosis** 170–1, 176–87
- search engines** 10, 59, 77
- security of data**
 - child-adult communications 200–1
 - Computer Security Incident Response Teams (CSIRTs) 162–3
 - GDPR 135
 - Industry 4.0 144, 159–64
 - machine learning for profiling, use of 100
 - technical and organisational security measures 36, 43, 45–7, 56, 97, 102
- Selbst, A** 43–4
- self-regulation** 3–4
- sensing** 196, 198–9
- sensitive personal data**
 - children and teenagers 177, 183, 184
 - definition 177
 - Industry 4.0 143–4, 156–7
 - risk-based approach 46
 - social media 183
 - telerehabilitation processes 177, 183, 184, 188
- sharing data**
 - attitudes 65–9, 74, 181–4, 186–7, 197
 - children and teenagers 181–2
 - GDPR 116, 125, 135
 - telerehabilitation processes 181–2, 184, 187
 - trade-offs 181–2
- Silbey, S** 177–8
- singling out** 118, 124–6, 127–31, 133–4, 140
- Siri (Apple)** 195, 196, 206–7
- smart cars**
 - chilling factor 91
 - harm 81
 - Industry 4.0 150–1
 - machine intelligence 2–3
 - machine learning for profiling, use of 91
 - Vienna Convention on Road Traffic 1968 91
- smart companies** 144, 160
- smart gloves** 148, 156, 158
- smart homes** 143–4
- smart machines** 144, 150–1
- smart toys** 196, 198–202, 205, 210–11
- smart TVs** 194
- smoking** 82
- social machines, communication**
 - between 147–8
- social media**
 - access, managing 183–4
 - children and teenagers 180–1, 183–4
 - conversational agents 196
 - Facebook 65, 77, 84, 183, 194
 - future events, anticipating 184
 - necessity 183
 - privacy paradox 66
 - profile pictures 183
 - telerehabilitation processes 180–1, 183–4
- social order, law as part of** 177
- socially-embedded systems** 198
- socially embedded phenomenon, privacy as** 177, 188
- specified, explicit, and legitimate purposes, processing for** 95
- speech recognition** 90–1
- Spotify** 77
- state and household, distinction between** 64
- state of the art** 43, 56–7
- state sovereignty** 14–17
- statements, updating of privacy** 188
- statistical or archiving purposes, processing relating to** 152
- stereotyping and prejudice in human decision-making** 91–2, 102
- strategic interests** 2, 11–13
- supervisory authorities** 81–2
- supranationalism** 7, 14, 18
- supremacy of EU law** 9, 11, 12–13
- surveillance**
 - algorithms 82–3, 85
 - analytical competence 81–2
 - assurance, data for 81, 85
 - audits 81, 84
 - automated decision-making 63, 77–84
 - breadth of data collected 82
 - breast cancer screening 79–80
 - child-facing technology 210–11
 - collection of survey data 83
 - collective ownership of data 83–4
 - commercial confidentiality 61
 - data linking 82
 - employer-employee nexus 155–9, 164
 - health 79–80
 - level of data access 81–2
 - model systems 78–9
 - net benefit of surveillance systems, estimating 79–80
 - normalisation 210–11
 - ownership of data 83–5
 - regulation 63, 81–4
 - reliable information on impact, ensuring 63, 81–4
 - risks and benefits 63, 81–4
 - smart toys 199–200, 210–11
 - supervisory authorities 81–2
 - telerehabilitation processes 184–5
 - third party access 82–3
 - transparency 81, 85

tailored/personalised services and communications 66–7

technical and organisational measures

- profiling 97, 102
- risk-based approach 36, 43, 45–7, 56
- telerehabilitation processes 172
- terminology 119, 121, 126–7

telemedicine 167–8

telerehabilitation processes 167–90

- amputation 168
- analytical framework 177–80
- Assist-as-needed functions 174–5
- automated decision-making 175
- BeMobil 168, 174–5
- brace therapy 170, 176–87
- challenges for data protection 167–8
- Charter of Fundamental Rights of the EU 176
- children and teenagers 170–1, 176–88
- co-laboration 169
- collective social practices, law as part of 177, 179
- confidentiality 185–6
- consent 170–1, 176
- context-relevant informational norms 179
- contextual integrity 178
- design of technologies 188–9
- design, privacy by 169–76
- discrimination 189
- emergency systems 175
- empirical findings 180–7
- ethical, legal, and social implications (ELSI) 168
- ethnography 187–9
- GDPR 171–5, 188
- gender 176
- health insurance companies 186–7
- homes of patients 168
- image preserve 182, 183
- individual experiences 176
- information preserves 178–80, 182–4, 186
- intelligent assistant systems 168, 174–6
- intelligent therapy machines 167–8
- Katz content 172–4
- knowledge of data protection 176–7
- legal anthropology 168–9, 174, 176–87
- legal certainty 172–4
- life-saving decisions 175
- location data 188
- location preserve 182
- methods and overview of findings 176–7
- Model Professional Code for Physicians (Germany) 176
- monitoring data 170, 175–7, 185–9
- Motivation Strategies in Orthosis Therapy 169–70
- multi-sensor-monitoring system 170
- new actors 168, 188

- Orthoses Project 169–70, 174–5
- parents, access to personal data by 186
- personal data 168, 171–2, 174–88
- reasonable expectations 167–89
- rejection of technologies 169
- reputation preserve 182, 183
- research context and methods 168–9
- research focus 169–70
- rural areas 168
- scoliosis 168–71, 176–87
- sensitive data 177, 183, 184, 188
- sharing data 181–4, 186–7
- social media 180–1, 183–4
- socially embedded phenomenon, privacy as 177, 188
- specific practices of data protection 176
- strokes 168
- surveillance 184–5
- territories of the self, concept of 177–80
- third parties 179, 184, 186–7
- trade-off, data sharing as 181–2
- transparency 175, 186, 188

terminology in GDPR 115–41

- additional information 121–2, 125, 127, 133–4, 140
- anonymisation 118–19, 124–34, 136, 139–41
- Article 11 data 117, 119–20, 126, 128–31, 133, 139, 141
- Article 29 Working Party (WP29) 118–19, 124–7, 130–1, 139–41
- background knowledge 121–2, 124, 128, 133
- categories of personal data 117–19
- characterisation of data 121, 126, 136–40
- classification of types of data 133
- confidentiality 134, 140–1
- contextual controls 118–19, 122–4, 134–41
- controllers 135, 139–40
- Data Protection Directive 116–17, 119
- definitions 119–24
- differential privacy 125, 131–6, 140
- domain linkability 118, 121, 125–6, 127–32, 134
- global linkability 118, 125–6, 130–3, 135–6
- hard and soft law instruments, analysis of 118
- identifiability 116–22, 126–8, 131–2
- improving data utility 139–40
- inference 122, 125–31, 133, 135–6, 140
- interdisciplinary, terminology as 118, 140–1
- K-anonymity 125, 127–9, 132–4, 136, 139
- L-diversity 127, 132–4, 136, 139
- local linkability 118, 120, 125–7, 130–3
- linkability 118, 120, 124–36, 139–40
- mitigation 127–9, 131–5, 139–40
- more than one dataset 125–6
- noise addition 125, 127, 131–3

- one entity, datasets held in (insider threat) 125–6
- permutation 125, 127, 131–3
- personal data, definition of 116
- pseudonymised data 116–18, 121–9, 131, 133, 135–6, 139, 141
- randomisation 124, 125, 132
- recipients of data 135–40
- re-identification risks 118–19, 122–8, 130–4, 140–1
- relativist approach 118–19, 139
- sanitisation techniques 118–19, 122–5, 127–8, 130–41
- singling out 118, 124–6, 127–31, 133–4, 140
- technical and organisational measures 119, 121, 126–7
- three types of data 115–41
- transferring controls 135
- terms and conditions** 207–8
- territories of the self, concept of**
 - information preserve 178
 - spatial and material dimension 179–80
 - telerehabilitation processes 177–80
- test error rate** 78–9
- third parties**
 - access 82–3
 - algorithms 82
 - consent 68
 - conversational agents 198, 208–9
 - insecure data 68
 - smart toys 201, 202
 - surveillance 82–3
 - telerehabilitation processes 179, 184, 186–7
 - territories of the self, concept of 179
- tokenisation** 131, 132
- toys** 196, 198–202, 205, 210–11
- tracing of decision trees** 205–6
- trade-offs** 66–8, 75, 181–2
- trade secrets** 107–8, 111, 143–4, 206
- transparency** 63–85
 - algorithms 71, 85, 106–8
 - automated decision-making 77–81, 84
 - consent 176
 - consumer protection 76
 - controllers 107
 - Data Protection Directive 108
 - data subjects, rights of 108–9
 - employer-employee nexus 157
 - explanation, right to an 107–8
 - fairness 108–9
 - harm 63, 64–71, 81
 - insecure and imprecise use of data 63, 71–7
 - logic 106–7
 - machine learning for profiling, use of 93–4, 97, 106–11
 - poor implementation of data processing 63
 - reliable information about impact of surveillance systems, ensuring 63, 81–4
 - risk-based approach 42, 54
 - surveillance 81, 85
 - telerehabilitation processes 175, 186, 188
 - trade secrets 108
- treaty-base games** 5, 18–20
- trust** 76, 210
- Turing, Alan** 89–90
- Turing Test** 89–90
- United Kingdom**
 - Brexit 15
 - Charter of Fundamental Rights of the EU 14–15
 - CJEU 16
 - Conservatives 15–16
 - Data Protection Directive 15
 - demonization of integration 15
 - deportation 16
 - European Convention on Human Rights 15–16
 - exemptions and opt-outs 15
 - GDPR 15
 - isolationism 15–16
 - policy initiatives, opposition to 15
 - public perceptions 66–7
 - sovereignty 14–16
 - terrorism 16
- United States**
 - Commercial Privacy Bill of Rights Act of 2011 171, 172
 - common law 3
 - Constitution 3, 172–3
 - consumer rights, privacy as part of 3
 - design, privacy by 172
 - development of EU data protection law 21
 - EU-US passenger Name Record (PNR) 21–2
 - Federal Trade Commission (FTC) 199–200
 - Florida, universal screening for gifted pupils in 92
 - Fourth Amendment 172–3
 - HEW Fair Information Practices 71
 - historical and cultural contexts 3
 - insecure use and imprecise use of data 71
 - interest-based paradigm 3
 - Katz content 172–4
 - likeness, appropriation of someone's name or 64
 - policy 4
 - press intrusion 64
 - private sector self-regulation 3
 - public perceptions 65, 67

- smart toys 199–200
- social media 183–4
- telerehabilitation processes 171–4
- unobtrusiveness** 197, 209
- unremarkability** 197
- user understanding** 207, 210
- value creation** 7
- virtual assistants** *see* conversational agents
- virtualisation** 155
- voice-activated devices** *see* conversational agents
- wake words** 198, 210
- Warren, Earl** 64
- Wachter, Sandra** 81
- Weber, Max** 40
- West, A** 183
- Westin, Alan** 65
- worn technologies** 196

